Katedra Inżynierii Klinicznej
Akademia Śląska w Katowicach

Metodologia ORION

Formalny model oceny ryzyka informatycznego w organizacjach nadzorowanych

DRAFT

dr inż. Bartosz Lewandowski
ORCID: 0009-0004-1158-0693

Katowice, 2026

Podziękowania

Ta książka nie powstałaby bez wsparcia wielu osób. Każda z nich wniosła coś innego do mojej pracy naukowej, a ich pomoc przychodziła na różnych jej etapach.

Szczególnie dziękuję prof. dr. inż. Ewarystowi Tkaczowi. Pomógł mi zaplanować karierę naukową, a później wspierał mnie na kolejnych jej etapach, także wtedy, gdy wybór dalszej drogi nie był oczywisty.

Dr. hab. Maciejowi Wróblowi dziękuję za inspirację i dyskusje. W naszych rozmowach wskazywał problemy, które pojawiają się przy przetwarzaniu danych medycznych. Dr. hab. Mirosławowi Michalskiemu jestem wdzięczny za pomoc w rozwoju naukowym i za to, że mogłem korzystać z jego doświadczenia.

Mecenas Magdalenie Dowgalec dziękuję za merytoryczną weryfikację zagadnień prawnych omawianych w książce. Jej uwagi pozwoliły mi precyzyjniej opisać tę część problematyki, która wykracza poza moją dziedzinę.

Mojej Rodzinie dziękuję za cierpliwość, wyrozumiałość i wsparcie. Praca nad książką zajmowała czas, który należał także do Was. Katarzynie dziękuję szczególnie: za obecność, otuchę i motywację, zwłaszcza w chwilach, gdy były najbardziej potrzebne.

DRAFT

Spis treści

1 Preambuła **5**

2 Wstęp **6**
2.1 Postulat: metodologia ORION 7

3 Krajobraz regulacyjny **9**
3.1 Krajowe ramy prawne cyberbezpieczeństwa i ochrony danych 9
3.1.1 Zakres obowiązków wynikający z ustawy o krajowym systemie cyberbezpieczeństwa z 2018 r. 9
3.1.2 Nowelizacja UKSC z 23 stycznia 2026 roku (implementacja NIS2) . 10
3.1.3 Ustawa o ochronie danych osobowych z 10 maja 2018 r. 11
3.1.4 Ustawa o zwalczaniu nieuczciwej konkurencji (1993) 12
3.1.5 Odpowiedzialność cywilna wg kodeksu cywilnego 12
3.1.6 Odpowiedzialność karna: Kodeks karny 13
3.1.7 Dyrektywa NIS2 jako fundament europejskiego cyberbezpieczeństwa 14
3.1.8 Nadzór i egzekwowanie przepisów 17
3.1.9 Odpowiedzialność zarządcza 18
3.1.10 Rejestracja i samoidentyfikacja 18
3.2 Regulacje związane z rynkiem finansowym 19
3.2.1 Prawo bankowe 19
3.3 Rozporządzenie DORA: cyfrowa odporność operacyjna sektora finansowego 20
3.4 Ochrona danych medycznych, regulacje prawne i nadzór 22

4 Ryzyka w praktyce: zagrożenia, konsekwencje i dobre praktyki **25**
4.1 Shadow IT 26
4.2 Shadow AI 27
4.3 Edukacja jako fundament ochrony danych osobowych 28
4.4 Często występujące ryzyka związane z nieprawidłowym przetwarzaniem danych 30

5 Konflikt jurysdykcji i suwerenność danych **34**
5.1 Problem CLOUD Act i FISA 702 34
5.2 Suwerenność danych: Gaia-X, suwerenne chmury obliczeniowe i poufne przetwarzanie danych 35
5.3 Schrems I, II i konsekwencje dla transferu danych poza EOG 38
5.3.1 Umowa Safe Harbour (2000–2015) 38
5.3.2 Maximilian Schrems: Tło i strategia prawna 38
5.3.3 Schrems I: Unieważnienie zasad Safe Harbor 39
5.3.4 Schrems II: Tarcza Prywatności 39
5.3.5 Ramy ochrony prywatności danych (2023–obecnie) 40
5.3.6 Implikacje dla struktury ORION 40
5.4 Strategia legislacyjna UE: Data Act, EUCS i CADA 40

DRAFT

5.5 Przykładowe scenariusze konfliktu . . . 43
5.5.1 Mechanizm telemetrii w systemie Windows . . . 44
5.5.2 Scenariusz kumulacji ryzyk: Windows Server na Google Cloud, Microsoft Azure, AWS . . . 44
5.5.3 Macierz wektorów dostępu . . . 45
5.5.4 Rekomendacje dla środowisk regulowanych (NIS2 / DORA / RODO) 45
5.5.5 Wnioski . . . 46

6 ORION - Ocena Ryzyka Informatycznego Organizacji Nadzorowanych 47
6.1 Luka badawcza . . . 47
6.2 Postulaty i cele ORION . . . 50
6.3 Identyfikacja podmiotu audytowanego . . . 51
6.4 Mechanizm walidacji jakości dowodów i odpowiedzi . . . 52
6.4.1 Struktura pytań . . . 52
6.4.2 Model dowodowy . . . 53
6.4.3 Walidacja odpowiedzi . . . 53
6.4.4 Skala jakości dowodów . . . 53
6.4.5 Wpływ dowodu na wartość odpowiedzi . . . 54
6.4.6 Walidacja krzyżowa oraz definicja konsensusu . . . 55
6.4.7 Interpretacja rozbieżności . . . 56
6.5 Definicje i aktorzy . . . 57
6.5.1 Perspektywa . . . 57
6.5.2 Obiekt . . . 58
6.5.3 Atrybuty obiektów . . . 60
6.5.4 Atrybut: dostępność systemu . . . 60
6.5.5 Atrybut: poziom krytyczności . . . 61
6.5.6 Atrybut: klasyfikacja utrzymania w chmurze . . . 63
6.5.7 Atrybut: klasyfikacja atrybutu typów przetwarzanych danych . . . 64
6.5.8 Atrybut: kraj pochodzenia . . . 65
6.6 Plan ciągłości działania . . . 66
6.7 Plan wyjścia z usługi (Exit plan) . . . 67

7 Przeprowadzenie audytu ORION 69
7.1 Faza 1: Klasyfikacja podmiotu . . . 69
7.1.1 Krok 1.1: Ustalenie reżimu regulacyjnego . . . 69
7.2 Faza 2: Inwentaryzacja i klasyfikacja obiektów . . . 71
7.2.1 Krok 2.1: Inwentaryzacja systemów . . . 72
7.2.2 Krok 2.2: Identyfikacja bezpośrednich dostawców . . . 72
7.2.3 Krok 2.3: Przypisanie atrybutów klasyfikacyjnych . . . 73
7.2.4 Ankieta klasyfikacji atrybutu dostępności . . . 73
7.2.5 Ankieta klasyfikacja atrybutu poziomu krytyczności . . . 75
7.2.6 Ankieta klasyfikacji atrybutu utrzymania w chmurze . . . 76
7.2.7 Ankieta klasyfikacji typu danych . . . 79
7.3 Faza 3: Kwestionariusz szczegółowy i zbieranie dowodów . . . 81
7.3.1 Warunkowe aktywowanie sekcji pytań . . . 81
7.3.2 Zasady konstrukcji pytań . . . 82
7.3.3 Sekcja organizacja . . . 84
7.3.4 Sekcja dane poufne: dane osobowe, w tym szczególne kategorie danych osobowych, oraz tajemnice przedsiębiorstwa . . . 87

DRAFT

7.3.5 Sekcja bezpieczeństwo techniczne . . . 88
7.3.6 Sekcja bezpieczeństwo fizyczne . . . 91
7.3.7 Sekcja system informatyczny . . . 94
7.3.8 Sekcja usługi w chmurze . . . 97
7.3.9 Sekcja Transfer Impact Assessment (TIA) . . . 99
7.3.10 Sekcja dostawcy ICT . . . 103
7.3.11 Sekcja exit plan . . . 106
7.3.12 Sekcja plan ciągłości działania (BCP) . . . 109
7.3.13 Sekcja koncentracja ryzyka . . . 110
7.4 Faza 4: Obliczenie scoringu i propagacja ryzyka . . . 114
7.4.1 Poziom 1: Wynik pytania . . . 114
7.4.2 Poziom 2: Wynik sekcji . . . 115
7.4.3 Poziom 3: Wynik obiektu . . . 117
7.4.4 Poziom 4: Wynik podmiotu z propagacją ryzyka . . . 118
7.4.5 Identyfikacja dostawców kluczowych . . . 120
7.5 Faza 5: Raport końcowy i rekomendacje . . . 121
7.5.1 Macierz zgodności . . . 121
7.5.2 Graf ICT z oznaczeniami . . . 122
7.5.3 Lista rekomendacji z priorytetami . . . 126
7.5.4 Karta dostawców kluczowych . . . 127
7.6 Wyniki audytu . . . 129
7.6.1 Klasyfikacja podmiotu . . . 129
7.6.2 Klasyfikacja atrybutu ekspozycji sieciowej . . . 129
7.6.3 Klasyfikacja atrybutu poziomu krytyczności . . . 130
7.6.4 Klasyfikacja atrybutu utrzymania w chmurze . . . 131
7.6.5 Klasyfikacja atrybutu typów przetwarzanych danych . . . 133
7.6.6 Klasyfikacja atrybutu kraju pochodzenia . . . 133
7.6.7 Analiza aktywowanych sekcji pytań . . . 133
7.6.8 Wyniki sekcji organizacja . . . 135
7.6.9 Wyniki sekcji bezpieczeństwo techniczne . . . 137
7.6.10 Wyniki sekcji bezpieczeństwo fizyczne . . . 138
7.6.11 Wyniki sekcji system informatyczny . . . 139
7.6.12 Wyniki sekcji usługi chmurowe . . . 141
7.6.13 Wyniki sekcji dane poufne . . . 143
7.6.14 Wyniki sekcji dostawcy ICT . . . 144
7.6.15 Wyniki sekcji plan wyjścia z usługi (exit plan) . . . 146
7.6.16 Wyniki sekcji plan ciągłości działania (BCP) . . . 147
7.6.17 Podsumowanie wyników audytu i obliczenie $S_{podmiot}$ . . . 148

8 Zakończenie **155**

9 Słownik pojęć **158**

DRAFT

1. Preambuła

Ocena Ryzyka Informatycznego Organizacji Nadzorowanych, w skrócie zwana ORION, jest nową, wieloperspektywiczną metodą oceny zgodności systemów informatycznych, odpowiadającą na ograniczenia tradycyjnych podejść audytowych. Klasyczne audyty ICT opierają się na deklaracjach i samoocenie, pomijają perspektywę prawną lub traktują ją rozłącznie od technicznej, a w efekcie nie wykrywają rzeczywistych luk w zarządzaniu łańcuchem dostaw i zgodności z wymogami regulacyjnymi. ORION adresuje te luki przez integrację trzech niezależnych perspektyw oceny: zgodności (prawnej), użytkownika (biznesowej) i technicznej, połączoną z rygorem dowodowym i modelowaniem propagacji ryzyka. Metoda adresowana jest przede wszystkim do podmiotów objętych nadzorem regulacyjnym, instytucji finansowych oraz podmiotów kluczowych i ważnych w rozumieniu dyrektywy NIS2, dla których zgodność z wymogami DORA, NIS2 i RODO stanowi obowiązek prawny, a nie dobrowolny standard. Warto jednak wykorzystać metodę ORION również w pozostałych przedsiębiorstwach, traktując podnoszone przez metodologię wyzwania wynikające z implementacji DORA oraz NIS2 jako zestaw dobrych praktych, równocześnie upewniając się, że działania podmiotu są zgodne z obowiązującymi przepisami np. w zakresie RODO.

Luka kompetencyjna na styku ocen rozwiązań informatycznych przez zespoły prawne oraz techniczne jest przyczyną nieprawidłowej klasyfikacji systemów informatycznych. Co więcej, organizacje nieprawidłowo zarządzają łańcuchem dostawców i poddostawców, nawet gdy są do tego zobowiązane przez rozporządzenie DORA (*Digital Operational Resilience Act*) oraz dyrektywę NIS2 (*Network and Information Security Directive 2*). Szczególnie jest to widoczne w relacjach z hiperskalerami objętymi jurysdykcją *Cloud Act* (*Clarifying Lawful Overseas Use of Data Act*), gdzie bardzo często pomija się ryzyka transferu danych do USA, co stoi w sprzeczności z RODO (Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2016/679, ogólne rozporządzenie o ochronie danych).

Niniejsza publikacja przedstawia założenia teoretyczne metody ORION, opisuje jej strukturę klasyfikacyjną oraz ilustruje jej zastosowanie praktyczne na przykładzie wybranej organizacji.

DRAFT

2. Wstęp

Transformacja cyfrowa przedsiębiorstw i instytucji publicznych, postępująca intensywnie od końca XX wiek, zmieniła charakter ryzyk i wyzwań stawianych przed organizacjami. Systemy informatyczne przestały być wyłącznie narzędziami wspierającymi codzienną pracę, stały się elementem strategii przedsiębiorstw, bez którego realizacja procesów jest praktycznie niemożliwa. Dotyczy to w równym stopniu banku przetwarzającego miliony transakcji konsumentów, szpitala prowadzącego elektroniczną dokumentację medyczną pacjentów, operatora infrastruktury energetycznej zarządzającego siecią dystrybucyjną, uczelni i szkoły prowadzącej cyfrowe ewidencje postępów podopiecznych, firm produkcyjnych opierających ciągłość działania na cyfrowych algorytmach. We wszystkich tych przypadkach niedostępność systemu informatycznego, nawet będąca awarią o ograniczonych skutkach operacyjnych, jest zdarzeniem prawnym i finansowym niosącym negatywne konsekwencje.

Ustawodawca zdefiniował standardy bezpieczeństwa opisane w przepisach prawa. Do kluczowych aktów prawnych, które wymagają prowadzenia szczegółowej analizy ryzyka, należą przede wszystkim Ustawa o Krajowym Systemie Cyberbezpieczeństwa[1] oraz Rozporządzenie w sprawie operacyjnej odporności cyfrowej sektora finansowego, potocznie zwane DORA.[2] Choć powyższe dokumenty jasno określają, kogo dotyczą ich zapisy, warto potraktować te publikacje jako uniwersalne źródło wiedzy. Wskazane w nich procedury oraz opisane wektory zagrożeń mogą pomóc zabezpieczyć każdą organizację przed skutkami cyberataków.

Równolegle z rosnącym uzależnieniem organizacji od technologii informatycznych rozwinął się złożony rynek dostawców, poddostawców i partnerów technologicznych, tworzący łańcuchy zależności ICT (*Information and Communications Technology*). Pojedyncza aplikacja biznesowa może dziś opierać się na wielu elementach dostarczanych przez szereg dostawców: platformach chmurowych, bibliotekach oprogramowania, usługach uwierzytelniania, systemach płatności, zewnętrznych centrach przetwarzania danych czy dostawcach łączności. Każde z tych elementów jest potencjalnym źródłem ryzyka, technicznego (awarii), prawnego (brak zgodności z obowiązującym prawem) i operacyjnego. To organizacja ponosi odpowiedzialność regulacyjną za skutki zdarzeń w całym tym łańcuchu, niezależnie od tego, czy posiada nad nim bezpośrednią kontrolę. Złożoność łańcuchów dostaw ICT sprawia, że ich pełna inwentaryzacja, ocena i nadzór są zadaniem, z którym większość organizacji radzi sobie niewystarczająco, nie z braku dobrej woli, lecz z braku odpowiednich narzędzi metodycznych.

Problem ten nabiera szczególnego wymiaru w kontekście intensywnej aktywności legislacyjnej europejskiego prawodawcy ostatniej dekady. Ochrona danych stanowi jeden z fundamentalnych elementów współczesnego porządku prawnego Unii Europejskiej. Dynamiczny rozwój technologii, w szczególności sztucznej inteligencji oraz gromadzenia in-

[1] *Ustawa z dnia 5 lipca 2018 r. o krajowym systemie cyberbezpieczeństwa*. Weszła w życie 28 sierpnia 2018 r. 2018 (dalej jako UKSC).

[2] Parlament Europejski i Rada Unii Europejskiej. *Rozporządzenie (UE) 2022/2554 w sprawie operacyjnej odporności cyfrowej sektora finansowego (DORA)*. Dz.Urz. UE L 333/1. Grudzień 2022. URL: `https://eur-lex.europa.eu/legal-content/PL/TXT/?uri=CELEX%3A32022R2554`.

DRAFT

formacji, a co za tym idzie szeroka cyfryzacja usług publicznych i prywatnych oraz rosnąca skala międzynarodowego przetwarzania danych osobowych sprawiły, że zagadnienie ochrony danych stało się przedmiotem prac legislacyjnych zarówno na poziomie unijnym, jak i krajowym. Unia Europejska oraz jej państwa członkowskie zwracają szczególną uwagę na jakość ochrony danych, uznając ją za istotny element ochrony praw jednostki, zaufania do gospodarki oraz bezpiecznego funkcjonowania społeczeństwa informacyjnego. Regulacje te, omówione szczegółowo w rozdziale *Krajobraz regulacyjny*, tworzą środowisko, w którym zgodność z prawem stała się warunkiem koniecznym prowadzenia działalności w sektorach takich jak finanse, ochrona zdrowia, energetyka czy transport. Niespełnienie wymogów wiąże się z sankcjami finansowymi wobec przedsiębiorstw, a odpowiedzialność za naruszenia spoczywa bezpośrednio na organach zarządczych podmiotów nadzorowanych.

W tym kontekście szczególnego znaczenia nabiera pytanie: w jaki sposób organizacja może w sposób wiarygodny, powtarzalny i oparty na obiektywnych dowodach ocenić rzeczywisty stan zgodności swoich systemów informatycznych i ich łańcucha dostawców z obowiązującymi wymogami prawnymi? Jest to teoretycznie proste pytanie. Praktyka audytowa i badawcza pokazuje bowiem, że istniejące metodyki, choć wartościowe w swoich dziedzinach, nie dają na nie zadowalającej odpowiedzi. Powstała więc luka, której wymiary nie były do tej pory szacowane, jednak luka jest realna, dotychczas nieadresowana, jednocześnie wskazuje na braki prawidłowej oceny zgodności zarządzania systemami informatycznymi. Deklarowana zgodność w wymagami regulatorów rynku często rozmija się z weryfikowalnym stanem faktycznym. Organizacje posiadają certyfikaty i polityki bezpieczeństwa, lecz nie potrafią wskazać, które konkretne systemy przetwarzają szczególne kategorie danych osobowych, kto jest faktycznym poddostawcą kluczowej platformy chmurowej ani czy dostawca zewnętrzny kiedykolwiek był przedmiotem oceny zgodności. Zjawisko to, opisywane w literaturze anglojęzycznej jako *compliance theater*, wynika ze słabości systemów oceny opartych wyłącznie na deklaracjach i samoocenie. Jest ono równie szkodliwe, jak jawna niezgodność: daje organizacji fałszywe poczucie bezpieczeństwa.

2.1 Postulat: metodologia ORION

Prezentowana praca opisuje metodologię Oceny Ryzyka Informatycznego Organizacji Nadzorowanych (ORION), oryginalny framework metodyczny zaprojektowany w celu wypełnienia opisanej luki. ORION nie jest kolejną implementacją istniejących standardów, nie zastępuje audytów ISO (*International Organization for Standardization*) czy NIST (*National Institute of Standards and Technology*), nie jest też systemem informatycznym w technicznym sensie tego słowa. Jest formalnie zdefiniowaną metodyką oceny zgodności systemów ICT i ich łańcucha dostaw, opartą na czterech innowacjach konceptualnych.

Fundamentem metodywi jest wieloperspektywiczność, którą można wytłumaczyć jako segmentację kompetencyjną. Celem jest rozdzielenie procesu oceny na trzy perspektywy: zgodności (prawną), użytkownika (biznesową) oraz techniczną. Zapewnia to, że odpowiedzi udzielają wyłącznie osoby posiadające realne kompetencje w danej dziedzinie.

Kolejny istotny element to rygor dowodowy. Kluczem jest zastąpienie deklaratywności ocen weryfikacją artefaktów (logi, certyfikaty). System wprowadza mechanizm penalizacji scoringowej za brak materialnych dowodów, co eliminuje zjawisko fasadowej zgodności (compliance theater).

Finalnie wynik mapowany jest jako sieć powiązań w modelu grafowym. Dzięki algorytmom propagacji ryzyka, ORION pozwala wyliczyć, jak błędy poddostawcy wpływają

DRAFT

na bezpieczeństwo i ciągłość działania podmiotu nadrzędnego.

Uzupełnieniem trzech powyższych elementów jest modułowa rozszerzalność sektorowa: rdzeń metodyczny, czyli model grafowy, formuły scoringu i struktura pytań, jest niezależny od branży, a zakres aktywnych pytań wynika z klasy regulacyjnej podmiotu i atrybutów ocenianych obiektów.

DRAFT

3. Krajobraz regulacyjny

3.1 Krajowe ramy prawne cyberbezpieczeństwa i ochrony danych

Polska, jako państwo członkowskie Unii Europejskiej, od lat aktywnie uczestniczy w budowaniu europejskiego systemu ochrony danych i cyberbezpieczeństwa. Punktem wyjścia dla krajowych regulacji w tym zakresie stało się wdrożenie unijnej dyrektywy NIS z 2016 roku,[1] która zobowiązała państwa członkowskie do ustanowienia krajowych norm cyberbezpieczeństwa. W odpowiedzi na te wymagania, Polska uchwaliła ustawę o krajowym systemie cyberbezpieczeństwa, przyjętą przez Sejm RP dnia 5 lipca 2018 roku i podpisaną przez Prezydenta RP dnia 1 sierpnia 2018 r., która weszła w życie 28 sierpnia 2018 r..[2]

3.1.1 Zakres obowiązków wynikający z ustawy o krajowym systemie cyberbezpieczeństwa z 2018 r.

Ustawa o krajowym systemie cyberbezpieczeństwa[3] nakłada kompleksowe obowiązki przede wszystkim na operatorów usług kluczowych (*OUK*) oraz dostawców usług cyfrowych (*DUC*), działających w sektorach takich jak energetyka, transport, bankowość, ochrona zdrowia czy infrastruktura cyfrowa.

[1] *Dyrektywa Parlamentu Europejskiego i Rady (UE) 2016/1148 z dnia 6 lipca 2016 r. w sprawie środków na rzecz wysokiego wspólnego poziomu bezpieczeństwa sieci i systemów informatycznych na terytorium Unii*. 19 lipca 2016 (dalej jako Dyrektywa NIS).

[2] UKSC.

[3] UKSC.

DRAFT

Tabela 3.1: Główne obowiązki nałożone ustawą o KSC z 2018 r.

Obszar obowiązku	Opis
Zarządzanie ryzykiem	Regularna identyfikacja i ocena ryzyk cyberbezpieczeństwa; opracowanie i wdrożenie strategii ochrony adekwatnej do specyfiki działalności.
Środki techniczne i org.	Zapewnienie bezpiecznej eksploatacji systemów, w tym bezpieczeństwa fizycznego, kontroli dostępu oraz ciągłości świadczenia usług.
Monitorowanie i zgłaszanie incydentów	Bieżące monitorowanie systemów informatycznych; raportowanie incydentów do właściwych zesp. CSIRT (Zespół reagowania na incydenty bezpieczeństwa komputerowego) (CSIRT GOV, CSIRT NASK, CSIRT MON).
Dokumentacja	Opracowanie i przechowywanie przez co najmniej 2 lata dokumentacji dotyczącej cyberbezpieczeństwa systemu informacyjnego.
Audyty	Przeprowadzanie regularnych audytów bezpieczeństwa oraz szkoleń dla pracowników.
Współpraca z organami	Koordynacja działań z organami właściwymi ds. cyberbezpieczeństwa; udostępnianie wyników audytów w razie kontroli.

3.1.2 Nowelizacja UKSC z 23 stycznia 2026 roku (implementacja NIS2)

W dniu 23 stycznia 2026 r. Sejm uchwalił nowelizację ustawy o krajowym systemie cyberbezpieczeństwa,[4] stanowiącą implementację unijnej dyrektywy NIS2[5] do polskiego porządku prawnego. Ustawa została następnie podpisana przez Prezydenta RP, który jednocześnie skierował ją do Trybunału Konstytucyjnego, podnosząc wątpliwości dotyczące m.in. obowiązku wymiany sprzętu bez odszkodowania oraz sposobu podejmowania decyzji przez organy nadzorcze.

[4] *Ustawa z dnia 23 stycznia 2026 r. o zmianie ustawy o krajowym systemie cyberbezpieczeństwa oraz niektórych innych ustaw.* 2026.

[5] *Dyrektywa Parlamentu Europejskiego i Rady (UE) 2022/2555 z dnia 14 grudnia 2022 r. w sprawie środków na rzecz wysokiego wspólnego poziomu cyberbezpieczeństwa na terytorium Unii (NIS2).* 27 grudnia 2022 (dalej jako Dyrektywa NIS2).

DRAFT

Tabela 3.2: Kluczowe zmiany wprowadzone nowelizacją UKSC z 2026 r.

Zmiana	Opis
Rozszerzenie zakresu podmiotowego	Poszerzenie katalogu branż i obniżenie progu wejścia do systemu
Obowiązek samoidentyfikacji	Organizacja samodzielnie ma obowiązek ustalić swój status, dokonać kwalifikacji i złożyć wniosek o wpis do właściwego wykazu.
Odpowiedzialność zarządcza	Odpowiedzialność przestaje być wyłącznie operacyjna i staje się elementem ładu korporacyjnego oraz osobistej odpowiedzialności członków zarządu.
Kary finansowe	Podmioty kluczowe: do 10 mln EUR lub 2% rocznego światowego obrotu; podmioty ważne: do 7 mln EUR lub 1,4% obrotu.
Odroczenie kar	Kary pieniężne za naruszenia mogą być nakładane dopiero po upływie 2 lat od wejścia w życie ustawy.
Modyfikacje definicji	Zawężenie definicji organizacji badawczej i doprecyzowanie zakresu podmiotowego wobec środowisk naukowych.

3.1.3 Ustawa o ochronie danych osobowych z 10 maja 2018 r.

Z punktu widzenia bezpieczeństwa, istotną ustawą w krajowym prawodawstwie jest Ustawa z dnia 10 maja 2018 r. o ochronie danych osobowych,[6] która stanowi akt wykonawczy wobec rozporządzenia RODO[7] i reguluje m.in. zasady działania Prezesa Urzędu Ochrony Danych Osobowych (PUODO) jako krajowego organu nadzorczego, tryb postępowania przed tym organem, szczegółowe zasady przetwarzania danych oraz krajowe przepisy uzupełniające RODO tam, gdzie rozporządzenie pozostawia swobodę regulacyjną państwom członkowskim.

Odpowiedzialność administracyjna na gruncie RODO

Rozporządzenie RODO[8] przewiduje dwustopniowy system administracyjnych kar pieniężnych (art. 83 RODO).

[6] *Ustawa z dnia 10 maja 2018 r. o ochronie danych osobowych*. Weszła w życie 25 maja 2018 r. 2018.

[7] *Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2016/679 z dnia 27 kwietnia 2016 r. w sprawie ochrony osób fizycznych w związku z przetwarzaniem danych osobowych i w sprawie swobodnego przepływu takich danych oraz uchylenia dyrektywy 95/46/WE (ogólne rozporządzenie o ochronie danych)*. Stosowane od 25 maja 2018 r. 4 maja 2016 (dalej jako RODO).

[8] RODO.

DRAFT

Tabela 3.3: Administracyjne kary pieniężne na mocy art. 83 RODO

Wysokość kary	Przykładowe naruszenia
Do 10 mln EUR lub 2% rocznego obrotu	Brak rejestru czynności przetwarzania; brak wyznaczenia inspektora ochrony danych w wymaganych przypadkach; brak współpracy z organem nadzorczym.
Do 20 mln EUR lub 4% rocznego obrotu	Złamanie podstawowych zasad przetwarzania danych; naruszenie praw osób, których dane dotyczą; nielegalny transfer danych do państw trzecich.

Organ nadzorczy dysponuje również wachlarzem środków nacisku (art. 58 RODO): ostrzeżenia i upomnienia, nakazanie spełnienia żądań osoby, której dane dotyczą, nakazanie dostosowania operacji przetwarzania do przepisów RODO, a w najpoważniejszych przypadkach, czasowe lub całkowite ograniczenie przetwarzania, w tym zakaz przetwarzania danych oraz nakaz ich usunięcia lub powiadomienia o naruszeniu.

3.1.4 Ustawa o zwalczaniu nieuczciwej konkurencji (1993)

Ustawa z dnia 16 kwietnia 1993 r. o zwalczaniu nieuczciwej konkurencji[9] stanowi istotne uzupełnienie systemu ochrony danych, zwłaszcza w zakresie ochrony tajemnicy przedsiębiorstwa. Zgodnie z art. 11 u.z.n.k., czynem nieuczciwej konkurencji jest ujawnienie, wykorzystanie lub pozyskanie cudzych informacji stanowiących tajemnicę przedsiębiorstwa. Za tajemnicę przedsiębiorstwa uznaje się informacje techniczne, technologiczne, organizacyjne lub inne posiadające wartość gospodarczą, które nie są powszechnie znane i co do których przedsiębiorca podjął należyte środki w celu zachowania ich poufności.

W kontekście naruszeń danych i cyberbezpieczeństwa ustawa ta nabiera szczególnego znaczenia: wyciek danych stanowiących tajemnicę przedsiębiorstwa (np. w wynik ataku hakerskiego, działania nielojalnego pracownika lub wadliwego zabezpieczenia systemów) może jednocześnie stanowić naruszenie RODO oraz czyn nieuczciwej konkurencji z u.z.n.k. Ustawa przewiduje cywilnoprawne środki ochrony, w tym roszczenia o zaniechanie, usunięcie skutków, naprawienie szkody i wydanie bezpodstawnie uzyskanych korzyści.[10]

3.1.5 Odpowiedzialność cywilna wg kodeksu cywilnego

Odpowiedzialności z tytułu naruszenia przepisów o ochronie danych nie można rozpatrywać wyłącznie przez pryzmat RODO, kluczową rolę odgrywa tu również Kodeks cywilny.[11]

[9] *Ustawa z dnia 16 kwietnia 1993 r. o zwalczaniu nieuczciwej konkurencji.* Tekst jednolity: Dz.U. z 2003 r. Nr 153, poz. 1503 z późn. zm. 1993 (dalej jako u.z.n.k.).

[10] u.z.n.k.

[11] *Ustawa z dnia 23 kwietnia 1964 r. – Kodeks cywilny.* Tekst jednolity: Dz.U. z 2023 r. poz. 1610 z późn. zm. 1964 (dalej jako k.c.).

DRAFT

Tabela 3.4: Reżimy odpowiedzialności cywilnej w obszarze ochrony danych

Podstawa prawna	Opis
Art. 415 k.c.: odpowiedzialność deliktowa	Administrator lub podmiot przetwarzający, który ze swojej winy wyrządził szkodę osobie fizycznej poprzez naruszenie zasad ochrony danych, zobowiązany jest do jej naprawienia. Przesłankami są: bezprawne działanie lub zaniechanie, wina, szkoda oraz związek przyczynowo-skutkowy.
Art. 23, 24 i 448 k.c.: dobra osobiste	Prywatność jest traktowana jako dobro osobiste. W razie jego naruszenia pokrzywdzony może żądać zaniechania naruszeń i zasądzenia zadośćuczynienia (sądy orzekają w zbiegu z art. 82 RODO).
Art. 82 ust. 4 RODO w zw. z k.c.: solidarność	Jeżeli w tym samym przetwarzaniu uczestniczy więcej niż jeden podmiot, odpowiadają oni solidarnie za całą szkodę, co zapewnia poszkodowanemu rzeczywiste uzyskanie odszkodowania.
Art. 471 k.c.: odpowiedzialność odszkodowawcza	Jeżeli naruszenie ochrony danych stanowi jednocześnie niewykonanie lub nienależyte wykonanie zobowiązania umownego. Najbardziej typowym przykładem jest odpowiedzialność dostawcy IT wobec klienta za naruszenie obowiązków wynikających z umowy usługowej lub umowy powierzenia przetwarzania danych. Przykładowo: dostawca zobowiązał się do określonej konfiguracji uprawnień, szyfrowania danych albo wykonywania kopii zapasowych. Nie wykonał tych obowiązków, doszło do ujawnienia lub utraty danych, a klient poniósł koszty usunięcia skutków incydentu.
Zbieg podstaw odpowiedzialności	Nałożenie kary przez PUODO nie zwalnia administratora z równoległej odpowiedzialności cywilnej wobec osób poszkodowanych.

3.1.6 Odpowiedzialność karna: Kodeks karny

Odrębnym, lecz komplementarnym reżimem jest odpowiedzialność karna przewidziana w Kodeksie karnym,[12] w szczególności w rozdziale XXXIII „Przestępstwa przeciwko ochronie informacji" (art. 265–269b k.k.).

[12] *Ustawa z dnia 6 czerwca 1997 r. – Kodeks karny.* Tekst jednolity: Dz.U. z 2024 r. poz. 17 z późn. zm. 1997 (dalej jako k.k.).

DRAFT

Tabela 3.5: Przestępstwa z zakresu ochrony informacji (art. 265–269b k.k.)

Przepis	Opis
Art. 267 k.k. hacking	Kara grzywny, ograniczenia wolności albo pozbawienia wolności do 2 lat za bezprawne uzyskanie dostępu do informacji poprzez przełamanie zabezpieczeń elektronicznych, podpięcie do sieci lub stosowanie oprogramowania szpiegującego; penalizowane również ujawnianie tak pozyskanych informacji.
Art. 268 i 268a k.k.	Niszczenie lub uszkadzanie danych informatycznych i udaremnianie osobie uprawnionej zapoznania się z informacją; kara do 3 lat pozbawienia wolności, a przy znacznej szkodzie majątkowej od 3 miesięcy do 5 lat.
Art. 269 k.k.: sabotaż komputerowy	Uszkodzenie danych informatycznych lub oprogramowania o szczególnym znaczeniu dla obronności lub bezpieczeństwa państwa; kara pozbawienia wolności od 6 miesięcy do 8 lat.
Art. 269a k.k.: zakłócenie systemu	Istotne zakłócenie pracy systemu komputerowego lub sieci teleinformatycznej przez transmisję, usunięcie lub zmianę danych; kara pozbawienia wolności od 3 miesięcy do 5 lat.
Art. 269b k.k.: narzędzia ataków	Wytwarzanie, pozyskiwanie lub udostępnianie narzędzi informatycznych przeznaczonych do popełnienia powyższych przestępstw.
Art. 23 u.z.n.k. (uzupełniająco)	Ujawnienie tajemnicy przedsiębiorstwa przez osobę zobowiązaną do jej zachowania, jeżeli wyrządza to poważną szkodę: kara grzywny, ograniczenia wolności albo pozbawienia wolności do 2 lat.

Warto podkreślić, że reżim karny funkcjonuje równolegle do odpowiedzialności administracyjnej (kary RODO/UKSC) i cywilnej, skazanie sprawcy nie eliminuje roszczeń odszkodowawczych poszkodowanych ani nie uchyla administracyjnych kar nałożonych na administratora danych.[13]

3.1.7 Dyrektywa NIS2 jako fundament europejskiego cyberbezpieczeństwa

Dyrektywa Parlamentu Europejskiego i Rady (UE) 2022/2555 z dnia 14 grudnia 2022 r., znana jako NIS2,[14] reformuje unijny system cyberbezpieczeństwa. NIS2 uchyliła i zastąpiła dyrektywę NIS z 2016 r.,[15] która okazała się niewystarczająca wobec wzrostu zagrożeń cybernetycznych oraz rosnącej zależności gospodarki i administracji od systemów informatycznych. Dyrektywa NIS2 weszła w życie 16 stycznia 2023 r., zaś państwa członkowskie zobowiązane były do dokonania jej transpozycji do krajowych porządków prawnych do 17 października 2024 r. W Polsce implementacji dyrektywy dokonała nowelizacja ustawy

[13] k.k.; RODO.
[14] Dyrektywa NIS2.
[15] Dyrektywa NIS.

DRAFT

o Krajowym Systemie Cyberbezpieczeństwa z dnia 23 stycznia 2026 r..[16]

Zakres podmiotowy: podmioty kluczowe i ważne

Dyrektywa NIS2 odchodzi od dotychczasowego podziału na operatorów usług kluczowych i dostawców usług cyfrowych, dyrektywa definiuje nowe kategorie: podmioty kluczowe (ang. *essential entities*) oraz podmioty ważne (ang. *important entities*). Dyrektywą objęte są podmioty będące co najmniej średnim przedsiębiorstwem wg definicji MŚP[17] (tj. zatrudniające co najmniej 50 osób lub osiągające roczny obrót i sumę bilansową powyżej 10 mln EUR), działające w sektorach wskazanych w załącznikach I i II do dyrektywy. Jednocześnie przewidziano szereg wyjątków, na mocy których dyrektywa stosuje się niezależnie od wielkości podmiotu.

Tabela 3.6: Sektory objęte dyrektywą NIS2 według kategorii podmiotów

Kategoria	Sektory (wybrane)
Podmioty kluczowe (załącznik I)	Energetyka (energia elektryczna, gaz, ropa, wodór); transport (lotniczy, kolejowy, wodny, drogowy); bankowość i infrastruktura rynków finansowych; ochrona zdrowia; woda pitna i ścieki; infrastruktura cyfrowa (IXP, DNS, usługi chmurowe, centra danych, sieci CDN); zarządzanie usługami ICT (B2B); administracja publiczna; przestrzeń kosmiczna.
Podmioty ważne (załącznik II)	Usługi pocztowe i kurierskie; gospodarka odpadami; produkcja i dystrybucja chemikaliów; produkcja i dystrybucja żywności; produkcja (wyroby medyczne, sprzęt elektroniczny, pojazdy); dostawcy usług cyfrowych (platformy handlowe, wyszukiwarki, serwisy społecznościowe); organizacje badawcze.

Zakresem dyrektywy nie są objęte podmioty administracji publicznej prowadzące działalność w dziedzinie bezpieczeństwa narodowego, obronności lub ścigania przestępstw, podmioty wyłączone ze stosowania rozporządzenia DORA[18] (stosownie do art. 2 ust. 4 DORA), a także dostawcy świadczący usługi wyłącznie na rzecz zwolnionych organów administracji publicznej. Z obowiązku zwolnienia nie można jednak skorzystać wobec dostawców usług zaufania.

Obowiązki podmiotów kluczowych i ważnych

Dyrektywa NIS2 wprowadza identyczne obowiązki dla obu kategorii podmiotów (kluczowe oraz ważne), rozróżniając jedynie intensywność nadzoru i poziom kar. Obowiązki te mają

[16] *Ustawa z dnia 23 stycznia 2026 r. o zmianie ustawy o krajowym systemie cyberbezpieczeństwa oraz niektórych innych ustaw.*

[17] *Ustawa z dnia 6 marca 2018 r. – Prawo przedsiębiorców.* Dz.U. 2018 poz. 646. art. 7; ELI: https://eli.gov.pl/eli/DU/2018/646/ogl. 2018. URL: `https://eli.gov.pl/eli/DU/2018/646/ogl`.

[18] Parlament Europejski i Rada Unii Europejskiej, *Rozporządzenie (UE) 2022/2554 w sprawie operacyjnej odporności cyfrowej sektora finansowego (DORA).*

DRAFT

być stosowane w sposób proporcjonalny do specyfiki, wielkości i poziomu narażenia danego podmiotu na ryzyko.

Podmioty muszą zaimplementować *System Zarządzania Bezpieczeństwem Informacji*, w tym zarządzania ryzykiem. Wymaga do opracowania, wdrożenia i testowania planów ciągłości działania (*BCP*) oraz politykę bezpieczeństwa łańcucha dostaw, polegającą na szacowaniu ryzyk współpracy z dostawcami oraz poddostawcami.

Każdy podmiot kluczowy i ważny zobowiązany jest do wdrożenia odpowiednich i proporcjonalnych środków technicznych, operacyjnych i organizacyjnych, obejmujących co najmniej:

Tabela 3.7: Minimalne środki zarządzania ryzykiem wymagane przez art. 21 NIS2

Obszar	Wymagania minimalne
Polityki bezpieczeństwa i analizy ryzyka	Opracowanie i wdrożenie polityk bezpieczeństwa systemów informatycznych; regularna ocena ryzyka uwzględniająca zagrożenia, prawdopodobieństwo i dotkliwość incydentów oraz skutki społeczne i gospodarcze.
Obsługa incydentów	Ustanowienie procedur wykrywania, analizy, reakcji i odtwarzania po incydentach bezpieczeństwa.
Ciągłość działania	Wdrożenie planów ciągłości działania (BCP) i odtwarzania po awarii (DRP), w tym zarządzanie kopiami zapasowymi i zarządzanie kryzysowe.
Bezpieczeństwo łańcucha dostaw	Ocena i zarządzanie ryzykiem ze strony dostawców i usługodawców ICT; stosowanie klauzul bezpieczeństwa w umowach z dostawcami.
Bezpieczeństwo sieci i systemów	Środki kontroli dostępu, uwierzytelnianie wieloskładnikowe (MFA), szyfrowanie danych w spoczynku i w tranzycie, segmentacja sieci, zarządzanie podatnościami i aktualizacjami.
Szkolenia i świadomość	Regularne szkolenia dla zarządu i pracowników; organy zarządzające obowiązane do zatwierdzania środków zarządzania ryzykiem i odbycia wymaganych szkoleń.
Kryptografia i szyfrowanie	Wdrożenie polityk stosowania kryptografii i szyfrowania w odniesieniu do przetwarzanych danych i komunikacji.
Bezpieczeństwo zasobów ludzkich	Procedury zarządzania dostępem i polityki kontroli dostępu oparte na zasadzie najmniejszych uprawnień; bezpieczeństwo personelu.

Środki zarządzania ryzykiem muszą być zatwierdzone przez organ zarządzający podmiotu. W przypadku stwierdzenia niezgodności z wymaganiami dyrektywy, podmiot zobowiązany jest do bezzwłocznego wdrożenia środków naprawczych.

DRAFT

Zgłaszanie incydentów (art. 23 NIS2)

Podmioty kluczowe i ważne zobowiązane są do zgłaszania poważnych incydentów do właściwego zespołu CSIRT lub organu nadzorczego. Za poważny incydent uznaje się zdarzenie, które powoduje lub może spowodować znaczne zakłócenia operacyjne lub straty finansowe, albo wpływa na inne osoby lub organizacje powodując znaczne szkody.

Tabela 3.8: Harmonogram obowiązkowego raportowania incydentów na mocy art. 23 NIS2

Termin	Zakres informacji
Max. 24 h: wczesne ostrzeżenie	Niezwłoczne poinformowanie o poważnym incydencie z wskazaniem: czy incydent mógł być wywołany działaniem bezprawnym lub złym zamiarem; czy mógł wywrzeć wpływ transgraniczny.
Max. 72 h: zgłoszenie incydentu	Pełna aktualizacja wczesnego ostrzeżenia z wstępną oceną incydentu, jego dotkliwości i skutków oraz wskaźnikami integralności systemu. Dostawcy usług zaufania dokonują zgłoszenia w ciągu 24 h.
Na wniosek organu: sprawozdanie okresowe	Aktualizacje statusu w trakcie obsługi incydentu, stosownie do żądań CSIRT lub właściwego organu.
Max. 1 miesiąc: sprawozdanie końcowe	Szczegółowy opis incydentu, rodzaj zagrożenia i pierwotna przyczyna, zastosowane środki ograniczające ryzyko, transgraniczne skutki incydentu. Jeżeli incydent trwa - w terminie miesiąca od jego zakończenia.

Podmioty mają również obowiązek poinformowania odbiorców usług o poważnych incydentach mogących negatywnie wpłynąć na świadczone usługi, a także o poważnych cyberzagrożeniach i środkach zaradczych, jakie mogą podjąć. Samo zgłoszenie incydentu nie nakłada na podmiot zgłaszający zwiększonej odpowiedzialności prawnej.

3.1.8 Nadzór i egzekwowanie przepisów

Dyrektywa NIS2 wprowadza wyraźne rozróżnienie reżimów nadzoru w zależności od kategorii podmiotu.

DRAFT

Tabela 3.9: Różnice w nadzorze nad podmiotami kluczowymi i ważnymi

Aspekt	Podmioty kluczowe	Podmioty ważne
Charakter nadzoru	Nadzór ex ante (prewencyjny, ciągły) i ex post	Nadzór ex post (reaktywny, po incydencie lub sygnale)
Inspekcje i audyty	Regularne inspekcje na miejscu, zdalne audyty, testy	Inspekcje na żądanie, po stwierdzeniu naruszeń
Maks. kara administracyjna	Do 10 mln EUR lub 2% rocznego światowego obrotu	Do 7 mln EUR lub 1,4% rocznego światowego obrotu
Odpowiedzialność osobista	Możliwy zakaz pełnienia funkcji kierowniczych przez osoby fizyczne	Możliwa odpowiedzialność kierownictwa za naruszenie obowiązków w zakresie cyberbezpieczeństwa, bez przewidzianego w NIS2 zakazu pełnienia funkcji kierowniczych

3.1.9 Odpowiedzialność zarządcza

Jedną z najistotniejszych zmian wprowadzanych dyrektywą NIS2 jest *bezpośrednia odpowiedzialność organów zarządzających* za przestrzeganie wymogów cyberbezpieczeństwa. Oznacza to, że członkowie zarządu i inne osoby pełniące funkcje kierownicze mogą być osobiście pociągnięci do odpowiedzialności za poważne naruszenia przepisów dyrektywy. Organy zarządzające podmiotów zobowiązane są do:

(i) zatwierdzania środków zarządzania ryzykiem,

(ii) nadzoru nad ich wdrożeniem,

(iii) odbywania regularnych szkoleń z zakresu cyberbezpieczeństwa.

W skrajnych przypadkach właściwy organ może zwrócić się do właściwego sądu o tymczasowe zawieszenie osoby fizycznej w pełnieniu funkcji kierowniczej w danym podmiocie.

3.1.10 Rejestracja i samoidentyfikacja

Dyrektywa NIS2 wprowadza mechanizm samoidentyfikacji: to sam podmiot, a nie organ nadzorczy, ma obowiązek ustalić, czy mieści się w zakresie stosowania dyrektywy, a następnie dokonać rejestracji u właściwego organu, przekazując dane adresowe, kontaktowe, sektor i podsektor oraz wykaz państw członkowskich, w których świadczy usługi. O każdej zmianie tych danych podmiot zobowiązany jest do powiadomienia organu w terminie dwóch tygodni. W polskiej implementacji dokonanej Krajową Ustawą o Cyberbezpieczeństwie[19] termin na zgłoszenie przedsiębiorstwa do wykazu podmiotów kluczowych i ważnych wynosi 6 miesięcy od wejścia w życie ustawy, zaś na wdrożenie środków zarządzania ryzykiem 12 miesięcy.

[19] *Ustawa z dnia 23 stycznia 2026 r. o zmianie ustawy o krajowym systemie cyberbezpieczeństwa oraz niektórych innych ustaw.*

DRAFT

3.2 Regulacje związane z rynkiem finansowym

Rynek finansowy w Polsce podlega nadzorowi Komisji Nadzoru Finansowego (*KNF*). Do stycznia 2025 roku w kontekście bezpieczeństwa i odporności cyfrowej, podstawowym dokumentem obowiązującym banki była Rekomendacja D KNF.[20] KNF wydaje rekomendacje na podstawie art. 137 pkt 5 ustawy Prawo bankowe z dnia 29 sierpnia 1997 roku, Rekomendacje to dokumenty o charakterze nadzorczym, działające na zasadzie „zastosuj albo wyjaśnij", które definiują i opisują oczekiwania KNF wobec instytucji finansowych w zakresie zarządzania ryzykiem, bezpieczeństwa IT oraz ochrony danych klientów. Formalnie nie są aktami prawnymi, w praktyce traktowane są przez nadzorowane podmioty jako wymogi, ponieważ ich niestosowanie skutkuje negatywną oceną w ramach Badania i Oceny Nadzorczej (BION).[21]

Rekomendacja D została przyjęta uchwałą KNF nr 7/2013 z dnia 8 stycznia 2013 roku, następnie uchylona z dniem 17 stycznia 2025 r. i zastąpiona bezpośrednio stosowanym *Rozporządzeniem Parlamentu Europejskiego i Rady (UE) 2022/2554 z dnia 14 grudnia 2022 r. w sprawie operacyjnej odporności cyfrowej sektora finansowego i zmieniającym rozporządzenia (WE) nr 1060/2009, (UE) nr 648/2012, (UE) nr 600/2014, (UE) nr 909/2014 oraz (UE) 2016/1011*, powszechnie zwanym DORA (*Digital Operational Resilience Act*).[22]

Wytyczne i dobre praktyki zawarte w Rekomendacji D zostały w większości zachowane i przeniesione do DORA oraz towarzyszących jej regulacyjnych standardów technicznych (RTS) i wykonawczych standardów technicznych (ITS) opracowanych przez Europejski Urząd Nadzoru Bankowego (EBA).

3.2.1 Prawo bankowe

Ustawa z dnia 29 sierpnia 1997 r. - Prawo bankowe to akt prawny uchwalony przez Sejm RP 29 sierpnia 1997 r., opublikowana w Dzienniku Ustaw 1997 nr 140 poz. 939, weszła w życie 1 stycznia 1998 roku. Od tamtej pory była wielokrotnie nowelizowana, aktualny tekst jednolity obejmuje zmiany wprowadzone m.in. przez przepisy implementujące dyrektywy unijne (CRD IV, PSD2, AML).

Art. 104 ustawy Prawo bankowe nakłada na bank, jego pracowników oraz wszystkich pośredników wykonujących czynności bankowe bezwzględny obowiązek zachowania tajemnicy bankowej, obejmuje ona wszelkie informacje o czynnościach bankowych uzyskane podczas negocjacji, zawierania i realizacji umowy z klientem, a więc m.in. salda rachunków, historię transakcji, dane o kredytach, zabezpieczeniach czy zdolności kredytowej. Ujawnienie tych informacji osobom trzecim jest dopuszczalne wyłącznie za pisemną zgodą klienta lub w ściśle określonych przypadkach przewidzianych przez prawo (np. na żądanie prokuratury lub organów podatkowych). W praktyce oznacza to, że każdy pod-

[20] Komisja Nadzoru Finansowego. *Rekomendacja D dotycząca zarządzania obszarami technologii informacyjnej i bezpieczeństwa środowiska teleinformatycznego w bankach.* Załącznik do uchwały nr 7/2013 Komisji Nadzoru Finansowego z dnia 8 stycznia 2013 r., Dz. Urz. KNF z 2013 r. poz. 5. Ogłoszona 27 lutego 2013 r. 2013. URL: `https://www.knf.gov.pl/knf/pl/komponenty/img/rekomendacja_d_8_01_13_uchwala_7_33016.pdf`.

[21] Urząd Komisji Nadzoru Finansowego. *Metodyka badania i oceny nadzorczej banków komercyjnych, zrzeszających oraz spółdzielczych (Metodyka BION).* Urząd Komisji Nadzoru Finansowego, Warszawa, 12 lutego 2024 r. Dokument opisujący proces BION stosowany przez KNF. 2024. URL: `https://www.knf.gov.pl/knf/pl/komponenty/img/Metodyka_BION_2024.pdf`.

[22] Parlament Europejski i Rada Unii Europejskiej, *Rozporządzenie (UE) 2022/2554 w sprawie operacyjnej odporności cyfrowej sektora finansowego (DORA).*

DRAFT

miot zewnętrzny, w tym dostawca chmury czy firma technologiczna któremu bank powierza przetwarzanie danych, przejmuje obowiązek zachowania tajemnicy bankowej i musi gwarantować jej nienaruszalność kontraktowo oraz technicznie.

3.3 Rozporządzenie DORA: cyfrowa odporność operacyjna sektora finansowego

Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2022/2554, znane jako DORA (*Digital Operational Resilience Act*), weszło w życie 16 stycznia 2023 roku, a jego stosowanie stało się obowiązkowe od 17 stycznia 2025 roku. Rozporządzenie stanowi odpowiedź na rosnącą zależność sektora finansowego od technologii informacyjno-komunikacyjnych (ICT) oraz systematyczny wzrost liczby cyberincydentów dotykających instytucje finansowe w całej Unii Europejskiej.[23]

Rozporządzenie strukturyzuje obowiązki wokół pięciu wzajemnie powiązanych filarów, opisanych szczegółowo poniżej.

Filar I, Zarządzanie ryzykiem ICT

Pierwszy filar zobowiązuje instytucje finansowe do ustanowienia kompleksowych i udokumentowanych ram zarządzania ryzykiem ICT, za które odpowiedzialność ponosi bezpośrednio kierownictwo wyższego szczebla.[24] Ramy te muszą obejmować szczegółowy rejestr wszystkich aktywów ICT wspierających funkcje krytyczne, polityki bezpieczeństwa informacji, mechanizmy ciągłego monitorowania anomalii oraz plany ciągłości działania i odtwarzania po awarii. Podmiot finansowy zobowiązany jest do regularnego przeglądu i aktualizacji tych ram, a organ nadzoru może w każdej chwili zażądać ich udostępnienia.[25]

Filar II, Zarządzanie incydentami ICT i ich raportowanie

Drugi filar wprowadza ujednolicone, rygorystyczne reguły klasyfikowania, rejestrowania i zgłaszania incydentów związanych z ICT. W przypadku wykrycia poważnego incydentu podmiot finansowy zobowiązany jest do przekazania wstępnego powiadomienia właściwemu organowi nadzorczemu w ciągu 4 godzin, raportu pośredniego w ciągu 72 godzin oraz raportu końcowego w ciągu miesiąca. Naruszenie bezpieczeństwa ICT prowadzące do wycieku danych osobowych podlega równolegle obowiązkowi zgłoszenia do UODO na podstawie art. 33 RODO, co czyni z DORA i RODO komplementarne reżimy sprawozdawcze.

[23] Parlament Europejski i Rada Unii Europejskiej, *Rozporządzenie (UE) 2022/2554 w sprawie operacyjnej odporności cyfrowej sektora finansowego (DORA)*.

[24] Parlament Europejski i Rada Unii Europejskiej, *Rozporządzenie (UE) 2022/2554 w sprawie operacyjnej odporności cyfrowej sektora finansowego (DORA)*.

[25] *Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2022/2554 z dnia 14 grudnia 2022 r. w sprawie operacyjnej odporności cyfrowej sektora finansowego i zmieniające rozporządzenia (WE) nr 1060/2009, (UE) nr 648/2012, (UE) nr 600/2014, (UE) nr 909/2014 oraz (UE) 2016/1011 (DORA)*. 27 grudnia 2022. URL: `https://eur-lex.europa.eu/legal-content/PL/TXT/?uri=CELEX:32022R2554`.

DRAFT

Filar III, Testowanie cyfrowej odporności operacyjnej

Trzeci filar nakłada obowiązek regularnego, ustrukturyzowanego testowania odporności systemów ICT na zagrożenia. Co najmniej raz w roku podmioty finansowe muszą przeprowadzać testy obejmujące m.in. oceny podatności, testy scenariuszowe i testy penetracyjne. Duże, systemowo istotne instytucje zobowiązane są do wykonywania zaawansowanych testów penetracyjnych sterowanych zagrożeniami (*Threat-Led Penetration Testing, TLPT*) z udziałem zewnętrznych certyfikowanych podmiotów, przy czym zewnętrzny dostawca ICT musi w pełni współpracować przy ich przeprowadzaniu.

Filar IV, Zarządzanie ryzykiem zewnętrznych dostawców ICT

Czwarty filar stanowi najbardziej przełomowy element rozporządzenia. DORA ustanawia wymagania dotyczące współpracy podmiotów finansowych z zewnętrznymi dostawcami usług ICT, realizowane przede wszystkim przez obowiązki w zakresie zarządzania ryzykiem oraz obowiązkowe postanowienia umowne. Jednocześnie nakłada bezpośrednie obowiązki związane z unijnym mechanizmem nadzoru na dostawców wyznaczonych jako kluczowi zewnętrzni dostawcy usług ICT (ang. *Critical ICT Third-Party Providers (CTPP)*) na podstawie art. 31 DORA. Przykładem takich dostawców są tzw. hiperscalerzy chmurowi reprezentowani przez Google Cloud, Microsoft Azure czy Amazon Web Services. Kategoria *CTPP* jest odrębna od dostawcy kluczowego w metodologii ORION (definicja 7.3). Instytucje finansowe muszą przeprowadzać ocenę ryzyka przed zawarciem każdej umowy z dostawcą ICT, a sama umowa musi zawierać postanowienia o prawie do audytu, lokalizacji przetwarzania danych, planach wyjścia (ang. *exit plan*) oraz minimalnych okresach przejściowych przy zmianie dostawcy.[26] Korzystanie z niezatwierdzonych narzędzi chmurowych (ang. *shadow IT*) stanowi naruszenie tego filaru, a jednocześnie naruszenie zasady rozliczalności z art. 5 ust. 2 RODO.

Filar V, Wymiana informacji o cyberzagrożeniach

Piąty filar zachęca, a w określonych przypadkach zobowiązuje, podmioty finansowe do uczestnictwa w schematach wymiany informacji o zagrożeniach cybernetycznych, podatnościach i technikach ataku w ramach zaufanych społeczności sektorowych.[27] Celem jest budowanie zbiorowej odporności sektora: wczesne ostrzeżenie jednej instytucji o nowym wektorze ataku pozwala innym podmiotom na podjęcie środków zapobiegawczych zanim incydent zdąży się rozprzestrzenić. Uczestnictwo w takich schematach musi jednak odbywać się zgodnie z przepisami o ochronie danych osobowych oraz z zachowaniem tajemnicy zawodowej.[28]

[26] European Insurance and Occupational Pensions Authority (EIOPA). *Digital Operational Resilience Act (DORA)*. Strona instytucjonalna EIOPA. Informacje dotyczące wymogów DORA w zakresie zarządzania ryzykiem ICT, raportowania incydentów oraz wymiany informacji o zagrożeniach cybernetycznych. 2024. URL: `https://www.eiopa.europa.eu/digital-operational-resilience-act-dora_en` (dostęp 10.03.2025).

[27] European Insurance and Occupational Pensions Authority (EIOPA), *Digital Operational Resilience Act (DORA)*.

[28] *Rozporządzenie DORA*.

DRAFT

Sankcje

Za naruszenie rozporządzenia Wiodący Organ Nadzorczy (ang *Lead Overseer*) może nakładać na kluczowych dostawców ICT kary w wysokości do 1% średniego dziennego światowego obrotu za każdy dzień naruszenia, przez okres do sześciu miesięcy. Dla podmiotów finansowych nadzorowanych przez KNF sankcje określa prawo krajowe wdrażające uprawnienia nadzorcze wynikające z rozporządzenia.[29]

Wiodący Organ Nadzorczy to instytucja wyznaczona na poziomie UE do bezpośredniego nadzoru nad kluczowymi dostawcami ICT w ramach rozporządzenia DORA. Rolę Wiodącego Organu Nadzorczego pełni jedna z trzech unijnych instytucji:

(i) EBA (European Banking Authority) - dla dostawców ICT obsługujących głównie sektor bankowy,

(ii) ESMA (European Securities and Markets Authority) - dla dostawców obsługujących rynki kapitałowe,

(iii) EIOPA (European Insurance and Occupational Pensions Authority) - dla dostawców obsługujących ubezpieczenia i fundusze emerytalne.

Przypisanie konkretnego dostawcy do jednego z tych organów zależy od tego, jaki typ podmiotów finansowych jest jego głównym klientem. Wiodący Organ Nadzorczy ma szerokie uprawnienia wobec krytycznych dostawców ICT: może żądać informacji i dokumentacji, przeprowadzać inspekcje, wydawać zalecenia naprawcze oraz nakładać kary finansowe.

3.4 Ochrona danych medycznych, regulacje prawne i nadzór

Dane dotyczące zdrowia należą do szczególnych kategorii danych osobowych w rozumieniu art. 9 rozporządzenia (UE) 2016/679 (*RODO*),[30] co oznacza, że ich przetwarzanie jest co do zasady zakazane, a wyjątki od tego zakazu są ściśle i enumeratywnie określone w przepisach.[31] Do kategorii tej zalicza się wszelkie informacje o stanie zdrowia fizycznego lub psychicznego osoby, dane genetyczne i biometryczne, a także informacje pośrednie (takie jak numer recepty, historia wizyt lekarskich czy przynależność do grupy ubezpieczenia zdrowotnego) jeżeli pozwalają one na wyciągnięcie wniosków o stanie zdrowia danej osoby. Podwyższony reżim ochrony danych zdrowotnych uzasadniony jest ich szczególną wrażliwością: ujawnienie informacji o chorobie, leczeniu psychiatrycznym czy uzależnieniu może prowadzić do dyskryminacji w zatrudnieniu, wykluczenia z rynku ubezpieczeń lub stygmatyzacji społecznej.

[29] Komisja Nadzoru Finansowego (KNF). *Rozporządzenie DORA – strona tematyczna.* Serwis instytucjonalny KNF. Zbiór materiałów nadzorczych KNF dotyczących wdrożenia rozporządzenia (UE) 2022/2554 (DORA). 2024. URL: `https://www.knf.gov.pl/dla_rynku/dora` (dostęp 10.03.2025).

[30] RODO.

[31] *Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2016/679 z dnia 27 kwietnia 2016 r. w sprawie ochrony osób fizycznych w związku z przetwarzaniem danych osobowych i w sprawie swobodnego przepływu takich danych oraz uchylenia dyrektywy 95/46/WE (Ogólne rozporządzenie o ochronie danych, RODO).* W szczególności art. 9 dotyczący szczególnych kategorii danych osobowych (w tym danych zdrowotnych). 27 kwietnia 2016. URL: `https://eur-lex.europa.eu/legal-content/PL/TXT/?uri=CELEX:32016R0679`.

DRAFT

Krajowe ramy prawne i wielość nadzorców

Ochrona danych medycznych w Polsce regulowana jest przez trzy nakładające się warstwy prawa, za których egzekwowanie odpowiadają odrębne organy nadzorcze.

(i) Pierwszą warstwę stanowi RODO wraz z krajową ustawą o ochronie danych osobowych z 2018 roku. Nadzór nad jej przestrzeganiem sprawuje Prezes Urzędu Ochrony Danych Osobowych (UODO), uprawniony do przeprowadzania kontroli w placówkach medycznych, wydawania decyzji nakazowych i nakładania kar administracyjnych sięgających 20 milionów euro lub 4% rocznego obrotu. Każda placówka medyczna przetwarzająca dane zdrowotne na dużą skalę, zobowiązana jest do wyznaczenia Inspektora Ochrony Danych (IOD), który monitoruje zgodność przetwarzania z RODO, szkoli personel i pełni rolę punktu kontaktowego dla pacjentów oraz organu nadzoru.[32]

(ii) Drugą warstwę tworzy ustawa z dnia 6 listopada 2008 roku o prawach pacjenta i Rzeczniku Praw Pacjenta. Nadzór nad prawem pacjenta do dostępu do dokumentacji medycznej (art. 23–29 ustawy) sprawuje Rzecznik Praw Pacjenta, który rozpatruje skargi pacjentów i może kierować zalecenia do podmiotów leczniczych. Ustawa nakłada na każdy podmiot udzielający świadczeń zdrowotnych obowiązek prowadzenia, przechowywania i udostępniania dokumentacji medycznej w ściśle określony sposób, a dokumentacja ta podlega ochronie zarówno na podstawie ustawy, jak i RODO.[33]

(iii) Trzecią warstwę stanowi system akredytacji i nadzoru nad podmiotami leczniczymi, który sprawuje Ministerstwo Zdrowia we współpracy z *Narodowym Funduszem Zdrowia* oraz, w zakresie standardów informatycznych, Centrum e-Zdrowia, odpowiadające za systemy P1. Systemy P1 to centralny system e-zdrowia w Polsce, formalnie określany jako *Elektroniczna Platforma Gromadzenia, Analizy i Udostępniania Zasobów Cyfrowych o Zdarzeniach Medycznych*. Jest to państwowa platforma teleinformatyczna rozwijana przez Centrum e-Zdrowia, służąca do gromadzenia, przetwarzania i udostępniania danych o zdarzeniach medycznych oraz do obsługi usług takich jak e-recepta, e-skierowanie i wymiana EDM.[34]

Europejska Przestrzeń Danych Zdrowotnych (EHDS)

Nową regulacją jest *Europejska Przestrzeń Danych Zdrowotnych* (*European Health Data Space, EHDS*), której rozporządzenie weszło w życie 26 marca 2025 roku.[35] EHDS tworzy

[32] *Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2016/679 z dnia 27 kwietnia 2016 r.* (RODO). W szczególności art. 37–39 RODO regulujące obowiązek wyznaczenia, zadania i pozycję Inspektora Ochrony Danych (IOD). 27 kwietnia 2016. URL: `https://eur-lex.europa.eu/legal-content/PL/TXT/?uri=CELEX:32016R0679`.

[33] *Ustawa z dnia 6 listopada 2008 r. o prawach pacjenta i Rzeczniku Praw Pacjenta*. W szczególności art. 23–29 regulujące prawo pacjenta do dokumentacji medycznej oraz obowiązki podmiotów leczniczych w zakresie jej prowadzenia, przechowywania i udostępniania. 6 listopada 2008. URL: `https://isap.sejm.gov.pl/isap.nsf/download.xsp/WDU20240000581/O/D20240581.pdf`.

[34] Centrum e-Zdrowia. *Systemy informacyjne w ochronie zdrowia – P1 (e-recepta, e-skierowanie) i krajowa infrastruktura elektronicznej dokumentacji medycznej*. Serwis instytucjonalny Centrum e-Zdrowia. Informacje o systemach P1, P2 oraz standardach informatycznych elektronicznej dokumentacji medycznej zarządzanych przez Centrum e-Zdrowia. 2024. URL: `https://www.cez.gov.pl` (dostęp 10.03.2025).

[35] *Rozporządzenia EHDS (UE) 2025/327, daty wejścia w życie (26.03.2025 r.) oraz harmonogramu wdrożenia do 26.03.2027 r.* Parlament Europejski. 2025. URL: `https://eur-lex.europa.eu/legal-`

DRAFT

ogólnounijne ramy pierwotnego i wtórnego wykorzystania elektronicznych danych zdrowotnych: pacjent uzyskuje prawo dostępu do swoich danych w standardowym europejskim formacie (*EEHRxF*), możliwość kontrolowania kto ma do nich wgląd oraz prawo do ograniczenia dostępu do wybranych części dokumentacji.[36] Pełne wdrożenie systemu przewidziane jest do 26 marca 2027 roku.[37]

EHDS działa równolegle do RODO, nie zastępując go, lecz nadając sektorowi zdrowotnemu dodatkowy, sektorowy wymiar regulacyjny. Oznacza to, że placówki medyczne będą podlegać jednocześnie: RODO (nadzór UODO), ustawie o prawach pacjenta (nadzór Rzecznika Praw Pacjenta) oraz EHDS (nadzór krajowego organu ds. elektronicznych danych zdrowotnych, który Polska wyznaczy do 2027 roku). Naruszenie bezpieczeństwa systemu ICT przechowującego dane medyczne będzie tym samym incydentem, który należy raportować do wielu organów jednocześnie, analogicznie do zbieżności DORA i RODO w sektorze finansowym.

DRAFT

`content/PL/TXT/PDF/?uri=OJ:L_202500327` (dostęp 10.03.2025).

[36] *Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2025/327 z dnia 11 lutego 2025 r. w sprawie Europejskiej Przestrzeni Danych Dotyczących Zdrowia i zmieniające rozporządzenie (UE) 2018/1724 i dyrektywę 2011/24/UE.* Weszło w życie 26 marca 2025 r.; ustanawia EHDS jako ogólnounijne ramy pierwotnego i wtórnego wykorzystania elektronicznych danych zdrowotnych. 5 marca 2025. URL: `https://eur-lex.europa.eu/legal-content/PL/TXT/?uri=CELEX:32025R0327`.

[37] *Rozporządzenia EHDS (UE) 2025/327, daty wejścia w życie (26.03.2025 r.) oraz harmonogramu wdrożenia do 26.03.2027 r.*

4. Ryzyka w praktyce: zagrożenia, konsekwencje i dobre praktyki

Zrozumienie architektury środowiska organizacji oraz pełna inwentaryzacja usług jest kluczem do prawidłowego zarządzania ryzykiem ICT. Badania przeprowadzone przez firmę *Swimlane* wykazały, że 71% organizacji nie jest w stanie całościowo dokonać audytu wszystkich systemów zgodnie z wewnętrznymi i zewnętrznymi standardami.[1]
Badania wskazują jako przyczyny:

(i) *Fragmentację narzędzi*: 92% respondentów korzysta z co najmniej trzech różnych narzędzi do zbierania dowodów audytowych, co powoduje powielanie pracy i niespójność danych;

(ii) *Uzależnienie od procesów manualnych*: średnio jedynie 39% procesu zbierania dowodów jest zautomatyzowane; ponad połowa organizacji (54%) poświęca ponad 5 godzin tygodniowo na ręczne zadania compliance;

(iii) *Podatność na błędy w danych*: 62% organizacji przyznaje, że proces zbierania dowodów audytowych jest przynajmniej sporadycznie obarczony błędem;

(iv) *Brak współpracy między zespołami*: 90% organizacji wskazuje, że słaba koordynacja między zespołami podważa gotowość do audytu;

(v) *Rosnącą złożoność regulacyjną*: 96% organizacji twierdzi, że dotrzymanie kroku rosnącej liczbie regulacji branżowych stanowi istotne wyzwanie.

Jakość prowadzonych audytów bywa podważana przez samych badanych. Brak kompetencji osób wypełniających kwestionariusze audytowe nie gwarantuje poprawności udzielanych odpowiedzi. Badanie *The Next Generation Cybersecurity Auditor* przeprowadzone na próbie 151 tys. audytorów IT z firm Big Four (*Deloitte, Ernst & Young, KPMG, PricewaterhouseCoopers*) wykazało, że poziom wiedzy proceduralnej (praktycznej) audytorów był o 17% niższy niż poziom ich wiedzy teoretycznej, a poziom pewności siebie respondentów nie był skorelowany z ich rzeczywistymi wynikami, co wskazuje na efekt Dunninga-Krugera w środowisku audytorskim.[2]

Dodatkowym problemem obniżającym jakość audytów jest zjawisko nierzetelnego wypełniania kwestionariuszy przez respondentów. Badania z zakresu ekonomii behawioralnej wskazują, że nieuczciwość w systemach samoraportowania jest powszechna, Friesen

[1] Swimlane. *GRC Chaos: The High Price of Audits and Non-Compliance*. Sprawozdanie techniczne. Survey conducted by Sapio Research among 500 IT and cybersecurity decision-makers in the US and UK, March 2025. Swimlane, Inc., kwiecień 2025. URL: `https://swimlane.com/news/grc-audit-research/` (dostęp 10.03.2026).

[2] Brandon Henry. „The Next Generation Cybersecurity Auditor: Technical Competency Gaps in 151,000 IT Auditors in the Audit Industry". W: *Security Magazine* (październik 2022). Dotyczy luki kompetencyjnej między wiedzą deklaratywną a proceduralną u audytorów IT w firmach Big Four; wykazano 17% spadek poziomu wiedzy praktycznej względem teoretycznej. URL: `https://www.securitymagazine.com/articles/98555-technical-competency-gaps-in-151-000-it-auditors-in-the-audit-industry` (dostęp 10.03.2026).

DRAFT

i Gangadharan wykazali eksperymentalnie, że respondenci częściej podają prawdziwe informacje w reżimach raportowania obowiązkowego niż dobrowolnego, co sugeruje, iż bez odpowiednio zaprojektowanych mechanizmów egzekwowania trudno osiągnąć satysfakcjonujący poziom zgodności odpowiedzi ze stanem faktycznym.[3] Potwierdzają to badania Peer i in., którzy wykazali, że zobowiązanie do złożenia przysięgi uczciwości zmniejsza skłonność do nieuczciwości (wyrażona w miarze statystycznej „iloraz szans" (ang. *Odds Ration, OR*)): $OR = 0{,}79$ [0,72; 0,88], jednak sama relacja interpersonalna między wypełniającym a audytorem nie wywiera istotnego wpływu na rzetelność odpowiedzi ($OR = 1{,}08$ [0,97; 1,20]).[4] Oznacza to, że dowody pozyskane poprzez nieusystematyzowane, dobrowolne kwestionariusze audytowe mogą być obarczone istotną słabością metodologiczną, a ich wartość jako podstawy oceny ryzyka ICT powinna być traktowana z należytą ostrożnością.

4.1 Shadow IT

Trudnym do wykrycia problemów z bezpieczeństwem jest zjawisko zwane jako *Shadow IT*. Definiuje się je, jako wykorzystanie przez pracowników narzędzi informatycznych, aplikacji, urządzeń lub usług bez wiedzy i zgody działu IT organizacji.[5] W wyniku restrykcyjnych polityk bezpieczeństwa, użytkownicy sięgają po nieautoryzowane rozwiązania informatyczne w celu usprawnienia codziennej pracy, zjawisko to nasilił wzrost popularności modelu pracy zdalnej.[6]

Raport Capterra z 2023 roku wskazuje, że 76% małych i średnich przedsiębiorstw identyfikuje *Shadow IT* jako umiarkowane lub poważne zagrożenie dla cyberbezpieczeństwa.[7] Badania JumpCloud pokazują, że w 2023 roku 41% pracowników korporacyjnych korzystało z technologii pozostających poza nadzorem działu IT,[8] a średnio firma dysponuje 975 nieznanymi usługami chmurowymi, podczas gdy jedynie 108 jest przez nią oficjalnie monitorowanych.[9]

Niepokojący jest wpływ *Shadow IT* na bezpieczeństwo organizacji. Badanie Kaspersky z 2023 roku wykazało, że 85% firm doświadczyło incydentów cyberbezpieczeństwa, przy czym w co najmniej 11% przypadków rola *Shadow IT* była bezpośrednio udokumentowana.[10] Szacuje się, że prawie połowa wszystkich cyberataków ma swoje źródło właśnie *w Shadow IT*. Wykrycie *Shadow IT* jest szczególnie trudne, ponieważ zasoby te z definicji funkcjonują poza zasięgiem standardowych narzędzi monitorowania sieci i systemów

DRAFT

[3] Lana Friesen. „Designing Self-Reporting Regimes to Encourage Truth Telling". W: *Journal of Economic Behavior & Organization* 95 (2013). DOI: 10.1016/j.jebo.2013.08.007. URL: https://www.sciencedirect.com/science/article/abs/pii/S0167268113002072.

[4] Eyal Peer, Thomas Vanhoof i in. „Commitment to honesty oaths decreases dishonesty, but commitment to another individual does not". W: *Communications Psychology* 1.1 (2023). DOI: 10.1038/s44271-023-00028-7. URL: https://www.nature.com/articles/s44271-023-00028-7.

[5] IBM. *What Is Shadow IT?* Dostęp: 2026. 2022. URL: https://www.ibm.com/think/topics/shadow-it.

[6] JumpCloud. *What Is Shadow IT? 2024 Statistics & Solutions*. Dostęp: 2026. 2024. URL: https://jumpcloud.com/blog/shadow-it.

[7] Capterra. *Shadow IT Report 2023*. Cytowane w: Auvik (2024), dostęp: 2026. 2023. URL: https://www.capterra.com.

[8] JumpCloud, *What Is Shadow IT? 2024 Statistics & Solutions*.

[9] Josys. *Shadow IT Definition: 2024 Statistics and Solutions*. Dostęp: 2026. 2024. URL: https://josys.com/article/article-shadow-it-shadow-it-definition-2024-statistics-and-solutions.

[10] Kaspersky. *IT Security Economics Report 2023*. Cytowane w: ISACA Journal (2024), dostęp: 2026. 2023. URL: https://www.kaspersky.com.

bezpieczeństwa.[11]

Istnienie *Shadow IT* w organizacji stanowi sygnał, że istniejące polityki i narzędzia IT nie zaspokajają w pełni potrzeb pracowników. Pracownicy wykorzystujący w swojej pracy nieautoryzowane rozwiązania pokazują, że istnieją luki w oficjalnej ofercie narzędziowej organizacji. Sutuacja ta powinna skłoniać działy IT do werfyikacji swoich polityk oraz systemów szkoleń.[12]

4.2 Shadow AI

Dynamiczny rozwój narzędzi generatywnej sztucznej inteligencji w latach 2022-2025 wytworzył nową kategorię zjawiska Shadow IT, określaną jako *Shadow AI*. Definiuje się je jako wykorzystanie przez pracowników systemów sztucznej inteligencji, w szczególności narzędzi generatywnych, bez wiedzy, zgody i oceny bezpieczeństwa ze strony działu IT organizacji.[13]

Shadow AI wyróżnia się od klasycznego Shadow IT jedną właściwością istotnie zwiększającą profil ryzyka: użycie narzędzia AI nieodłącznie wiąże się z przesyłaniem danych wejściowych do infrastruktury zewnętrznego dostawcy. Klasyczne Shadow IT może działać lokalnie, bez transferu danych poza organizację. Shadow AI natomiast z definicji eksportuje dane wejściowe każdorazowo, gdy pracownik sformułuje zapytanie do modelu.

Skala zjawiska jest znaczna. Raport LayerX Security wykazał, że 50% pracowników przyznało się do wklejania wrażliwych danych firmowych do narzędzi generatywnej AI, z czego 18% deklarowało udostępnianie danych szczególnie wrażliwych.[14] Analiza Cyberhaven Labs, obejmująca 1,6 mln pracowników, wykazała, że 11% danych wklejanych do ChatGPT stanowią informacje poufne, a przeciętna firma notuje kilkaset takich zdarzeń tygodniowo.[15] Raport Microsoft *Work Trend Index 2024* wskazał, że 78% pracowników korzystających z AI w pracy robi to za pomocą własnych, prywatnych kont w narzędziach niezatwierdzonych przez pracodawcę.[16]

Shadow AI generuje trzy odrębne kategorie ryzyka regulacyjnego.

(i) *Ryzyko naruszenia RODO.* Dane przesyłane do modeli generatywnej AI trafiają na serwery dostawców zlokalizowane poza Europejskim Obszarem Gospodarczym. Stanowi to transfer danych osobowych wymagający ważnej podstawy prawnej w rozumieniu rozdziału V RODO, takiej jak standardowe klauzule umowne (SCC) lub

[11] ISACA. „Risk in the Shadows". W: *ISACA Journal* 6 (2024). Dostęp: 2026. URL: https://www.isaca.org/resources/isaca-journal/issues/2024/volume-6/risk-in-the-shadows.

[12] Grip Security. *How to Detect and Manage Shadow IT in 5 Steps*. Dostęp: 2026. 2025. URL: https://www.grip.security/blog/5-steps-to-detect-and-control-shadow-it.

[13] Gartner, Inc. *Gartner Predicts Forty Percent of AI Data Breaches Will Arise from Cross-Border GenAI Misuse by 2027*. Gartner Newsroom Press Release. Accessed: June 2026. Luty 2025. URL: https://www.gartner.com/en/newsroom/press-releases/2025-02-17-gartner-predicts-forty-percent-of-ai-data-breaches-will-arise-from-cross-border-genai-misuse-by-2027.

[14] LayerX Security. *Enterprise AI and SaaS Data Security Report 2025*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. LayerX Security Ltd., 2025. URL: https://www.cybersecurity-insiders.com/research-says-over-77-percent-of-data-is-shared-to-chatgpt-by-employees/.

[15] Cyberhaven Labs. *11% of data employees paste into ChatGPT is confidential*. Dostęp: 10 marca 2026. 2023. URL: https://www.cyberhaven.com/blog/4-2-of-workers-have-pasted-company-data-into-chatgpt.

[16] Microsoft i LinkedIn. *2024 Work Trend Index Annual Report: AI at Work Is Here. Now Comes the Hard Part*. Sprawozdanie techniczne. Based on a survey of 31,000 professionals across 31 countries. Accessed: June 2026. Microsoft Corporation, maj 2024. URL: https://www.microsoft.com/en-us/worklab/work-trend-index/ai-at-work-is-here-now-comes-the-hard-part.

DRAFT

przynależność dostawcy do Ram Ochrony Prywatności Danych (DPF). W przypadku Shadow AI transfer ten odbywa się bez wiedzy administratora, co wyklucza spełnienie wymogu rozliczalności z art. 5 ust. 2 RODO: pracownik, bez stosownego umocowania, dokonuje transferu danych, za który organizacja ponosi pełną odpowiedzialność.

(ii) *Ryzyko na gruncie AI Act.* Rozporządzenie (UE) 2024/1689, zwane *AI Act*, które weszło w życie 1 sierpnia 2024 roku, nakłada na podmioty *stosujące* systemy AI obowiązki uzależnione od poziomu ryzyka danego systemu.[17] Korzystanie przez pracownika z niezatwierdzonego modelu AI do wspomagania decyzji kredytowych, rekrutacyjnych lub diagnostyki medycznej może oznaczać, że organizacja faktycznie stosuje system AI wysokiego ryzyka w rozumieniu art. 6 i załącznika III AI Act bez przeprowadzenia wymaganej oceny zgodności i bez zapewnienia nadzoru ludzkiego. Odpowiedzialność spoczywa na organizacji niezależnie od tego, że wdrożenie nastąpiło bez wiedzy zarządu.

(iii) *Ryzyko jakości i wiarygodności.* Modele generatywnej AI mogą generować błędne informacje, określane jako *halucynacje modelu*. Wbudowanie wyników działania niezweryfikowanego modelu w procesy decyzyjne, na przykład w analizy prawne, rekomendacje medyczne lub wyceny finansowe, bez procedury weryfikacji tworzy ryzyko operacyjne, za które odpowiada organizacja. Warunki korzystania z większości narzędzi generatywnej AI wprost wyłączają odpowiedzialność dostawcy za skutki biznesowe zastosowania generowanych treści.

Podobnie jak Shadow IT, Shadow AI jest diagnozą organizacyjną: pracownicy sięgają po niezatwierdzone modele AI, ponieważ zatwierdzone rozwiązania nie spełniają ich potrzeb lub procedura akceptacji jest zbyt długa. Odpowiedzią nie jest wyłącznie zakaz, lecz wdrożenie zatwierdzonego środowiska AI uzupełnionego polityką dopuszczalnego użycia, która definiuje, jakich danych nie wolno wprowadzać do żadnego zewnętrznego modelu.

4.3 Edukacja jako fundament ochrony danych osobowych

Problem *shadow IT* oraz niewłaściwego posługiwania się danymi osobowymi jest w znacznej mierze wynikiem niewystarczającego poziomu świadomości i wiedzy pracowników. Badania przeprowadzone przez Stanford University i firmę Tessian wskazują, że 88% naruszeń bezpieczeństwa informacji wynika z błędu ludzkiego, a nie z działania cyberprzestępców.[18] Raport Verizon *Data Breach Investigations Report 2024* wskazuje, że czynnik ludzki, zdefinowany jako nieświadome błędy lub brak kompetencji, pozostaje głów-

[17] European Parliament i Council of the European Union. *Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 Laying Down Harmonised Rules on Artificial Intelligence (Artificial Intelligence Act)*. Entered into force: 1 August 2024. Accessed: June 2026. Lipiec 2024. URL: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32024R1689.

[18] ISOQAR CEE. *Błąd ludzki – cichy sprawca naruszeń bezpieczeństwa informacji*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. ISOQAR CEE Sp. z o.o., 2024. URL: https://www.isoqar.pl/pl/aktualnosci/bezpieczenstwo-informacji/blad-ludzki-cichy-sprawca-naruszen-bezpieczenstwa-informacji.

DRAFT

nym źródłem naruszeń bezpieczeństwa danych.[19] Raport *Cyberportret polskiego biznesu* z 2024 roku przedstawił dane dla Polski: ponad połowa pracowników w polskich firmach nie przeszła żadnego szkolenia z zakresu cyberbezpieczeństwa i ochrony danych w ciągu ostatnich pięciu lat.[20]

Skala i charakter najczęstszych incydentów potwierdzają diagnozę. W 2024 roku zespół CERT Polska odnotował wzrost liczby cyberzagrożeń, liczba zgłoszeń w jednym roku przekroczyła 600 tysięcy, najczęstszym incydentem były ataki phishinggowe, czyli uzyskanie korzyści przez przestępców poprzez manipulacje zachowania ofiary, a nie na przełamaniu zabezpieczeń technicznych.[21] W badaniu przeprowadzonym przez Keepnet Labs w 2026 roku 45% pracowników przyznało, że ich organizacja nie zapewniła szkoleń z zakresu bezpieczeństwa.[22]

W kontekście polskiego rynku sygnałem pozytywnym jest fakt, że cyberbezpieczeństwo stało się najszybciej rosnącym segmentem rynku IT w Polsce, a w latach 2024-2025 niemal dwie trzecie respondentów wskazało je na pierwszym miejscu wśród inwestycji IT, 43% badanych uznało je za najważniejszy pojedynczy obszar.[23] Wzrost wydatków koncentruje się na rozwiązaniach technicznych, a nie na edukacji pracowników, co przy dominacji błędu ludzkiego jako źródła incydentów stanowi strategiczną asymetrię w alokacji zasobów.[24]

Wymiar regulacyjny obowiązku szkolenia

Edukacja pracowników nie jest jedynie kwestią dobrej praktyki lub woli pracodawcy. Aktualnie jest obowiązkiem, wynikającym aktów prawnych. RODO nakłada na administratora obowiązek zapewnienia, by osoby upoważnione do przetwarzania danych osobowych były odpowiednio przeszkolone (art. 32 ust. 4 RODO), a brak szkoleń jako środka techniczno-organizacyjnego stanowi podstawę do nałożenia kary przez UODO.[25] Rozporządzenie DORA zobowiązuje instytucje finansowe do prowadzenia programów podnoszenia świadomości w zakresie ryzyka ICT, w tym kadry zarządzającej.[26] Norma ISO/IEC 27001 wprost wymaga wdrożenia udokumentowanych programów szkoleń i uświadamiania jako kontroli organizacyjnej.[27] Brak lub niewystarczający program szkoleniowy staje się zatem

[19]Verizon Business. *2024 Data Breach Investigations Report*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. Verizon Communications Inc., 2024. URL: https://www.verizon.com/business/resources/reports/dbir/.

[20]BrandsIT. *Im mniej szkoleń, tym więcej ataków. Jak brak edukacji wpływa na cyberbezpieczeństwo firm*. Dostęp: 10 marca 2026. 2025. URL: https://brandsit.pl/im-mniej-szkolen-tym-wiecej-atakow-jak-brak-edukacji-wplywa-na-cyberbezpieczenstwo-firm/.

[21]CERT Polska / NASK. *Analiza bezpieczeństwa polskiego internetu w 2024 roku*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. Ministerstwo Cyfryzacji / NASK PIB, 2025. URL: https://www.gov.pl/web/baza-wiedzy/analiza-bezpieczenstwa-polskiego-internetu-w-2024-roku.

[22]Keepnet Labs. *Security Awareness Training Statistics [Updated 2026]*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. Keepnet Labs Ltd., 2026. URL: https://keepnetlabs.com/blog/security-awareness-training-statistics.

[23]PAP Biznes. *Cyberbezpieczeństwo najszybciej rosnącym segmentem rynku IT w Polsce*. Dostęp: 10 marca 2026. 2026. URL: https://biznes.pap.pl/wiadomosci/gry-i-technologie/cyberbezpieczenstwo-najszybciej-rosnacym-segmentem-rynku-it-w-polsce-w.

[24]BrandsIT, *Im mniej szkoleń, tym więcej ataków. Jak brak edukacji wpływa na cyberbezpieczeństwo firm*.

[25]ISOQAR CEE, *Błąd ludzki – cichy sprawca naruszeń bezpieczeństwa informacji*.

[26]Autoriteit Financiële Markten (AFM). *Digital Operational Resilience Act (DORA)*. Strona instytucjonalna AFM. Informacje nt. wymogów DORA, w tym zarządzania ryzykiem ICT i obowiązków raportowania incydentów dla podmiotów finansowych. 2025. URL: https://www.afm.nl/en/sector/themas/digitalisering/dora (dostęp 10.03.2025).

[27]ISOQAR CEE, *Błąd ludzki – cichy sprawca naruszeń bezpieczeństwa informacji*.

DRAFT

nie tylko źródłem ryzyka operacyjnego, lecz również jest przyczyną i źródłem niezgodności z obowiązującym prawem.

4.4 Często występujące ryzyka związane z nieprawidłowym przetwarzaniem danych

Niewłaściwe i ryzykowne zachowania pracowników można zidentyfikować i wskazać główne ich źródła. Poniżej przedstawiono najistotniejsze kategorie zachowań, udokumentowane przez raporty branżowe, organy nadzoru oraz literaturę naukową.

(i) *Przekazywanie danych do narzędzi generatywnej AI.* Pracownicy przekazują dane wrażliwe, treści umów, numery PESEL, historię transakcji, do narzędzi takich jak ChatGPT, Copilot czy Gemini, w celu ich podsumowania lub analizy. Dane te trafiają bezpośrednio na serwery dostawców zlokalizowane w Stanach Zjednoczonych, poza kontrolą organizacji. Raport LayerX Security *Enterprise AI and SaaS Data Security Report 2025* wykazał, że *50% pracowników* przyznało się do wklejania wrażliwych danych firmowych do narzędzi generatywnej AI, przy czym 18% z nich deklarowało udostępnianie danych szczególnie wrażliwych, w tym danych produkcyjnych i zastrzeżonych.[28] Równolegle analiza Cyberhaven Labs, obejmująca 1,6 mln pracowników, wykazała, że 11% danych wklejanych przez pracowników do ChatGPT stanowią informacje poufne, a przeciętna firma notuje kilkaset takich zdarzeń tygodniowo.[29]

(ii) *Używanie prywatnych kont w usługach chmurowych do transferu dokumentów służbowych.* Pracownicy przesyłają dokumenty zawierające dane osobowe na prywatne konta Google Drive, Dropbox czy Microsoft OneDrive, omijając firmowe procedury DLP (*Data Loss Prevention*). Według raportu WifiTalents *Shadow IT Statistics 2025*, 58% pracowników korzysta z prywatnych rozwiązań do przechowywania plików bez zgody działu IT, a 47% omija kontrole bezpieczeństwa przy użyciu narzędzi shadow IT.[30] Dane te, gdy zostaną umieszczone poza infrastrukturą organizacji, stają się niedostępne w celach nadzorczych, co uniemożliwia wykazanie zgodności z zasadą rozliczalności wynikającą z art. 5 ust. 2 RODO.

(iii) *Przesyłanie danych przez niezatwierdzone komunikatory i dyski chmurowe.* Pracownicy korzystają z komunikatorów takich jak WhatsApp lub Messenger. Choć komunikacja w aplikacjach takich jak WhatsApp jest szyfrowana *end-to-end*, czyli wyłącznie między urządzeniami uczestników, nie gwarantuje to zgodności z RODO, ponieważ metadane, kopie zapasowe i historia czatów mogą być przechowywane przez dostawcę poza EOG.[31] Badanie WifiTalents wykazało, że 37% pracowników używa niezatwierdzonych komunikatorów do komunikacji służbowej.[32]

[28] LayerX Security, *Enterprise AI and SaaS Data Security Report 2025*.

[29] Cyberhaven Labs, *11% of data employees paste into ChatGPT is confidential*.

[30] WifiTalents. *Shadow IT Statistics: Reports 2025*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. WifiTalents, 2025. URL: `https://wifitalents.com/shadow-it-statistics/`.

[31] Data Protection People. *GDPR Data Breaches & Human Error: How Bad Is It?* Dostęp: 10 marca 2026. 2026. URL: `https://dataprotectionpeople.com/resource-centre/gdpr-data-breaches-human-error-how-bad-is-it/`.

[32] WifiTalents, *Shadow IT Statistics: Reports 2025*.

DRAFT

(iv) *Błędne utożsamianie pseudonimizacji z anonimizacją.* W dokumentach przekazywanych do analizy lub testów pozostają inicjały, numery PESEL lub numery rachunków bankowych, które pracownicy nierzadko traktują jako wystarczające zanonimizowanie danych. Dane pseudonimowe nadal identyfikują osobę fizyczną w rozumieniu art. 4 pkt 1 RODO i nie wyłączają stosowania przepisów rozporządzenia.[33] Preuveneers i in. wykazali, że modele głębokiego uczenia są w stanie z dokładnością 73,4% zidentyfikować gospodarstwa domowe na podstawie pozornie pseudonimowych danych pomiarowych w zbiorze liczącym ponad 5000 podmiotów.[34]

(v) *Używanie narzędzi do transkrypcji spotkań bez oceny ryzyka.* Narzędzia takie jak Otter.ai, Fireflies.ai czy rozszerzenia oparte na ChatGPT automatycznie dołączają do posiedzeń, nagrywają rozmowy i przesyłają transkrypty na serwery zewnętrznych dostawców, często zlokalizowane w USA.[35] Uczestnicy spotkań mogą nie być świadomi obecności utomatu nagrywającego, co stanowi naruszenie zasady przejrzystości z art. 5 ust. 1 lit. a RODO. Co istotne, warunki korzystania wielu narzędzi transkrypcyjnych, zezwalają na wykorzystanie nagrań i transkrypcji do trenowania modeli AI, co oznacza, że treści posiedzeń z danymi klientów mogą zasilać bazy treningowe dostawcy bez podstawy prawnej.[36]

(vi) *Przesyłanie danych wrażliwych mailem.* Przekazywane danych wrażliwych pocztą elektroniczną do zewnętrznych adresatów bez uprzedniego zawarcia umowy powierzenia przetwarzania danych (DPA) oraz odpowiedniego zabezpieczenia załącznika (bezpiecznycm hasłem), wymaganej przez art. 28 RODO. Badanie MailIntelligence wykazało, że 65% incydentów utraty danych jest powodowanych przez wiadomości e-mail skierowane do niewłaściwego adresata lub przesłane bez odpowiednich zabezpieczeń.[37] Takie przekazanie danych stanowi naruszenie RODO, niezależnie od tego, czy doszło do faktycznego wycieku.

(vii) *Kopiowanie danych produkcyjnych do środowisk testowych bez anonimizacji.* Dane wrażliwe z systemów produkcyjnych są przenoszone do środowisk deweloperskich lub testowych w niezmienionej formie, co narusza art. 25 RODO (zasada *privacy by design and by default*) oraz zasady minimalizacji i ograniczenia celu.[38] Agencja ochrony danych Hiszpanii (AEPD) wprost wskazuje, że używanie rzeczywistych danych osobowych w środowiskach testowych jest dopuszczalne jedynie gdy jest

[33] Agencia Española de Protección de Datos (AEPD). *Personal Data Breaches: Development and Pre-Production Environments*. Dostęp: 10 marca 2026. 2022. URL: https://www.aepd.es/en/prensa-y-comunicacion/blog/data-breaches-development-and-pre-production-enviroments.

[34] Davy Preuveneers i in. „Re-pseudonymization Strategies for Smart Meter Data Are Not Robust to Deep Learning Profiling Attacks". W: *arXiv preprint* (2024). DOI: 10.48550/arXiv.2404.03948. URL: https://arxiv.org/abs/2404.03948.

[35] Legal.io / Bloomberg Law. *AI Meeting Tools Raise Privacy, Privilege, and Discovery Risks for Employers*. Dostęp: 10 marca 2026. 2025. URL: https://www.legal.io/articles/5767845/AI-Meeting-Tools-Raise-Privacy-Privilege-And-Discovery-Risks-For-Employers.

[36] Privacy Partnership. *Why AI Transcription Bots Pose a Data Privacy Risk*. Dostęp: 10 marca 2026. 2025. URL: https://www.linkedin.com/posts/privacy-partnership_ai-bots-gdpr-activity-7387443108201787396-3dRL.

[37] MailIntelligence. *Human Error Cases in Enterprise Email Security 2024*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. MailIntelligence AI, 2024. URL: https://mailintelligence.ai/reports/human-error-cases-2024.

[38] Agencia Española de Protección de Datos (AEPD), *Personal Data Breaches: Development and Pre-Production Environments*.

DRAFT

bezwzględnie konieczne i zabezpieczone zgodnie z art. 32 RODO.[39] W praktyce konieczność ta rzadko zachodzi, dostępne są narzędzia do generowania danych syntetycznych, a rezygnacja z ich stosowania wynika z wygody, nie z merytorycznej potrzeby.

(viii) *Przekazywanie danych pacjentów firmom IT bez podstawy prawnej.* Podczas zgłaszania usterek w oprogramowaniu medycznym pracownicy przekazują firmom serwisowym fragmenty dokumentacji pacjentów lub całe zrzuty baz danych. Najwyższa Izba Kontroli w raporcie *RODO w szpitalu* z 2019 roku wykryła ten proceder w 11 z kontrolowanych szpital, gdzie udostępniono dane podmiotom zewnętrznym bez umowy powierzenia ani innej podstawy prawnej.[40]

(ix) *Kopiowanie i przechowywanie dokumentów tożsamości bez uzasadnionej potrzeby.* Instytucje obowiązane, w tym banki, mogą na podstawie art. 34 ust. 4 ustawy o przeciwdziałaniu praniu pieniędzy oraz finansowaniu terroryzmu sporządzać kopie dokumentów tożsamości na potrzeby stosowania środków bezpieczeństwa finansowego. Uprawnienie to nie uzasadnia jednak automatycznego kopiowania dokumentów przy każdej czynności klienta, konieczna jest ocena niezbędności takiego działania w konkretnym przypadku. W 2025 r. Prezes UODO nałożył na *ING Bank Śląski* karę w wysokości 18,4 mln zł za nieuzasadnione skanowanie dokumentów tożsamości klientów i potencjalnych klientów, także w sytuacjach niezwiązanych z realizacją obowiązków wynikających z ustawy AML, np. przy składaniu reklamacji dotyczącej bankomatu.[41]

(x) *Wysyłanie dokumentów kadrowych do niewłaściwych adresatów.* Świadectwa pracy, paski płac, aneksy do umów i inne dokumenty HR zawierające dane osobowe kierowane są pocztą elektroniczną lub tradycyjną do błędnych odbiorców wskutek pomyłek przy wpisywaniu adresu lub autouzupełniania skrzynki pocztowej. Błędne skierowanie korespondencji jest jednym z najczęściej zgłaszanych naruszeń do UODO, stanowi 18% wszystkich raportowanych incydentów bezpieczeństwa danych.[42] Każde takie zdarzenie wymaga oceny ryzyka i potencjalnego zgłoszenia do organu nadzoru w ciągu 72 godzin od wykrycia.

(xi) *Ignorowanie alertów DLP i poszukiwanie obejść.* Pracownicy traktują ostrzeżenia systemów DLP jako fałszywe alarmy i aktywnie szukają sposobów ich ominięcia, kopiując dane na prywatne pendrive'y, wysyłając pliki przez prywatne konto e-mail lub korzystając z platform wymiany plików (WeTransfer, Smash). Badanie WifiTalents wykazało, że 47% pracowników omija kontrole bezpieczeństwa, a organizacje

DRAFT

[39] Agencia Española de Protección de Datos (AEPD), *Personal Data Breaches: Development and Pre-Production Environments*.

[40] Najwyższa Izba Kontroli. *RODO w szpitalu – wyniki kontroli*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. Najwyższa Izba Kontroli, 2019. URL: https://www.nik.gov.pl/najnowsze-informacje-o-wynikach-kontroli/rodo-w-szpitalu.html.

[41] Gazeta Prawna. „Raport: w 2025 r. padły rekordowe kary za naruszenia RODO – najwyższa dla Poczty Polskiej". W: *Gazeta Prawna* (2026). Dostęp: 10 marca 2026. URL: https://www.gazetaprawna.pl/firma-i-prawo/artykuly/10648769,raport-w-2025-r-padly-rekordowe-kary-za-naruszenia-rodo-najwyzsza-.html.

[42] Data Protection People, *GDPR Data Breaches & Human Error: How Bad Is It?*; ODO 24. *Naruszenia ochrony danych – jakie są zgłaszane najczęściej i jak można im zapobiegać*. Dostęp: 10 marca 2026. 2020. URL: https://odo24.pl/blog-post.naruszenia-ochrony-danych-jakie-sa-zglaszane-najczesciej-i-w-jaki-sposob-mozna-im-zapobiegac.

dysponują średnio 975 nieznanych usług chmurowych, z których monitorują jedynie ok. 108.[43] Gartner szacuje, że na typowego pracownika korporacyjnego przypada średnio 13 aplikacji shadow IT używanych równolegle.[44]

DRAFT

[43]WifiTalents, *Shadow IT Statistics: Reports 2025*; Fidelis Security. *Shadow IT Risks, Examples, and Detection*. Dostęp: 10 marca 2026. 2026. URL: https://fidelissecurity.com/cybersecurity-101/cloud-security/shadow-it-risks-examples-and-detection/.

[44]WifiTalents, *Shadow IT Statistics: Reports 2025*.

5. Konflikt jurysdykcji i suwerenność danych

Informacja jest współczesną walutą, jest to bardzo popularne, jednocześnie prawdziwe stwierdzenie. Dane, które posiadają przedsiębiorstwa, uczelnie oraz rządy stanowią o sile gospodarczej i przewadze technologicznej. Nic więc dziwnego w działaniach, które mają na celu ochronę informacji przed nieautoryzowanym dostępem. Do szpiegostwa gospodarczego ze strony takich państw jak Rosja czy Chiny dochodziło od wielu lat,[1] ale nowością jest wykorzystywanie informacji i technologii przeciwko sojusznikom, gdy decyzje podejmowane nie podobają się jednej ze stron.

Flagowym przykładem była sytuacja związana z działaniami administracji amerykańskiej w stosunku do Międzynarodowego Trybunału Karnego w Hadze, a źródłem ich była decyzja sądu, której treść nie była zgodna z oczekiwaniami administracji Donalda Trumpa.

Sankcje USA wobec MTK przełożyły się na odcięcie dostępu do niektórych usług amerykańskich, w szczególności do usług Microsoft w odniesieniu do prokuratora Karima Khana, a także do ograniczeń finansowych i wizowych. Podstawę tych działań stanowił nakaz (*executive order*) USA z 5 lutego 2025 roku, przewidujący m.in. blokowanie majątku i aktywów oraz restrykcje wizowe wobec urzędników MTK i ich rodzin.[2]

Jednocześnie sankcje zostały rozszerzone w czerwcu 2025 na kolejne osoby, Reine Adelaide Sophie Alapini Gansou, sędzia MTK i druga wiceprezes MTK, oraz sędziowe Solomy Balungi Bossa, Luz del Carmen Ibáñez Carranza oraz Beti Hohler, sędzia MTK.

Decyzja zaostrza napięcie między USA, a państwami popierającymi porządek oparty na prawie międzynarodowym. Ta decyzja buduje precedens, że państwo może używać sankcji nie tylko wobec przeciwników geopolitycznych, lecz także wobec międzynarodowego sądu i osób współpracujących z nim. Taki precedens może zachęcać inne rządy do podobnych działań wobec instytucji międzynarodowych, gdy ich decyzje staną się politycznie niewygodne.

Incydent związany z odcięciem amerykańskich usług cyfrowych dla osób objętych sankcjami USA nie wydaje się stanowić jedynej przyczyny działań UE w obszarze suwerenności danych, lecz stał się katalizatorem politycznym wzmacniającym unijną debatę o ryzykach wynikających z zależności od dostawców podlegających jurysdykcji Stanów Zjednoczonych.

5.1 Problem CLOUD Act i FISA 702

Istotnym źródłem konfliktów prawnych dotyczących przetwarzania danych w chmurze i dostępu do nich przez władze Stanów Zjednoczonych są dwie amerykańskie regulacje:

[1] Johan Putter i Sascha-Dominik Bachmann. „Russia and China Expected to Renew Their Espionage Vigour". W: *Journal on Baltic Security* 9.1 (2023), s. 1–31. DOI: 10.2478/jobs-2023-0001. URL: https://journalonbalticsecurity.com/journal/JOBS/article/113/text.

[2] The White House. *Imposing Sanctions on the International Criminal Court*. Luty 2025. URL: https://www.whitehouse.gov/presidential-actions/2025/02/imposing-sanctions-on-the-international-criminal-court/ (dostęp 7.03.2026).

DRAFT

Clarifying Lawful Overseas Use of Data Act (CLOUD Act, 2018)[3] oraz sekcja 702 ustawy *Foreign Intelligence Surveillance Act* (FISA 702).[4] Regulacje te, choć służą różnym celom i przewidują odmienne procedury, umożliwiają władzom amerykańskim uzyskiwanie dostępu do danych za pośrednictwem przedsiębiorstw podlegających jurysdykcji USA, również gdy dane są przechowywane poza terytorium tego państwa.

Źródłem napięć prawnych jest zatem nie tylko możliwość uzyskania dostępu do danych przechowywanych w Europejskim Obszarze Gospodarczym (EOG), lecz także kierowanie żądań bezpośrednio do dostawców usług, z pominięciem pośrednictwa właściwych organów państwa, w którym znajdują się dane. Nie oznacza to jednak, że mechanizm bezpośredniego pozyskiwania danych od dostawców jest charakterystyczny wyłącznie dla prawa amerykańskiego. Unia Europejska i Stany Zjednoczone prowadzą negocjacje umowy dotyczącej bezpośredniego pozyskiwania dowodów elektronicznych od dostawców usług. Ponadto od 18 sierpnia 2026 r. w UE stosuje się rozporządzenie *e-evidence*, które umożliwia kierowanie nakazów do wyznaczonego zakładu lub przedstawiciela prawnego dostawcy w innym państwie członkowskim.

Pod tym względem unijny mechanizm *e-evidence* wykazuje podobieństwo do CLOUD Act: oba rozwiązania umożliwiają pozyskiwanie dowodów elektronicznych bezpośrednio od dostawcy usług, a miejsce przechowywania danych nie przesądza o możliwości ich uzyskania. Porównanie to dotyczy jednak konstrukcji dostępu do danych, a nie pełnej równoważności obu regulacji.

Amerykański ustawodawca zdefiniował jurysdykcję w CLOUD Act, określając, że dotyczy ona podmiotu, a nie danych. Oznacza to, że Amazon, Microsoft i Google, które łącznie kontrolują około 70 procent europejskiego rynku usług w chmurze,[5] mogą zostać zobowiązane nakazem sądowym do ujawnienia danych swoich klientów, nawet jeśli serwery znajdują się na terytorium Unii Europejskiej.[6] Co istotne, ani osoba, której dane dotyczą, ani też żaden europejski organ nadzoru nie muszą być powiadamiani. Ustawa FISA 702 działa równolegle, upoważniając agencje wywiadowcze, bez nakazu, do gromadzenia komunikacji osób spoza Stanów Zjednoczonych.

5.2 Suwerenność danych: Gaia-X, suwerenne chmury obliczeniowe i poufne przetwarzanie danych

Europejską odpowiedzią na strukturalną zależność od dostawców spoza Unii Europejskiej jest opracowanie koncepcji suwerenności danych cyfrowych. Składa się ona z trzech wymiarów: rezydencja danych (ang. *data residency*), suwerenność prawna (ang. *data sovereignty*) oraz suwerenność operacyjna (ang. *operational sovereignty*). Kluczowym problemem jest

[3]United States Congress. *Clarifying Lawful Overseas Use of Data Act (CLOUD Act)*. Pub. L. No. 115-141, div. V, 132 Stat. 348. 2018. URL: https://www.congress.gov/115/plaws/publ141/PLAW-115publ141.pdf.

[4]United States Congress. *Foreign Intelligence Surveillance Act, Section 702*. 50 U.S.C. §1881a; reauthorized most recently by the FISA Reform and Reauthorization Act of 2024. 1978. URL: https://www.govinfo.gov/content/pkg/STATUTE-92/pdf/STATUTE-92-Pg1783.pdf.

[5]Synergy Research Group. *European Cloud Providers' Local Market Share Holds Steady at 15%*. Market Report. 2023. URL: https://www.srgresearch.com/articles/european-cloud-providers-local-market-share-now-holds-steady-at-15.

[6]European Data Protection Board i European Data Protection Supervisor. *Initial Legal Assessment of the Impact of the US CLOUD Act on the European Union Legal Framework for Personal Data Protection*. Joint Response Annex. 2019. URL: https://www.edpb.europa.eu/sites/default/files/files/file2/edpb_edps_joint_response_us_cloudact_annex.pdf.

DRAFT

fakt, że fizyczna lokalizacja serwerów na terytorium Unii Europejskiej nie przesądza o jurysdykcji prawnej. Stąd UE podjęła szereg inicjatyw: inicjatywę GAIA-X, suwerenne chmury, poufne przetwarzanie.

Gaia-X

Inicjatywa Gaia-X, ogłoszona przez Niemcy i Francję w 2019 r. i formalnie zainicjowana przez Komisję Europejską w 2020 roku, ma na celu stworzenie interoperacyjnej, zdecentralizowanej infrastruktury danych zgodnej z europejskimi normami prawnymi i wartościami.[7] Jego główne cele to: zapewnienie użytkownikom pełnej kontroli nad swoimi danymi i ich wykorzystaniem, standaryzacja usług chmurowych w oparciu o otwarte standardy oraz stworzenie alternatywy dla dominujących trzech amerykańskich hiperskalerów: Amazon, Google oraz Microsoft.[8]

Realizacja projektu jest kontrowersyjna. Krytycy zauważają, że do konsorcjum Gaia-X dołączyli sami hiperskalerzy, Amazon, Google i Microsoft, co rodzi pytania i wątpliwości o faktyczną suwerenność usług w ramach inicjatywy.

Operator Chmury Krajowej (OChK)

Polska inicjatywa, czyli Operator Chmury Krajowej (OChK), jest poddawana podobnej krytyce jak Gaia-X. OChK jest spółką z ograniczoną odpowiedzialnością, w której po 50% udziałów posiadają PKO Bank Polski oraz Polski Fundusz Rozwoju (PFR), oba podmioty z dominującym udziałem Skarbu Państwa. Spółka została powołana w celu utworzenia suwerennego, krajowego środowiska chmurowego dla polskiego sektora publicznego i finansowego.

W roku 2019 OChK zawarł strategiczne partnerstwo z Google Cloud. W jego ramach OChK stał się certyfikowanym sprzedawcą usług Google w Polsce, a Google otworzył region chmurowy w Warszawie. Partnerstwo jest analogiczne do krytykowanego wejścia amerykańskich hiperskalerów do Gaia-X: OChK, który miał stanowić polską alternatywę dla dostawców spoza UE, stał się pośrednikiem sprzedaży ich usług.

OChK w październiku 2025 roku ogłosiło, że platforma „osiągnęła pełną suwerenność cyfrową zgodnie z definicją Cloud Sovereignty Framework Komisji Europejskiej" i że usługi podlegają „całkowitej kontroli podmiotów z UE oraz unijnemu prawu, bez krytycznych zależności od dostawców spoza Europy".[9] Twierdzenie to wymaga jednak zastrzeżenia: dotyczy ono własnej warstwy platformowej OChK, natomiast nie eliminuje faktu, że klienci korzystający za pośrednictwem OChK z usług Google Cloud w dalszym ciągu korzystają z infrastruktury podmiotu podlegającego prawu USA, w tym CLOUD Act i FISA 702. W praktyce OChK umożliwia dwa różne modele, usługi własne (suwerenne) oraz usługi Google dystrybuowane przez OChK, które są niesuwerenne w sensie prawnym, i to od odbiorcy usługi i wybranej przez niego konfiguracji zamówienia oraz świadomości użytkownika zależy, z którego modelu faktycznie korzysta.

[7] Tristan Braud i in. „Scaling the Gaia-X Lighthouse: An Analysis of European Data Infrastructure". W: *Proceedings of the 2021 IEEE International Conference on Cloud Engineering (IC2E)*. IEEE, 2021. URL: https://publikationen.bibliothek.kit.edu/1000139020.

[8] Braud i in., „Scaling the Gaia-X Lighthouse: An Analysis of European Data Infrastructure".

[9] Operator Chmury Krajowej. *OChK osiągnął pełną suwerenność cyfrową zgodnie z Cloud Sovereignty Framework Komisji Europejskiej*. Komunikat prasowy. Październik 2025. URL: https://chmura.gov.pl.

DRAFT

Suwerenne chmury

Koncepcja suwerennej chmury odnosi się do oferty usług chmurowych, która gwarantuje, że dane pozostają pod prawną kontrolą jurysdykcji europejskiej. Jedyną drogą do prawdziwej suwerenności danych jest wybór dostawcy, który nie ma żadnych prawnych powiązań z jurysdykcją USA, czyli europejskich dostawców usług chmurowych całkowicie niezależnych od amerykańskich korporacji.

Przetwarzanie poufne

Szyfrowanie danych w spoczynku i podczas przesyłania to wymóg stawiany przed przetwarzaniem poufnym (ang. *confidential computing*). Jego bazę stanowią *Zaufane Środowiska Wykonawcze* (TEE), sprzętowo izolowane środowiska, w których dane pozostają zaszyfrowane w czasie aktywnego przetwarzania, niedostępne ani dla hiperwizora, ani systemu operacyjnego, ani tym bardziej dla personelu dostawcy chmury.[10]

TEE chronią przed nieautoryzowanym i pozajurysdykcyjnym dostępem do danych podczas ich przechowywania, transmisji oraz podczas obliczeń.[11]

Warto podkreślić, że takie podejście wpisuje się bezpośrednio w oczekiwania polskiego i europejskiego nadzoru finansowego. Komisja Nadzoru Finansowego już w Komunikacie Chmurowym z 2020 roku wymagała od podmiotów nadzorowanych, by informacje prawnie chronione były szyfrowane zawsze w spoczynku (ang. *at rest*) oraz w trakcie transferu (ang. *in transit*),[12] a kontrola nad kluczami kryptograficznymi pozostawała po stronie instytucji finansowej, nie dostawcy chmury. Obowiązujące od stycznia 2025 r. rozporządzenie DORA idzie o krok dalej, nakładając wymóg kompleksowej polityki szyfrowania obejmującej dane *at rest*, *in transit*, a także w trakcie użycia (ang. *in use*), co jest bezpośrednim odniesieniem do scenariusza, w którym przetwarzanie poufne staje się nie tyle opcją, ile techniczną odpowiedzią na regulacyjne oczekiwania[13].[14]

Z perspektywy jurysdykcyjnej, szczególnie wynikającej z ryzyk CLOUD Act, poufne obliczenia umożliwiają techniczne egzekwowanie reguł dotyczących lokalizacji przetwarzania, operacje mogą być wykonywane wyłącznie w autoryzowanych geograficznie lokalizacjach (powinowactwo lokalizacji) i na dedykowanych hostach (powinowactwo hosta).[15] Co ważne, choć sama technologia nie uchyla prawnych obowiązków dostawcy wynikających z amerykańskiej ustawy CLOUD Act, to utrudnia realizację ewentualnych nakazów dostępu, a przede wszystkim eliminuje ryzyko cichego dostępu operacyjnego ze strony dostawcy.

DRAFT

[10] Sulaiman Almutairi i in. „Confidential Computing Using Trusted Execution Environments". W: *International Journal of Advances in Internet of Big Data and Cloud Management System* 3.1 (2024). URL: https://ijaibdcms.org/index.php/ijaibdcms/article/view/240.

[11] Almutairi i in., „Confidential Computing Using Trusted Execution Environments".

[12] Urząd Komisji Nadzoru Finansowego. *Komunikat UKNF w sprawie przetwarzania przez podmioty nadzorowane informacji w chmurze obliczeniowej publicznej i hybrydowej.* Komunikat UKNF. Styczeń 2020. URL: https://www.knf.gov.pl/knf/pl/komponenty/img/Komunikat_UKNF_Chmura_Obliczeniowa_68669.pdf.

[13] Parlament Europejski i Rada Unii Europejskiej, *Rozporządzenie (UE) 2022/2554 w sprawie operacyjnej odporności cyfrowej sektora finansowego (DORA).*

[14] Komisja Europejska. *Commission Delegated Regulation (EU) 2024/1532 — RTS on ICT Risk Management Tools, Methods, Processes and Policies (DORA Article 15).* Dz.Urz. UE. 2024. URL: https://ec.europa.eu/finance/docs/level-2-measures/dora-regulation-rts--2024-1532_en.pdf.

[15] Almutairi i in., „Confidential Computing Using Trusted Execution Environments".

5.3 Schrems I, II i konsekwencje dla transferu danych poza EOG

Rozwiązania prawne regulujące zakres transferu danych osobowych między Unią Europejską, a Stanami Zjednoczonymi stanowią jeden z najważniejszych punktów w historii prawa o ochronie danych. Z perspektywy oceny ryzyka łańcuchów dostaw ICT, stanowi ona również przykład tego, jak strukturalna luka prawna może podważyć zgodność z przepisami tysięcy organizacji jednocześnie. Sekwencja zdarzeń zainicjowana przez jednego austriackiego studenta prawa doskonale ilustruje kategorię ryzyka, którą system ORION ma wykrywać i mierzyć.

5.3.1 Umowa Safe Harbour (2000–2015)

Podstawowym instrumentem regulującym transfer danych osobowych między UE a USA była decyzja Komisji 2000/520/WE, powszechnie znana jako *Umowa Safe Harbour*. Przyjęta 26 lipca 2000 roku decyzja ustanowiła mechanizm autocertyfikacji, w ramach którego amerykańskie firmy mogły dobrowolnie zobowiązać się do przestrzegania siedmiu zasad ochrony danych: powiadomienia, wyboru, dalszego przekazywania, bezpieczeństwa, integralności danych, dostępu i egzekwowania. Po dokonaniu autocertyfikacji uzyskiwały prawo do otrzymywania danych osobowych z państw członkowskich UE bez dalszego uzasadnienia prawnego.[16]

Mechanizm działał na podstawie oświadczeń składanych w Departamencie Handlu USA, a ramy dostępu do danych opierały się wyłącznie na dobrej wierze organizacji uczestniczących i teoretycznej możliwości egzekwowania zasad przez Federalną Komisję Handlu USA. W szczytowym okresie ponad 4500 amerykańskich firm, w tym Facebook, Google, Microsoft i Amazon, działało na podstawie certyfikatu Safe Harbour, który stanowił podstawę prawną dla zdecydowanej większości komercyjnych przepływów danych między UE a USA..[17]

5.3.2 Maximilian Schrems: Tło i strategia prawna

Maximilian Schrems jest austriackim prawnikiem, działaczem na rzecz ochrony prywatności i założycielem organizacji pozarządowej *noyb* (None of Your Business), zajmującej się egzekwowaniem europejskich przepisów o ochronie danych. W wyniku działania Schremsa sprawa trafiła do Trybunału Sprawiedliwości Unii Europejskiej (TSUE) z wnioskiem o wydanie orzeczenia w trybie prejudycjalnym.

[16]Komisja Europejska. *Decyzja Komisji 2000/520/WE z dnia 26 lipca 2000 r. wydana na podstawie dyrektywy 95/46/WE Parlamentu Europejskiego i Rady w sprawie adekwatności ochrony przewidzianej przez zasady „bezpiecznej przystani" oraz związane z nimi najczęściej zadawane pytania, wydane przez Departament Handlu Stanów Zjednoczonych*. Dz.U. L 215 z 25.08.2000, s. 7–47. 2000.

[17]Komisja Europejska, *Decyzja Komisji 2000/520/WE z dnia 26 lipca 2000 r. wydana na podstawie dyrektywy 95/46/WE Parlamentu Europejskiego i Rady w sprawie adekwatności ochrony przewidzianej przez zasady „bezpiecznej przystani" oraz związane z nimi najczęściej zadawane pytania, wydane przez Departament Handlu Stanów Zjednoczonych.*

DRAFT

5.3.3 Schrems I: Unieważnienie zasad Safe Harbor

6 października 2015 roku TSUE wydał wyrok w sprawie C-362/14, *Maximillian Schrems przeciwko Komisarzowi Ochrony Danych*, powszechnie znanej jako *Schrems I*.[18] Trybunał orzekł nieważność decyzji Komisji 2000/520/WE ze skutkiem natychmiastowym. Orzeczenie opierało się na dwóch zasadniczych podstawach. Po pierwsze, Trybunał orzekł, że pierwszeństwo przyznane wymogom bezpieczeństwa narodowego, interesu publicznego i egzekwowania prawa USA nad zasadami Safe Harbor oznaczało, że amerykańskie firmy były systematycznie uprawnione, a w praktyce zmuszone, do odchodzenia od tych zasad, ilekroć wymagało tego prawo amerykańskie. Ramy, które mogą zostać uchylone przez suwerenne prawo państwa odbiorcy, nie mogą stanowić odpowiedniego poziomu ochrony w rozumieniu dyrektywy o ochronie danych.

Po drugie, Trybunał stwierdził, że obywatele UE, których dane zostały przekazane do Stanów Zjednoczonych, nie mieli skutecznego środka odwoławczego ani administracyjnego, aby egzekwować swoje prawa wobec władz USA. Brak jakiegokolwiek mechanizmu umożliwiającego osobom z UE, których dane dotyczą, uzyskanie dostępu, poprawienie lub usunięcie danych przechowywanych przez amerykańskie agencje wywiadowcze, był nie do pogodzenia z podstawowym prawem do skutecznej ochrony sądowej zapisanym w artykule 47 Karty praw podstawowych UE.

5.3.4 Schrems II: Tarcza Prywatności

W odpowiedzi na wyrok w sprawie Schrems I, Komisja Europejska i Departament Handlu USA wynegocjowały nowe ramy prawne, Tarczę Prywatności UE–USA, która weszła w życie 12 lipca 2016 roku.

Schrems natychmiast zakwestionował Tarczę Prywatności, argumentując, że nie rozwiązała ona fundamentalnych braków strukturalnych zidentyfikowanych w sprawie Schrems I. 16 lipca 2020 r. TSUE potwierdził tę ocenę w sprawie C-311/18, *Data Protection Commissioner przeciwko Facebook Ireland Limited i Maximillian Schrems*, zwanej dalej *Schrems II*.[19] Sąd unieważnił Tarczę Prywatności z zasadniczo tych samych powodów, co Safe Harbor: amerykańskie prawo dotyczące nadzoru (w szczególności art. 702 ustawy o nadzorze nad wywiadem zagranicznym (FISA)) oraz rozporządzenie wykonawcze 12333, nadal zezwalały na masowe gromadzenie danych obywateli UE bez odpowiednich ograniczeń, niezależnego nadzoru lub skutecznych mechanizmów dochodzenia roszczeń.

Sprawa Schrems II miała jednak szersze znaczenie niż samo unieważnienie Tarczy Prywatności. Trybunał wydał również niezwykle istotne wytyczne dotyczące standardowych klauzul umownych (SCC), orzekając, że eksporterzy i importerzy danych powołujący się na standardowe klauzule umowne są zobowiązani do oceny, w każdym indywidualnym przypadku, czy prawo kraju przeznaczenia zapewnia odpowiednią ochronę w praktyce, a nie tylko w teorii. Ten obowiązek, Ocena Skutków Transferu (TIA), stał się nowym, obowiązkowym elementem zgodności dla organizacji przekazujących dane osobowe poza EOG na podstawie standardowych klauzul umownych lub innych zabezpieczeń z art. 46 RODO; nie dotyczy transferów opartych na decyzji stwierdzającej odpowiedni stopień ochrony. Jest on również istotnym aspektem w modelu ORION.

[18]Trybunał Sprawiedliwości Unii Europejskiej. *Wyrok z dnia 6 października 2015 r., Maximillian Schrems przeciwko Data Protection Commissioner, C-362/14*. ECLI: EU:C:2015:650. Schrems I. 2015.

[19]Trybunał Sprawiedliwości Unii Europejskiej. *Wyrok z dnia 16 lipca 2020 r., Data Protection Commissioner przeciwko Facebook Ireland Ltd i Maximillian Schrems, C-311/18*. ECLI: EU:C:2020:559. Schrems II. 2020.

DRAFT

5.3.5 Ramy ochrony prywatności danych (2023–obecnie)

Po trzech latach intensywnych negocjacji Komisja Europejska przyjęła 10 lipca 2023 roku *Ramy ochrony prywatności danych UE–USA (DPF)* w formie *Decyzji wykonawczej Komisji (UE) 2023/1795*.[20] DPF wprowadził nowy mechanizm odwoławczy: Sąd ds. Ochrony Danych (DPRC), mający na celu zapewnienie obywatelom UE wiążącego środka odwoławczego w przypadku bezprawnego gromadzenia informacji wywiadowczych.

DPF stanowi obecnie główną podstawę prawną przekazywania danych osobowych między UE a USA. Jednakże już Maximillian Schrems zapowiedział dalsze postępowanie sądowe kwestionujące DPF przed sądami europejskimi, argumentując, że DPRC nie stanowi niezależnego organu sądowego w rozumieniu wymaganym przez orzecznictwo TSUE i że sekcja 702 ustawy FISA pozostaje niezmieniona w swoich najbardziej problematycznych aspektach.

5.3.6 Implikacje dla struktury ORION

Wyroki bedące skutkiem działań Schremsa niosą bezpośrednie implikacje dla metodologii ORION. Decyzje sądów wskazują, że ryzyko regulacyjne związane z geograficznym pochodzeniem dostawcy ICT jest problemem realnym, który musi być przez dostawców usług ICT brany pod uwagę.

W modelu ORION ryzyko to jest wyliczane. Dostawcy geograficznie lokalizowani poaza EOG uruchamiają obowiązkowy zestaw pytań audytowych obejmujących aktualną podstawę prawną transferu danych, istnienia *Oceny Skutków Transferu (TIA)* oraz weryfikacji postanowień umów regulujących wnioski rządowe o dostęp do danych. Historia Safe Harbor, Privacy Shield i ciągła niepewność związana z DPF stanowią zatem empiryczne uzasadnienie dla jednej z kluczowych decyzji projektowych ORION: klasyfikacji pochodzenia geograficznego jako ryzka kluczowego.

5.4 Strategia legislacyjna UE: Data Act, EUCS i CADA

Europejska odpowiedź na ryzyko jurysdykcyjne ewoluuje z poziomu inicjatyw przemysłowych (Gaia-X) w stronę wiążących instrumentów prawnych, tworzących zalążek spójnego ekosystemu suwerenności cyfrowej. Trzy wzajemnie uzupełniające się inicjatywy: *EU Data Act*, *EUCS* oraz *Cloud and AI Development Act* adresują kolejno: prawa dostępu do danych i ich przenoszalność, certyfikację bezpieczeństwa dostawców chmury oraz budowę europejskiej infrastruktury obliczeniowej.

EU Data Act (Rozporządzenie 2023/2854)

Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2023/2854, powszechnie znane jako *EU Data Act*, zostało opublikowane w Dzienniku Urzędowym UE 22 grudnia 2023 r. i stało się w pełni stosowane od 12 września 2025 r..[21] Regulacja wprowadza dwa mecha-

[20] Komisja Europejska. *Decyzja wykonawcza Komisji (UE) 2023/1795 z dnia 10 lipca 2023 r. wydana na podstawie rozporządzenia (UE) 2016/679 Parlamentu Europejskiego i Rady w sprawie odpowiedniego poziomu ochrony danych osobowych na podstawie ram ochrony danych UE–USA*. Dz.U. UE L 231 z 20.09.2023. dokument C(2023) 4745. 2023.

[21] Parlament Europejski i Rada Unii Europejskiej. *Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2023/2854 z dnia 13 grudnia 2023 r. w sprawie zharmonizowanych przepisów dotyczących sprawiedliwego dostępu do danych i ich wykorzystywania oraz w sprawie ich zmiany*. Stosowane od 12 września

DRAFT

nizmy bezpośrednio adresujące ryzyko jurysdykcyjne:

(i) Po pierwsze, art. 32 Data Act

Zweryfikować podstawę: numer artykułu Data Act dotyczącego dostępu rządowego państw trzecich do danych nieosobowych (wcześniej wskazany art. 31).

nakłada na dostawców usług przetwarzania danych obowiązek wdrożenia środków technicznych i organizacyjnych uniemożliwiających organom państw spoza Europejskiego Obszaru Gospodarczego dostęp do danych przechowywanych w UE bez ważnej podstawy w prawie międzynarodowym lub w umowie między UE a danym państwem trzecim.[22] Przepis ten nie uchyla obowiązków dostawcy wynikających bezpośrednio z prawa państwa jego inkorporacji (takich jak CLOUD Act), lecz nakłada na dostawcę obowiązek aktywnego kwestionowania wniosków uznanych za sprzeczne z prawem unijnym i powiadamiania klienta.

(ii) Po drugie, Data Act zakazuje z dniem 12 stycznia 2027 r. pobierania opłat za przełączenie dostawcy (*switching fees*) i ekstrakcję danych, co bezpośrednio ogranicza ryzyko uzależnienia od jednego hiperskalera (*vendor lock-in*) identyfikowane przez EBA i Parlament Europejski.[23]

Europejski Schemat Certyfikacji Bezpieczeństwa Chmury (EUCS)

Europejski Schemat Certyfikacji Bezpieczeństwa Chmury (*European Cybersecurity Certification Scheme for Cloud Services , EUCS*), opracowywany przez Agencję Unii Europejskiej ds. Cyberbezpieczeństwa (*ENISA*) na podstawie unijnego *Aktu o Cyberbezpieczeństwie (Rozporządzenie 2019/881)*, definiuje trzy poziomy zapewnienia: *Basic*, *Substantial* i *High*.[24] Projekt przewidywał również poziom *High+*, który wprowadzałby wymogi jurysdykcyjne, rezydencję danych, personel operacyjny z EOG i brak wiążących powiązań korporacyjnych z podmiotami spoza EOG, jako warunek certyfikacji dla usług krytycznych.[25]

Brak politycznego porozumienia wśród państw członkowskich co do poziomu *High+* jest jednym z głównych czynników blokujących wdrożenie suwerennej oferty chmurowej dla sektora finansowego i publicznego i stanowi potwierdzenie tezy, że samo umieszczenie serwerów na terytorium UE nie przesądza o jurysdykcji prawnej. Z perspektywy zgodności z DORA oznacza to, że instytucje finansowe nie dysponują dotychczas uzgodnionym, zharmonizowanym poziomem odniesienia dla oceny suwerenności dostawcy ICT na poziomie unijnym.

2025 r. 22 grudnia 2023. URL: `https://data.europa.eu/eli/reg/2023/2854/oj` (dostęp 21.03.2026) (dalej jako Data Act).

[22] Data Act.

[23] Data Act.

[24] European Union Agency for Cybersecurity (ENISA). *EUCS – Cloud Services Scheme: Draft Candidate Scheme for the European Cybersecurity Certification of Cloud Services*. Draft Candidate Scheme. ENISA, 2022. URL: `https://www.enisa.europa.eu/publications/eucs-cloud-service-scheme` (dostęp 21.03.2026).

[25] European Union Agency for Cybersecurity (ENISA), *EUCS – Cloud Services Scheme: Draft Candidate Scheme for the European Cybersecurity Certification of Cloud Services*.

DRAFT

Cloud and AI Development Act (CADA)

W dniu 3 czerwca 2026 r. Komisja Europejska złożyła wniosek legislacyjny dotyczący *Cloud and AI Development Act* (CADA), COM(2026) 502.[26] Inicjatywa ta, zapowiadana wcześniej w programie prac Komisji na rok 2026[27] i analizowana przez Europejskie Biuro Badań Parlamentarnych (EPRS) już w grudniu 2025 roku,[28] stanowi najdalej idące narzędzie prawne w arsenale unijnej suwerenności cyfrowej.

CADA wyrasta bezpośrednio z rekomendacji raportu Draghiego z 2024 r., który wskazał strukturalną zależność UE od nieeuropejskich dostawców chmury jako ryzyko strategiczne dla konkurencyjności europejskiej gospodarki.[29] Wniosek legislacyjny opiera się na trzech filarach:

(i) rozbudowie europejskiej infrastruktury obliczeniowej, obejmującej tzw. *AI Gigafactories*, czyli dużych centrów superobliczeniowych dedykowanych trenowaniu modeli sztucznej inteligencji,

(ii) ustanowieniu europejskiego systemu oceny i certyfikacji dostawców chmury i AI, powiązanego z preferencjami w zamówieniach publicznych dla dostawców spełniających kryteria zgodności,

(iii) wzmocnieniu europejskiej niezależności infrastrukturalnej przez mechanizmy prawne ograniczające ryzyko pozajurysdykcyjnego dostępu do danych.

Podstawą prawną wniosku jest art. 114 Traktatu o Funkcjonowaniu Unii Europejskiej (TFUE), a projekt przewiduje możliwość nałożenia kar finansowych za niezgodność z wymaganiami.[30]

Definicja suwerenności chmury jako oś konfliktu. Kluczowym nierozstrzygniętym zagadnieniem CADA jest definicja *suwerennej chmury*. Projekt przekształca cyfrową suwerenność z politycznej deklaracji w wiążący wymóg prawny, jednak nie przesądza, jak ścisłe mają być kryteria kwalifikacji. Zarysowały się dwa stanowiska. Po pierwsze, definicja wąska (popierana m.in. przez Francję i grupę lobby CISPE): suwerenność wymaga pełnej europejskiej kontroli kapitałowej nad dostawcą, co w praktyce wyklucza z zamówień publicznych podmioty kontrolowane przez korporacje spoza EOG. Po drugie, definicja szeroka: suwerenność oceniana jest na podstawie faktycznych gwarancji prawno-technicznych

DRAFT

[26] Komisja Europejska. *Proposal for a Regulation of the European Parliament and of the Council on Cloud and AI Development (CADA)*. Czerwiec 2026. URL: https://digital-strategy.ec.europa.eu/pl/library/proposal-cloud-and-ai-development-act-cada (dostęp 11.06.2026).

[27] Komisja Europejska. *Commission Work Programme 2026*. Inicjatywa Cloud and AI Development Act (CADA) zapowiedziana na I kwartał 2026 r.; wniosek złożony 3 czerwca 2026 jako COM(2026) 502; podstawa prawna: art. 114 TFUE. 2025. URL: https://commission.europa.eu/document/09579818-64a6-4dd5-9577-446ab6219113_en (dostęp 21.03.2026).

[28] European Parliamentary Research Service (EPRS). *Cloud and AI Development Act*. Sprawozdanie techniczne EPRS_BRI(2025)779251. Europejski Parlament – EPRS, grudzień 2025. URL: https://www.europarl.europa.eu/thinktank/en/document/EPRS_BRI(2025)779251 (dostęp 21.03.2026).

[29] Mario Draghi. *The Future of European Competitiveness. A Competitiveness Strategy for Europe*. Bruksela: Komisja Europejska, wrzesień 2024. URL: https://commission.europa.eu/topics/strengthening-european-competitiveness/eu-competitiveness-looking-ahead_en (dostęp 21.03.2026).

[30] Komisja Europejska, *Proposal for a Regulation of the European Parliament and of the Council on Cloud and AI Development (CADA)*.

(rezydencji danych, szyfrowania i braku dostępu operacyjnego podmiotu macierzystego) niezależnie od struktury właścicielskiej.

Spór ten ma bezpośrednie implikacje rynkowe. Przyjęcie wąskiej definicji oznaczałoby de facto ograniczenie dostępu do rynku zamówień publicznych dla Amazon Web Services, Microsoft Azure i Google Cloud, które łącznie kontrolują około 70% europejskiego rynku chmury.[31] CADA działałby wówczas jako nieformalna bariera regulacyjna wobec podmiotów objętych jurysdykcją CLOUD Act i FISA 702. Szerokie kryterium pozwoliłoby natomiast hiperskalersom na zachowanie dostępu do rynku publicznego przez joint ventures z europejskimi partnerami lub wdrożenie rozwiązań *confidential computing* jako środka kompensacyjnego.

Status legislacyjny i perspektywa czasowa. Na dzień złożenia niniejszej pracy CADA znajduje się na wczesnym etapie procesu legislacyjnego UE, złożony wniosek Komisji musi przejść przez negocjacje w Parlamencie Europejskim i Radzie UE (trilog). Kluczowe parametry aktu (w tym wiążąca definicja suwerenności oraz zakres sankcji) pozostają otwarte na etapie prac legislacyjnych.[32] Przy typowym dla unijnych regulacji cyfrowych tempie prac, realistyczny termin wejścia w życie CADA to nie wcześniej niż 2028–2029 r., z uwzględnieniem standardowego okresu *vacatio legis*.

Implikacje dla modelu ORION

Trzy omówione inicjatywy, tj. Data Act, EUCS i CADA, tworzą wzajemnie uzupełniający się system regulacyjny. Data Act reguluje prawa dostępu i przenoszenia danych *ex post*, EUCS certyfikuje bezpieczeństwo dostawców, a CADA (jako złożony wniosek legislacyjny) ma budować alternatywną, europejską infrastrukturę *ex ante*. Z perspektywy metodologii ORION istotne jest jednak, że żadna z tych regulacji nie eliminuje jeszcze w całości konfliktu jurysdykcyjnego wynikającego z CLOUD Act: Data Act nie uchyla prawnych obowiązków dostawcy wynikających z prawa USA, EUCS pozostaje nieukończony na poziomie wymaganym dla usług krytycznych, a CADA jest na wczesnym etapie procesu legislacyjnego.

Stanowi to empiryczne uzasadnienie dla jednej z kluczowych decyzji projektowych ORION: traktowania jurysdykcji geograficznej dostawcy jako czynnika ryzyka, którego nie można się pozbyć w drodze samej konfiguracji usługi, wymagającego wymiany dostawcy lub zastosowania poufnego przetwarzania jako warstwy kompensacyjnej.

5.5 Przykładowe scenariusze konfliktu

Konflikt wynikający z Cloud Act pojawia się na wielu płaszczyznach. Ogólny ogląd na przechowywanie danych w chmurze należy uszczegółowić, by wskazać, jakie informacje i w jakich sytuacjach mogą opuszczać EOG. Po pierwsze należy zwrócić uwagę, w jaki sposób dane są przechowywane.

Przekazywane mogą być całe kopie maszyn wirtualnych, bez względu na jakim systemie operacyjnym działają. W takiej sytuacji nie ma znaczenia czy podmiot korzysta

[31] Synergy Research Group, *European Cloud Providers' Local Market Share Holds Steady at 15%*.

[32] Komisja Europejska, *Proposal for a Regulation of the European Parliament and of the Council on Cloud and AI Development (CADA)*.

DRAFT

z rozwiązań Open Source (Linux vs Windows), nie ma również znaczenia jakie oprogramowanie jest na danym systemie zainstalowane oraz kto jest jego producentem, np. komercyjny silnik bazy danych Oracle, Microsoft SQL, etc. vs PostgreSQL, MySQL. Ryzyko związane z CLOUD Act zależy nie od silnika bazy danych (MySQL, Oracle, PostgreSQL), lecz od lokalizacji infrastruktury i jej operatora. Sama zmiana silnika bazy danych nic nie zmienia, decydująca jest jurysdykcja nad infrastrukturą hostingową.

W przypadku systemów operacyjnych użytkownik narażony jest na dodatkowy kanał ryzyka, równoległy do przesłania danych z maszyn wirtualnych, czyli informacji zebranych przez system, przykładowo mechanizm telemetrii dostępny nie tylko w systemie Windows,[33] ale również macOS[34] oraz zostanie dołączona do dystrybucji Linux Fedora,[35] rozwijanej przez RedHat / IBM.

Telemetria Windows nie przesyła wprost zawartości baz danych, jednak może przekazywać informacje takie jak nazwy procesów i ścieżki plików, zdarzenia audytu logowania (np. SQL Server Audit), czy błędy połączeń bazodanowych. W kontekście postępowania informacje te mogą być wystarczające do ukierunkowania żądania CLOUD Act wobec Google (jak i każdego innego hiperscalera podlegającego pod CLOUD Act) o wydanie pełnych danych z dysku VM.

5.5.1 Mechanizm telemetrii w systemie Windows

Systemy operacyjne z rodziny Windows zbierają dane diagnostyczne i behawioralne tzw. *telemetrię*, obejmujące informacje o:

- używanych aplikacjach i ich awariach,
- aktywności sieciowej i połączeniach,
- konfiguracji sprzętu,
- zdarzeniach systemowych rejestrowanych w Event Viewer,
- lokalizacji użytkownika (przy odpowiednim poziomie uprawnień).

Kluczową usługą odpowiedzialną za transmisję telemetrii jest `DiagTrack` (*Connected User Experiences and Telemetry*), która regularnie przesyła dane do serwerów Microsoft zlokalizowanych w USA. Dane te, trafiając do infrastruktury podmiotu objętego jurysdykcją amerykańską, wchodzą automatycznie w zakres CLOUD Act.

5.5.2 Scenariusz kumulacji ryzyk: Windows Server na Google Cloud, Microsoft Azure, AWS

Warto przeprowadzić eksperyment myślowy ze scenariuszem, w który uruchamiono system operacyjny na maszynie wirtualnej w centrum danych. Szczególnie wysokim profilem ryzyka charakteryzuje się konfiguracja polegająca na uruchomieniu Windows Server jako maszyny wirtualnej w Google Cloud Platform (lub innej podległej pod jurysdykcję

[33] Microsoft Corporation. *Configure Windows diagnostic data in your organization*. Microsoft Learn. Dostęp: 2026-04-07. 2023. URL: `https://learn.microsoft.com/en-us/windows/privacy/configure-windows-diagnostic-data-in-your-organization`.

[34] Privacy Guides. *macOS Overview — Privacy and Telemetry*. Privacy Guides. Dostęp: 2026-04-07. 2025. URL: `https://www.privacyguides.org/en/os/macos-overview/`.

[35] Fedora Project. *Changes/Telemetry — Fedora Project Wiki*. Fedora Project Wiki. Dostęp: 2026-04-07. 2024. URL: `https://fedoraproject.org/wiki/Changes/Telemetry`.

DRAFT

CLOUD Act) z zainstalowanym silnikiem bazy danych. Wskazanie Google Cloud Platform oraz Microsoft Windows są wizualizacją przykładu i wynikają z popularności usług. Scenariusz ten łączy jednocześnie trzy warstwy ryzyka.

(i) *Warstwa 1, Chmura a CLOUD Act.* Hostingującą firmą jest podmiot amerykański, z tego wynika, że każda maszyna wirtualna w tym centrum danych, niezależnie od regionu (w tym `europe-central2` w Warszawie), podlega CLOUD Act. Organy USA mogą żądać danych od dostawcy bezpośrednio, bez informowania właściciela.

(ii) *Warstwa 2, Windows Server a telemetria.* Windows Server uruchomiony jako VM na chmurze generuje telemetrię przesyłaną do serwerów Microsoft. Oznacza to dwa niezależne podmioty objęte CLOUD Act: Google (infrastruktura VM) oraz Microsoft (telemetria systemowa). Możliwe jest równoległe żądanie skierowane do obu firm.

(iii) *Warstwa 3, Dostęp Google do danych bazy danych.* Google jako hypervisor ma techniczną możliwość dostępu do dysków Persistent Disk przypisanych do maszyny wirtualnej. Przy domyślnym szyfrowaniu zarządzanym przez Google KMS, firma może odczytać zawartość dysku w tym pliki danych bazy snapshoty, logi i backupy.

5.5.3 Macierz wektorów dostępu

Tabela 5.1: Wektory dostępu do danych bazy przy konfiguracji Windows Server / GCP

Wektor dostępu	**Podmiot**	**Co może być ujawnione**
Nakaz CLOUD Act do Google	Google LLC	Pliki danych bazy, snapshoty dysków, logi, backupy GCS
Telemetria Windows	Microsoft Corp	Metadane systemu, Event Log, ścieżki plików
Cloud SQL (jeśli użyte)	Google LLC	Bezpośredni dostęp do tabel przez DBaaS API
Klucze Google KMS (domyślne)	Google LLC	Możliwość odszyfrowania dysków VM

5.5.4 Rekomendacje dla środowisk regulowanych (NIS2 / DORA / RODO)

Na podstawie przeprowadzonej analizy formułuje się następujące rekomendacje dla organizacji przetwarzających dane wrażliwe lub dane operacyjne podlegające dyrektywie NIS2 i rozporządzeniu DORA:

(i) *CMEK z zewnętrznym HSM* (*Customer-Managed Encryption Keys*), klucze do dysków VM przechowywane poza infrastrukturą dostawcy chmury eliminują techniczną możliwość odszyfrowania przez Google lub AWS.

DRAFT

(ii) *HYOK dla baz danych* (*Hold Your Own Key*), niezależne szyfrowanie danych w bazie (np. TDE *Transparent Data Encryption*) z kluczem zarządzanym przez klienta i przechowywanym poza środowiskiem chmurowym; w modelu BYOK (*Bring Your Own Key*) klucz dostarczony przez klienta jest przechowywany w KMS dostawcy, co nie eliminuje jego dostępu technicznego.

(iii) *Wyłączenie telemetrii Windows* na poziomie GPO (`Security level`) oraz zablokowanie ruchu do endpointów telemetrycznych na poziomie firewalla egress.

(iv) *Wybór europejskiego dostawcy infrastruktury w usłudze* spoza jurysdykcji USA (w pełni zlokalizowane w EOG) jako infrastruktury dla systemów krytycznych.

(v) *Uwzględnienie CLOUD Act w rejestrze ryzyk IT*, jako ryzyko regulacyjne kategorii *prawne / compliance*, z przypisaniem prawdopodobieństwa i wpływu zgodnie z metodologią przyjętą w organizacji.

(vi) *Audyt umów z dostawcami chmurowymi* pod kątem klauzul dotyczących żądań rządowych oraz regularny monitoring *Government Request Transparency Reports* publikowanych przez Google, Microsoft i Amazon.

5.5.5 Wnioski

CLOUD Act stanowi realne i wielowarstwowe zagrożenie dla suwerenności danych europejskich organizacji. Zagrożenie to nie ogranicza się do danych przechowywanych bezpośrednio w usługach chmurowych (DBaaS, SaaS), lecz obejmuje również metadane generowane przez systemy operacyjne (telemetria Windows) oraz dane na dyskach wirtualnych maszyn IaaS zarządzanych przez podmioty podlegające prawu USA.

Konfiguracja łącząca Windows Server z Google Cloud Platform jako infrastrukturą hostingową bazy danych tworzy najwyższy profil ryzyka, dwa niezależne podmioty objęte CLOUD Act uzyskują potencjalny dostęp do danych przez różne kanały techniczne.

Skuteczna mitigacja tego ryzyka wymaga działań na poziomie infrastrukturalnym (wybór dostawcy spoza jurysdykcji USA), kryptograficznym (CMEK, BYOK) oraz operacyjnym (wyłączenie telemetrii, audyt umów). Środki te powinny być traktowane jako elementy systemu zarządzania ryzykiem IT, spójne z wymogami dyrektywy NIS2 i rozporządzenia DORA.

DRAFT

6. ORION - Ocena Ryzyka Informatycznego Organizacji Nadzorowanych

6.1 Luka badawcza

Istniejące metodologie obejmują zarządzanie bezpieczeństwem, zarządzanie ryzykiem i kontrole organizacyjne w znacznym stopniu w kierunku analizy systemów informatycznych. Są to standardy rynkowe, takie jak metodologie zdefiniowane w ISO/IEC 27001, NIST Cybersecurity Framework, COBIT. Jednak żadna z nich nie spełnia jednocześnie zasadniczych wymagań stawianych przez współczesne środowiska regulacyjne. Po pierwsze, brakuje im wielostronnej perspektywy obejmującej cały łańcuch dostaw ICT, od nadzorowanego podmiotu, poprzez jego bezpośrednich dostawców oraz podprocesorów działających na wielu poziomach. Po drugie, nie zawierają one opartego na dowodach mechanizmu punktacji, który rozróżniałby zweryfikowaną zgodność od zwykłego zapewnienia deklaratywnego rozróżnienia, które jest fundamentalne dla przeciwdziałania dobrze udokumentowanemu zjawisku *teatru zgodności*. Po trzecie, nie zapewniają one wieloaspektowej struktury analitycznej, która formalnie przypisuje pytania audytowe do odpowiedniego podmiotu w organizacji, tj. radcy prawnego, biznesu, architekta oprogramowania lub administratora infrastruktury, w oparciu o charakter pytania, a nie wygodę organizacji. Po czwarte, nie oferują modułowej rozszerzalności sektorowej, która zachowuje uniwersalny rdzeń metodologiczny, jednocześnie aktywując perspektywy i zestawy pytań specyficzne dla danej dziedziny dla regulowanych branż, takich jak finanse czy opieka zdrowotna.

Tabela 6.1: Analiza porównawcza frameworków stosowanych w polskiej praktyce audytowej względem wymagań ORION

Wymaganie	**ISO/IEC 27001**	**NIST CSF**	**COBIT 2019**	**Narzędzia GRC**	**ORION**
Pokrycie całego łańcucha dostaw ICT	Częściowe (tylko załącznik dot. dostawców)	Częściowe (profil łańcucha dostaw)	Częściowe (zarządzanie dostawcami)	Częściowe (zależne od narzędzia)	**Pełne**
Ocena oparta na dowodach	Nie	Nie	Nie	Częściowe (zależne od konfiguracji)	**Tak**

Kontynuacja na następnej stronie...

DRAFT

Tabela 6.1 – kontynuacja z poprzedniej strony

Wymaganie	ISO/IEC 27001	NIST CSF	COBIT 2019	Narzędzia GRC	ORION
Wieloperspektywiczne przypisanie pytań (zgodności / użytkownika / techniczna)	Nie	Nie	Częściowe (tylko macierz RACI)	Nie	**Tak**
Formalny model grafowy zależności ICT	Nie	Nie	Nie	Nie	**Tak**
Propagacja ryzyka przez warstwy łańcucha dostaw	Nie	Nie	Nie	Nie	**Tak**
Scoring zgodności z regulacjami (DORA / NIS2 / RODO)	Częściowe (istnieją mapowania)	Częściowe (istnieją mapowania)	Częściowe (istnieją mapowania)	Częściowe (zależne od konfiguracji)	**Tak**
Rozróżnienie wymogów obowiązkowych od dobrych praktyk	Nie	Nie	Nie	Częściowe	**Tak**
Modułowa rozszerzalność sektorowa (finanse, zdrowie, energetyka)	Nie	Częściowe (profile branżowe)	Nie	Częściowe (płatne moduły)	**Tak**
Penalizacja niezweryfikowanych deklaracji	Nie	Nie	Nie	Nie	**Tak**
Identyfikacja dostawców kluczowych	Częściowe	Częściowe	Częściowe	Częściowe	**Tak**
Ocena planu wyjścia (exit plan)	Nie	Nie	Częściowe	Częściowe	**Tak**
Transparentna, replikowalna metodyka	Tak	Tak	Tak	Nie (metodyka zastrzeżona)	**Tak**
Formalny model matematyczny	Nie	Nie	Nie	Nie	**Tak**

Kontynuacja na następnej stronie...

DRAFT

Tabela 6.1 – kontynuacja z poprzedniej strony

Wymaganie	ISO/IEC 27001	NIST CSF	COBIT 2019	Narzędzia GRC	ORION
Klasyfikacja ryzyka wg pochodzenia geograficznego (EOG / państwa trzecie)	Nie	Nie	Nie	Nie	**Tak**

Legenda: **Tak** - wymaganie w pełni adresowane; **Częściowe** - wymaganie adresowane w ograniczonym zakresie lub wymagające dodatkowej konfiguracji; **Nie** - wymaganie nieadresowane.
Uwaga: Porównanie obejmuje frameworki powszechnie stosowane w polskiej praktyce audytowej i compliance. Frameworki NIST SP 800-161 oraz ISACA CMMI, choć obecne w literaturze akademickiej, nie są szeroko stosowane jako samodzielne metodyki przez polskie organizacje i zostały pominięte w niniejszym zestawieniu.
Skróty: CSF - *Cybersecurity Framework*; GRC - *Governance, Risk and Compliance* (ład, ryzyko i zgodność).

Mimo intensywności regulacyjnej prowadzonej przez regulatorów krajowych oraz międzynarodowych, brakuje usystematyzowanej metodyki, która pozwoliłaby organizacjom w sposób transparentny, co bardzo istotne powtarzalny i oparty na obiektywnych dowodach ocenić stan zgodności wdrożonych systemów informatycznych wraz z ich łańcuchem dostawców. Dobrze przeprowadzony audyt systemów tworzy raport czytelny i zrozumiały dla wszystkich interesariuszy i faktycznie wskazuje na niezgodności. Istniejące narzędzia i frameworki, norma ISO/IEC 27001, NIST Cybersecurity Framework, model COBIT czy metodyki ISACA, dostarczają wskazówek w zakresie zarządzania bezpieczeństwem informacji, jednak żaden z nich nie adresuje jednocześnie:

(i) perspektywy wielopodmiotowej obejmującej cały łańcuch ICT,

(ii) oceny opartej na weryfikowalnych dowodach jako mechanizmu przeciwdziałającego deklaratywnej zgodności,

(iii) wieloperspektywicznej analizy uwzględniającej punkt widzenia prawnika, menedżera biznesowego i inżyniera IT,

(iv) rozszerzalności sektorowej pozwalającej na adaptację do specyfiki regulacyjnej różnych branż przy zachowaniu wspólnego rdzenia metodycznego.

Rezultatem jest rozdrobniona praktyka, w której oceny prawne, techniczne i biznesowe są przeprowadzane w izolacji, podwykonawcy pozostają niesprawdzani, a wnioski z audytu opierają się na deklaracjach, a nie na weryfikowalnych dowodach. Audyty przeprowadzane według istniejących metodyk często kończą się certyfikatami potwierdzającymi zgodność procesową, które nie odzwierciedlają faktycznego stanu bezpieczeństwa wdrożeń. Zjawisko to, zwane *compliance theater*, wynika ze słabości systemów oceny opartych na deklaracjach. Organizacja może, z pełną znajomością swoich procedur oświadczyć, że wdrożyła wymagane środki ochrony, podczas gdy stan faktyczny jest odmienny, dokumentacja jest nieaktualna, mechanizmy kontrolne nieskuteczne, a dostawcy zewnętrzni nie podlegają żadnej weryfikacji.

DRAFT

6.2 Postulaty i cele ORION

Metodologia ORION (*Ocena Ryzyka Informatycznego Organizacji Nadzorowanych*) nie ma na celu zastępowania metodologii audytowania zgodnych z ISO czy NIST. Wypełnia istotną lukę w analizie wdrożeń systemów informatycznych z punktu widzenia zgodności z regulacjami. Jest to system oparty na dowodach, ponieważ, jak wykazują badania przytoczone w rozdziale poświęconym walidacji odpowiedzi, organizacje nagminnie deklarują zgodność, której nie są w stanie udokumentować, a ta funkcja jest kluczowa.

Audyt prowadzony w ORION jest wykonywany ogólnie dla przedsiębiorstwa jako całości, analizując jego zgodność prawną z wymogami regulacyjnymi, a następnie, zgodnie z przejściem grafu ICT, przeprowadzany jest na wszystkich systemach i ich dostawcach. Identyfikowani są wszyscy poddostawcy w łańcuchu ICT i wszyscy podlegają badaniu. Wynikiem działania systemu jest określenie, który dostawca jest kluczowy, oraz wyznaczenie poziomu zgodności z prawem i rekomendacji naprawczych z przypisanymi priorytetami.

ORION wprowadza cztery kluczowe innowacje metodyczne względem istniejących frameworków.

Pierwszą z nich jest zasada wieloperspektywiczności. ORION przyjmuje, że każdy element składowy infrastruktury ICT (system informatyczny, dostawca, wymóg, etc), jest rozumiany odmiennie przez prawnika, menedżera biznesowego, architekta oprogramowania czy administratora infrastruktury. Odmienność ta nie jest wadą, którą należy eliminować, jest naturalną cechą wynikającą z różnych wyzwań i zadań na poszczególnych stanowiskach, którą metodyka musi uwzględniać. Perspektywa nie jest wyłącznie kategorią opisową, determinuje, kto w organizacji jest właściwą osobą do udzielenia odpowiedzi na konkretne pytanie audytowe, co eliminuje jeden z fundamentalnych błędów istniejącej praktyki: odpowiadanie na pytania prawne przez inżynierów i na pytania techniczne przez prawników.

Drugą innowacją jest ocena oparta na dowodach. Każda odpowiedź na pytanie audytowe podlega weryfikacji przez pryzmat dostarczonego dowodu materialnego. Metodyka rozróżnia cztery poziomy jakości dowodu (tabela 6.2): brak dowodu, dowód słaby (dokument anonimowy lub ogólny), dowód średni (oświadczenie podpisane, dokument wskazujący na system) oraz dowód silny, potwierdzony materialnie: log systemowy, wynik testu penetracyjnego, protokół z próby odtworzenia systemu. Dodatkowo, dowód pisemny jest traktowany w zależności od jego sporządzenia, inaczej system bierze pod uwagę oświadczenie pisemne czytelnie podpisane, inaczej oświadczenie pisemne będące wynikiem anonimowego dokumentu. Odpowiedź twierdząca bez żadnego dowodu jest traktowana jak przecząca, a dowód słabszy niż silny obniża efektywną wartość odpowiedzi w modelu scoringowym w sposób kontrolowany i konfigurowalny. Mechanizm ten precyzyjnie odzwierciedla rzeczywistość audytu: organizacja może stosować właściwe praktyki bez ich pełnej dokumentacji, ale twierdzenie bez weryfikacji ma mniejszą wartość poznawczą niż twierdzenie udokumentowane. Jednoczenie konieczność przygotowania dowodu, co więcej, osobistego podpisania się pod dowodem, skutkuje wysoką rzetelnością odpowiedzi. Jest to bezpośrednia odpowiedź na compliance theater.

Trzecią innowacją jest grafowe modelowanie łańcucha ICT z propagacją ryzyka. Audyt w ORION nie jest przeprowadzany wyłącznie dla podmiotu nadzorowanego traktowanego jako niepodzielna całość, obejmuje wszystkich dostawców i poddostawców ICT, reprezentowanych jako wierzchołki skierowanego grafu zależności. Mechanizm systematycznego przejścia grafu zapewnia pełną identyfikację podmiotów w łańcuchu dostaw, które w tradycyjnych audytach pozostają poza polem widzenia. Algorytm propagacji ryzyka umoż-

DRAFT

liwia z kolei obliczenie skumulowanego wpływu niezgodności na poziomie poddostawcy na ryzyko całego podmiotu nadzorowanego ,co odpowiada na pytanie, które organizacje zadają coraz częściej: czy mój dostawca jest bezpieczny, a jeśli nie, jak bardzo to mnie dotyczy?

Czwartą innowacją jest modułowa rozszerzalność sektorowa. System ORION jest zaprojektowany jako uniwersalne narzędzie z możliwością rozszerzenia na kolejne sektory. Rdzeń metodyczny, ontologia pojęć, model grafowy, formuły scoringu, struktura pytań i raportowania, jest niezależny od branży i może być stosowany wobec dowolnego podmiotu przetwarzającego dane w systemach ICT. Rozszerzenia domenowe, aktywowane w zależności od sektora audytowanego podmiotu, wprowadzają dodatkowe perspektywy, grupy pytań i wymogi regulacyjne specyficzne dla danej branży. Oznacza to w praktyce, że ten system ORION może obsłużyć audyt banku, szpitala i operatora energetycznego, różniąc się zestawem aktywnych pytań i perspektyw, lecz zachowując identyczny model matematyczny, ontologię i strukturę raportu. Ta cecha ORION ma istotne znaczenie nie tylko praktyczne, lecz także naukowe: pozwala na prowadzenie badań porównawczych między sektorami z użyciem jednolitej metodyki.

6.3 Identyfikacja podmiotu audytowanego

Przed przystąpieniem do właściwego audytu systemów informatycznych metodologia ORION wymaga przeprowadzenia wstępnej klasyfikacji podmiotu audytowanego. Celem tej fazy jest ustalenie, jakim reżimem regulacyjnym podlega organizacja, w szczególności, czy jest ona podmiotem kluczowym lub ważnym w rozumieniu dyrektywy NIS2,[1] podmiotem objętym zakresem stosowania rozporządzenia DORA,[2] czy też jednostką podlegającą wyłącznie wymogom ogólnym, takim jak RODO.[3] Wynik tej klasyfikacji determinuje, które moduły pytań zostaną aktywowane w dalszych etapach audytu, jakie mnożniki wagowe zostaną przypisane do poszczególnych wymogów oraz które elementy, takie jak plan ciągłości działania czy exit plan, mają charakter obowiązkowy, a które stanowią dobrowolne zalecenie.

Klasyfikacja podmiotu jest przeprowadzana metodą walidacji krzyżowej, gdzie zagadnienie analizowane jest niezależnie w perspektywie zgodności, perspektywie użytkownika oraz perspektywie technicznej, a wynik jest ustalany na podstawie konsensusu odpowiedzi. Wynikiem klasyfikacji jest przypisanie podmiotu do jednej z czterech kategorii regulacyjnych: `FINANSOWY` (podmioty objęte rozporządzeniem DORA), `KLUCZOWY` (podmioty kluczowe w rozumieniu dyrektywy NIS2 i ustawy KSC), `WAŻNY` (podmioty ważne w rozumieniu NIS2 i KSC) lub `POZOSTAŁE` (podmioty podlegające wyłącznie wymogom ogólnym, w szczególności RODO). Kategoria determinuje zakres obowiązkowych elementów audytu (tabela 7.1) oraz zbiór aktów prawnych stosowanych do podmiotu: DORA i RODO dla podmiotu finansowego, NIS2 i RODO dla podmiotów kluczowych i ważnych, wyłącznie RODO dla pozostałych (równanie (7.11)). Od tego zbioru i zakresu regulacyjnego pytania zależą efektywna obligatoryjność i waga pytania $\omega(q_j, k)$ (równanie (7.10)) oraz to, czy pytanie jest blokujące (równanie (7.13)). Ten sam kwestionariusz daje więc 25 pytań blokujących dla podmiotu finansowego, 17 dla podmiotów kluczowych i ważnych oraz 5 dla pozostałych.

[1] Dyrektywa NIS2.

[2] Parlament Europejski i Rada Unii Europejskiej, *Rozporządzenie (UE) 2022/2554 w sprawie operacyjnej odporności cyfrowej sektora finansowego (DORA)*.

[3] RODO.

DRAFT

6.4 Mechanizm walidacji jakości dowodów i odpowiedzi

6.4.1 Struktura pytań

Pytania stawiane w audycie mają z definicji wartość binarną. Oznacza to, że ankietowany moze odpowiedzieć na pytanie tylko i wyłącznie `TAK` lub `NIE`. Jedynym dopuszczalnym wyjątkiem jest odpowiedź `N/D` (nie dotyczy), która nie wyraża stanu wiedzy respondenta, lecz stwierdza, że wymaganie nie ma zastosowania do ocenianego obiektu; wymaga ona uzasadnienia i akceptacji audytora (sekcja 7.3.2). Każdemu pytaniu przypisana jest `ODPOWIEDŹ OCZEKIWANA`, rozumiana jako wartość wskazująca na stan zgodności z wymaganiem zgodne z semantyką treści pytania.

Działanie wartości oczekiwanej idealnie zilustruje przykład dwóch pytań:

Czy dwa plus dwa jest cztery?

Oraz pytanie drugie:

Czy dwa plus dwa różne od czterech?

W przypadku pierwszym odpowiedzią oczekiwaną jest `TAK`, w przypadku drugim `NIE`. Przykład pokazuje, że o interpretacji odpowiedzi decyduje polaryzacja pytania. Aby uniknąć tej niejednoznaczności, wszystkie pytania kwestionariusza szczegółowego formułuje się tak, aby odpowiedź oczekiwana brzmiała `TAK` (zasada jednolitej polaryzacji, sekcja 7.3.2). Odpowiedzi zgodnej z odpowiedzią oczekiwaną przypisuje się wartość $a_{ij} = 1$, a pozostałym $a_{ij} = 0$ (równanie (6.1)).

Zrezygnowano z opcji `NIE WIEM / BRAK DANYCH`. W sytuacji braku znajomości odpowiedzi oczekuje się, że ankietowany podejmie wysiłek uzyskania informacji. Brak pewności w odpowiedzi powinien być rozstrzygany na niekorzyść audytu i wynika to z konieczności ochrony organizacji.

Decyzja o rezygnacji z opcji `NIE WIEM / BRAK DANYCH` jest uzasadniona zarówno metodologicznie, jak i z perspektywy zarządzania ryzykiem. Badania nad konstrukcją kwestionariuszy wykazują, że obecność opcji neutralnej skłania respondentów do udzielania odpowiedzi zastępczych zamiast podejmowania wysiłku poznawczego niezbędnego do udzielenia odpowiedzi merytorycznej, zjawisko to określane jest w literaturze jako *satisficing*.[4] Kwestionariusze z wymuszonym wyborem binarnym generują dane wyższej jakości i lepiej różnicują rzeczywiste stany wiedzy respondentów niż skale z opcją neutralną.[5] W kontekście audytu bezpieczeństwa informatycznego brak wiedzy o stanie systemu jest sam w sobie wskaźnikiem ryzyka. Organizacja, która nie jest w stanie potwierdzić zgodności z wymaganiem, nie spełnia go z punktu widzenia ochrony.[6] Przyjęcie zasady rozstrzygania wątpliwości na niekorzyść audytu odpowiada powszechnie stosowanej w zarządzaniu ryzykiem zasadzie, zgodnie z którą niepewność nie redukuje ryzyka, lecz je potęguje.

[4] Jon A. Krosnick i in. „The Impact of “No Opinion” Response Options on Data Quality: Non-Attitude Reduction or an Invitation to Satisfice?” W: *Public Opinion Quarterly* 66.3 (2002), s. 371–403. DOI: 10.1086/341394.

[5] Sara Dolnicar, Bettina Grün i Friedrich Leisch. „Quick, simple and reliable: forced binary survey questions”. W: *International Journal of Market Research* 53.2 (2011), s. 231–252. DOI: 10.2501/IJMR-53-2-231-252.

[6] Erika A. Waters i in. „Dismissing “don’t know” responses to perceived risk survey questions”. W: *Sage Journals* (2021). DOI: 10.1177/17456916211017860.

DRAFT

Dodatkowo, wprowadzona została opcja `flagi blokującej` $\mathrm{FLAG}_{block}(\mathcal{S}) = \texttt{TRUE}$ dla pytań kluczowych, które muszą być bezwzględnie spełnione. Niespełnienie pytania blokującego, tj. odpowiedź `NIE` perspektywy zgodności albo wynik pytania poniżej progu θ_{block}, oznacza przypisanie wartości zerowej całej sekcji (równanie (7.7)). To, czy pytanie jest blokujące dla danego podmiotu, zależy od jego klasy regulacyjnej (równanie (7.13)).

6.4.2 Model dowodowy

Każda odpowiedź twierdząca na pytanie audytowe w ORION powinna być opatrzona dowodem. Dowód nie zamienia odpowiedzi `NIE` na `TAK`; odpowiedź `TAK` bez żadnego dowodu liczy się jak `NIE`, a jakość dowodu modyfikuje wagę odpowiedzi twierdzącej w modelu scoringowym (sekcja 6.4.5). Logika ta odzwierciedla cel audytu, organizacja może faktycznie stosować właściwe praktyki bez ich pełnej i faktycznej dokumentacji istnieje ryzyko, że dowód jest wadliwiwy.

Równie istotny jest aspekt behawioralny: badania z zakresu psychologii decyzji wskazują, że osoby podpisujące oświadczenia własnym imieniem i nazwiskiem kłamią istotnie rzadziej niż autorzy anonimowych dokumentów.[7] Wymóg osobistego podpisania dowodu jest zatem nie tylko formalny, lecz pełni funkcję mechanizmu antydefraudacyjnego wbudowanego w strukturę audytu.

6.4.3 Walidacja odpowiedzi

Walidacja odpowiedzi jest kluczowa, do prawidłowego przeprowadzenia procesu audytowania. Wskazują na to wyniki badań, które wskazują, że awersja do kłamstwa pojawia się głównie przy obowiązkowym raportowaniu.[8]

Osoby wypełniające dane ograniczają kłamstwo w wypełnianych ankietach, gdy są zobligowane do złożenia oświadczenia imiennego, potwierdzającego zgodne z prawdą wypełnienie ankiety. Badania wskazują, że efekt takiego zobowiązania, mierzony wielkością efektu, wynosi $g = 0{,}24$.[9] Współczynnik g (zwany *Hedges' g*) to standaryzowana miara wielkości efektu, wyraża jak duża jest różnica między grupami w jednostkach odchylenia standardowego.

6.4.4 Skala jakości dowodów

Metodologia ORION wymaga przeprowadzenia odpowiedniej walidacji dowodu i jakość dowodu, co bezpośrednio wpływa na wagę odpowiedzi. ORION wyróżnia cztery poziomy jakości dowodu,zdefiniowane w tabeli 6.2. oznaczane symbolem $d \in \{0;\ 0{,}4;\ 0{,}7;\ 1{,}0\}$.

DRAFT

[7] Friesen, „Designing Self-Reporting Regimes to Encourage Truth Telling".

[8] Friesen, „Designing Self-Reporting Regimes to Encourage Truth Telling".

[9] Peer, Vanhoof i in., „Commitment to honesty oaths decreases dishonesty, but commitment to another individual does not".

Tabela 6.2: Skala jakości dowodów w metodologii ORION

Poziom	**Symbol** d	**Definicja**	**Przykłady**
Brak dowodu	$d = 0$	Odpowiedź udzielona wyłącznie ustnie lub pisemnie bez jakiegokolwiek dokumentu potwierdzającego; niemożliwa do weryfikacji przez audytora.	Oświadczenie słowne podczas wywiadu, odpowiedź wpisana bezpośrednio w formularz bez załącznika
Dowód słaby	$d = 0{,}4$	Dokument pisemny bez wskazania autora lub anonimowy; dokument ogólny niepowiązany wprost z audytowanym systemem.	Regulamin ogólny dostawcy, polityka bezpieczeństwa bez daty i podpisu, screen z systemu bez kontekstu
Dowód średni	$d = 0{,}7$	Oświadczenie pisemne z czytelnym podpisem osoby fizycznej i datą; dokument wskazujący jednoznacznie na audytowany system.	Podpisana deklaracja zgodności, umowa powierzenia z klauzulą TIA, certyfikat ISO z numerem seryjnym
Dowód silny	$d = 1{,}0$	Dowód materialny niemożliwy do sfałszowania bez pozostawienia śladu technicznego; log systemowy, wynik testu automatycznego, lub oświadczenie podpisane z poświadczeniem tożsamości wskazujące na pytanie audytowe.	Log z systemu SIEM, wynik testu penetracyjnego, protokół z próby odtworzenia z BCP, oświadczenie potwierdzone podpisem osobistym.

DRAFT

6.4.5 Wpływ dowodu na wartość odpowiedzi

Efektywna wartość odpowiedzi na pytanie audytowe jest iloczynem odpowiedzi binarnej i jakości dowodu:

$$V_{eff}(q_j, \pi_i) = a_{ij} \cdot d_{ij} \tag{6.1}$$

gdzie $a_{ij} \in \{0, 1\}$ jest odpowiedzią perspektywy π_i na pytanie q_j, a $d_{ij} \in \{0;\ 0{,}4;\ 0{,}7;\ 1{,}0\}$ jest jakością dostarczonego dowodu.

Konsekwencje praktyczne wzoru (6.1) są następujące:

(i) odpowiedź TAK bez dowodu ($a = 1$, $d = 0$) daje $V_{eff} = 0$ i jest traktowana identycznie jak odpowiedź NIE, także przy ustalaniu konsensusu (definicja 6.1),

(ii) odpowiedź TAK z dowodem silnym ($a = 1$, $d = 1{,}0$) daje $V_{eff} = 1{,}0$ pełna wartość,

(iii) odpowiedź NIE z dowodem silnym ($a = 0$, $d = 1{,}0$) daje $V_{eff} = 0$ wskazuje na niezgodność między odpowiedzią, a dowodem.

Mechanizm ten precyzyjnie odzwierciedla cel audytu: nie interesuje nas, co organizacja mówi, że robi, interesuje nas, co jest w stanie udowodnić.

Dowód perspektywy użytkownika. Perspektywa użytkownika z natury opisuje obserwacje z codziennej pracy i zwykle nie dysponuje dowodem materialnym. Aby jej odpowiedzi nie były z definicji zerowane, użytkownik składa odpowiedzi w formie imiennego, podpisanego i datowanego oświadczenia. Zgodnie z tabelą 6.2 odpowiada to dowodowi średniemu, $d = 0{,}7$; oświadczenie podpisane z poświadczeniem tożsamości (np. podpisem kwalifikowanym) jest dowodem silnym, $d = 1{,}0$. Mechanizm ten wykorzystuje efekt opisany w sekcji walidacji odpowiedzi: osoby podpisujące oświadczenie imiennie rzadziej podają nieprawdę. Odpowiedź użytkownika udzielona wyłącznie ustnie, bez podpisanego oświadczenia, ma $d = 0$. Perspektywy zgodności i techniczna są oceniane według rzeczywiście przedstawionych dowodów.

6.4.6 Walidacja krzyżowa oraz definicja konsensusu

Walidacja krzyżowa (*cross-validation*) jest kluczowym mechanizmem metodologii ORION, zapewniającym rzetelność klasyfikacji atrybutów i odpowiedzi na pytania audytowe. To samo zagadnienie przedstawione jest użytkownikom z co najmniej dwóch perspektyw z trzech, a wynik jest ustalany na podstawie porównania odpowiedzi. Mechanizm ten realizuje dwa cele jednocześnie: po pierwsze, wykrywa rozbieżności między perspektywami, które są same w sobie wartościowymi sygnałami audytowymi; po drugie, zwiększa odporność systemu na celowe lub niecelowe podawanie nieprawdziwych informacji przez jeden z aktorów.

Definicja 6.1 (Formalna definicja konsensusu)**.** *Niech Q będzie zagadnieniem audytowym zadanym perspektywom ze zbioru $\Pi_Q \subseteq \Pi$, gdzie $|\Pi_Q| \geq 2$. Każda perspektywa $\pi_i \in \Pi_Q$ udziela odpowiedzi $a_i \in \{0, 1\}$ (NIE / TAK). W kwestionariuszu szczegółowym, gdzie odpowiedzi są opatrzone dowodem, a_i oznacza odpowiedź efektywną $a_i \cdot \mathbb{1}[d_i > 0]$: odpowiedź `TAK` bez żadnego dowodu liczy się jak `NIE`. Wynik cross-validation zagadnienia Q definiuje się jako:*

$$CV(Q) = \begin{cases} 1 & \text{jeśli } |\{i : a_i = 1\}| > |\{i : a_i = 0\}| \\ 0 & \text{jeśli } |\{i : a_i = 0\}| > |\{i : a_i = 1\}| \\ \varnothing & \text{jeśli remis} \end{cases} \tag{6.2}$$

Gdy $CV(Q) = \varnothing$ (remis, możliwy przy dwóch perspektywach), zagadnienie jest oznaczane flagą Rozbieżność *i nie może zostać zatwierdzone bez interwencji audytora. Flagą* Rozbieżność *oznaczane jest również każde zagadnienie, w którym odpowiedzi perspektyw nie są jednomyślne.*

Wynik pytania audytowego q_j jest wyznaczany na podstawie konsensusu, z karą za brak jednomyślności:

DRAFT

$$S(q_j) = \begin{cases} \bar{d}_j^+ & \textit{jeśli } a_i = 1 \textit{ dla wszystkich } \pi_i \in \Pi_{q_j}, \\ \beta_{cv} \cdot \bar{d}_j^+ & \textit{jeśli } CV(q_j) = 1 \textit{ bez jednomyślności}, \\ 0 & \textit{jeśli } CV(q_j) \in \{0, \varnothing\}, \end{cases} \tag{6.3}$$

gdzie

$$\bar{d}_j^+ = \frac{\sum_{\pi_i \in \Pi_{q_j} : a_{ij}=1} V_{eff}(q_j, \pi_i) \cdot w_{\pi_i}}{\sum_{\pi_i \in \Pi_{q_j} : a_{ij}=1} w_{\pi_i}}$$

jest ważoną średnią efektywnych wartości odpowiedzi (równanie (6.1)*) perspektyw, które odpowiedziały* `TAK`*, czyli średnią jakością ich dowodów,* w_{π_i} *jest wagą perspektywy (w rdzeniu metodycznym* $w_{\pi_i} = 1$*), a* $\beta_{cv} \in [0, 1]$ *jest konfigurowalnym współczynnikiem kary za brak jednomyślności (wartość domyślna:* $\beta_{cv} = 0{,}5$*).*

Innymi słowy: odpowiedź twierdząca większości perspektyw przy sprzeciwie choćby jednej z nich jest traktowana jako połowicznie pozytywna, a przewaga odpowiedzi przeczących daje wynik zerowy, nawet jeśli jeden z aktorów odpowiedział twierdząco. Przy trzech perspektywach i dowodach silnych wszystkich perspektyw wynik wynosi 1,0 (jednomyślne `TAK`), 0,5 (dwa `TAK`) albo 0 (co najmniej dwa `NIE`). W typowym przypadku, gdy zgodność i technika przedstawiają dowody silne, a użytkownik podpisane oświadczenie imienne ($d = 0{,}7$), jednomyślne `TAK` daje 0,9, dwa `TAK` zgodności i techniki przy `NIE` użytkownika dają 0,5, a dwa `TAK` z udziałem użytkownika przy `NIE` jednej z pozostałych perspektyw dają $0{,}5 \cdot (1{,}0 + 0{,}7)/2 = 0{,}425$. Wynik pytania mieści się zawsze w przedziale $[0, 1]$. Metodologia nie przewiduje dodatkowej premii za pełny konsensus: jednomyślne `TAK` z dowodami silnymi wszystkich perspektyw osiąga już wartość maksymalną.

6.4.7 Interpretacja rozbieżności

Rozbieżność między perspektywami nie jest błędem procesu audytowego, jest wartościową informacją merytoryczną. Tabela 6.3 przedstawia najczęstsze wzorce rozbieżności i ich standardową interpretację w ORION.

DRAFT

Tabela 6.3: Wzorce rozbieżności cross-validation i ich interpretacja audytowa

Wzorzec rozbieżności	**Typowa przyczyna**	**Interpretacja i zalecane działanie**
Zgodność: TAK Użytkownik: NIE Techniczna: NIE	Wymóg zdefiniowany w przepisach, lecz nieimplementowany	Compliance theater: organizacja deklaruje zgodność formalną bez rzeczywistego wdrożenia. $S(q_j) = 0$; dla pytania obowiązkowego priorytet P1 (tabela 7.10).
Zgodność: NIE Użytkownik: TAK Techniczna: TAK	Praktyka wdrożona bez formalnej podstawy prawnej	Brak świadomości regulacyjnej. Ryzyko braku dokumentacji wymaganej przez regulatora. Rekomendacja formalizacji. $S(q_j) = \beta_{cv} \cdot \bar{d}_j^+$; w pytaniu blokującym odpowiedź `NIE` perspektywy zgodności aktywuje blokadę sekcji.
Zgodność: TAK Użytkownik: TAK Techniczna: NIE	Wymaganie znane, polityka istnieje, wdrożenie niezrealizowane	Luka techniczna. Wymóg zdefiniowany lecz nieimplementowany na poziomie systemów. $S(q_j) = \beta_{cv} \cdot \bar{d}_j^+$ (przy oświadczeniu użytkownika 0,425); dla pytania obowiązkowego priorytet co najmniej P2, a P1, gdy $S(q_j) < 0{,}3$ (tabela 7.10). W pytaniu blokującym wynik poniżej $\theta_{block} = 0{,}5$ aktywuje blokadę sekcji.
Zgodność: NIE Użytkownik: NIE Techniczna: TAK	System techniczny bez świadomości biznesowej i prawnej	Shadow IT lub wdrożenie bez akceptacji zarządczej. Wymaga formalnej inwentaryzacji i decyzji. $S(q_j) = 0$.

6.5 Definicje i aktorzy

6.5.1 Perspektywa

Perspektywa punktu widzenia systemu określa interesariuszy uczestniczących w ocenie oraz sposób ich rozumienia analizowanych zagadnień. Każde pytanie ankietowe jest przypisane do co najmniej dwóch perspektyw, o ile jest to możliwe, do wszystkich trzech. Umożliwia to prowadzenie analizy porównawczej odpowiedzi na to samo kryterium, udzielonych niezależnie przez różnych interesariuszy. Rozbieżności między perspektywami stanowią sygnał do dalszego wyjaśnienia i są równie wartościowe analitycznie jak odpowiedzi zgodne.

Zdefiniowane są trzy perspektywy:

DRAFT

(i) *Perspektywa zgodności*, reprezentuje punkt widzenia osób odpowiedzialnych za przestrzeganie regulacji, takich jak prawnik, inspektor ochrony danych osobowych (IOD/DPO) czy specjalista ds. compliance. Celem tej perspektywy jest ocena kryterium pod kątem zgodności z obowiązującymi przepisami prawa, regulacjami rynkowymi oraz wewnętrznymi politykami organizacji (np. RODO, NIS2, DORA).

(ii) *Perspektywa użytkownika*, reprezentuje jednostki organizacyjne firmy aktywnie korzystające z systemu w codziennej pracy, takie jak właściciel biznesowy systemu, kierownik działu lub kluczowy użytkownik końcowy. Celem tej perspektywy jest uzyskanie odpowiedzi odzwierciedlającej rzeczywisty sposób wykorzystania systemu, nie jego założenia projektowe, lecz faktyczny stan i pola eksploatacji.

(iii) *Perspektywa techniczna*, reprezentuje punkt widzenia osób odpowiedzialnych za budowę, utrzymanie i bezpieczeństwo systemu, takich jak architekt systemów, administrator lub inżynier. Celem tej perspektywy jest ocena, czy implementacja i wdrożenie systemu zostały przeprowadzone zgodnie z obowiązującymi standardami technicznymi i najlepszymi praktykami branżowymi.

Przyjęte perspektywy determinują strukturę pytań ankietowych, w których pojedyncze kryterium analizowane jest przez pryzmat trzech różnych ujęć oraz wpływają na sposób definiowania obiektów. Ilustrując to podejście przykładem, zadajmy sobie pytanie:

Jaka jest definicja systemu CRM?

Na tak postawione pytanie zostaną udzielone trzy komplementarne odpowiedzi:

(i) Z punktu widzenia *użytkownika*, system CRM służy do rejestrowania wszyskich kontaktów z klientami oraz realizacji procesów sprzedażowych.

(ii) Z punktu widzenia *zgodności*, system oraz jego fizyczna lokalizacja muszą gwarantować zgodność z polityką RODO, zapewniając organizacji pełną wiedzę o miejscu przetwarzania danych osobowych.

(iii) Z punktu widzenia *technicznego*, jest to rozwiązanie informatyczne, które ma zapewniać dostępność zasobów dla uprawnionych użytkowników poprzez określone kanały komunikacyjne.

6.5.2 Obiekt

Centralnym pojęciem metodyki ORION jest `obiekt`, reprezentujący byt w systemie ICT organizacji, który może być przedmiotem oceny zgodności regulacyjnej. Pojęcie obiektu jest szerokie: obejmuje zarówno systemy informatyczne działające na infrastrukturze własnej organizacji, jak i zewnętrznych dostawców usług, platformy chmurowe oraz poddostawców odkrytych w toku rozszerzania grafu ICT.

Definicja 6.2 (Obiekt)**.** *Obiekt jest formalną jednostką audytową systemu ORION, reprezentującą byt w ekosystemie ICT organizacji, który:*

(i) posiada tożsamość możliwą do jednoznacznej identyfikacji w grafie zależności ICT,

(ii) może być przypisany do co najmniej jednego właściciela lub podmiotu odpowiedzialnego,

DRAFT

(iii) podlega co najmniej jednemu wymogowi regulacyjnemu wynikającemu z obowiązujących przepisów prawa,

(iv) może być oceniany z co najmniej dwóch perspektyw audytowych zdefiniowanych w zbiorze Π*.*

Formalnie, obiekt jest wierzchołkiem $v \in V$ *grafu ICT* $G = (V, E, W)$*, posiadającym zbiór atrybutów klasyfikacyjnych* $\mathcal{A}(v)$ *determinujących zakres i intensywność przeprowadzanego audytu.*

W ORION obiektem jest zarówno aplikacja webowa obsługująca klientów banku, dostawca chmury publicznej, na której ta aplikacja działa, jak i usługi firmy świadczącej usługi zarządzania kluczami kryptograficznymi na rzecz tego dostawcy chmury. Każdy z tych bytów jest odrębnym wierzchołkiem grafu, odrębnym podmiotem audytu i odrębnym źródłem ryzyka, choć wszystkie wymione podmioty uczestniczą w tym samym łańcuchu przetwarzania danych.

Typy obiektów

ORION wyróżnia cztery typy obiektów, które determinują domyślny zestaw aktywowanych sekcji pytań oraz rolę wierzchołka w grafie ICT. Każdy obiekt posiada właściwości, czyli pola przyjmujące definiowane przez audytora wartości:

DRAFT

Tabela 6.4: Typy obiektów w systemie ORION

Typ	Definicja	Przykłady
`PODMIOT` Właściwości: nazwa	Korzeń grafu ICT (v_0); audytowana organizacja jako całość. Oceniany sekcjami pytań na poziomie organizacji (np. `ORGANIZACJA`); jego wynik końcowy łączy wynik organizacyjny z agregacją wyników pozostałych obiektów (równanie (7.18)).	Bank, szpital, operator infrastruktury krytycznej
`SYSTEM_INFORMATYCZNY` Właściwości: nazwa, dostawca, właściciel biznesowy	Oprogramowanie służące do gromadzenia, przetwarzania i przesyłania informacji.	System kadrowo-płacowy, baza danych pacjentów, portal intranetowy, API płatności
`DOSTAWCA` Właściwości: nazwa, kraj pochodzenia, kraj kontroli kapitałowej, poddostawcy	Zewnętrzny podmiot prawny świadczący usługi ICT na rzecz organizacji na podstawie umowy; bezpośredni dostawca systemu informatycznego (głębokość 2 grafu).	Dostawca ERP, operator chmury publicznej, firma hostingowa, integrator systemów
`PODDOSTAWCA` Właściwości: nazwa, kraj pochodzenia, kraj kontroli kapitałowej, poddostawcy	Zewnętrzny podmiot prawny świadczący usługi ICT na rzecz dostawcy lub innego poddostawcy; zidentyfikowany w toku obowiązkowej identyfikacji poddostawców na podstawie deklaracji dostawcy wyższego poziomu, zweryfikowanej przez audytora.	Google LLC jako operator infrastruktury dostawcy ERP, Cloudflare jako CDN aplikacji webowej, firma zarządzająca kluczami kryptograficznymi

6.5.3 Atrybuty obiektów

Każdy obiekt jest scharakteryzowany przez zbiór atrybutów klasyfikacyjnych $\mathcal{A}(v)$, które pełnią dwie funkcje. Po pierwsze, determinują, które sekcje pytań audytowych zostaną aktywowane dla danego obiektu, na przykład system wewnętrzny działający wyłącznie on-premise nie otrzyma pytań dotyczących transferu danych do chmury. Po drugie, wyznaczają wagi stosowane w modelu scoringowym, decydując o tym, jak mocno wynik danego obiektu wpływa na wynik całego podmiotu.

6.5.4 Atrybut: dostępność systemu

Atrybuty obiektów są ustalane w fazie wstępnej audytu za pomocą pomocniczej ankiety, przed wygenerowaniem kwestionariusza szczegółowego. Dostępność systemu i jego krytyczność są wyznaczane przez mechanizm cross-validation z udziałem trzech perspektyw:

DRAFT

krytyczność według reguły większości, a dostępność według zasady ostrożności (wystarcza jedna odpowiedź twierdząca).

Definicja 6.3 (Poziom dostępności systemu)**.** *Poziom dostępności obiektu v jest wartością ze zbioru:*

$$\textit{dostępność}(v) \in \{\texttt{PRYWATNY},\ \texttt{PUBLICZNY}\}$$

wyznaczaną na podstawie odpowiedzi trzech perspektyw rdzeniowych: `ZGODNOŚCI`*,* `UŻYTKOWNIKA` *i* `TECHNICZNEJ`*, zgodnie z zasadą ostrożności: do uznania kryterium za spełnione wystarcza jedna odpowiedź twierdząca.*

Tabela 6.5: Poziomy dostępności obiektu, kryteria klasyfikacji i mnożniki wagowe

Poziom	w_{dost}	**Kryteria klasyfikacji**	**Przykład**
`PRYWATNY`	1,0	System dostępny wyłącznie z sieci wewnętrznej organizacji i wyłącznie dla jej użytkowników; bez dostępu z sieci publicznej i bez użytkowników ani integracji zewnętrznych.	System kadrowo-płacowy on-premise, baza danych pacjentów, wewnętrzny portal intranetowy
`PUBLICZNY`	1,8	System dostępny z sieci publicznej, posiadający użytkowników lub integracje zewnętrzne albo publiczny adres (kryteria D1–D4).	Portal klienta banku, system e-rejestracji, API płatności

Klasyfikacja jest przeprowadzana przez cztery kryteria, z których każde jest zadawane wszystkim trzem perspektywom. Logika wynikowa jest progowa: nawet jedna odpowiedź twierdząca z dowolnej perspektywy na dowolne kryterium skutkuje klasyfikacją `PUBLICZNY`. Uzasadnienie tej asymetrii jest regulacyjne: jedna niepotwierdzona ścieżka dostępu zewnętrznego jest wystarczającym powodem do traktowania systemu jako publicznie dostępnego i stosowania względem niego pełnego zestawu wymogów bezpieczeństwa dla systemów publicznych.

6.5.5 Atrybut: poziom krytyczności

Poziom krytyczności jest atrybutem klasyfikacyjnym obiektu określającym, jak poważne skutki operacyjne, prawne i społeczne pociągnęłaby za sobą niedostępność, naruszenie integralności lub utrata poufności danego systemu lub dostawcy. Atrybut ten jest wyznaczany w fazie wstępnej audytu metodą cross-validation, to samo zagadnienie jest zadawane niezależnie trzem perspektywom audytowym, a wynik klasyfikacji jest ustalany na podstawie konsensusu odpowiedzi.

DRAFT

Definicja 6.4 (Poziom krytyczności obiektu)**.** *Poziom krytyczności obiektu v jest wartością ze zbioru:*

$$\textit{krytyczność}(v) \in \{\texttt{KRYTYCZNY},\ \texttt{WAŻNY},\ \texttt{STANDARDOWY}\}$$

wyznaczaną przez mechanizm cross-validation na podstawie odpowiedzi co najmniej dwóch z trzech perspektyw rdzeniowych: `ZGODNOŚCI`*,* `UŻYTKOWNIKA` *i* `TECHNICZNEJ`*. Poziom krytyczności determinuje mnożnik wagowy $w_{krit}(v)$ stosowany w równaniu agregacji wyników na poziomie podmiotu* (7.17)*.*

Tabela 6.6: Poziomy krytyczności obiektu, kryteria klasyfikacji i mnożniki wagowe

Poziom	w_{krit}	**Kryteria klasyfikacji**	**Podstawa regulacyjna**
`KRYTYCZNY`	2,0	Niedostępność przez ponad 4 h powoduje bezpośrednie straty operacyjne, naruszenie przepisów prawa lub zagrożenie bezpieczeństwa osób; brak możliwości zastąpienia; system wspiera funkcję kluczową w rozumieniu NIS2 lub DORA	NIS2 Art. 3; DORA Art. 2; ustawa o krajowym systemie cyberbezpieczeństwa
`WAŻNY`	1,5	Niedostępność poważnie utrudnia działalność, lecz jej nie wstrzymuje; istnieje procedura zastępcza; system wspiera funkcję ważną w rozumieniu NIS2	NIS2 Art. 3 ust. 2; ISO/IEC 22301
`STANDARDOWY`	1,0	Niedostępność powoduje utrudnienia pomocnicze; istnieje możliwość pracy bez systemu przez co najmniej 48 h bez istotnych strat	—

Opisy w kolumnie „Kryteria klasyfikacji” mają charakter poglądowy i charakteryzują typowy system danej klasy. Klasa jest wyznaczana wyłącznie ankietą K1–K6. Klasyfikacja krytyczności jest przeprowadzana przez sześć kryteriów (K1–K6) zadawanych wszystkim trzem perspektywom. Wynik końcowy wyznaczany jest progowo: każde kryterium przyjmuje wartość `TAK`, gdy odpowiedziały tak co najmniej dwie perspektywy, a o klasie decyduje liczba kryteriów o wartości `TAK` (od 0 do 6) zgodnie z ankietą przedstawioną w sekcji 7.2.3.

DRAFT

6.5.6 Atrybut: klasyfikacja utrzymania w chmurze

Lokalizacja miejsca utrzymania usługi ma kluczowy wpływ na warunki jej świadczenia. Oprogramowanie działające *on-premise*, czyli w siedzibie organizacji, nie jest narażone na ryzyko przechowywania danych u zewnętrznych dostawców, może jednak podlegać ryzyku dostępu z państwa trzeciego, jeśli wsparcie techniczne jest świadczone spoza EOG lub dostawca systemu pochodzi z państwa trzeciego. Istotna jest również prawna jurysdykcja podmiotu, który hostuje dane. Przechowywanie danych w chmurze wymaga dokładnego audytu łańcucha dostawców, a w przypadku lokalizacji, jurysdykcji lub wsparcia spoza Europejskiego Obszaru Gospodarczego (*EOG*) także oceny skutków transferu (*TIA*); warunek ten ($\mathcal{C}_{TIA}$) może być spełniony także dla systemu `ON_PREMISE`.

Klasyfikacja utrzymania w chmurze

Metodologia ORION definiuje trzy klasy utrzymania systemu, a ich atrybut wpływa na aktywację sekcji pytań dotyczących rozwiązań chmurowych oraz transferu danych.

Tabela 6.7: Klasyfikacja utrzymania w chmurze w ORION

Typ utrzymania	Opis
`CHMURA_K3`	Dane przechowywane są poza organizacją u zewnętrznego podmiotu (SaaS, IaaS/PaaS, model hybrydowy, hosting, kolokacja), którego lokalizacja, jurysdykcja lub wsparcie techniczne nie gwarantuje pozostania danych w EOG, albo w którego łańcuchu dostaw występuje dostawca lub poddostawca z siedzibą w państwie trzecim lub kontrolowany kapitałowo z państwa trzeciego. Obejmuje dostawców podlegających prawu państw trzecich, np. Amazon Web Services, Google Cloud, Microsoft Azure.
`CHMURA_EOG`	Dane przechowywane są poza organizacją u zewnętrznego podmiotu (SaaS, IaaS/PaaS, model hybrydowy, hosting, kolokacja), którego lokalizacja i jurysdykcja gwarantuje przechowywanie danych wyłącznie w EOG, np. NASK SA, Exea Data Center, Beyond.pl, OVH (region PL/EU).
`ON_PREMISE`	Dane przechowywane są wyłącznie na serwerach i infrastrukturze będącej własnością organizacji, fizycznie zlokalizowanej w jej siedzibie lub własnym centrum danych.

DRAFT

6.5.7 Atrybut: klasyfikacja atrybutu typów przetwarzanych danych

Dotychczasowe modele oceny ryzyka ICT nie uwzględniają charakter przetwarzanych danych jako samodzielny wymiar ryzyka z formalnym przełożeniem na wynik scoringowy. W metodologii ORION charakter danych jest traktowany jako atrybut pierwszorzędny, który wpływa bezpośrednio na wagę obiektu w agregacji końcowej. Logika jest prosta: naruszenie bezpieczeństwa systemu przetwarzającego tajemnicę lekarską lub dane finansowe klientów pociąga za sobą nieporównywalnie poważniejsze skutki prawne, finansowe i społeczne niż naruszenie systemu obsługującego wyłącznie dane wewnętrzne organizacji.

Klasyfikacja typów danych

Metodologia ORION wyróżnia cztery typy przetwarzanych danych, uporządkowane rosnąco według wrażliwości prawnej i społecznej. Każdemu typowi przypisany jest mnożnik wagowy w_{data}, który modyfikuje wpływ obiektu na wynik podmiotu zgodnie z równaniem (7.17).

DRAFT

Tabela 6.8: Klasyfikacja typów danych w ORION i odpowiadające mnożniki wagowe

Typ danych	**Symbol**	w_{data}	**Podstawa prawna**	**Przykłady**
`BRAK`	T_0	1,0	—	Dane konfiguracyjne, logi techniczne bez PII
`OSOBOWE`	T_1	1,3	RODO art. 4 pkt 1	Imię, adres, adres e-mail, numer IP
`SZCZEGÓLNE`	T_2	1,6	RODO Art. 9 oraz Art. 10	Stan zdrowia, dane biometryczne, przekonania religijne, orientacja seksualna
`TAJEMNICA`	T_3	2,0	Ustawa sektorowa (bankowa, lekarska, adwokacka)	Tajemnica przedsiębiorstwa, tajemnica zawodowa, tajemnica sektorowa, tajemnica związana z działalnością organów i postępowaniami, informacje niejawne (ściśle tajne, tajne, zastrzeżone, poufne), informacje poufne w rozumieniu MAR 7, informacje objęte poufnością umowną, informacje chronione obowiązkiem pracowniczym

6.5.8 Atrybut: kraj pochodzenia

Atrybut ten określa kraj pochodzenia podmiotu w celu jednoznacznego ustalenia jego statusu prawnego, tj. czy jest to podmiot mający siedzibę na terenie Europejskiego Obszaru Gospodarczego (EOG), czy też kwalifikuje się on jako podmiot z kraju trzeciego w myśl obowiązujących przepisów prawa (w szczególności w kontekście regulacji dotyczących ochrony danych osobowych RODO oraz cyberbezpieczeństwa).

Wartość tego atrybutu ma kluczowe znaczenie dla logiki warunkowego uruchamiania sekcji pytań podczas procesu audytowego. W przypadku zidentyfikowania podmiotu pochodzącego z kraju spoza EOG, system automatycznie rozszerza zakres audytu o dodatkowe wymagania. Wynika to z podwyższonego ryzyka operacyjnego i prawnego (np. w obszarze transferu danych lub łańcucha dostaw). W konsekwencji na organizację audytującą nakładany jest obowiązek przeprowadzenia pogłębionej weryfikacji, obejmującej m.in. szczegółowe badanie mechanizmów zabezpieczeń, umów transferowych oraz analizę wpływu na ryzyko (np. TIA).

DRAFT

Obok kraju siedziby ustalany jest kraj podmiotu dominującego, czyli podmiotu sprawującego kontrolę kapitałową nad dostawcą lub poddostawcą ($kontrola(d)$). Spółka z siedzibą w EOG kontrolowana przez podmiot z państwa trzeciego może podlegać prawu tego państwa w zakresie dostępu do danych (np. US CLOUD Act), dlatego oba atrybuty są uwzględniane w warunku triggera TIA (równanie (7.3)).

Tabela 6.9: Dopuszczalne wartości pochodzenia przedsiębiorstw

Kod kraju	**Opis i zakres odpowiedzialności**
`KOD ISO`	Kod kraju pochodzenia, np. PL, DE, US

6.6 Plan ciągłości dzialania

Plan ciągłości działania jest procedurą wymaganą od podmiotów kluczowych i ważnych na gruncie ustawy o KSC[10] oraz od podmiotów finansowych na gruncie rozporządzenia DORA.[11]

Definicja 6.5 (Plan ciągłości działania (BCP))**.** *Zbiór udokumentowanych procedur, które określają działania, jakie podmiot musi podjąć w celu odzyskania zdolności do wykonywania operacji oraz zapewnienia ciągłości procesów krytycznych na akceptowalnym poziomie po wystąpieniu incydentu zakłócającego.*

Podstawą planu ciągłości działania jest określenie dwóch wskaźników odporności. Pierwszy, RTO (*Recovery Time Objective*) określa maksymalny dopuszczalny czas, przez jaki system może pozostawać niedostępny po wystąpieniu awarii, im niższy, tym wyższe wymagania wobec infrastruktury. Drugi, RPO (Recovery *Point Objective*) wyznacza maksymalną akceptowalną utratę danych, wyrażoną jako punkt w czasie, do którego dane muszą zostać odtworzone, ilustrując przykładem, RPO wynoszące 15 minut oznacza, że żadna transakcja starsza niż kwadrans nie może zostać bezpowrotnie utracona.

Plan musi przewidywać konkretne scenariusze postępowania na wypadek różnych klas awarii systemów IT, ataku ransomware czy niedostępności kluczowego personelu. Równolegle obowiązują procedury wykrywania, klasyfikacji i eskalacji incydentów, w tym raportowania do organów nadzorczych, takich jak KNF, w ściśle określonych ramach czasowych wynikających z obiwązującego prawa, a ich definicje szczegółowo określa DORA i KSC.

Niezbędne jest opracowanie polityki wytwarzania oraz przywracania kopii zapasowych (DRP). Kopie zapasowe muszą być fizycznie lub logicznie odizolowane od głównej infrastuktury produkcyjnej, co chroni jest przed zaszyfrowaniem w przypadku ataku ransomware. Plan odtwarzania precyzuje harmonogram tworzenia kopii, lokalizację ich przechowywania, odpowiedzialnych za proces oraz procedury testowego odtwarzania danych w kontrolowanych warunkach.

Bardzo ważnym elementem planu ciągłości działania jest strategia komunikacji na czas kryzysu, który określa, kto, kiedy i w jaki sposób informuje klientów, pracowników, kontrahentów oraz nadzór o wystąpieniu awarii i przewidywanym czasie jej usunięcia.

[10] *Ustawa z dnia 23 stycznia 2026 r. o zmianie ustawy o krajowym systemie cyberbezpieczeństwa oraz niektórych innych ustaw.*

[11] Parlament Europejski i Rada Unii Europejskiej, *Rozporządzenie (UE) 2022/2554 w sprawie operacyjnej odporności cyfrowej sektora finansowego (DORA).*

DRAFT

Zgodnie z wymogami DORA, instytucja finansowa nie może ograniczyć planowania ciągłości wyłącznie do własnych zasobów, obowiązkiem jest zapewnienie, że dostawcy usług chmurowych i IT również dysponują udokumentowanymi planami ciągłości i są w stanie dotrzymać uzgodnionych poziomów usług (*SLA*) w sytuacji kryzysowej. Wymóg ten powinien być wprost zawarty w umowach z dostawcami, wraz z prawem do audytu.

Plan ciągłości działania podlega obowiązkowym testom ich skuteczności, które obejmują symulacje cyberataków, przełączanie ruchu na ośrodek zapasowy oraz testy odtwarzania danych z kopii zapasowych. Wyniki każdego testu powinny skutkować aktualizacją dokumentacji.

Odpowiedzialność za zatwierdzenie i skuteczność planów ciągłości działania, spoczywa na zarządzie instytucji. Od strony technicznej plan musi eliminować Single Point of Failure (*SPOF*) poprzez zapewnienie redundantnych systemów, łączy komunikacyjnych i zasilania, tak aby awaria pojedynczego komponentu nie prowadziła do niedostępności całej usługi.

W metodologii ORION, plan ciągłości działania jest wymagany dla podmiotów określonych w KSC oraz DORA. Jego brak lub nieprawidłowe zdefiniowanie w organizacjach, gdzie jest on obowiązkowy wskazują binarnie na uchybienia w działaniu organizacji.

Tabela 6.10: Obowiązkowość BCP wg typu organizacji

Typ organizacji	**Obowiązkowe**
`FINANSOWY`	tak
`KLUCZOWY`	tak
`WAŻNY`	tak
`POZOSTAŁE`	nie

6.7 Plan wyjścia z usługi (Exit plan)

Plan wyjścia z usługi (ang. *Exit plan*)) to obowiązkowy element zarządzania dostawcami IT w banku, wymagany przez rozporządzenie DORA (art. 28 ust. 8[12]); w odniesieniu do podmiotów kluczowych podstawa w ustawie o KSC wymaga weryfikacji (zob. niżej).

Definicja 6.6 (Exit plan)**.** *Strategia wyjścia z usługi pozwalająca organizacji wyłączyć system, zakończyć współpracę z dotychczasowym dostawcą oraz ponownie uruchomić usługę u innego dostawcy przy zachowaniu ciągłości działania lub minimalizacji przestoju.*

Plan wyjścia stanowi pisemnie udokumentowaną procedurę umożliwiającą organizacji zakończenie współpracy z dostawcą ICT i przeniesienie usług do alternatywnego środowiska, bez przestoju operacyjnego i bez utraty danych. Definicja ma zagwarantować ciągłości działania, czyli zapewnić minimalny czas niedostępności usługi dla jej użytkowników. Równie istotna jest ochrona przed zjawiskiem *vendor lock-in*, czyli uzależnienia od jednego dostawcy

[12]Parlament Europejski i Rada Unii Europejskiej, *Rozporządzenie (UE) 2022/2554 w sprawie operacyjnej odporności cyfrowej sektora finansowego (DORA).*

DRAFT

Zgodnie z art. 28 ust. 8 DORA podmiot finansowy określa rozwiązania alternatywne i opracowuje plany przejściowe, umożliwiające bezpieczne i integralne przekazanie usług oraz danych dostawcy alternatywnemu lub ponowne włączenie ich do struktury wewnętrznej. Co istotne, umowa z dostawcą musi zawierać klauzulę zobowiązującą go do udostępnienia wszystkich danych w formacie umożliwiającym ich import do innego systemu

Dostawca ICT jest zobowiązany do świadczenia usług przez określony czas po wypowiedzeniu umowy, tak aby organizacja przeprowadziła migrację danych. Co istotne, wsparcie to nie może mieć charakteru pasywnego, dostawca ma obowiązek aktywnej pomocy technicznej przy przenoszeniu procesów, danych i konfiguracji do nowego środowiska. Tego rodzaju zobowiązania muszą być precyzyjnie zapisane w umowie, z określonymi terminami i zakresem odpowiedzialności.

Exit plan traci swoją wartość, jeśli nie jest regularnie weryfikowany. DORA wymaga, aby plany wyjścia były kompleksowe, udokumentowane, wystarczająco przetestowane i poddawane okresowym przeglądom (art. 28 ust. 8[13]). Całość procesu musi być zaplanowana tak, aby klient instytucji w ogóle nie odczuł zmiany dostawcy.

Ważna jest forma przygotowania dokumentacji. DORA, w art. 28 ust. 8,[14] wymaga odrębnie udokumentowanego planu wyjścia. W odniesieniu do podmiotów kluczowych ustawa o KSC[15] realizuje cele exit planu przede wszystkim poprzez wymagania dotyczące bezpieczeństwa łańcucha dostaw i postanowienia umowne z dostawcą.

W metodologii ORION sekcja exit plan jest aktywowana dla podmiotów `FINANSOWY` i `KLUCZOWY` w odniesieniu do systemów krytycznych i ważnych obsługiwanych przez co najmniej jednego dostawcę zewnętrznego (tabela 7.6); system utrzymywany wyłącznie siłami własnymi nie ma usługi, z której można by wyjść. Dla podmiotu `KLUCZOWY` pytania sekcji, mające zakres wyłącznie DORA, nie są obowiązkowe ani blokujące, dopóki nie zostanie wskazana ich podstawa w ustawie o KSC (równanie (7.12)). Podobnie jak plan ciągłości działania, brak lub nieprawidłowo zdefiniowany exit plan, gdy jest obowiązkowy, wskazuje binarnie na uchybienia w działaniu organizacji.

Tabela 6.11: Obowiązkowość exit planu wg typu organizacji

Typ organizacji	**Obowiązkowe**
`FINANSOWY`	tak
`KLUCZOWY`	sekcja aktywna; pytania zalecane (do weryfikacji KSC)
`WAŻNY`	nie
`POZOSTAŁE`	nie

DRAFT

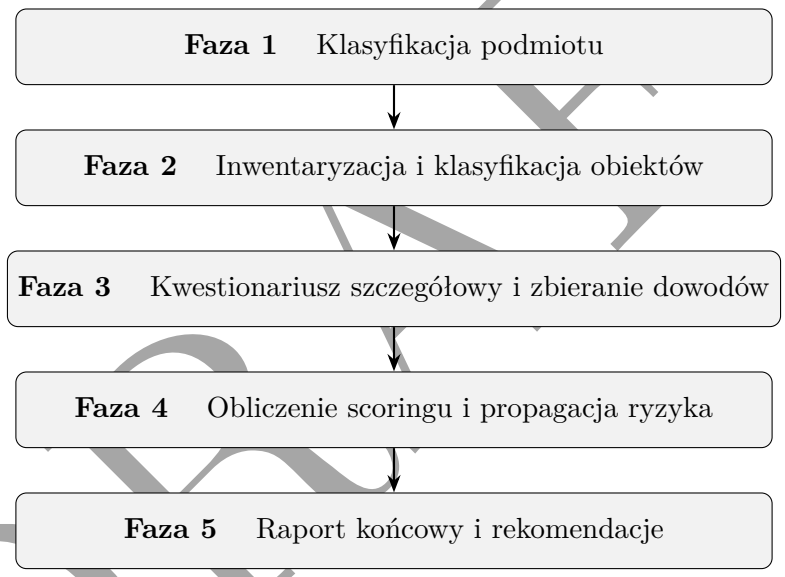
[13]Parlament Europejski i Rada Unii Europejskiej, *Rozporządzenie (UE) 2022/2554 w sprawie operacyjnej odporności cyfrowej sektora finansowego (DORA)*.

[14]Parlament Europejski i Rada Unii Europejskiej, *Rozporządzenie (UE) 2022/2554 w sprawie operacyjnej odporności cyfrowej sektora finansowego (DORA)*.

[15]*Ustawa z dnia 23 stycznia 2026 r. o zmianie ustawy o krajowym systemie cyberbezpieczeństwa oraz niektórych innych ustaw.*

7. Przeprowadzenie audytu ORION

Niniejszy rozdział opisuje pełny algorytm przeprowadzenia audytu zgodności systemów informatycznych w metodologii ORION. Audyt składa się z pięciu faz wykonywanych sekwencyjnie, w ściśle określonej kolejności: po zakończeniu jednej fazy audytor przechodzi do kolejnej, a każda faza produkuje dane wejściowe dla fazy następnej. Element iteracyjny występuje wyłącznie w fazie trzeciej: gdy identyfikacja poddostawców (sekcja 7.3.9) ujawni nowe podmioty w łańcuchu dostaw, graf ICT jest rozszerzany, a dla nowo dodanych wierzchołków ponawiane są kroki klasyfikacji z fazy drugiej i kwestionariusz z fazy trzeciej, aż do wyczerpania nowych wierzchołków. Wynik całości, czyli ocena zgodności podmiotu z aktualnym stanem regulacyjnym z punktu widzenia ICT, jest wynikiem wszystkich odpowiedzi udzielonych na każdym etapie. Schemat ogólny procesu przedstawia rysunek 7.1.



Rysunek 7.1: Pięć faz audytu ORION

7.1 Faza 1: Klasyfikacja podmiotu

Audyt rozpoczyna się od ustalenia tożsamości regulacyjnej audytowanego podmiotu. Wynik tej fazy determinuje, które zestawy pytań zostaną zaprezentowane w dalszych etapach, jakie wymogi mają charakter obligatoryjny, a jakie fakultatywne, oraz które pytania są blokujące. Faza pierwsza składa się z jednego kroku wykonywanego wyłącznie raz, przed przystąpieniem do analizy jakiegokolwiek obiektu i dotyczy globalnie całej organizacji.

7.1.1 Krok 1.1: Ustalenie reżimu regulacyjnego

Dla każdego kryterium poniżej każda z trzech perspektyw odpowiada `TAK` lub `NIE`. Kryterium przyjmuje wartość `TAK`, gdy co najmniej dwie z trzech perspektyw odpowiedziały `TAK` (konsensus w rozumieniu definicji 6.1).

DRAFT

Kryterium R1: Podleganie reżimowi regulacyjnemu

- **Perspektywa zgodności** (DPO / Radca prawny): Czy podmiot prowadzi działalność wymienioną w załączniku I lub II dyrektywy uKSC i spełnia kryteria wielkości określone w art. 2 tej dyrektywy albo należy do podmiotów finansowych wymienionych w art. 2 ust. 1 rozporządzenia DORA?
- **Perspektywa użytkownika** (Zarząd / Właściciel): Czy organizacja świadczy usługi finansowe, prowadzi infrastrukturę krytyczną lub przetwarza dane na zlecenie podmiotów regulowanych?
- **Perspektywa techniczna** (CTO / Architekt): Czy systemy IT organizacji były kiedykolwiek objęte obowiązkowym audytem regulacyjnym lub wymogiem zgłaszania incydentów do organu nadzorczego?

Kryterium R2: Podmiot sektora finansowego (DORA)

- **Perspektywa zgodności**: Czy podmiot należy do jednej z kategorii podmiotów finansowych wymienionych w art. 2 ust. 1 rozporządzenia DORA i nie korzysta z wyłączenia przewidzianego w art. 2 ust. 3?
- **Perspektywa użytkownika**: Czy organizacja prowadzi działalność na podstawie zezwolenia lub wpisu do rejestru organu nadzoru finansowego (np. KNF)?
- **Perspektywa techniczna**: Czy organizacja przekazuje do organu nadzoru finansowego sprawozdania lub zgłoszenia generowane z jej systemów ICT (np. raportowanie incydentów, rejestr informacji o umowach ICT)?

Kryterium R3: Podmiot kluczowy (uKSC / KSC)

- **Perspektywa zgodności**: Czy podmiot jest wskazany w załączniku nr 1 do uKSC i przewyższa wymogi dla średniego przedsiębiorstwa albo spełnia inne przesłanki uznania za podmiot kluczowy określone w art. 5 ust. 1 uKSC?
- **Perspektywa użytkownika**: Czy organizacja zatrudnia co najmniej 250 osób lub osiąga roczny obrót przekraczający 50 mln EUR i sumę bilansową przekraczającą 43 mln EUR, świadcząc usługi z sektora wymienionego w załączniku I?
- **Perspektywa techniczna**: Czy systemy organizacji bezpośrednio realizują usługę z sektora wymienionego w załączniku I (np. dystrybucję energii, usługi DNS, centrum danych, usługi zarządzane ICT)?

Kryterium R4: Podmiot ważny (uKSC / KSC)

- **Perspektywa zgodności**: Czy podmiot jest wskazany w załączniku nr 1 lub 2 do uKSC i spełnia przesłanki uznania za podmiot kluczowy lub ważny określone w art. 5 uKSC?
- **Perspektywa użytkownika**: Czy organizacja zatrudnia co najmniej 50 osób lub osiąga roczny obrót i sumę bilansową przekraczające 10 mln EUR, świadcząc usługi z sektora wymienionego w załączniku I lub II?

DRAFT

- **Perspektywa techniczna**: Czy systemy organizacji bezpośrednio realizują usługę z sektora wymienionego w załączniku I lub II (np. usługi pocztowe, gospodarkę odpadami, produkcję, platformę handlową)?

Klasa regulacyjna podmiotu $k(v_0)$ jest wyznaczana z kryteriów szczegółowych R2–R4 według reguły pierwszeństwa, w której kryteria są sprawdzane w podanej kolejności:

$$k(v_0) = \begin{cases} \texttt{FINANSOWY} & \text{jeśli } R2 = \texttt{TAK}, \\ \texttt{KLUCZOWY} & \text{jeśli } R2 = \texttt{NIE} \wedge R3 = \texttt{TAK}, \\ \texttt{WAŻNY} & \text{jeśli } R2 = R3 = \texttt{NIE} \wedge R4 = \texttt{TAK}, \\ \texttt{POZOSTAŁE} & \text{jeśli } R2 = R3 = R4 = \texttt{NIE}. \end{cases} \tag{7.1}$$

Kryterium R1 pełni funkcję kontrolną: pyta ogólnie o to samo, co kryteria R2–R4 szczegółowo. Jeżeli wartość R1 nie zgadza się z wynikiem kryteriów szczegółowych, tzn.

$$R1 \neq \big(R2 \vee R3 \vee R4\big),$$

klasyfikacja jest oznaczana flagą Rozbieżność i wymaga rozstrzygnięcia przez audytora przed przejściem do fazy drugiej. Sprzeczność może wystąpić w obu kierunkach: perspektywy mogą ogólnie zaprzeczyć podleganiu regulacjom (R1 = NIE), a jednocześnie potwierdzić, że podmiot należy np. do sektora finansowego (R2 = TAK); albo odwrotnie, potwierdzić podleganie regulacjom bez wskazania żadnej konkretnej kategorii. Do czasu rozstrzygnięcia stosuje się klasę wynikającą z kryteriów szczegółowych, która w pierwszym przypadku jest bardziej wymagająca. Pierwszeństwo kryterium R2 wynika z zasady *lex specialis*: w odniesieniu do podmiotów finansowych wymogi dotyczące zarządzania ryzykiem ICT i zgłaszania incydentów określa rozporządzenie DORA (art. 4 dyrektywy NIS2).

Zweryfikować podstawę: numeracja artykułów znowelizowanej ustawy o KSC określających podmioty kluczowe i ważne.

- od prawnika informacja: art. 5

Klasa regulacyjna określa obowiązkowość kluczowych elementów audytu, zbiór aktów prawnych $\mathcal{A}_{reg}(k)$ stosowanych do podmiotu (równanie (7.11)), a przez niego efektywną obligatoryjność i wagę pytań $\omega(q_j, k)$ (równanie (7.10)) oraz to, które pytania są blokujące (równanie (7.13)). Zestawienie przedstawia tabela 7.1.
Obowiązek BCP obejmuje zarówno podmioty kluczowe, jak i ważne, ponieważ art. 21 ust. 2 lit. c dyrektywy NIS2 nakłada te same środki zarządzania ryzykiem na obie kategorie. Sekcja TIA nie zależy od klasy podmiotu, lecz od ekspozycji danych na jurysdykcję państwa trzeciego, dlatego dla wszystkich klas jest warunkowana przez $\mathcal{C}_{TIA}(v)$ (równanie (7.3)), niezależnie od typu przetwarzanych danych (sekcja 7.3.9).

7.2 Faza 2: Inwentaryzacja i klasyfikacja obiektów

Celem fazy drugiej jest zbudowanie grafu ICT podmiotu, pełnego rejestru wszystkich obiektów podlegających audytowi wraz z ich atrybutami klasyfikacyjnymi. Graf ICT jest strukturą dynamiczną: jego wierzchołki są odkrywane iteracyjnie, a identyfikacja poddostawców opisana w sekcji 7.3.9 rozszerza graf o nowe obiekty w trakcie fazy trzeciej. Faza druga stanowi zatem pierwszą, wstępną wersję grafu, która ulega uzupełnieniu w toku audytu szczegółowego.

DRAFT

Tabela 7.1: Klasyfikacja regulacyjna podmiotu i jej wpływ na zakres audytu

Klasyfikacja	Podstawa	Akty $\mathcal{A}_{reg}(k)$	BCP	Exit plan	TIA (warunek)	Pytania obow. / blok.
`FINANSOWY`	DORA art. 2 ust. 1	DORA, RODO	Tak	Tak	$\mathcal{C}_{TIA}(v)$	57 / 25
`KLUCZOWY`	NIS2 art. 3 ust. 1 / KSC	NIS2, RODO	Tak	Tak*	$\mathcal{C}_{TIA}(v)$	45 / 17
`WAŻNY`	NIS2 art. 3 ust. 2 / KSC	NIS2, RODO	Tak	Nie	$\mathcal{C}_{TIA}(v)$	45 / 17
`POZOSTAŁE`	RODO / ogólne	RODO	Nie	Nie	$\mathcal{C}_{TIA}(v)$	14 / 5

Kolumna „Pytania obow. / blok." podaje liczbę pytań kwestionariusza o efektywnym statusie obowiązkowym i blokującym (równania (7.12) i (7.13)), niezależnie od tego, które sekcje zostaną aktywowane dla danego podmiotu.
* Sekcja jest aktywowana, lecz jej pytania, z wyjątkiem bezpiecznego usunięcia danych (zakres RODO), mają zakres wyłącznie DORA, więc dla podmiotu `KLUCZOWY` tracą status obowiązkowy i nie są blokujące. Zmiana tego stanu wymaga wskazania w kolumnie „Podstawa prawna" przepisu ustawy o KSC nakładającego obowiązek exit planu.

7.2.1 Krok 2.1: Inwentaryzacja systemów

Audytor przeprowadza inwentaryzację wszystkich systemów informatycznych eksploatowanych przez podmiot. Jako punkt wyjścia służą: rejestr systemów prowadzony przez dział IT, wykaz aplikacji z licencji oprogramowania (pobranych z systemów księgowych oraz archiwów licencji), rejestr umów z dostawcami ICT, wyniki poprzednich audytów lub testów penetracyjnych. Każdy zidentyfikowany system jest rejestrowany jako obiekt w grafie ICT i przypisany do właściciela biznesowego. Należy również przeskanować systemy informatyczne w celu zinwentaryzowania zainstalowanego oprogramowania, na rynku dostępne są do tego narzędzia typu *open source*.

Kluczowe w inwentaryzacji jest podejście wieloperspektywiczne: inwentaryzacja przeprowadzana wyłącznie przez dział IT często pomija systemy zakupione i utrzymywane bezpośrednio przez jednostki biznesowe (*shadow IT*), podczas gdy wywiad z właścicielami biznesowymi i prawnikami ujawnia dodatkowe systemy i usługi SaaS nieprzechodzące przez standardowy proces zakupów IT. Wynikiem operacji identyfikacji będzie lista obiektów typu `SYSTEM_INFORMATYCZNY`, która będzie dołączona do grafu ICT.

7.2.2 Krok 2.2: Identyfikacja bezpośrednich dostawców

Dla każdego zidentyfikowanego systemu audytor identyfikuje bezpośrednich dostawców ICT: podmioty zewnętrzne świadczące usługi hostingu, utrzymania, wsparcia lub integracji. Każdy dostawca jest rejestrowany jako odrębny obiekt typu `DOSTAWCA` w grafie ICT i połączony krawędzią skierowaną z systemem, który obsługuje. Dla każdego dostawcy ustalany jest kraj pochodzenia oraz kraj podmiotu sprawującego nad nim kontrolę kapita-

DRAFT

łową (sekcja 6.5.8). Oznaczmy przez V_{SYS} zbiór wierzchołków typu `SYSTEM_INFORMATYCZNY`, przez V_{DOST} zbiór wierzchołków typu `DOSTAWCA`, a przez $E_{svc} \subseteq V_{SYS} \times V_{DOST}$ zbiór krawędzi usługowych: $(u, v) \in E_{svc}$ wtedy i tylko wtedy, gdy system u jest obsługiwany przez dostawcę v. Na tym etapie nie są jeszcze identyfikowani poddostawcy; ich identyfikacja następuje w fazie trzeciej dla każdego dostawcy (sekcja 7.3.9).

7.2.3 Krok 2.3: Przypisanie atrybutów klasyfikacyjnych

Dla każdego obiektu zidentyfikowanego w kroku 7.2.1 audytor przeprowadza klasyfikację wstępną, ustalając wartości atrybutów: *dostępność*(v), *krytyczność*(v), *utrzymanie_chmura*(v), *typ_danych*(v).

Każdy atrybut jest wyznaczany metodą cross-validation opisaną w sekcji 6.4.6.

Reguła agregacji perspektyw. Każde kryterium ankiety atrybutu jest zadawane trzem perspektywom. O ile opis ankiety nie stanowi inaczej, kryterium przyjmuje wartość `TAK`, gdy co najmniej dwie z trzech perspektyw odpowiedziały `TAK` (tak jak w kroku 7.1.1), a wynik ankiety jest wyznaczany na podstawie liczby kryteriów o wartości `TAK`. Wyjątek stanowią ankiety dostępności, typu danych i utrzymania w chmurze, w których niedoszacowanie ryzyka skutkowałoby pominięciem wymogów (sekcji pytań lub TIA). Zgodnie z zasadą ostrożności o wartości kryterium decyduje w nich jedna odpowiedź wskazująca wyższe ryzyko: w ankietach dostępności i typu danych oraz w kryteriach L1–L3 wystarcza jedna odpowiedź `TAK`, a w kryteriach L4–L6, w których `TAK` oznacza pozostanie w EOG, wystarcza jedna odpowiedź `NIE`. Brak konsensusu jest oznaczany flagą Rozbieżność do wyjaśnienia przez audytora. W ankiecie krytyczności stosowana jest reguła większości, ponieważ zawyżanie krytyczności ogranicza zasada dominacji operacyjnej.

7.2.4 Ankieta klasyfikacji atrybutu dostępności

Poniższe kryteria służą do określenia, czy system jest dostępny wyłącznie wewnątrz organizacji, czy także dla podmiotów lub sieci zewnętrznych. Dla każdego kryterium każda perspektywa odpowiada `TAK` lub `NIE`. Wartość kryterium ustala się według zasady ostrożności (jedna odpowiedź `TAK` wystarcza), a klasyfikacja jest wyznaczana na podstawie liczby kryteriów D1–D4 o wartości `TAK`.

Kryterium D1: Dostęp spoza sieci organizacji

- **Perspektywa zgodności:** Czy umowa lub regulamin systemu przewiduje dostęp dla podmiotów spoza struktury prawnej organizacji?
- **Perspektywa użytkownika:** Czy z systemu korzystają osoby lub firmy spoza naszej organizacji (klienci, partnerzy, dostawcy)?
- **Perspektywa techniczna:** Czy system jest dostępny spoza sieci LAN/VPN organizacji (publiczny IP, internet)?

Kryterium D2: Użytkownicy zewnętrzni

- **Perspektywa zgodności:** Czy system wymaga odrębnych umów powierzenia danych lub regulaminów dla jego użytkowników?

DRAFT

- **Perspektywa użytkownika:** Czy system służy do komunikacji lub wymiany informacji z klientami bądź kontrahentami?
- **Perspektywa techniczna:** Czy system posiada konta lub sesje dla użytkowników spoza domeny organizacji?

Kryterium D3: Integracje zewnętrzne

- **Perspektywa zgodności:** Czy system przesyła dane do podmiotów trzecich na podstawie umów lub przepisów prawa?
- **Perspektywa użytkownika:** Czy system automatycznie wymienia dane z zewnętrznymi dostawcami, bankami lub platformami?
- **Perspektywa techniczna:** Czy system wywołuje zewnętrzne API lub odbiera dane z systemów spoza infrastruktury organizacji?

Kryterium D4: Publiczny adres lub domena

- **Perspektywa zgodności:** Czy system jest zarejestrowany lub dostępny pod adresem publicznie widocznym w internecie?
- **Perspektywa użytkownika:** Czy system ma adres www lub można do niego dotrzeć bez łączenia się z siecią wewnętrzną firmy?
- **Perspektywa techniczna:** Czy system posiada publiczny rekord DNS lub publiczny adres IP?

Wynik końcowy:

Tabela 7.2: Wynik klasyfikacji dostępności

Liczba kryteriów D1–D4 o wartości `TAK`	Klasyfikacja
Zero	System **prywatny**
Co najmniej jedno	System **publiczny**

Atrybut *dostępność*(v) nie aktywuje żadnej sekcji pytań. Wpływa na wynik podmiotu przez mnożnik $w_{dost}(v)$ (tabela 6.5): $w_{dost} = 1{,}0$ dla systemu prywatnego i $w_{dost} = 1{,}8$ dla systemu publicznego. Mnożnik ten jest składnikiem łącznej wagi obiektu $w_{total}(v)$ w równaniu (7.17). Wartość 1,8 jest niższa od maksymalnego mnożnika krytyczności ($w_{krit} = 2{,}0$), dzięki czemu publiczny system standardowy nie przeważa nad prywatnym systemem krytycznym.

DRAFT

7.2.5 Ankieta klasyfikacja atrybutu poziomu krytyczności

Poniższe kryteria służą do określenia, z jakim poziomem krytyczności operuje system. Dla każdego kryterium każda perspektywa odpowiada `TAK` lub `NIE`; kryterium przyjmuje wartość `TAK` przy co najmniej dwóch odpowiedziach twierdzących. Klasyfikacja jest wyznaczana na podstawie liczby kryteriów K1–K6 o wartości `TAK` (od 0 do 6).

Kryterium K1: Wpływ finansowy i operacyjny niedostępności systemu

- **Perspektywa zgodności:** Czy niedostępność systemu może powodować roszczenia kontraktowe lub kary umowne?
- **Perspektywa użytkownika:** Czy kilkugodzinny przestój zatrzymuje sprzedaż, obsługę klienta lub kluczowy proces biznesowy?
- **Perspektywa techniczna:** Czy system ma zdefiniowane RTO poniżej 4 godzin lub SLA z karami za niedostępność?

Kryterium K2: Przetwarzanie danych osobowych, w tym szczególnych kategorii danych osobowych

- **Perspektywa zgodności:** Czy system przetwarza dane osobowe, w tym szczególne kategorie danych osobowych w rozumieniu art. 9 RODO?
- **Perspektywa użytkownika:** Czy w systemie przechowywane są dane klientów, pracowników lub inne informacje poufne?
- **Perspektywa techniczna:** Czy baza danych zawiera pola z danymi PII (np. imię, PESEL, adres, numer konta)?

Kryterium K3: Podleganie regulacjom zewnętrznym

- **Perspektywa zgodności:** Czy system podlega regulacjom sektorowym (np. DORA, NIS2, ustawa KSC)?
- **Perspektywa użytkownika:** Czy system był przedmiotem pytań audytorów lub regulatorów podczas kontroli?
- **Perspektywa techniczna:** Czy system znajduje się w wykazie systemów objętych audytem zgodności lub testami penetracyjnymi?

Kryterium K4: Zależności innych systemów produkcyjnych

- **Perspektywa zgodności:** Czy awaria systemu może uniemożliwić realizację zobowiązań wobec klientów lub partnerów?
- **Perspektywa użytkownika:** Czy inne działy lub systemy firmy nie mogą działać, gdy system jest niedostępny?
- **Perspektywa techniczna:** Czy inne systemy produkcyjne mają bezpośrednie zależności od tego systemu?

Kryterium K5: Ryzyko wycieku lub utraty danych

DRAFT

- **Perspektywa zgodności:** Czy wyciek danych z systemu wymagałby zgłoszenia incydentu do UODO lub regulatora?
- **Perspektywa użytkownika:** Czy ujawnienie danych mogłoby zaszkodzić reputacji firmy lub spowodować utratę klientów?
- **Perspektywa techniczna:** Czy system przechowuje dane bez szyfrowania lub bez możliwości pseudonimizacji?

Kryterium K6: Obsługa procesów podstawowej działalności (core business)

- **Perspektywa zgodności:** Czy system jest wskazany w dokumentacji BCM/BCP jako niezbędny do kontynuacji działalności?
- **Perspektywa użytkownika:** Czy system obsługuje główny produkt lub usługę firmy?
- **Perspektywa techniczna:** Czy system jest sklasyfikowany jako produkcyjny tier-1 w architekturze IT?

W celu uniknięcia zjawiska sztucznego zawyżania krytyczności (gdzie niemal każdy system przetwarzający dane osobowe stawał się krytyczny), w metodologii ORION zastosowano zasadę dominacji operacyjnej. System nie może zostać uznany za krytyczny tylko na podstawie faktu, że podlega regulacjom (K3), przetwarza dane (K2), niesie ryzyko wycieku (K5) lub ma zależności (K4), o ile jego niedostępność nie paraliżuje podstawowej działalności organizacji (K1 lub K6). Warunek ten ma realne znaczenie przy czterech kryteriach o wartości `TAK`: system spełniający wyłącznie K2–K5 pozostaje systemem ważnym.

Tabela 7.3: Wynik klasyfikacji krytyczności na podstawie liczby kryteriów o wartości `TAK`

Liczba kryteriów TAK	**Klasyfikacja**	**Warunek dodatkowy**
0–2	System **standardowy**	—
3	System **ważny**	—
4–6	System **krytyczny**	K1 = TAK lub K6 = TAK (zasada dominacji operacyjnej)
4	System **ważny**	K1 = NIE i K6 = NIE (wyłącznie K2–K5)

7.2.6 Ankieta klasyfikacji atrybutu utrzymania w chmurze

Poniższe kryteria służą do określenia, czy system jest rozwiązaniem on-premise czy chmurowym, a w przypadku chmury, w jakiej jurysdykcji jest utrzymywany. Ankieta składa się z dwóch kroków o jednolitej polaryzacji w obrębie każdego z nich. Dla każdego kryterium

DRAFT

każda perspektywa odpowiada `TAK` lub `NIE`. Zgodnie z zasadą ostrożności kryterium L1–L3 przyjmuje wartość `TAK` (utrzymanie zewnętrzne) przy co najmniej jednej odpowiedzi twierdzącej, a kryterium L4–L6 wartość `TAK` (pozostanie w EOG) wyłącznie przy trzech odpowiedziach twierdzących.

Krok (a): model utrzymania. W kryteriach L1–L3 odpowiedź `TAK` oznacza utrzymanie systemu przez podmiot zewnętrzny.

Kryterium L1: Model wdrożenia infrastruktury

- **Perspektywa zgodności:** Czy umowa lub dokumentacja systemu wskazuje na dostawcę chmury publicznej, prywatnej lub hybrydowej (np. AWS, Azure, GCP, OVH)?
- **Perspektywa użytkownika:** Czy system działa w internecie lub w środowisku zarządzanym przez zewnętrznego dostawcę, a nie na serwerach w siedzibie firmy?
- **Perspektywa techniczna:** Czy serwery lub maszyny wirtualne systemu są uruchomione poza fizycznym data center organizacji?

Kryterium L2: Odpowiedzialność operacyjna

- **Perspektywa zgodności:** Czy odpowiedzialność za dostępność i utrzymanie infrastruktury systemu spoczywa na zewnętrznym dostawcy zgodnie z umową SLA?
- **Perspektywa użytkownika:** Czy w przypadku awarii serwera zgłaszamy problem do zewnętrznej firmy, a nie do naszego działu IT?
- **Perspektywa techniczna:** Czy organizacja nie ma bezpośredniego dostępu administracyjnego do warstwy sprzętowej lub hiperwizora systemu?

Kryterium L3: Umowa outsourcingowa lub chmurowa

- **Perspektywa zgodności:** Czy z dostawcą systemu lub infrastruktury podpisano umowę outsourcingu IT, umowę SaaS/PaaS/IaaS lub umowę powierzenia przetwarzania danych?
- **Perspektywa użytkownika:** Czy dostęp do systemu lub jego funkcji jest uzależniony od aktywnej subskrypcji lub kontraktu z zewnętrznym dostawcą?
- **Perspektywa techniczna:** Czy system jest wdrożony w modelu usługowym (SaaS, PaaS lub IaaS), w którym zasoby obliczeniowe są rozliczane na podstawie zużycia lub abonamentu?

Krok (b): jurysdykcja. W kryteriach L4–L6 odpowiedź `TAK` oznacza, że dany element pozostaje w EOG. Kryteria L4 i L5 są zadawane wyłącznie systemom zakwalifikowanym w kroku (a) jako chmurowe. Kryterium L6 jest zadawane wszystkim systemom, także `ON_PREMISE`, ponieważ zdalne wsparcie techniczne świadczone spoza EOG oznacza dostęp do danych z państwa trzeciego niezależnie od miejsca ich przechowywania. Każde z kryteriów odpowiada jednemu składnikowi warunku $\mathcal{C}_{TIA}(v)$ (równanie (7.3)): L4 — lokalizacji danych, L5 — pochodzeniu podmiotu, L6 — wsparciu systemu.

Kryterium L4: Lokalizacja danych

DRAFT

- **Perspektywa zgodności:** Czy umowa z dostawcą lub jej załącznik wskazuje, że dane produkcyjne i kopie zapasowe systemu są przechowywane wyłącznie w państwach EOG?
- **Perspektywa użytkownika:** Czy w ustawieniach, regulaminie lub dokumentacji systemu, z których korzystasz, wskazano region przechowywania danych położony w państwie EOG?
- **Perspektywa techniczna:** Czy konfiguracja usługi (region, lokalizacja magazynów danych i kopii zapasowych) wskazuje wyłącznie centra danych położone w EOG?

Kryterium L5: Jurysdykcja podmiotu hostującego

- **Perspektywa zgodności:** Czy dostawca oraz wszyscy jego poddostawcy uczestniczący w przetwarzaniu danych mają siedzibę w EOG i nie są kontrolowani przez podmioty podlegające jurysdykcji państw trzecich przewidującej dostęp do danych (np. US CLOUD Act, FISA Section 702)?
- **Perspektywa użytkownika:** Czy użytkownik może potwierdzić, że wszystkie usługi i okna logowania systemu należą do podmiotów zarejestrowanych i działających wyłącznie na podstawie prawa europejskiego?
- **Perspektywa techniczna:** Czy certyfikaty SSL/TLS, adresy IP, rekordy DNS oraz dane WHOIS infrastruktury systemu wskazują wyłącznie na podmioty zarejestrowane w EOG, a żaden z komponentów technicznych (CDN, load balancer, usługa uwierzytelniania) nie pochodzi od dostawcy spoza EOG lub podlegającego obcemu prawu dostępu do danych?

Kryterium L6: Wsparcie techniczne

- **Perspektywa zgodności:** Czy umowa z dostawcą systemu jednoznacznie określa, że wsparcie techniczne (helpdesk, administracja, dostęp serwisowy) jest świadczone wyłącznie przez osoby lub podmioty mające siedzibę w EOG?
- **Perspektywa użytkownika:** Czy użytkownik może potwierdzić, że wszystkie punkty kontaktowe wsparcia technicznego (w tym adresy e-mail, domeny helpdesk, numery telefonów oraz profile agentów w systemie zgłoszeń) wskazują na podmioty zarejestrowane w EOG (europejskie domeny, kierunkowe numery telefonów, europejskie dane rejestrowe dostawcy)?
- **Perspektywa techniczna:** Czy narzędzia zdalnego dostępu serwisowego (np. VPN, RDP, sesje administracyjne) są skonfigurowane w sposób uniemożliwiający połączenie spoza EOG, a logi dostępu potwierdzają, że żadna sesja wsparcia technicznego nie była inicjowana z adresów IP spoza Europejskiego Obszaru Gospodarczego?

Wynik końcowy:
Niech $R(v)$ oznacza zbiór dostawców i poddostawców osiągalnych w grafie ICT z obiektu v (dostawcy bezpośredni, ich poddostawcy i dalsze ogniwa łańcucha), a

$$obcy(w) \iff kraj(w) \notin \texttt{EOG} \ \vee \ kontrola(w) \notin \texttt{EOG}$$

DRAFT

Tabela 7.4: Wynik klasyfikacji utrzymania w chmurze

Warunek	Klasyfikacja
Krok (a): wszystkie kryteria L1–L3 = `NIE`	`ON_PREMISE`
Krok (a): co najmniej jedno kryterium L1–L3 = `TAK` Krok (b): L4 = L5 = L6 = `TAK` oraz żaden dostawca ani poddostawca w łańcuchu systemu nie pochodzi spoza EOG ani nie jest kontrolowany z państwa trzeciego	`CHMURA_EOG`
Krok (a): co najmniej jedno kryterium L1–L3 = `TAK` Krok (b): co najmniej jedno kryterium L4–L6 = `NIE` lub dostawca bądź poddostawca w łańcuchu systemu spoza EOG lub kontrolowany z państwa trzeciego	`CHMURA_K3`

oznacza, że dostawca lub poddostawca w ma siedzibę poza EOG albo jest kontrolowany kapitałowo przez podmiot z państwa trzeciego (sekcja 6.5.8). Dla systemu v składniki warunku (7.3) są wyznaczane z kroku (b) oraz z atrybutów podmiotów w jego łańcuchu dostaw:

$$\begin{aligned} \textit{lokalizacja danych}(v) \neq \texttt{EOG} &\iff L4 = \texttt{NIE}, \\ \textit{pochodzenie podmiotu}(v) \neq \texttt{EOG} &\iff L5 = \texttt{NIE} \vee \exists\, w \in R(v) : \textit{obcy}(w), \\ \textit{wsparcie systemu}(v) \neq \texttt{EOG} &\iff L6 = \texttt{NIE}. \end{aligned}$$

Pochodzenie i kontrola kapitałowa każdego ogniwa łańcucha przenoszą się więc na obsługiwany system: system utrzymywany przez dostawcę z EOG, który korzysta z poddostawcy spoza EOG lub jest kontrolowany z państwa trzeciego, spełnia warunek $\mathcal{C}_{TIA}$, nawet jeśli dane są przechowywane w EOG. Ponieważ poddostawcy są identyfikowani w fazie trzeciej, warunek $\mathcal{C}_{TIA}$ jest wyznaczany ponownie po każdym rozszerzeniu grafu. Dla systemu `ON_PREMISE` kryteria L4 i L5 nie są zadawane, a lokalizacją danych jest siedziba organizacji; warunek $\mathcal{C}_{TIA}$ może zostać spełniony przez kryterium L6 lub przez pochodzenie albo kontrolę kapitałową dowolnego ogniwa łańcucha $R(v)$. Dla systemów chmurowych zachodzi $\textit{utrzymanie_chmura}(v) = \texttt{CHMURA_K3} \iff \mathcal{C}_{TIA}(v) = \texttt{TRUE}$, a klasa `CHMURA_K3` jest szczególnym przypadkiem spełnienia warunku $\mathcal{C}_{TIA}$.

7.2.7 Ankieta klasyfikacji typu danych

Poniższe kryteria służą do określenia, z jakim typem danych operuje system. Dla każdego kryterium każda perspektywa odpowiada `TAK` lub `NIE`; zgodnie z zasadą ostrożności kryterium przyjmuje wartość `TAK` przy co najmniej jednej odpowiedzi twierdzącej. Wynikiem ankiety jest zbiór spełnionych kategorii $D(v) \subseteq \{W, O, T\}$, a na jego podstawie wyznaczany jest typ danych obiektu.

Kryterium W: Szczególne kategorie danych osobowych

DRAFT

- **Perspektywa zgodności:** Czy system przetwarza szczególne kategorie danych osobowych w rozumieniu art. 9 RODO (np. dane dotyczące zdrowia, przekonań religijnych, orientacji seksualnej, przynależności związkowej) lub dane dotyczące wyroków skazujących w rozumieniu art. 10 RODO?
- **Perspektywa użytkownika:** Czy system zawiera dokumentację medyczną, orzeczenia, dane HR o niepełnosprawności lub inne informacje uznawane za szczególnie chronione?
- **Perspektywa techniczna:** Czy baza danych zawiera pola klasyfikowane jako szczególne kategorie danych osobowych (np. diagnoza, orzeczenie, wyznanie, dane biometryczne)?

Kryterium O: Dane osobowe (zwykłe)

- **Perspektywa zgodności:** Czy system przetwarza dane osobowe w rozumieniu art. 4 pkt 1 RODO, pozwalające na identyfikację osoby fizycznej (np. imię i nazwisko, PESEL, adres e-mail, numer konta)?
- **Perspektywa użytkownika:** Czy w systemie przechowywane są dane klientów, pracowników lub kontrahentów w jakiejkolwiek formie?
- **Perspektywa techniczna:** Czy baza danych zawiera pola, takie jak imię, adres, identyfikator użytkownika, adres IP lub dane logowania?

Kryterium T: Tajemnice prawnie chronione

- **Perspektywa zgodności:** Czy system przetwarza informacje objęte tajemnicą zawodową, handlową, bankową, skarbową, adwokacką lub inną tajemnicą chronioną przepisami prawa?
- **Perspektywa użytkownika:** Czy ujawnienie danych z systemu mogłoby naruszyć obowiązki zachowania poufności wynikające z umów lub przepisów prawa (np. NDA, tajemnica przedsiębiorstwa)?
- **Perspektywa techniczna:** Czy system posiada oznaczenie klauzulą poufności lub jest objęty restrykcjami dostępu wynikającymi z wymogów regulacyjnych lub umownych?

DRAFT

Tabela 7.5: Wynik klasyfikacji typu danych na podstawie zbioru spełnionych kategorii $D(v)$

Warunek	**Typ danych**	**Reżim ochrony**
$T \in D(v)$	`TAJEMNICA`	przepisy sektorowe, NDA
$W \in D(v)$, $T \notin D(v)$	`SZCZEGÓLNE`	art. 9 i 10 RODO, DPIA wymagane
$O \in D(v)$, $W, T \notin D(v)$	`OSOBOWE`	RODO, zgłoszenie do UODO
$D(v) = \emptyset$	`BRAK`	brak szczególnych wymogów

Uwaga: Klasyfikacja ma charakter kaskadowy. Jeśli system spełnia kilka kryteriów jednocześnie, *typ_danych*(v) przyjmuje kategorię o najwyższym mnożniku w_{data} zgodnie z tabelą 6.8 (`TAJEMNICA` > `SZCZEGÓLNE` > `OSOBOWE` > `BRAK`). Pełny zbiór $D(v)$ jest jednak zachowywany, ponieważ decyduje o aktywacji sekcji `DANE_SZCZEGÓLNE`: system z tajemnicą bankową i danymi klientów ma typ `TAJEMNICA`, lecz nadal przetwarza dane osobowe w rozumieniu RODO.

7.3 Faza 3: Kwestionariusz szczegółowy i zbieranie dowodów

Na podstawie atrybutów obiektów i wartości im przypisanych w fazie drugiej system ORION generuje dla każdego obiektu indywidualny kwestionariusz szczegółowy, zestaw pytań audytowych pogrupowanych w sekcje tematyczne, aktywowane warunkowo w zależności od wartości atrybutów. Żaden obiekt nie jest pytany o aspekty, które są dla niego nieistotne z powodów technicznych lub regulacyjnych.

7.3.1 Warunkowe aktywowanie sekcji pytań

Zestaw aktywnych sekcji pytań dla obiektu v jest wyznaczany przez funkcję:

$$\mathcal{S}(v) = \bigcup_{\substack{\tau \in \mathcal{T} \\ \text{type}(v) = \tau}} \mathcal{S}_\tau \cup \bigcup_{\substack{k \in K \\ \Phi_k(v)}} \mathcal{S}_k \tag{7.2}$$

gdzie:

- $\mathcal{T} = \{$`PODMIOT`, `SYSTEM_INFORMATYCZNY`, `DOSTAWCA`, `PODDOSTAWCA`$\}$ jest zbiorem typów obiektów w grafie ICT,
- $\mathcal{S}_\tau$ jest zbiorem sekcji aktywowanych wyłącznie dla obiektów danego typu τ: $\mathcal{S}_{\texttt{PODMIOT}} = \{$`ORGANIZACJA`, `BEZPIECZENSTWO_TECH`, `BEZPIECZENSTWO_FIZYCZNE`$\}$, $\mathcal{S}_{\texttt{SYSTEM_INFORMATYCZNY}} = \{$`APLIKACJA`$\}$, $\mathcal{S}_{\texttt{DOSTAWCA}} = \mathcal{S}_{\texttt{PODDOSTAWCA}} = \{$`DOSTAWCY`$\}$; poddostawca jest oceniany tak samo jak dostawca, a różni się od niego wyłącznie głębokością w grafie,

DRAFT

- K jest zbiorem indeksów wszystkich sekcji aktywowanych warunkowo,
- $\mathcal{S}_k$ jest k-tą sekcją aktywowaną warunkowo na podstawie atrybutów obiektu,
- $\Phi_k(v)$ jest warunkiem logicznym aktywacji sekcji $\mathcal{S}_k$, który może zależeć od typu obiektu type(v), od wektora atrybutów $\mathcal{A}(v)$ (np. klasyfikacji utrzymania w chmurze, typu danych, krytyczności) oraz od klasy regulacyjnej podmiotu $k(v_0)$ (tabela 7.6). Dla podmiotu-korzenia v_0 wektor $\mathcal{A}(v_0)$ obejmuje klasę regulacyjną $k(v_0)$ oraz atrybuty zagregowane z grafu ICT (np. istnienie systemu przetwarzającego dane osobowe lub dostawcy albo poddostawcy, od którego zależy co najmniej $n^*_{KV} = 3$ systemów; równanie (7.20)).

Pierwszy składnik sumy pokrywa sekcje aktywowane wyłącznie przez *typ* obiektu i jest niezależny od jego atrybutów. Drugi składnik pokrywa sekcje aktywowane warunkowo: przez *atrybuty* obiektu, w połączeniu z jego typem lub klasą regulacyjną podmiotu. Oba zbiory mogą być rozłączne lub przecinać się, przy czym wynikowy zbiór aktywnych sekcji $\mathcal{S}(v)$ jest ich sumą teoriomnogościową.

Przykład. Dla obiektu v z type$(v) =$ `SYSTEM_INFORMATYCZNY` i atrybutem *utrzymanie_chmura*$(v) =$ `CHMURA_K3` pierwszy składnik wzoru (7.2) daje $\mathcal{S}_{\texttt{SYSTEM_INFORMATYCZNY}}$. Drugi składnik dodaje $\mathcal{S}_{\texttt{CHMURA}}$, ponieważ warunek $\Phi_{\texttt{CHMURA}}$ jest spełniony, oraz $\mathcal{S}_{\texttt{TIA}}$, ponieważ klasa `CHMURA_K3` implikuje $\mathcal{C}_{TIA}(v) =$ `TRUE`. Wynikowy zbiór aktywnych sekcji to $\mathcal{S}(v) = \mathcal{S}_{\texttt{SYSTEM_INFORMATYCZNY}} \cup \mathcal{S}_{\texttt{CHMURA}} \cup \mathcal{S}_{\texttt{TIA}}$, uzupełniony o sekcje `EXIT_PLAN` i `PLAN_CIAGLOSCI_DZIALANIA`, jeżeli spełnione są ich warunki (tabela 7.6).

Pytania zostały podzielone na sekcje tematyczne, a w każdym pytaniu wyodrębniono trzy perspektywy opisane w sekcji 6.5.1. Każda pozycja odnosi się do konkretnego obszaru zagadnień, zawiera podstawę prawną, zakres regulacyjny, definicję istotności oraz oznaczenie (flagę binarną) pytania blokującego.

Zakres regulacyjny pytania. Zakres regulacyjny zakres$(q_j) \subseteq \{\texttt{DORA}, \texttt{NIS2}, \texttt{RODO}\}$ wskazuje akty prawne, z których wynika wymaganie; przepisy ustawy o KSC są traktowane łącznie z NIS2, którą implementują. Zakres wyznacza się z kolumny „Podstawa prawna", pomijając źródła niebędące aktami prawa powszechnie obowiązującego (normy ISO, wytyczne EBA, komunikaty UKNF). Pytanie bez podstawy w żadnym z tych aktów oznaczane jest jako dobra praktyka. W wykazie pytań zakres przedstawiono znacznikami: akt, z którego wynika wymaganie, wyróżniono ramką (**DORA**), a akty nieobjęte zakresem zapisano szarym tekstem (NIS2). Zakres decyduje o efektywnej obligatoryjności pytania dla podmiotu danej klasy (równanie (7.12)).

7.3.2 Zasady konstrukcji pytań

Cross-validation (sekcja 6.4.6) ma wartość poznawczą tylko wtedy, gdy trzy perspektywy oceniają ten sam stan faktyczny, każda przy użyciu innego, niezależnego źródła wiedzy. Rozbieżność odpowiedzi może być interpretowana jako sygnał audytowy (tabela 6.3) wyłącznie wtedy, gdy nie wynika z konstrukcji pytania: z różnej polaryzacji, z różnych obiektów audytu albo z pytania o wiedzę zamiast o stan. Dlatego każde pytanie audytowe ORION podlega następującym zasadom.

Model odpowiedzi. Perspektywa π_i udziela na pytanie q_j jednej z odpowiedzi ze zbioru {`TAK`, `NIE`, `N/D`}. Odpowiedź `N/D` (nie dotyczy) oznacza, że wymaganie nie ma zastosowania do obiektu, np. pytanie o szyfrowanie TLS dla systemu bez interfejsu sieciowego.

DRAFT

Nie jest to deklaracja braku wiedzy. Zgodnie z uzasadnieniem przedstawionym w sekcji 6.4.1 metodologia nie przewiduje odpowiedzi `NIE WIEM`: respondent, który nie zna stanu faktycznego, ma obowiązek go ustalić przed udzieleniem odpowiedzi. Brak odpowiedzi w terminie jest traktowany jak odpowiedź `NIE` ($a_{ij} = 0$, $d_{ij} = 0$). Odpowiedź `N/D` wymaga pisemnego uzasadnienia i akceptacji audytora; w przypadku pytania blokującego dodatkowo dowodu co najmniej średniej jakości ($d \geq 0{,}7$). Odpowiedź `N/D` niespełniająca tych warunków jest traktowana jak `NIE`. Sposób uwzględnienia `N/D` w scoringu określa sekcja 7.4.1.

Zasady konstrukcji.

(Z1) *Binarność i jednolita polaryzacja.* Na pytanie można odpowiedzieć `TAK` albo `NIE`, a odpowiedź `TAK` zawsze oznacza stan zgodny z wymaganiem. Odpowiedź oczekiwana wynosi więc `TAK` dla wszystkich pytań kwestionariusza szczegółowego.

(Z2) *Jedna kwestia.* Jedno pytanie dotyczy jednej weryfikowalnej kwestii. Niedopuszczalne są pytania alternatywne („X — czy Y?") oraz pytania podwójne, w których `TAK` wymagałoby spełnienia dwóch niezależnych warunków, chyba że warunki te stanowią łącznie jedno wymaganie prawne. Dopuszczalne jest natomiast wskazanie alternatywnych sposobów potwierdzenia tej samej kwestii (np. „w aplikacji albo przez dział IT") oraz przykładów rozwiązań poprzedzonych skrótem „np.".

(Z3) *Wspólny obiekt.* Wszystkie trzy perspektywy dotyczą tego samego obiektu audytu: podmiotu albo konkretnego systemu, albo konkretnego dostawcy.

(Z4) *Perspektywa zgodności* weryfikuje istnienie dokumentu, zapisu umownego lub decyzji organu zarządzającego.

(Z5) *Perspektywa techniczna* weryfikuje konfigurację lub artefakt, który można sprawdzić technicznie (ustawienie, log, wynik skanu, raport z testu), a nie treść umów.

(Z6) *Perspektywa użytkownika* weryfikuje to, co respondent obserwuje w codziennej pracy, albo to, czy wie, gdzie coś się znajduje i kto za to odpowiada. Nie pyta o znajomość przepisów („Czy wiesz, że…"), ponieważ takie pytanie mierzy wiedzę respondenta, a nie stan organizacji.

(Z7) *Niezależność od zdarzeń.* Odpowiedź nie może zależeć od zdarzenia, które mogło nie wystąpić (np. „czy po ostatnim incydencie…"). Pytanie dotyczy istnienia mechanizmu, a nie jego dotychczasowego użycia. Dopuszczalne jest pytanie o zdarzenie, które zgodnie z wymaganiem musi nastąpić w określonym czasie (np. coroczny test planu ciągłości działania lub szkolenie), ponieważ jego brak jest niezgodnością, a nie przypadkiem.

(Z8) *Neutralność technologiczna i zakres pokrycia.* Pytanie weryfikuje osiągnięcie celu (np. rejestrowanie, ochronę i dostępność logów, wykrywanie zdarzeń bezpieczeństwa), a nie posiadanie konkretnego narzędzia; nazwy rozwiązań (SIEM, WORM, EDR, SOC) są wyłącznie przykładami. Organizacja bez własnego zespołu monitorowania może spełnić wymaganie przez usługę zewnętrzną lub rozwiązanie równoważne. Pytania o monitorowanie (zdarzeń bezpieczeństwa, logów, obiektów) oceniają zadeklarowany zakres pokrycia: system, strefa sieci lub strefa fizyczna nieobjęta monitoringiem jest dopuszczalna, jeżeli wyłączenie zostało udokumentowane

DRAFT

wraz z uzasadnieniem i środkami kompensującymi. Obszar nieobjęty monitoringiem i nieudokumentowany oznacza odpowiedź `NIE`.

Rodzaje logów. W kwestionariuszu rozróżnia się trzy rodzaje logów, oceniane w różnych sekcjach, tak aby każde pytanie dotyczyło jednego obiektu (zasada Z3):

(i) *logi zdarzeń bezpieczeństwa* (logowania, zmiany uprawnień, dostęp uprzywilejowany, alerty), służące wykrywaniu i analizie incydentów; ich monitorowanie ocenia sekcja `BEZPIECZENSTWO_TECH`;

(ii) *logi aplikacji wraz ze śladem zmian danych* (kto, kiedy i co zmienił w rekordzie), służące rozliczalności; ich retencję i ochronę ocenia sekcja `APLIKACJA` dla każdego systemu;

(iii) *logi operacji dostawcy* (dostępy administracyjne i zmiany konfiguracji wykonywane przez dostawcę), oceniane w sekcji `DOSTAWCY`.

Perspektywa użytkownika nie ma wglądu w repozytoria logów, dlatego w pytaniach o logi weryfikuje, czy potrafi uzyskać potrzebną informację, bezpośrednio w systemie albo za pośrednictwem działu IT (zasada Z6).

7.3.3 Sekcja organizacja

Aktywacja: *sekcja aktywna jednorazowo dla całego audytowanego podmiotu.*
Pytania w tej sekcji służą do oceny dojrzałości zarządczej organizacji w zakresie cyberbezpieczeństwa i odporności cyfrowej. Sprawdzają, czy na poziomie strategicznym podmiot jest świadomy ryzyk ICT, czyli czy zarząd formalnie zatwierdził strategię cyberbezpieczeństwa i ponosi za nią odpowiedzialność prawną, czy przeszedł wymagane szkolenia oraz czy wdrożono ramy zarządzania ryzykiem ICT z rejestrem ryzyk, właścicielami i planami. Ocenie podlega również gotowość operacyjna: czy organizacja potrafi klasyfikować incydenty, zgłaszać poważne zdarzenia do organów krajowych w ustawowych terminach oraz informować klientów o incydentach według gotowych procedur. Na poziomie organizacji weryfikowane są również ocena ryzyka łańcucha dostaw oraz prowadzenie rejestru dostawców ICT. Pytania blokujące obejmują brak zatwierdzonej strategii cyberbezpieczeństwa, brak ram zarządzania ryzykiem ICT, brak zdolności do zgłoszenia poważnego incydentu w ciągu 24 godzin oraz brak rejestru dostawców ICT; to ostatnie pytanie ma zakres wyłącznie DORA i jest blokujące tylko dla podmiotu `FINANSOWY`.

Pytania w sekcji:

Obszar: **Strategia cyberbezpieczeństwa w organizacji**
Podstawa prawna: **NIS2 art. 20 ust. 1, DORA art. 5**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy organ zarządzający formalnie zatwierdził strategię cyberbezpieczeństwa i ponosi za nią odpowiedzialność prawną?
- **Perspektywa użytkownika:** Czy wiesz, gdzie w firmie można znaleźć strategię lub politykę cyberbezpieczeństwa?

DRAFT

- **Perspektywa techniczna:** Czy strategia cyberbezpieczeństwa jest przełożona na udokumentowane wymagania techniczne (polityki, standardy konfiguracji) obowiązujące we wszystkich systemach informatycznych organizacji?

Obszar: **Przeprowadzone szkolenia zarządu**
Podstawa prawna: **NIS2 art. 20 ust. 2 / DORA art. 5 ust. 4**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy członkowie zarządu przeszli obowiązkowe szkolenia z cyberbezpieczeństwa?
- **Perspektywa użytkownika:** Czy wiesz, kto w zarządzie Twojej firmy odpowiada za cyberbezpieczeństwo i nadzór nad ryzykiem ICT?
- **Perspektywa techniczna:** Czy rejestr szkoleń (np. platforma e-learningowa lub system kadrowy) zawiera zapisy ukończenia szkolenia z cyberbezpieczeństwa przez członków zarządu z datą i zakresem?

Obszar: **Ramy zarządzania ryzykiem ICT**
Podstawa prawna: **NIS2 art. 21 ust. 1 / DORA art. 6**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy organizacja wdrożyła udokumentowane ramy zarządzania ryzykiem ICT zatwierdzone przez zarząd?
- **Perspektywa użytkownika:** Czy wiesz, komu w firmie zgłosić zauważone ryzyko związane z systemami IT (np. przestarzałe oprogramowanie, brak kopii zapasowej)?
- **Perspektywa techniczna:** Czy rejestr ryzyk ICT jest prowadzony w narzędziu z historią zmian (np. GRC lub rejestr z kontrolą wersji), z przypisanymi właścicielami i aktualizacją w ciągu ostatnich 12 miesięcy?

Obszar: **Ocena ryzyka łańcucha dostaw**
Podstawa prawna: **NIS2 art. 21 ust. 2 lit. d / DORA art. 28**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy przeprowadzana jest regularna ocena ryzyka uwzględniająca łańcuch dostaw i dostawców zewnętrznych?
- **Perspektywa użytkownika:** Czy wiesz, jakie zewnętrzne firmy mają dostęp do systemów lub danych Twojej organizacji?
- **Perspektywa techniczna:** Czy wyniki oceny ryzyka są zapisane w rejestrze dostawców lub narzędziu GRC dla każdego dostawcy ICT?

Obszar: **Zgłaszanie poważnych incydentów w 24h**
Podstawa prawna: **NIS2 art. 23 ust. 4 lit. a / DORA art. 19 ust. 4 i art. 20**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **tak**

DRAFT

- **Perspektywa zgodności:** Czy organizacja jest w stanie zgłosić poważny incydent do organu krajowego w ciągu 24 godzin od wykrycia?
- **Perspektywa użytkownika:** Czy wiesz, co zrobić i do kogo zadzwonić, gdy zauważysz coś podejrzanego na swoim komputerze?
- **Perspektywa techniczna:** Czy system ticketowy (lub równoważny) wymusza terminy zgłoszeń wynikające z NIS2/DORA (np. 24 h / 72 h) z automatycznym przypomnieniem i obowiązkowym polem zgłoszenia do KNF/CSIRT?

Obszar: **Klasyfikacja incydentów**
Podstawa prawna: **NIS2 art. 23 ust. 3 / DORA art. 18**
Zakres regulacyjny: **DORA** **NIS2** RODO
Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja posiada procedurę klasyfikacji incydentów pozwalającą ocenić, czy incydent jest poważny/znaczący?
- **Perspektywa użytkownika:** Czy wiesz, gdzie znaleźć opis, kiedy zdarzenie należy zgłosić jako incydent bezpieczeństwa (np. instrukcja w intranecie)?
- **Perspektywa techniczna:** Czy kryteria klasyfikacji są zaimplementowane w narzędziu obsługi incydentów (np. SIEM, system zgłoszeń lub rozwiązanie równoważne) jako reguły eskalacji lub obowiązkowe pola zgłoszenia?

Obszar: **Powiadamianie klientów o incydentach**
Podstawa prawna: **NIS2 art. 23 ust. 1 / DORA art. 14, art. 19 ust. 3**
Zakres regulacyjny: **DORA** **NIS2** RODO
Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja posiada zatwierdzoną procedurę komunikacji kryzysowej, która w sposób operacyjny (szablony, kanały, progi istotności) wdraża obowiązek niezwłocznego informowania odbiorców usług o poważnych incydentach?
- **Perspektywa użytkownika:** Czy wiesz, kto w firmie decyduje o powiadomieniu klientów lub pracowników o poważnym incydencie?
- **Perspektywa techniczna:** Czy istnieje system komunikacji z klientami / pracownikami z gotowymi szablonami uruchamialny w ciągu minut?

Obszar: **Rejestr dostawców ICT**
Podstawa prawna: **DORA art. 28 ust. 3 / art. 29 ust. 1**
Zakres regulacyjny: **DORA** NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy organizacja prowadzi aktualny rejestr wszystkich zewnętrznych dostawców ICT z klasyfikacją ich krytyczności i przypisaniem do funkcji krytycznych lub istotnych?
- **Perspektywa użytkownika:** Czy wiesz, który zewnętrzny dostawca IT świadczy usługi najważniejsze dla pracy Twojego działu?
- **Perspektywa techniczna:** Czy rejestr dostawców jest powiązany z rejestrem systemów IT (np. CMDB), tak że dla każdego systemu można wskazać obsługujących go dostawców?

DRAFT

7.3.4 Sekcja dane poufne: dane osobowe, w tym szczególne kategorie danych osobowych, oraz tajemnice przedsiębiorstwa

Aktywacja: *sekcja aktywna jednorazowo dla całego audytowanego podmiotu, gdy co najmniej jeden system przetwarza dane osobowe:* $\exists\, u \in V : D(u) \cap \{W, O\} \neq \emptyset$
Pytania w tej sekcji służą do oceny, czy organizacja prawidłowo zarządza procesem gromadzenia oraz przetwarzania danych poufnych. Sekcja jest oceniana na poziomie podmiotu, ponieważ obowiązki, których dotyczy (rejestr czynności przetwarzania, powołanie IOD, procedura zgłaszania naruszeń, harmonogram retencji), ciążą na administratorze danych, a nie na pojedynczym systemie. Weryfikowane jest, czy organizacja prowadzi aktualny rejestr czynności przetwarzania (RCP) zawierający cel, podstawę prawną, kategorie danych, odbiorców, okresy retencji i środki bezpieczeństwa dla każdej czynności (art. 30 RODO). Weryfikowana jest również gotowość do zgłoszenia naruszenia ochrony danych osobowych, które chroni prawa osób fizycznych i wymaga odrębnej procedury, odrębnej ścieżki eskalacji i odrębnych formularzy. Organizacja nieposiadająca oddzielnej procedury zgłoszeń do UODO nie wykazuje gotowości do wywiązania się z fundamentalnego obowiązku w zakresie ochrony danych osobowych. Pytania blokujące obejmują brak procedury zgłaszania naruszeń do UODO oraz brak rejestru czynności przetwarzania.

Pytania w sekcji:

Obszar: **Zgłaszanie naruszeń danych osobowych do UODO (72h)**
Podstawa prawna: **RODO art. 33**
Zakres regulacyjny: DORA NIS2 **RODO**
Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy organizacja posiada odrębną procedurę zgłaszania naruszeń ochrony danych osobowych do Prezesa UODO w ciągu 72 godzin, niezależną od procedury zgłoszeń NIS2/DORA do CSIRT?
- **Perspektywa użytkownika:** Czy wiesz, komu zgłosić podejrzenie wycieku danych osobowych (np. wysłanie e-maila z danymi klientów do niewłaściwej osoby)?
- **Perspektywa techniczna:** Czy narzędzie obsługi zgłoszeń pozwala oznaczyć zdarzenie jako naruszenie ochrony danych osobowych i kieruje je do IOD ścieżką odrębną od incydentów ICT?

Obszar: **Inspektor Ochrony Danych (IOD), powołanie i rejestracja**
Podstawa prawna: **RODO art. 37–39**
Zakres regulacyjny: DORA NIS2 **RODO**
Typ pytania: **zalecane**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja powołała IOD, zarejestrowała go w UODO i udostępniła jego dane kontaktowe osobom, których dane dotyczą?
- **Perspektywa użytkownika:** Czy wiesz, kto w Twojej firmie jest Inspektorem Ochrony Danych i jak możesz się z nim skontaktować?
- **Perspektywa techniczna:** Czy dane kontaktowe IOD (adres e-mail, formularz) są opublikowane na stronie internetowej i w klauzulach informacyjnych systemów, a skrzynka IOD jest aktywna i monitorowana?

DRAFT

Obszar: **Rejestr Czynności Przetwarzania (RCP/ROPA)**
Podstawa prawna: **RODO art. 30**
Zakres regulacyjny: DORA NIS2 **RODO**
Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy organizacja prowadzi aktualny RCP zawierający: cel, podstawę prawną, kategorie danych, odbiorców, okresy retencji i środki bezpieczeństwa dla każdej czynności przetwarzania?
- **Perspektywa użytkownika:** Czy wiesz, kto w firmie prowadzi rejestr czynności przetwarzania, do którego zgłasza się nowe procesy przetwarzania danych osobowych?
- **Perspektywa techniczna:** Czy każdy system przetwarzający dane osobowe ma w rejestrze systemów IT (np. CMDB) przypisane czynności przetwarzania z rejestru czynności przetwarzania?

Obszar: **Harmonogram retencji i usuwania danych osobowych**
Podstawa prawna: **RODO art. 5**
Zakres regulacyjny: DORA NIS2 **RODO**
Typ pytania: **zalecane**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja posiada formalny harmonogram retencji (retention schedule) z maksymalnymi okresami przechowywania dla każdej kategorii danych osobowych i przypisaną odpowiedzialnością za ich usuwanie?
- **Perspektywa użytkownika:** Czy w systemach, z których korzystasz, dane osobowe dawnych klientów lub byłych pracowników są usuwane lub anonimizowane (nie widzisz danych osób, z którymi firma dawno zakończyła współpracę)?
- **Perspektywa techniczna:** Czy systemy IT mają skonfigurowane reguły automatycznego usuwania lub anonimizacji danych osobowych po upływie okresu retencji?

7.3.5 Sekcja bezpieczeństwo techniczne

Aktywacja: *sekcja aktywna jednorazowo dla całego audytowanego podmiotu.*
Pytania w tej sekcji służą do oceny skuteczności technicznych środków ochrony systemów i infrastruktury ICT organizacji przed zagrożeniami cybernetycznymi. Sprawdzane jest, czy organizacja określiła zakres monitorowania bezpieczeństwa (z udokumentowanymi wyłączeniami i środkami kompensującymi), wdrożyła mechanizmy ciągłego monitorowania i wykrywania anomalii, własne lub w formie usługi zewnętrznej, oraz czy przeprowadza regularne testy bezpieczeństwa i testy penetracyjne z udokumentowanymi wynikami i planem naprawy zidentyfikowanych podatności. Ocenie podlega stosowanie zasady minimalnych uprawnień (ang. *least privilege*) w dostępie do systemów krytycznych, z określoną częstotliwością przeglądu uprawnień, przy czym od strony technicznej weryfikowane jest, czy przegląd odbywa się co najmniej raz na kwartał i jest odnotowany w narzędziu zarządzania dostępem, a także proces dezaktywacji kont przy odejściu pracownika, segmentacja sieci ograniczająca boczne przemieszczanie się atakującego, zarządzanie certyfikatami TLS, szkolenia pracowników oraz bezpieczeństwo poczty elektronicznej. Uprawnienia kont serwisowych aplikacji dostawców są oceniane odrębnie dla każdego systemu w sekcji

DRAFT

`APLIKACJA`. Pytania blokujące obejmują brak stosowania zasady minimalnych uprawnień oraz brak segmentacji sieci.

Pytania w sekcji:

Obszar: **Testy bezpieczeństwa i testy penetracyjne**
Podstawa prawna: **NIS2 art. 21 ust. 2 lit. f / DORA art. 24–25**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja ma zatwierdzony program regularnych testów bezpieczeństwa obejmujący testy penetracyjne systemów krytycznych?
- **Perspektywa użytkownika:** Czy wiesz, kto w firmie odpowiada za testy bezpieczeństwa systemów, z których korzystasz?
- **Perspektywa techniczna:** Czy podatności wykryte w testach penetracyjnych z ostatnich 12 miesięcy są zarejestrowane w systemie obsługi zgłoszeń z przypisanym terminem naprawy?

Obszar: **Monitoring i wykrywanie anomalii**
Podstawa prawna: **NIS2 art. 21 ust. 2 lit. b / DORA art. 10**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **zalecane**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja określiła i zatwierdziła zakres monitorowania bezpieczeństwa, tzn. które systemy krytyczne i strefy sieci są objęte ciągłym monitorowaniem, a dla obszarów nieobjętych monitoringiem udokumentowała uzasadnienie i środki kompensujące?
- **Perspektywa użytkownika:** Czy w firmie działa zespół lub usługa (np. SOC, dział bezpieczeństwa), do której możesz zgłosić podejrzane zdarzenie o każdej porze?
- **Perspektywa techniczna:** Czy zdarzenia bezpieczeństwa z systemów objętych zakresem monitorowania generują alerty w czasie zbliżonym do rzeczywistego, obsługiwane przez wyznaczony zespół lub usługę zewnętrzną (np. SIEM, SOC/MDR, EDR lub rozwiązanie równoważne)?

Obszar: **Zasada minimalnych uprawnień**
Podstawa prawna: **DORA art. 9 / NIS2 art. 21**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy polityka kontroli dostępu do systemów krytycznych określa zasadę minimalnych uprawnień i częstotliwość przeglądu uprawnień?
- **Perspektywa użytkownika:** Czy Twoje uprawnienia w systemach krytycznych, z których korzystasz, ograniczają się do tego, czego potrzebujesz w codziennej pracy?
- **Perspektywa techniczna:** Czy uprawnienia do systemów krytycznych są przeglądane co najmniej raz na kwartał, a każdy przegląd jest odnotowany w narzędziu zarządzania dostępem (np. PAM, IAM lub rozwiązanie równoważne)?

DRAFT

Obszar: **Szkolenia i świadomość pracowników**
Podstawa prawna: **NIS2 art. 21 ust. 2 lit. g / DORA art. 13 ust. 6**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy pracownicy przechodzą regularne szkolenia z cyberbezpieczeństwa?
- **Perspektywa użytkownika:** Czy w ciągu ostatnich 12 miesięcy uczestniczyłeś/aś w szkoleniu z cyberbezpieczeństwa?
- **Perspektywa techniczna:** Czy skuteczność szkoleń jest mierzona (np. przez symulowane ataki phishingowe lub testy wiedzy), a wyniki są dokumentowane?

Obszar: **Offboarding (usuwanie dostępu)**
Podstawa prawna: **DORA art. 9 ust. 4 lit. c / NIS2 art. 21 ust. 2 lit. i**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy istnieje udokumentowany proces dezaktywacji kont przy odejściu pracownika?
- **Perspektywa użytkownika:** Czy konta osób, które odeszły z firmy, znikają z książki adresowej i komunikatora najpóźniej w dniu ich odejścia?
- **Perspektywa techniczna:** Czy offboarding jest zautomatyzowany i dezaktywuje wszystkie konta w dniu odejścia pracownika bez konieczności ręcznej akcji administratora w poszczególnych systemach?

Obszar: **Bezpieczeństwo e-mail i załączników**
Podstawa prawna: **RODO art. 32 / NIS2 art. 21 / DORA art. 9 ust. 3 lit. a**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **zalecane**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja posiada politykę regulującą wysyłanie danych osobowych, w tym szczególnych kategorii danych osobowych, przez e-mail i wymóg szyfrowania załączników?
- **Perspektywa użytkownika:** Czy wysyłając e-mailem plik z danymi klientów, zawsze stosujesz szyfrowanie (np. archiwum z hasłem przekazanym innym kanałem) lub firmowe narzędzie do bezpiecznego udostępniania plików?
- **Perspektywa techniczna:** Czy system pocztowy technicznie wykrywa i blokuje wysyłkę danych osobowych, w tym szczególnych kategorii danych osobowych, bez szyfrowania (np. DLP lub rozwiązanie równoważne)?

Obszar: **Segmentacja sieci i kontrola ruchu bocznego**
Podstawa prawna: **DORA art. 9 / NIS2 art. 21**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **tak**

DRAFT

- **Perspektywa zgodności:** Czy polityka bezpieczeństwa sieci określa segmentację systemów krytycznych i zasady dopuszczalnego ruchu między segmentami?
- **Perspektywa użytkownika:** Czy aby połączyć się z systemami krytycznymi (np. panele administracyjne, serwery produkcyjne), trzeba korzystać ze specjalnego dostępu (VPN, osobna sieć, stacja przesiadkowa), a nie łączyć się z nimi bezpośrednio z sieci biurowej?
- **Perspektywa techniczna:** Czy ruch sieciowy do systemów krytycznych jest ograniczony regułami filtrowania między segmentami (np. VLAN z zaporą, mikrosegmentacja, ZTNA lub rozwiązanie równoważne)?

Obszar: **Zarządzanie certyfikatami TLS**
Podstawa prawna: **DORA art. 9 / NIS2 art. 21 ust. 2 lit. h**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **zalecane**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja posiada inwentarz certyfikatów TLS z datami wygasania i procesem automatycznego odnawiania eliminującym ryzyko niedostępności usług z powodu wygasłego certyfikatu?
- **Perspektywa użytkownika:** Czy firmowe strony i systemy, z których korzystasz, otwierają się bez ostrzeżeń przeglądarki o nieważnym lub wygasłym certyfikacie?
- **Perspektywa techniczna:** Czy stosowane jest narzędzie do monitorowania certyfikatów (np. cert-manager, Venafi, DigiCert) z alertowaniem co najmniej 30 dni przed wygaśnięciem i automatycznym odnawianiem tam, gdzie jest to możliwe (np. ACME/Let's Encrypt)?

7.3.6 Sekcja bezpieczeństwo fizyczne

Aktywacja: *sekcja aktywna jednorazowo dla całego audytowanego podmiotu.*
Pytania w tej sekcji służą do oceny środków ochrony fizycznej stosowanych w obiektach, w których zlokalizowana jest infrastruktura ICT organizacji. Sprawdzane jest, czy organizacja posiada zatwierdzoną politykę bezpieczeństwa fizycznego centrów danych, obejmującą także ochronę przed zagrożeniami środowiskowymi, oraz politykę kontroli dostępu fizycznego, a od strony technicznej, czy każde wejście do pomieszczeń przetwarzających dane jest rejestrowane elektronicznie (karta, biometria), bez możliwości wejścia wyłącznie na klucz mechaniczny. Ocenie podlega podział obiektu na strefy bezpieczeństwa o różnych poziomach dostępu, w tym poruszanie się gości i serwisantów zewnętrznych wyłącznie w towarzystwie pracownika, określony w polityce zakres monitoringu wizyjnego CCTV stref krytycznych (z udokumentowanymi wyjątkami i środkami kompensującymi), redundancja zasilania z UPS i agregatem testowanymi pod obciążeniem oraz procedura wynoszenia urządzeń z rejestrem wydanych urządzeń i wymuszonym szyfrowaniem całego dysku. Weryfikowane jest ponadto, czy istnieje procedura bezpiecznego niszczenia nośników danych, a dyski są niszczone fizycznie lub nadpisywane skuteczną metodą, oraz czy wdrożono udokumentowane środki ochrony przed kradzieżą i sabotażem (np. system alarmowy, zamykane szafy rack, kontrola portów USB). Pytania blokujące obejmują brak zatwierdzonej polityki bezpieczeństwa fizycznego centrów danych oraz brak formalnej polityki kontroli dostępu fizycznego do obiektów przetwarzających dane.

DRAFT

Pytania w sekcji:

Obszar: **Bezpieczeństwo fizyczne centrów danych**
Podstawa prawna: **DORA art. 9 / NIS2 art. 21**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy organizacja posiada zatwierdzoną politykę bezpieczeństwa fizycznego centrów danych obejmującą kontrolę dostępu, ochronę poufności i integralności sprzętu oraz ochronę przed zagrożeniami środowiskowymi (pożar, zalanie, temperatura)?
- **Perspektywa użytkownika:** Czy pomieszczenia z serwerami i urządzeniami sieciowymi w Twojej lokalizacji są zamknięte i niedostępne dla pracowników bez uprawnień?
- **Perspektywa techniczna:** Czy centrum danych ma monitoring środowiskowy (temperatura, zalanie, dym) z alertowaniem 24/7?

Obszar: **Kontrola dostępu fizycznego do obiektów**
Podstawa prawna: **DORA art. 9 / NIS2 art. 21**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy organizacja posiada formalną politykę kontroli dostępu fizycznego do obiektów przetwarzających dane?
- **Perspektywa użytkownika:** Czy do pomieszczeń technicznych, do których masz uprawnienia, wchodzisz przy użyciu imiennej karty lub innej indywidualnej identyfikacji, a nie wspólnego klucza lub kodu?
- **Perspektywa techniczna:** Czy każde wejście do pomieszczeń przetwarzających dane (serwerownia, pomieszczenia techniczne) jest rejestrowane elektronicznie (karta, biometria), bez możliwości wejścia wyłącznie na klucz mechaniczny?

Obszar: **Strefy bezpieczeństwa i segmentacja fizyczna**
Podstawa prawna: **NIS2 art. 21 / DORA art. 6 ust. 2, art. 9 ust. 4 lit. c / ISO 27001 A.11**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **zalecane**, blokujące: **nie**

- **Perspektywa zgodności:** Czy obiekty są podzielone na strefy bezpieczeństwa z różnymi poziomami dostępu: strefa publiczna, biurowa, techniczna, krytyczna?
- **Perspektywa użytkownika:** Czy goście i serwisanci zewnętrzni poruszają się po Twoim biurze wyłącznie w towarzystwie pracownika?
- **Perspektywa techniczna:** Czy przejście między strefami wymaga oddzielnej autoryzacji, tzn. osoba z dostępem do biura nie ma automatycznie dostępu do serwerowni i innych pomieszczeń krytycznych?

DRAFT

Obszar: **Monitoring CCTV i rejestracja wideo**
Podstawa prawna: **RODO art. 5 ust. 1 lit. e / NIS2 art. 21 / DORA art. 6 ust. 2**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **zalecane**, blokujące: **nie**

- **Perspektywa zgodności:** Czy polityka bezpieczeństwa fizycznego określa, które strefy krytyczne są objęte monitoringiem CCTV z retencją nagrań zgodną z RODO, a wyjątki są udokumentowane wraz ze środkami kompensującymi?
- **Perspektywa użytkownika:** Czy wejścia do stref krytycznych (np. serwerownia, archiwum) są monitorowane kamerami lub kontrolowane w inny widoczny sposób (np. czytnik kart z rejestracją wejść)?
- **Perspektywa techniczna:** Czy każdy punkt wejścia do stref krytycznych jest objęty monitoringiem kamer z nagraniami chronionymi przed modyfikacją albo, jeśli kamery nie ma, udokumentowanym środkiem kompensującym (np. kontrolą dostępu z rejestracją wejść)?

Obszar: **Zasilanie i redundancja energetyczna**
Podstawa prawna: **DORA art. 11 / NIS2 art. 21**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy polityka lub standard infrastruktury wymaga dla obiektów krytycznych redundantnego zasilania z co najmniej dwóch niezależnych źródeł oraz UPS?
- **Perspektywa użytkownika:** Czy przy krótkim zaniku zasilania w budynku systemy, z których korzystasz, nadal działają lub pozwalają bezpiecznie zapisać pracę?
- **Perspektywa techniczna:** Czy UPS i generator są regularnie testowane pod obciążeniem - nie tylko w trybie symulacji?

Obszar: **Wynoszenie i transport urządzeń**
Podstawa prawna: **RODO art. 32 / NIS2 art. 21 / DORA art. 6 ust. 2**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja posiada procedurę wynoszenia urządzeń poza siedzibę z rejestrem wydanych urządzeń?
- **Perspektywa użytkownika:** Czy wiesz, co zrobić i do kogo zadzwonić w ciągu pierwszych 30 minut, gdybyś zgubił/a służbowego laptopa lub telefon?
- **Perspektywa techniczna:** Czy wszystkie urządzenia przenośne mają przymusowo aktywne szyfrowanie całego dysku (np. wymuszone przez system zarządzania urządzeniami)?

Obszar: **Niszczenie i utylizacja nośników danych**
Podstawa prawna: **RODO art. 5 / NIS2 art. 21 / DORA art. 6 ust. 2**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **nie**

DRAFT

- **Perspektywa zgodności:** Czy organizacja posiada procedurę bezpiecznego niszczenia nośników danych (dysków, pendrive'ów, wydruków)?
- **Perspektywa użytkownika:** Czy wiesz, komu oddać służbowy sprzęt lub nośnik danych do bezpiecznego usunięcia danych lub zniszczenia?
- **Perspektywa techniczna:** Czy dyski są niszczone fizycznie lub nadpisywane skuteczną metodą przed utylizacją?

Obszar: **Ochrona przed kradzieżą i sabotażem fizycznym**
Podstawa prawna: **NIS2 art. 21 / DORA art. 6 ust. 2, art. 9 ust. 4 lit. c / ISO 27001 A.11**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **zalecane**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja wdrożyła udokumentowane środki ochrony przed kradzieżą i fizycznym sabotażem sprzętu IT (np. system alarmowy, szafy rack zamykane na klucz, kable zabezpieczające)?
- **Perspektywa użytkownika:** Czy po podłączeniu prywatnego pendrive'a do komputera służbowego system blokuje jego użycie bez zgody administratora?
- **Perspektywa techniczna:** Czy porty USB serwerów i stacji roboczych są technicznie kontrolowane (blokada lub biała lista urządzeń)?

7.3.7 Sekcja system informatyczny

Aktywacja: *aktywacja warunkowa, gdy typ obiektu* = `SYSTEM_INFORMATYCZNY`
Pytania w tej sekcji służą do oceny bezpieczeństwa i zgodności konkretnego systemu informatycznego rozpatrywanego jako samodzielna jednostka. Zakres oceny jest stosowany odrębnie dla każdego audytowanego systemu, co pozwala zidentyfikować różnice w poziomach zabezpieczeń między poszczególnymi aplikacjami w portfelu ICT organizacji. Sprawdzane jest, czy system figuruje w oficjalnym rejestrze zasobów ICT z przypisaną klasyfikacją krytyczności i właścicielem, czy polityka wymaga uwierzytelniania wieloskładnikowego (MFA) dla wszystkich kont systemu, a MFA jest wymuszane technicznie bez możliwości pominięcia, czy standard bezpieczeństwa wymaga szyfrowania komunikacji protokołem TLS 1.2 lub nowszym oraz czy polityka rejestrowania zdarzeń określa zakres, okres przechowywania i ochronę logów aplikacji, w tym śladu zmian danych, przechowywanych technicznie przez co najmniej 12 miesięcy w repozytorium chronionym przed modyfikacją. Ocenie podlegają również polityka haseł wymuszana technicznie, zarządzanie podatnościami z udokumentowanymi terminami naprawy, zasada minimalnych uprawnień dla kont i integracji aplikacji dostawcy wraz z okresowym przeglądem, warunki zdalnego dostępu dostawcy (akceptacja sesji, rejestrowanie, ograniczenie czasowe) oraz, jako kryterium o szczególnym znaczeniu dla ciągłości działania, polityka kopii zapasowych określająca geograficznie odrębną lokalizację, retencję i regularne testy odtwarzania, przy kopiach technicznie odizolowanych od środowiska produkcyjnego i chronionych przed modyfikacją lub usunięciem. Pytania blokujące obejmują brak wpisu w rejestrze CMDB, brak MFA oraz brak backupu.

Pytania w sekcji:

DRAFT

Obszar: **Uprawnienia i dostępy aplikacji dostawcy**
Podstawa prawna: **DORA art. 9 / NIS2 art. 21**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy polityka dostępu określa zasadę minimalnych uprawnień dla kont i integracji aplikacji dostawców, wraz z procedurą ich okresowego przeglądu?
- **Perspektywa użytkownika:** Czy wiesz, kto w firmie zatwierdza zakres dostępu aplikacji i integracji dostawcy do systemów i danych, z których korzystasz?
- **Perspektywa techniczna:** Czy konta serwisowe aplikacji dostawcy mają ograniczony zakres uprawnień w AD/IAM, bez dostępu do niezwiązanych systemów, i są regularnie przeglądane?

Obszar: **Dostęp zdalny dostawcy (remote access)**
Podstawa prawna: **DORA art. 28 / NIS2 art. 21 ust. 2 lit. d i lit. i**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy procedura lub umowa dotycząca zdalnego dostępu dostawcy do tej aplikacji określa warunki dostępu (akceptacja sesji, rejestrowanie, ograniczenie czasowe)?
- **Perspektywa użytkownika:** Czy zanim serwisant zewnętrznego dostawcy połączy się zdalnie z tą aplikacją, ktoś w firmie (Ty lub dział IT) musi to zaakceptować?
- **Perspektywa techniczna:** Czy każda sesja zdalna dostawcy wymaga jawnej akceptacji po stronie organizacji i wygasa po zakończeniu prac (np. mechanizm JIT lub rozwiązanie równoważne), tak że dostawca nie ma stałego dostępu?

Obszar: **Rejestr zasobów ICT (CMDB)**
Podstawa prawna: **DORA art. 8 / NIS2 art. 21 ust. 2 lit. i**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy aplikacja figuruje w oficjalnym rejestrze zasobów ICT z przypisaną klasyfikacją krytyczności i właścicielem?
- **Perspektywa użytkownika:** Czy wiesz, kto jest właścicielem tej aplikacji w organizacji, czyli kto odpowiada za jej bezpieczeństwo i aktualizacje?
- **Perspektywa techniczna:** Czy wpis systemu w rejestrze zasobów ICT (CMDB) zawiera aktualne dane techniczne (środowisko, wersja, integracje) zgodne ze stanem systemu?

Obszar: **Retencja i ochrona logów aplikacji**
Podstawa prawna: **DORA art. 10 / NIS2 art. 21**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **nie**

DRAFT

- **Perspektywa zgodności:** Czy polityka rejestrowania zdarzeń określa dla tej aplikacji zakres rejestrowanych zdarzeń (logowania, zmiany uprawnień, operacje na danych), okres przechowywania logów i sposób ich ochrony przed modyfikacją?
- **Perspektywa użytkownika:** Czy możesz uzyskać informację, kto, kiedy i co zmienił w rekordzie, na którym pracujesz, także dla operacji sprzed kilku miesięcy (bezpośrednio w aplikacji albo na zgłoszenie do działu IT)?
- **Perspektywa techniczna:** Czy logi aplikacji są przechowywane przez co najmniej 12 miesięcy w repozytorium chronionym przed modyfikacją i usunięciem (np. magazyn WORM, SIEM, centralny serwer logów lub usługa zewnętrzna z kontrolą dostępu)?

Obszar: **Szyfrowanie komunikacji (TLS)**
Podstawa prawna: **DORA art. 9 / NIS2 art. 21 ust. 2 lit. h / RODO art. 32**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy standard bezpieczeństwa organizacji wymaga dla tej aplikacji szyfrowania komunikacji protokołem TLS 1.2 lub nowszym?
- **Perspektywa użytkownika:** Czy gdy logujesz się do tej aplikacji przez przeglądarkę, adres zaczyna się od https:// w przeglądarce?
- **Perspektywa techniczna:** Czy skanowanie konfiguracji potwierdza brak przestarzałych protokołów (TLS 1.0/1.1, SSL) i poprawność certyfikatów?

Obszar: **MFA dla wszystkich użytkowników**
Podstawa prawna: **DORA art. 9 / NIS2 art. 21 ust. 2 lit. j**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy organizacja posiada formalną politykę wymagającą MFA dla wszystkich kont tego systemu, w szczególności uprzywilejowanych i dostępu zdalnego, bez nieudokumentowanych wyjątków?
- **Perspektywa użytkownika:** Czy logując się do tej aplikacji, musisz oprócz hasła potwierdzić tożsamość w drugi sposób (kod SMS, aplikacja w telefonie, klucz sprzętowy)?
- **Perspektywa techniczna:** Czy MFA jest wymuszane technicznie (w IdP lub w samej aplikacji) dla wszystkich kont, w tym uprzywilejowanych i zdalnych, bez możliwości pominięcia przez użytkownika?

Obszar: **Zarządzanie hasłami i polityką haseł**
Podstawa prawna: **NIS2 art. 21 / DORA art. 9**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja stosuje formalną politykę haseł (minimalna długość, złożoność, zakaz ponownego użycia)?

DRAFT

- **Perspektywa użytkownika:** Czy system odrzuca zbyt krótkie lub popularne hasła (np. „Haslo123") i nie pozwala ustawić hasła, którego używałeś/aś wcześniej?
- **Perspektywa techniczna:** Czy polityka haseł jest wymuszana technicznie przez IdP/AD - niemożliwa do obejścia przez użytkownika?

Obszar: **Backup**
Podstawa prawna: **DORA art. 12 / NIS2 art. 21 ust. 2 lit. c**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy organizacja posiada zatwierdzoną politykę kopii zapasowych określającą przechowywanie kopii w geograficznie odrębnej lokalizacji, okres retencji zgodny z wymogami regulacyjnymi oraz obowiązek regularnego testowania odtwarzania?
- **Perspektywa użytkownika:** Czy przypadkowo usunięte lub uszkodzone dane w tej aplikacji można odzyskać na Twoją prośbę (np. przez zgłoszenie do IT)?
- **Perspektywa techniczna:** Czy kopie zapasowe systemu są odizolowane od środowiska produkcyjnego i chronione przed modyfikacją lub usunięciem (np. WORM, air-gap lub rozwiązanie równoważne)?

Obszar: **Zarządzanie podatnościami**
Podstawa prawna: **NIS2 art. 21 ust. 2 lit. e / DORA art. 9**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja posiada formalny proces skanowania podatności CVE i patch managementu z udokumentowanymi terminami?
- **Perspektywa użytkownika:** Czy otrzymujesz informacje o aktualizacjach tej aplikacji (np. komunikaty o nowej wersji lub zaplanowanych przerwach serwisowych na instalację poprawek)?
- **Perspektywa techniczna:** Czy system jest objęty skanowaniem podatności co najmniej raz w miesiącu (np. Qualys, Tenable, Nessus lub narzędzie równoważne) z przypisaniem wyników do właściciela i terminu naprawy?

7.3.8 Sekcja usługi w chmurze

Aktywacja: *aktywacja warunkowa, gdy utrzymanie_chmura*$(v) \in \{$`CHMURA_K3`, `CHMURA_EOG`$\}$
Pytania w tej sekcji służą do oceny zgodności wynikającej ze specyfiki przetwarzania danych w środowisku chmurowym, gdzie organizacja powierza przetwarzanie zewnętrznemu dostawcy usług (CSP). Sprawdzane jest, czy przed uruchomieniem systemu przeprowadzono i udokumentowano Ocenę Skutków dla Ochrony Danych (DPIA) oraz czy jest ona aktualizowana przy każdej istotnej zmianie systemu lub dostawcy. Ocenie podlega model zarządzania kluczami kryptograficznymi, uniemożliwiający dostawcy samodzielny dostęp do przechowywanych danych. Weryfikowane jest również, czy dostawca zapewnia pełną logiczną izolację danych między klientami (multi-tenancy) oraz czy umowa określa maksymalny czas powiadomienia organizacji o incydencie po stronie dostawcy, pozwalający

DRAFT

organizacji dotrzymać własnych terminów zgłoszeń. Zagadnienia umowne niezależne od modelu utrzymania, tj. prawo do audytu dostawcy oraz klauzule odpowiedzialności i regresu, są oceniane w sekcji `DOSTAWCY`. Pytaniem blokującym jest brak aktualnej oceny skutków dla ochrony danych (DPIA).

Pytania w sekcji:

Obszar: **Dokumentacja DPIA dla przetwarzania w chmurze**
Podstawa prawna: **RODO art. 35**
Zakres regulacyjny: DORA NIS2 **RODO**
Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy przed uruchomieniem tego systemu chmurowego przeprowadzono i udokumentowano ocenę skutków dla ochrony danych (DPIA), a dokument ten jest aktualny (aktualizowany przy każdej istotnej zmianie systemu lub dostawcy)?
- **Perspektywa użytkownika:** Czy wiesz, gdzie znaleźć ocenę skutków dla ochrony danych (DPIA) tego systemu lub kto w firmie ją prowadzi?
- **Perspektywa techniczna:** Czy opis przepływów danych osobowych w DPIA tego systemu odpowiada jego rzeczywistej konfiguracji (np. zgodność z diagramem architektury i listą integracji)?

Obszar: **Szyfrowanie at-rest poza natywnymi funkcjami dostawcy**
Podstawa prawna: **DORA art. 9 ust. 4 lit. d / NIS2 art. 21 ust. 2 lit. h / RODO art. 32**
Zakres regulacyjny: **DORA** **NIS2** **RODO**
Typ pytania: **zalecane**, blokujące: **nie**

- **Perspektywa zgodności:** Czy polityka kryptograficzna organizacji wymaga, aby klucze szyfrujące dane tego systemu były kontrolowane wyłącznie przez organizację, a nie przez dostawcę chmury?
- **Perspektywa użytkownika:** Czy wiesz, kto w Twojej firmie (a nie po stronie dostawcy) odpowiada za klucze szyfrujące dane tego systemu?
- **Perspektywa techniczna:** Czy klucze szyfrujące dane tego systemu są generowane i przechowywane poza kontrolą dostawcy chmury (np. HSM organizacji, zewnętrzny KMS, model HYOK)?

Obszar: **Procedura reagowania na incydenty po stronie dostawcy**
Podstawa prawna: **DORA art. 30 ust. 2 lit. f i ust. 3 lit. b / NIS2 art. 21 ust. 2 lit. d**
Zakres regulacyjny: **DORA** **NIS2** RODO
Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy umowa z dostawcą chmury określa maksymalny czas powiadomienia organizacji o incydencie bezpieczeństwa po stronie dostawcy i czy czas ten umożliwia organizacji dotrzymanie własnego obowiązku zgłoszenia do CSIRT/KNF w ciągu 24 godzin?

DRAFT

- **Perspektywa użytkownika:** Czy wiesz, kto w Twojej firmie odbiera powiadomienia o awariach lub atakach od dostawcy chmury?
- **Perspektywa techniczna:** Czy powiadomienia dostawcy o incydentach trafiają technicznie do wyznaczonego kanału organizacji (np. skrzynka SOC, system zgłoszeń) i są w nim rejestrowane z czasem otrzymania?

Obszar: **Izolacja danych między klientami (multi-tenancy)**
Podstawa prawna: **DORA art. 9 / RODO art. 32 / ISO 27017**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja posiada dokumentację dostawcy (np. raport SOC 2, opis architektury) potwierdzającą mechanizmy izolacji danych organizacji od danych innych klientów?
- **Perspektywa użytkownika:** Czy w tym systemie widzisz wyłącznie dane swojej organizacji?
- **Perspektywa techniczna:** Czy dane organizacji są odseparowane od danych innych klientów na poziomie przechowywania (np. oddzielna baza, schemat lub przestrzeń wirtualna), a nie wyłącznie przez filtrowanie wierszy we wspólnej tabeli?

7.3.9 Sekcja Transfer Impact Assessment (TIA)

Aktywacja: *aktywacja warunkowa, gdy* $C_{TIA}(v) =$ `TRUE` *(równanie* (7.3)*), niezależnie od typu przetwarzanych danych; obejmuje systemy* `CHMURA_K3`*, systemy wspierane spoza EOG, systemy, w których łańcuchu dostaw występuje dostawca lub poddostawca spoza EOG albo kontrolowany z państwa trzeciego, oraz tych dostawców i poddostawców*
Pytania w tej sekcji służą do oceny ryzyka związanego z dostępem do danych i ich przekazywaniem poza Europejski Obszar Gospodarczy (EOG). Sekcja jest aktywowana niezależnie od tego, czy system przetwarza dane osobowe: jurysdykcja państwa trzeciego zagraża również danym nieosobowym objętym ochroną, takim jak tajemnica przedsiębiorstwa, tajemnica bankowa czy inne informacje poufne, których ochrona nie wynika z RODO. Część pytań sekcji (TIA w rozumieniu RODO, umowa powierzenia DPA) dotyczy wyłącznie danych osobowych; dla systemu, który ich nie przetwarza ($D(v) \cap \{W, O\} = \emptyset$), pytania te mogą zostać oznaczone jako `N/D` na zasadach opisanych w sekcji 7.3.2, czyli z uzasadnieniem, akceptacją audytora i dowodem co najmniej średniej jakości. Pozostałe pytania, dotyczące koncentracji jurysdykcyjnej i ryzyka dostępu eksterytorialnego, są oceniane zawsze.

W odniesieniu do danych osobowych obowiązek przeprowadzenia TIA wynika z wyroku Trybunału Sprawiedliwości UE w sprawie Schrems II z 2020 r., który stwierdził nieważność decyzji Komisji w sprawie Tarczy Prywatności (Privacy Shield) i nałożył na eksporterów danych obowiązek indywidualnej weryfikacji, czy prawo i praktyka państwa docelowego nie podważają skuteczności ochrony gwarantowanej przez Standardowe Klauzule Umowne (SCC). Sprawdzane jest, czy dla każdego transferu opartego na SCC przeprowadzono TIA uwzględniające ustawodawstwo krajowe państwa odbiorcy (w tym ryzyko eksterytorialnego dostępu wynikające z amerykańskiego CLOUD Act i FISA 702) a także czy taki transfer jest obsługiwany jako komplet trzech dokumentów: aktualnej umowy

DRAFT

DPA zgodnej z art. 28 RODO, klauzul SCC z 2021 r. oraz dokumentacji TIA. Weryfikowane jest ponadto, czy organizacja posiada od dostawcy pisemny wykaz wszystkich lokalizacji przetwarzania danych, obejmujący kopie zapasowe, logi i metadane, w którym każda lokalizacja poza EOG jest objęta udokumentowaną podstawą transferu (DPF lub SCC z TIA), oraz czy technicznie weryfikuje, że dane nie są przetwarzane poza lokalizacjami z wykazu. Ocenie podlega ponadto ryzyko koncentracji przetwarzania w jednej jurysdykcji poza EOG oraz ryzyko dostępu eksterytorialnego wynikające z prawa państwa dostawcy. Wyjątkiem są transfery oparte na decyzji Komisji stwierdzającej odpowiedni stopień ochrony (art. 45 RODO), w tym transfery do odbiorców w USA certyfikowanych w ramach DPF (decyzja wykonawcza Komisji (UE) 2023/1795).[1] Taki transfer jest legalny bez SCC i bez TIA, dlatego pytanie o TIA otrzymuje odpowiedź `N/D`. Dowodem jest aktualny wpis odbiorcy na liście DPF obejmujący przekazywany rodzaj danych. Kryteriami blokującymi są brak TIA oraz brak ważnej umowy DPA. Bez nich transfer danych osobowych nie spełnia wymogów rozdziału V i art. 28 RODO.

Identyfikacja poddostawców i trigger TIA

Jednym z najpoważniejszych i najczęściej pomijanych problemów współczesnej praktyki compliance jest zjawisko *deklaratywnego zatrzymania łańcucha* analizy poddostawców: organizacja lub jej dostawca deklaruje zgodność z wymogami regulacyjnymi dotyczącymi miejsca przetwarzania danych, nie weryfikując jednak, czy deklaracja ta jest prawdziwa w odniesieniu do wszystkich ogniw łańcucha dostaw ICT leżących poniżej.

Klasycznym przykładem jest firma zewnętrzna, która informuje audytowaną organizację: *„Hostujemy Państwa dane wyłącznie na serwerach zlokalizowanych w Unii Europejskiej”* i jako potwierdzenie wskazuje na regulamin usługi amerykańskiego dostawcy chmury, wskazujący region lokalizacji danych w europejskim obszarze gospodarczym. Jeśli serwer w EOG obsługiwany jest przez podmiot podlegający CLOUD Act oznacza to, że władze federalne USA mogą żądać dostępu do przechowywanych na nim danych bez wiedzy i zgody europejskiego podmiotu danych, a okoliczność ta powinna być objęta procedurą Transfer Impact Assessment (TIA), jednak w praktyce audytowej jest nagminnie pomijana.

ORION rozwiązuje ten problem dwoma powiązanymi mechanizmami. Pierwszy to obowiązkowa identyfikacja poddostawców, stosowana do każdego dostawcy niezależnie od jego jurysdykcji. Drugi to trigger TIA, który dla podmiotów związanych z jurysdykcją spoza EOG dodaje sekcję `TIA`. Warunek triggera jest wyznaczany z kryteriów L4–L6 ankiety chmury (sekcja 7.2.6), dotyczących pochodzenia podmiotu hostującego, lokalizacji przechowywania danych i wsparcia technicznego, oraz z kraju pochodzenia i kontroli kapitałowej wszystkich dostawców i poddostawców w łańcuchu obiektu.

Definicja 7.1 (Identyfikacja poddostawców)**.** *Dla każdego wierzchołka typu* `DOSTAWCA` *lub* `PODDOSTAWCA` *audytor identyfikuje wszystkich jego poddostawców uczestniczących w świadczeniu usługi na rzecz podmiotu (hosting, infrastruktura, wsparcie, przetwarzanie danych). Źródłem jest deklaracja dostawcy (np. lista sub-procesorów), weryfikowana przez audytora w dokumentacji umownej i technicznej. Dla każdego poddostawcy ustala się kraj pochodzenia i kraj podmiotu sprawującego nad nim kontrolę kapitałową. Każdy zidentyfikowany*

[1] Komisja Europejska, *Decyzja wykonawcza Komisji (UE) 2023/1795 z dnia 10 lipca 2023 r. wydana na podstawie rozporządzenia (UE) 2016/679 Parlamentu Europejskiego i Rady w sprawie odpowiedniego poziomu ochrony danych osobowych na podstawie ram ochrony danych UE–USA*.

DRAFT

poddostawca jest dodawany do grafu G jako wierzchołek typu `PODDOSTAWCA`*, połączony krawędzią z dostawcą, którego obsługuje, i poddawany audytowi ORION. Procedura jest powtarzana dla nowo dodanych wierzchołków, aż do wyczerpania łańcucha. Brak poddostawców jest wynikiem identyfikacji i wymaga udokumentowania, a nie założeniem.*

Definicja 7.2 (Trigger TIA)**.** *Trigger TIA jest mechanizmem aktywowanym, gdy obiekt v spełnia co najmniej jeden warunek ze zbioru $\mathcal{C}_{TIA}$. Po aktywacji do kwestionariusza obiektu v dodawana jest sekcja* `TIA`*. Ponieważ warunek zależy od łańcucha $R(v)$, jest on wyznaczany ponownie po każdym rozszerzeniu grafu w toku identyfikacji poddostawców.*

Zbiór warunków aktywujących trigger TIA:

$$\mathcal{C}_{TIA}(v) = \Big(\textit{pochodzenie podmiotu}(v) \neq \texttt{EOG}\Big) \;\vee\; \Big(\textit{lokalizacja danych}(v) \neq \texttt{EOG}\Big) \;\vee\; \Big(\textit{wsparcie systemu}(v) \neq \texttt{EOG}\Big) \quad (7.3)$$

Dla obiektu typu `SYSTEM_INFORMATYCZNY` składniki warunku są wyznaczane z kryteriów L4–L6 ankiety chmury oraz z pochodzenia i kontroli kapitałowej podmiotów z jego łańcucha $R(v)$ (sekcja 7.2.6). Dla obiektu typu `DOSTAWCA` lub `PODDOSTAWCA` warunek zależy od jego własnego kraju pochodzenia i kontroli kapitałowej oraz od jego dalszego łańcucha: $\mathcal{C}_{TIA}(d) = \textit{obcy}(d) \vee \exists\, w \in R(d) : \textit{obcy}(w)$. Dostawca spoza EOG, kontrolowany z państwa trzeciego lub korzystający z takiego poddostawcy otrzymuje więc sekcję `TIA` sam, a jego status aktywuje ją również dla każdego obsługiwanego przez niego systemu.

Gdy $\mathcal{C}_{TIA}(v) =$ `TRUE`, do kwestionariusza obiektu v dodawana jest sekcja `TIA`, zawierająca pytania dotyczące ryzyk przekazania danych poza EOG.

Pytania w sekcji:

Obszar: **Transfer Impact Assessment (TIA RODO)**
Podstawa prawna: **RODO art. 46 / Rekomendacje EDPB 01/2020**
Zakres regulacyjny: DORA NIS2 **RODO**
Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy dla każdego transferu opartego na SCC przeprowadzono TIA oceniający, czy prawo państwa docelowego nie podważa ochrony gwarantowanej przez SCC?
- **Perspektywa użytkownika:** Czy wiesz, kto w firmie przeprowadza ocenę skutków transferu (TIA) dla tego systemu lub usługi?
- **Perspektywa techniczna:** Czy środki uzupełniające wskazane w TIA (np. szyfrowanie kluczem organizacji, pseudonimizacja) są aktywne w konfiguracji systemu lub usługi?

Obszar: **Umowa powierzenia przetwarzania (DPA)**
Podstawa prawna: **RODO art. 28**
Zakres regulacyjny: DORA NIS2 **RODO**
Typ pytania: **obowiązkowe**, blokujące: **tak**

DRAFT

- **Perspektywa zgodności:** Czy z dostawcą tego systemu lub usługi, przetwarzającym dane osobowe organizacji, zawarto umowę powierzenia zgodną z art. 28 RODO?
- **Perspektywa użytkownika:** Czy wiesz, gdzie w firmie znajduje się umowa powierzenia przetwarzania danych (DPA) z dostawcą tego systemu lub usługi lub kto może ją pokazać?
- **Perspektywa techniczna:** Czy dostęp dostawcy do danych osobowych w tym systemie lub usłudze jest technicznie ograniczony do zakresu powierzenia (np. role, zakres danych, środowiska)?

Obszar: **Oświadczenia o nieprzekazywaniu danych poza EOG**
Podstawa prawna: **RODO art. 28 ust. 3 lit. a / art. 44**
Zakres regulacyjny: DORA NIS2 **RODO**
Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja posiada od dostawcy pisemny wykaz wszystkich lokalizacji przetwarzania danych (w tym kopii zapasowych, logów i metadanych), w którym każda lokalizacja poza EOG jest objęta udokumentowaną podstawą transferu (DPF lub SCC z TIA)?
- **Perspektywa użytkownika:** Czy dostawca tego systemu lub usługi albo Twoja firma przekazali informację (np. w regulaminie usługi lub komunikacie wewnętrznym), gdzie przechowywane są dane, w tym kopie zapasowe?
- **Perspektywa techniczna:** Czy organizacja technicznie weryfikuje, że dane nie są przetwarzane w lokalizacjach nieujętych w wykazie dostawcy (np. konfiguracja regionów, monitorowanie ruchu)?

Obszar: **Koncentracja przetwarzania danych w jednej jurysdykcji**
Podstawa prawna: **RODO art. 44–49 / DORA art. 29 / Rekomendacje EDPB 01/2020**
Zakres regulacyjny: **DORA** NIS2 **RODO**
Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja oceniła ryzyko wynikające z koncentracji przetwarzania danych osobowych w jednej jurysdykcji poza EOG (np. USA) i podjęła środki techniczne i prawne ograniczające to ryzyko?
- **Perspektywa użytkownika:** Czy wiesz, gdzie sprawdzić, w jakich krajach przetwarzane są dane klientów z systemów, z których korzystasz (np. rejestr systemów, IOD)?
- **Perspektywa techniczna:** Czy konfiguracja usług (regiony, replikacja, kopie zapasowe) ogranicza przetwarzanie danych osobowych do lokalizacji wskazanych w TIA?

Obszar: **Ryzyko regulacyjne kraju dostawcy (Cloud Act / FISA)**
Podstawa prawna: **RODO art. 48 / Cloud Act 2018 / FISA 702 / Rekomendacje EDPB 01/2020**
Zakres regulacyjny: DORA NIS2 **RODO**
Typ pytania: **zalecane**, blokujące: **nie**

DRAFT

- **Perspektywa zgodności:** Czy dla dostawców spoza EOG lub kontrolowanych kapitałowo z państwa trzeciego przeprowadzono udokumentowaną ocenę ryzyka dostępu eksterytorialnego (np. Cloud Act, FISA 702)?
- **Perspektywa użytkownika:** Czy wiesz, kto w firmie może wskazać, do jakiej grupy kapitałowej należy dostawca tego systemu lub usługi i jakie ryzyka z tego wynikają?
- **Perspektywa techniczna:** Czy zastosowano środki techniczne ograniczające dostęp dostawcy do danych w postaci jawnej (np. HYOK, zewnętrzny KMS, confidential computing), odpowiednie do ryzyka wskazanego w ocenie?

Niespełnienie któregokolwiek z dwóch pytań blokujących sekcji `TIA`, tj. pytania q_{TIA} („Transfer Impact Assessment (TIA RODO)") lub pytania q_{DPA} („Umowa powierzenia przetwarzania (DPA)"), aktywuje flagę:

$$\mathrm{FLAG}_{TIA}(v) = \mathcal{C}_{TIA}(v) \ \wedge \ \mathrm{FLAG}_{block}(\mathcal{S}_{\texttt{TIA}}) \tag{7.4}$$

gdzie $\mathrm{FLAG}_{block}(\mathcal{S}_{\texttt{TIA}})$ jest wyznaczana według ogólnej reguły (7.7). Dla sekcji `TIA` sprowadza się ona do warunku $a_{TIA,zg} = 0 \vee S(q_{TIA}) < \theta_{block} \vee a_{DPA,zg} = 0 \vee S(q_{DPA}) < \theta_{block}$, gdzie $\theta_{block} = 0{,}5$. Flaga $\mathrm{FLAG}_{TIA}(v)$ jest więc szczególnym przypadkiem flagi $\mathrm{FLAG}^{obj}_{block}(v)$ (równanie (7.15)) i podlega tej samej regule nadpisania klasyfikacji (sekcja 7.4.3). Obowiązek identyfikacji poddostawców obiektu v istnieje niezależnie od wartości flagi i od spełnienia warunku $\mathcal{C}_{TIA}(v)$. Aktywna flaga oznacza natomiast, że transfer danych nie ma udokumentowanej podstawy prawnej, co jest sygnalizowane w raporcie odrębnym oznaczeniem (tabela 7.9).

7.3.10 Sekcja dostawcy ICT

Aktywacja: *aktywacja warunkowa, gdy typ obiektu* $\in \{\texttt{DOSTAWCA}, \texttt{PODDOSTAWCA}\}$
Pytania w tej sekcji służą do oceny zarządzania ryzykiem stron trzecich w odniesieniu do konkretnego dostawcy ICT, który jest obiektem audytu. Jeżeli dostawca obsługuje kilka systemów podmiotu, odpowiedź `TAK` oznacza, że wymaganie jest spełnione dla każdego z nich (zasada wspólnego obiektu, sekcja 7.3.2). Sprawdzane jest, czy przed zawarciem umowy przeprowadzono udokumentowane due diligence i ocenę ryzyka dostawcy, uzupełnione techniczną weryfikacją jego zabezpieczeń (np. skan zewnętrzny, przegląd konfiguracji, wyniki testów penetracyjnych środowiska dostawcy), a także czy udokumentowano analizę skutków awarii lub niedostępności dostawcy dla funkcji organizacji. Ocenie podlega kompletność wymogów umownych: prawo do audytu dostawcy, w tym audytu na miejscu, którego nie można zastąpić wyłącznie raportem dostawcy; dostęp organizacji do logów bezpieczeństwa prowadzonych przez dostawcę; mierzalne i egzekwowalne wskaźniki SLA (dostępność, RTO, RPO), technicznie monitorowane przez organizację; obowiązek powiadamiania o istotnych zmianach (np. zmianie sub-procesora lub lokalizacji danych); klauzula exit gwarantująca pełny eksport danych w otwartym formacie i wsparcie przejściowe oraz klauzula odpowiedzialności i regresu umożliwiająca dochodzenie zwrotu kar regulacyjnych nałożonych z winy dostawcy. Pytania blokujące obejmują brak due diligence, brak prawa do audytu, brak mierzalnych SLA oraz brak klauzul exit; dla podmiotów `KLUCZOWY` i `WAŻNY` blokujące pozostaje wyłącznie due diligence, gdyż pozostałe trzy pytania mają zakres wyłącznie DORA (równanie (7.12)). W przypadku poddostawcy organizacja nie ma z nim bezpośredniej umowy, dlatego pytania o postanowienia umowne

DRAFT

dotyczą postanowień umowy dostawcy z poddostawcą, przeniesionych na poddostawcę na podstawie umowy z dostawcą bezpośrednim, oraz dokumentacji przekazanej przez dostawcę bezpośredniego.

Pytania w sekcji:

Obszar: **Dostęp do logów bezpieczeństwa po stronie dostawcy**
Podstawa prawna: **DORA art. 10 / NIS2 art. 21**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy umowa z dostawcą gwarantuje organizacji dostęp do logów bezpieczeństwa dotyczących obsługiwanego systemu (dostępy administracyjne, zmiany konfiguracji), przechowywanych przez co najmniej 12 miesięcy?
- **Perspektywa użytkownika:** Czy wiesz, jak uzyskać informację (w systemie albo od działu IT), kto po stronie dostawcy i kiedy wykonywał operacje administracyjne w tym systemie?
- **Perspektywa techniczna:** Czy logi dostawcy dotyczące systemu (dostępy administracyjne, zmiany konfiguracji) są przekazywane organizacji automatycznie (np. przez API lub syslog do SIEM albo centralnego repozytorium logów) lub udostępniane na żądanie w ciągu 24 godzin?

Obszar: **Due diligence i ocena ryzyka dostawcy**
Podstawa prawna: **DORA art. 28 / NIS2 art. 21 ust. 2 lit. d i ust. 3 / EBA/GL/2019/02**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy przed zawarciem umowy z tym dostawcą przeprowadzono udokumentowane due diligence i ocenę ryzyka zgodne z DORA art. 28?
- **Perspektywa użytkownika:** Czy wiesz, kto w firmie ocenia i zatwierdza dostawców IT przed podpisaniem umowy?
- **Perspektywa techniczna:** Czy przed dopuszczeniem dostawcy do środowiska organizacji przeprowadzono techniczną weryfikację jego zabezpieczeń (np. skan zewnętrzny, przegląd konfiguracji, wyniki testów penetracyjnych środowiska dostawcy)?

Obszar: **Prawa audytu dostawcy (również onsite)**
Podstawa prawna: **DORA art. 30 ust. 3 lit. e / EBA/GL/2019/02**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy umowa z dostawcą zapewnia organizacji prawo do przeprowadzenia audytu (samodzielnie lub przez wyznaczonego audytora zewnętrznego) w zakresie wymagań bezpieczeństwa i zgodności, w tym audytu na miejscu (onsite), którego nie można zastąpić wyłącznie raportem dostawcy?
- **Perspektywa użytkownika:** Czy wiesz, kto w firmie odpowiada za przeprowadzanie audytów lub przeglądów tego dostawcy?

DRAFT

- **Perspektywa techniczna:** Czy audytorzy organizacji mają techniczny dostęp do dokumentacji i środowiska dostawcy na potrzeby audytu (np. konto audytowe, dostęp do konfiguracji i logów bezpieczeństwa)?

Obszar: **Analiza skutków awarii dostawcy dla funkcji organizacji**
Podstawa prawna: **DORA art. 28 / NIS2 art. 21 ust. 2 lit. a i lit. d / Komunikat UKNF 2020**
Zakres regulacyjny: **DORA** **NIS2** RODO
Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy przeprowadzono i udokumentowano analizę skutków awarii lub niedostępności tego dostawcy dla funkcji organizacji?
- **Perspektywa użytkownika:** Czy ktoś z firmy uzgadniał z Tobą lub Twoim działem, jak będziecie pracować, gdy usługa tego dostawcy przestanie działać?
- **Perspektywa techniczna:** Czy zależności systemów organizacji od usług tego dostawcy są odwzorowane w rejestrze systemów lub mapie architektury (np. CMDB)?

Obszar: **Klauzule SLA i gwarantowana dostępność**
Podstawa prawna: **DORA art. 30 ust. 2 lit. e / ust. 3 lit. a**
Zakres regulacyjny: **DORA** NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy umowa z tym dostawcą zawiera mierzalne i egzekwowalne wskaźniki SLA (dostępność, RTO, RPO) dostosowane do krytyczności obsługiwanych funkcji?
- **Perspektywa użytkownika:** Czy wiesz, gdzie sprawdzić dopuszczalny czas niedostępności tego systemu wynikający z umowy z dostawcą (np. u właściciela systemu)?
- **Perspektywa techniczna:** Czy dostępność usługi dostawcy jest mierzona technicznie przez organizację (np. monitoring dostępności) i porównywana z wartościami SLA?

Obszar: **Klauzule exit i prawo do migracji danych**
Podstawa prawna: **DORA art. 30 ust. 3 lit. f**
Zakres regulacyjny: **DORA** NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy umowa z tym dostawcą zawiera klauzulę exit obejmującą prawo do pełnego eksportu danych w otwartym formacie, wsparcie przejściowe dostawcy i zakaz utrudniania migracji?
- **Perspektywa użytkownika:** Czy osoba odpowiedzialna za umowę z dostawcą tego systemu może wskazać zapis gwarantujący zabranie wszystkich danych po zakończeniu współpracy bez dodatkowych opłat?
- **Perspektywa techniczna:** Czy format i interfejs eksportu danych wskazane w umowie są udokumentowane technicznie (specyfikacja formatu, opis interfejsu) w sposób pozwalający organizacji przeprowadzić eksport?

DRAFT

Obszar: **Klauzule powiadomień o zmianach u dostawcy**
Podstawa prawna: **DORA art. 30 ust. 2 lit. b / ust. 3 lit. b**
Zakres regulacyjny: **DORA** NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy umowa z tym dostawcą zobowiązuje go do uprzedniego informowania organizacji o istotnych zmianach (np. sub-procesorów, lokalizacji danych, architektury bezpieczeństwa, struktury właścicielskiej)?
- **Perspektywa użytkownika:** Czy wiesz, kto w firmie otrzymuje od dostawcy powiadomienia o istotnych zmianach w usłudze (np. zmianie centrum danych lub podwykonawcy)?
- **Perspektywa techniczna:** Czy organizacja technicznie wykrywa zmiany po stronie dostawcy (np. zmianę regionu przetwarzania, adresów IP, rekordów DNS, listy subprocesorów) i porównuje je z otrzymanymi powiadomieniami?

Obszar: **Klauzule odpowiedzialności i regres od dostawcy**
Podstawa prawna: **dobra praktyka (brak wymogu ustawowego)**
Zakres regulacyjny: DORA NIS2 RODO (dobra praktyka)
Typ pytania: **zalecane**, blokujące: **nie**

- **Perspektywa zgodności:** Czy umowa z tym dostawcą zawiera klauzulę umożliwiającą organizacji dochodzenie regresem kosztów kar regulacyjnych (KNF, UODO) nałożonych z winy dostawcy, bez ograniczenia odpowiedzialności do wartości ostatniej faktury?
- **Perspektywa użytkownika:** Czy osoba odpowiedzialna za umowę z dostawcą może wskazać w umowie zapis o odpowiedzialności dostawcy za kary regulacyjne spowodowane jego błędem?
- **Perspektywa techniczna:** Czy incydenty po stronie dostawcy są dokumentowane technicznie (logi, osie czasu, raporty z analizy przyczyn) w sposób umożliwiający wykazanie winy dostawcy w razie dochodzenia roszczeń?

7.3.11 Sekcja exit plan

Aktywacja: *aktywacja warunkowa, gdy typ obiektu* = `SYSTEM_INFORMATYCZNY` **ORAZ** *krytyczność*$(v) \in \{$`KRYTYCZNY`, `WAŻNY`$\}$ **ORAZ** *system jest obsługiwany przez co najmniej jednego dostawcę* $(\exists\, d : (v, d) \in E_{svc})$ **ORAZ** *klasyfikacja podmiotu* $\in \{$`FINANSOWY`, `KLUCZOWY`$\}$
Warunek krytyczności odpowiada zakresowi art. 28 ust. 8 rozporządzenia DORA, który wymaga strategii wyjścia w odniesieniu do usług ICT wspierających krytyczne lub istotne funkcje. Pytania w tej sekcji służą do oceny gotowości organizacji do zakończenia współpracy z dostawcą ICT w sposób kontrolowany, bez utraty danych i bez zakłócenia ciągłości działania obsługiwanych funkcji krytycznych. Exit plan jest traktowany jako dokument żywy, zatwierdzony przez zarząd i aktualizowany przy każdej istotnej zmianie systemu lub dostawcy, zawierający konkretne kroki techniczne migracji, a nie jedynie deklaratywny opis intencji. Sprawdzane jest, czy exit plan gwarantuje pełny eksport danych w otwartym formacie niezależnym od narzędzi własnościowych dostawcy oraz czy procedura eksportu została przetestowana, a jej czas i kompletność udokumentowano. Ocenie podlega udokumentowany i zweryfikowany w teście czas pełnej migracji (RTE) wraz z kosztami wyjścia,

DRAFT

zidentyfikowanie alternatywnego dostawcy zdolnego do przejęcia funkcji, procedura weryfikacji bezpiecznego usunięcia wszystkich danych z infrastruktury dostawcy po migracji oraz testowanie exit planu co najmniej raz w roku z rzeczywistą próbą eksportu i importu danych do środowiska zastępczego. Pytaniem blokującym jest brak formalnego, zatwierdzonego exit planu.

Pytania w sekcji:

Obszar: **Istnienie i zatwierdzenie exit planu**
Podstawa prawna: **DORA art. 28 ust. 8**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy dla systemu istnieje formalny, zatwierdzony przez zarząd exit plan, traktowany jako dokument żywy aktualizowany przy każdej istotnej zmianie?
- **Perspektywa użytkownika:** Czy wiesz, kto w firmie odpowiada za plan zmiany dostawcy tej aplikacji na wypadek zakończenia współpracy lub zaprzestania działalności przez dostawcę?
- **Perspektywa techniczna:** Czy narzędzia i skrypty migracyjne wskazane w exit planie są dostępne w repozytorium organizacji i aktualne względem obecnej wersji systemu?

Obszar: **Kompletność i możliwość eksportu danych**
Podstawa prawna: **DORA art. 30 ust. 2 lit. d / art. 28 ust. 8**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy exit plan gwarantuje pełny eksport danych w otwartym formacie bez uzależnienia od narzędzi własnościowych dostawcy?
- **Perspektywa użytkownika:** Czy dane z systemu można pobrać w całości i otworzyć np. w Excelu lub innym standardowym programie?
- **Perspektywa techniczna:** Czy dla tego systemu zdefiniowano i przetestowano procedurę eksportu pełnego zbioru danych do formatu niezależnego od dostawcy, a czas i kompletność eksportu są udokumentowane w ramach testów ciągłości działania (BCP/DRP)?

Obszar: **Czas i koszty wyjścia (RTE)**
Podstawa prawna: **DORA art. 28 ust. 8**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **informacyjne**, blokujące: **nie**

- **Perspektywa zgodności:** Czy exit plan zawiera udokumentowany czas pełnej migracji (RTE) i koszty wyjścia zatwierdzone przez zarząd?
- **Perspektywa użytkownika:** Czy wiesz, ile czasu zajęłoby Twojej firmie przejście na inny system, gdyby obecny dostawca przestał działać?

DRAFT

- **Perspektywa techniczna:** Czy istnieje udokumentowana i zweryfikowana w teście analiza kosztów i czasu wyjścia obejmująca: czas migracji danych, koszt wdrożenia alternatywnego systemu, koszty równoległego utrzymania obu środowisk oraz ryzyko utraty ciągłości działania?

Obszar: **Alternatywny dostawca i przenośność usługi**
Podstawa prawna: **DORA art. 28 ust. 8**
Zakres regulacyjny: **DORA** NIS2 RODO
Typ pytania: **zalecane**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja zidentyfikowała co najmniej jednego alternatywnego dostawcę mogącego przejąć funkcję i oceniła jego zdolność do onboardingu?
- **Perspektywa użytkownika:** Gdyby firma, od której kupujemy ten system przestała działać czy Twoja organizacja ma już na liście inną firmę, która mogłaby przejąć tę usługę?
- **Perspektywa techniczna:** Czy architektura systemu jest zaprojektowana z myślą o przenośności - otwarte standardy, brak vendor lock-in na poziomie formatu i API?

Obszar: **Bezpieczne usunięcie danych u dostawcy po wyjściu**
Podstawa prawna: **RODO art. 28 ust. 3 lit. g / DORA art. 30 ust. 2 lit. d**
Zakres regulacyjny: **DORA** NIS2 **RODO**
Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy exit plan zawiera procedurę weryfikacji bezpiecznego usunięcia wszystkich danych organizacji z infrastruktury dostawcy po migracji?
- **Perspektywa użytkownika:** Czy wiesz, kto w firmie odbiera od dostawcy potwierdzenie usunięcia danych po zakończeniu współpracy?
- **Perspektywa techniczna:** Czy dla tego systemu zdefiniowano techniczną procedurę weryfikacji usunięcia danych u dostawcy (np. likwidacja kont, instancji i kluczy szyfrujących, certyfikat zniszczenia obejmujący kopie zapasowe i logi)?

Obszar: **Testowanie exit planu**
Podstawa prawna: **DORA art. 28 ust. 8**
Zakres regulacyjny: **DORA** NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy exit plan jest testowany co najmniej raz w roku z udokumentowanymi wynikami dostępnymi dla audytorów?
- **Perspektywa użytkownika:** Czy wiesz, gdzie znaleźć wyniki ostatniego testu exit planu tego systemu lub kto je przechowuje?
- **Perspektywa techniczna:** Czy test exit planu obejmuje rzeczywistą próbę eksportu i importu danych do środowiska zastępczego?

DRAFT

7.3.12 Sekcja plan ciągłości działania (BCP)

Aktywacja: *aktywacja warunkowa, gdy typ obiektu* = `SYSTEM_INFORMATYCZNY` **ORAZ** *krytyczność*$(v) \in \{$`KRYTYCZNY`, `WAŻNY`$\}$ **ORAZ** *klasyfikacja podmiotu* $\in \{$`FINANSOWY`, `KLUCZOWY`, `WAŻNY`$\}$
Pytania w tej sekcji służą do oceny zdolności organizacji do utrzymania lub sprawnego odtworzenia funkcji krytycznych w przypadku poważnego incydentu ICT, awarii dostawcy lub katastrofy. Sprawdzane jest, czy formalny, zatwierdzony przez zarząd plan BCP/DRP obejmuje dany system i wspieraną przez niego funkcję oraz czy zawiera dla systemu konkretne instrukcje wykonawcze (kroki techniczne, sekwencje przełączeń). Ocenie podlega zakres scenariuszy ujętych w planie (np. ransomware, utrata centrum danych, niedostępność dostawcy) z odrębną ścieżką odtwarzania dla każdego z nich, scenariusz awarii kaskadowej w łańcuchu dostaw, test planu w ciągu ostatnich 12 miesięcy z rzeczywistym przełączeniem na środowisko zapasowe i pomiarem osiągniętego RTO/RPO oraz plan komunikacji kryzysowej obejmujący użytkowników systemu. Pytaniem blokującym jest brak formalnych, zatwierdzonych planów BCP i DRP.

Pytania w sekcji:

Obszar: **Istnienie i zatwierdzenie planów BCP/DRP**
Podstawa prawna: **DORA art. 11 / NIS2 art. 21 ust. 2 lit. c**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy formalny, zatwierdzony przez zarząd plan BCP/DRP obejmuje ten system i wspieraną przez niego funkcję?
- **Perspektywa użytkownika:** Czy wiesz, jak pracować, gdy aplikacja jest niedostępna przez kilka godzin?
- **Perspektywa techniczna:** Czy BCP/DRP zawiera dla tego systemu konkretne instrukcje wykonawcze (kroki techniczne, sekwencje przełączeń, drzewa decyzyjne), a nie wyłącznie ogólny opis zasad?

Obszar: **Scenariusze zagrożeń w BCP/DRP**
Podstawa prawna: **DORA art. 11 / NIS2 art. 21**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy BCP/DRP obejmuje dla tego systemu zestaw scenariuszy zagrożeń (np. ransomware, utrata centrum danych, niedostępność dostawcy, atak na łańcuch dostaw)?
- **Perspektywa użytkownika:** Czy wiesz, co masz zrobić i od kogo otrzymasz instrukcje, jeśli ten system zostanie dziś zaszyfrowany przez ransomware?
- **Perspektywa techniczna:** Czy dla każdego scenariusza dotyczącego tego systemu zdefiniowano odrębną ścieżkę odtwarzania z konkretnymi krokami technicznymi?

Obszar: **Testowanie BCP/DRP**
Podstawa prawna: **DORA art. 11 ust. 6 / NIS2 art. 21 ust. 2 lit. c i lit. f**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **nie**

DRAFT

- **Perspektywa zgodności:** Czy plan ciągłości obejmujący ten system był testowany w ciągu ostatnich 12 miesięcy z udokumentowanymi wynikami dostępnymi dla audytorów?
- **Perspektywa użytkownika:** Czy Ty lub Twój dział uczestniczyliście w ciągu ostatnich 12 miesięcy w ćwiczeniu awaryjnym dotyczącym tego systemu?
- **Perspektywa techniczna:** Czy test obejmował rzeczywiste przełączenie tego systemu na środowisko zapasowe z pomiarem osiągniętego RTO/RPO (a nie wyłącznie ćwiczenie teoretyczne typu tabletop)?

Obszar: **Komunikacja kryzysowa**
Podstawa prawna: **NIS2 art. 21 ust. 2 lit. c / NIS2 art. 23 / DORA art. 14**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **zalecane**, blokujące: **nie**

- **Perspektywa zgodności:** Czy BCP zawiera plan komunikacji kryzysowej obejmujący użytkowników tego systemu (gotowe szablony, upoważnienia do komunikacji zewnętrznej)?
- **Perspektywa użytkownika:** Czy masz zapisany poza komputerem (np. w telefonie lub na papierze) kontakt do przełożonego i działu IT na wypadek niedostępności firmowych systemów komunikacji?
- **Perspektywa techniczna:** Czy dla użytkowników tego systemu istnieje alternatywny kanał komunikacji działający niezależnie od głównej infrastruktury IT (gdy e-mail i komunikator są niedostępne)?

Obszar: **Scenariusz awarii kaskadowej w łańcuchu dostaw**
Podstawa prawna: **DORA art. 11 / art. 29 ust. 1 / NIS2 art. 21 ust. 2 lit. c i lit. d**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy BCP/DRP zawiera scenariusz awarii kaskadowej, w którym awaria jednego dostawcy wywołuje niedostępność powiązanych usług, w tym tego systemu?
- **Perspektywa użytkownika:** Czy wiesz, gdzie znaleźć instrukcję postępowania na wypadek awarii dostawcy, od którego zależy ten system?
- **Perspektywa techniczna:** Czy mapa zależności w rejestrze systemów obejmuje dostawców i poddostawców (poziomy 1–3) powiązanych z tym systemem?

7.3.13 Sekcja koncentracja ryzyka

Aktywacja: *sekcja aktywna jednorazowo dla całego audytowanego podmiotu, gdy od co najmniej jednego dostawcy lub poddostawcy zależy, bezpośrednio lub pośrednio,* $\geq n^*_{KV} = 3$ *systemy podmiotu (równanie* (7.20)*)*
Pytania w tej sekcji są sformułowane na poziomie organizacji i służą do oceny narażenia

DRAFT

organizacji na ryzyko nadmiernego uzależnienia od ograniczonej liczby zewnętrznych dostawców ICT, grup powiązanych dostawców lub lokalizacji geograficznych, co może skutkować systemowym zakłóceniem funkcji krytycznych w przypadku pojedynczej awarii lub incydentu. Ryzyko koncentracji jest oceniane w czterech wymiarach: podmiotowym: uzależnienie od jednego dostawcy lub grupy kapitałowej; geograficznym: koncentracja przetwarzania w jednej lokalizacji lub jurysdykcji prawnej; technologicznym: vendor lock-in wynikający z zastrzeżonych formatów danych lub interfejsów API uniemożliwiających migrację; oraz systemowym: wspólna infrastruktura bazowa leżąca u podstaw pozornie niezależnych dostawców warstwy aplikacyjnej. Pytania blokujące obejmują brak mapowania funkcji krytycznych do dostawców, brak oceny ryzyka koncentracji u jednego dostawcy oraz brak oceny koncentracji u grupy powiązanych dostawców; mają one zakres wyłącznie DORA, więc są blokujące tylko dla podmiotu `FINANSOWY`.

Pytania w sekcji:

Obszar: **Mapowanie funkcji krytycznych do dostawców**
Podstawa prawna: **DORA art. 28 ust. 4 lit. a / art. 29 ust. 1**
Zakres regulacyjny: **DORA** NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy dla każdej funkcji krytycznej lub istotnej organizacja zidentyfikowała zewnętrznych dostawców ICT ją wspierających i oceniła stopień uzależnienia od każdego z nich?
- **Perspektywa użytkownika:** Czy wiesz, co stanie się z Twoją pracą, jeśli kluczowy zewnętrzny dostawca IT będzie niedostępny przez 24 godziny?
- **Perspektywa techniczna:** Czy mapa zależności funkcja–dostawca jest aktualizowana przy każdej zmianie architektury i dostępna dla zarządu oraz audytorów w formie dokumentacji GRC?

Obszar: **Identyfikacja sub-procesorów i łańcucha dostaw**
Podstawa prawna: **DORA art. 29 ust. 2 / RODO art. 28 ust. 2**
Zakres regulacyjny: **DORA** NIS2 **RODO**
Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja zidentyfikowała wszystkich sub-procesorów kluczowych dostawców ICT i oceniła ryzyko wynikające z ich działalności, w tym ryzyko kaskadowe?
- **Perspektywa użytkownika:** Czy wiesz, gdzie znaleźć listę podwykonawców (sub-procesorów) głównego dostawcy IT, z którego korzysta Twój dział?
- **Perspektywa techniczna:** Czy organizacja technicznie monitoruje publikowane przez kluczowych dostawców listy sub-procesorów (np. subskrypcja powiadomień, okresowy przegląd) i odnotowuje każdą zmianę w rejestrze dostawców?

Obszar: **Ocena ryzyka koncentracji u jednego dostawcy**
Podstawa prawna: **DORA art. 29 ust. 1 / Komunikat UKNF 2020**
Zakres regulacyjny: **DORA** NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **tak**

DRAFT

- **Perspektywa zgodności:** Czy organizacja przeprowadziła formalną ocenę ryzyka koncentracji dla każdego kluczowego dostawcy ICT, oceniając stopień uzależnienia, brak alternatyw i trudność migracji?
- **Perspektywa użytkownika:** Czy wiesz, które kluczowe procesy Twojej firmy zatrzymałyby się, gdyby jeden główny dostawca IT nagle przestał działać?
- **Perspektywa techniczna:** Czy dane o udziale dostawcy w obsłudze funkcji krytycznych (np. liczba systemów, wolumen transakcji) są pozyskiwane z rejestru systemów lub monitoringu, a nie szacowane?

Obszar: **Ryzyko koncentracji geograficznej (lokalizacja danych)**
Podstawa prawna: **DORA art. 29 ust. 1 / RODO art. 44–49 / Rekomendacje EDPB 01/2020**
Zakres regulacyjny: **DORA** NIS2 **RODO**
Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja oceniła ryzyko wynikające z koncentracji danych i usług w jednej lokalizacji geograficznej lub jednym centrum danych, w tym ryzyko awarii regionalnej lub klęski żywiołowej?
- **Perspektywa użytkownika:** Czy wiesz, w jakim kraju lub regionie znajdują się serwery, na których przechowywane są dane Twojej organizacji?
- **Perspektywa techniczna:** Czy dane i usługi wspierające funkcje krytyczne są replikowane do co najmniej dwóch geograficznie odrębnych lokalizacji (np. w trybie aktywny–aktywny lub aktywny–pasywny)?

Obszar: **Ryzyko koncentracji u grupy powiązanych dostawców**
Podstawa prawna: **DORA art. 29 ust. 1**
Zakres regulacyjny: **DORA** NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **tak**

- **Perspektywa zgodności:** Czy organizacja oceniła, czy kilku pozornie różnych dostawców ICT nie należy do tej samej grupy kapitałowej lub nie korzysta z tych samych krytycznych usług infrastrukturalnych (np. tego samego CSP)?
- **Perspektywa użytkownika:** Czy wiesz, kto w firmie odpowiada za ocenę uzależnienia od dostawców IT, z których korzysta Twój dział?
- **Perspektywa techniczna:** Czy rejestr systemów lub mapa architektury wskazuje dla każdego systemu dostawcę infrastruktury bazowej (np. dostawcę chmury, centrum danych), także pośredniego?

Obszar: **Próg koncentracji i limity umowne**
Podstawa prawna: **DORA art. 29 ust. 1**
Zakres regulacyjny: **DORA** NIS2 RODO
Typ pytania: **zalecane**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja ustaliła i zatwierdziła formalne progi koncentracji (np. maksymalny odsetek funkcji krytycznych obsługiwanych przez jednego dostawcę)?

DRAFT

- **Perspektywa użytkownika:** Czy wiesz, kto w firmie monitoruje progi uzależnienia od dostawców IT?
- **Perspektywa techniczna:** Czy narzędzie do zarządzania dostawcami (np. GRC lub rozwiązanie równoważne) sygnalizuje przekroczenie zdefiniowanego progu koncentracji dla dostawcy lub grupy dostawców?

Obszar: **Strategia multi-cloud i multi-vendor**
Podstawa prawna: **DORA art. 29 ust. 1 / art. 28 ust. 5**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **zalecane**, blokujące: **nie**

- **Perspektywa zgodności:** Czy organizacja wdrożyła strategię multi-cloud lub multi-vendor dla usług krytycznych, uniemożliwiającą uzależnienie od jednego dostawcy chmury lub technologii?
- **Perspektywa użytkownika:** Czy dla kluczowych narzędzi, z których korzystasz, istnieje rozwiązanie zapasowe innego dostawcy, na które można się przełączyć w razie awarii?
- **Perspektywa techniczna:** Czy architektura zakłada aktywne użytkowanie co najmniej dwóch niezależnych dostawców chmury dla funkcji krytycznych (nie tylko backup), z automatycznym failover przetestowanym empirycznie?

Obszar: **Plan redukcji koncentracji dla zidentyfikowanych ryzyk**
Podstawa prawna: **DORA art. 29 ust. 1 / art. 6 ust. 5**
Zakres regulacyjny: DORA NIS2 RODO
Typ pytania: **obowiązkowe**, blokujące: **nie**

- **Perspektywa zgodności:** Czy dla każdego zidentyfikowanego ryzyka koncentracji przekraczającego ustalone progi opracowano i zatwierdzono plan jego redukcji z harmonogramem i miernikami sukcesu?
- **Perspektywa użytkownika:** Czy wiesz, kto w firmie odpowiada za realizację planu ograniczenia uzależnienia od dostawców IT?
- **Perspektywa techniczna:** Czy działania z planu redukcji koncentracji są zarejestrowane w systemie zarządzania zadaniami lub projektami z przypisanymi właścicielami i terminami?

DRAFT

Tabela 7.6: Podsumowanie pytań audytowych ORION i warunki aktywacji

Sekcja	**Typ obiektu**	**Warunek aktywacji**
Organizacja	PODMIOT	zawsze (składnik $\mathcal{S}_{\texttt{PODMIOT}}$)
Bezpieczeństwo techniczne	PODMIOT	zawsze (składnik $\mathcal{S}_{\texttt{PODMIOT}}$)
Bezpieczeństwo fizyczne	PODMIOT	zawsze (składnik $\mathcal{S}_{\texttt{PODMIOT}}$)
Dane poufne: dane osobowe, w tym szczególne kategorie danych osobowych, oraz tajemnice przedsiębiorstwa	PODMIOT	$\exists\, u \in V : D(u) \cap \{W, O\} \neq \emptyset$ (co najmniej jeden system z kategorią SZCZEGÓLNE lub OSOBOWE)
Koncentracja ryzyka	PODMIOT	$\exists\, w : \lvert\{u \in V_{SYS} : w \in R(u)\}\rvert \geq n^*_{KV}$ (dostawca lub poddostawca)
System informatyczny	SYSTEM_INFORMATYCZNY	zawsze (składnik $\mathcal{S}_{\texttt{SYSTEM_INFORMATYCZNY}}$)
Usługi w chmurze	SYSTEM_INFORMATYCZNY	$\mathit{Utrzymanie_chmura}(v) \in \{\texttt{CHMURA_K3}, \texttt{CHMURA_EOG}\}$
Transfer Impact Assessment (TIA)	SYSTEM_INFORMATYCZNY, DOSTAWCA, PODDOSTAWCA	$\mathit{TIA}(v) = \texttt{TRUE}$ (równanie (7.3))
Plan ciągłości działania (BCP)	SYSTEM_INFORMATYCZNY	$\mathit{Krytyczność}(v) \in \{\texttt{KRYTYCZNY}, \texttt{WAŻNY}\}$ **ORAZ** $k(v_0) \in \{\texttt{FINANSOWY}, \texttt{KLUCZOWY}, \texttt{WAŻNY}\}$
Exit plan	SYSTEM_INFORMATYCZNY	$\mathit{Krytyczność}(v) \in \{\texttt{KRYTYCZNY}, \texttt{WAŻNY}\}$ **ORAZ** $\exists\, d : (v, d) \in E_{svc}$ **ORAZ** $k(v_0) \in \{\texttt{FINANSOWY}, \texttt{KLUCZOWY}\}$
Dostawcy ICT	DOSTAWCA, PODDOSTAWCA	zawsze (składnik $\mathcal{S}_{\texttt{DOSTAWCA}}$)

7.4 Faza 4: Obliczenie scoringu i propagacja ryzyka

Po zebraniu wszystkich odpowiedzi i dowodów dla wszystkich obiektów w grafie ICT system ORION oblicza wyniki scoringowe na czterech poziomach agregacji: pytania, sekcji, obiektu i podmiotu.

7.4.1 Poziom 1: Wynik pytania

Wynik pojedynczego pytania q_j jest wyznaczany na podstawie konsensusu perspektyw, które udzieliły odpowiedzi, z karą za brak jednomyślności (definicja 6.1):

DRAFT

$$S(q_j) = \begin{cases} \bar{d}_j^{+} & \text{jeśli wszystkie perspektywy z } \Pi_{q_j} \text{ odpowiedziały } \texttt{TAK}, \\ \beta_{cv} \cdot \bar{d}_j^{+} & \text{jeśli większość odpowiedziała } \texttt{TAK}\text{, lecz nie wszystkie}, \\ 0 & \text{jeśli większość odpowiedziała } \texttt{NIE} \text{ lub wystąpił remis}, \end{cases} \tag{7.5}$$

gdzie Π_{q_j} jest zbiorem perspektyw, którym zadano pytanie q_j i które udzieliły odpowiedzi `TAK` lub `NIE` (perspektywy z odpowiedzią `N/D` są ze zbioru wyłączone), $\bar{d}_j^{+}$ jest ważoną średnią efektywnych wartości odpowiedzi $V_{eff}(q_j, \pi_i)$ (równanie (6.1)) perspektyw, które odpowiedziały `TAK`, a $\beta_{cv} = 0{,}5$ jest współczynnikiem kary za brak jednomyślności (równanie (6.3)). Przy ustalaniu większości odpowiedź `TAK` bez żadnego dowodu ($d_{ij} = 0$) liczy się jak `NIE` (definicja 6.1). Perspektywa użytkownika składa odpowiedzi jako podpisane oświadczenie imienne, co odpowiada dowodowi średniemu $d = 0{,}7$ (albo silnemu $d = 1{,}0$ przy podpisie z poświadczeniem tożsamości); perspektywy zgodności i techniczna są oceniane według przedstawionych dowodów. Przy dowodach silnych po stronie zgodności i techniki jednomyślne `TAK` daje więc $\bar{d}_j^{+} = (1 + 1 + 0{,}7)/3 = 0{,}9$, a dwie odpowiedzi `TAK` tych perspektyw przy `NIE` użytkownika dają $0{,}5 \cdot 1{,}0 = 0{,}5$. Wynik pytania zawsze mieści się w przedziale $[0, 1]$. W rdzeniu metodycznym wszystkie perspektywy mają równą wagę $w_{\pi_i} = 1$. Wagi perspektyw mogą być różnicowane w rozszerzeniach domenowych, na przykład w module finansowym DORA perspektywa zgodności może otrzymać wyższą wagę w pytaniach dotyczących obowiązków sprawozdawczych.

Wyłączenie pytania (`N/D`). Pytanie q_j jest wyłączane z oceny, gdy odpowiedź `N/D` zaznaczyła perspektywa zgodności albo co najmniej dwie perspektywy. Zbiór pytań sekcji $\mathcal{S}_k$ uwzględnianych w scoringu oznaczamy

$$\mathcal{Q}_k^{*} = \Big\{ q_j \in \mathcal{S}_k : \neg\Big(r_{j,zg} = \texttt{N/D} \;\vee\; \big|\{\pi_i : r_{ij} = \texttt{N/D}\}\big| \geq 2 \Big) \Big\}, \tag{7.6}$$

gdzie r_{ij} jest odpowiedzią perspektywy π_i na pytanie q_j, a $r_{j,zg}$ odpowiedzią perspektywy zgodności. Reguła ta gwarantuje, że dla każdego $q_j \in \mathcal{Q}_k^{*}$ zadanego trzem perspektywom zachodzi $|\Pi_{q_j}| \geq 2$, co spełnia wymóg definicji konsensusu (definicja 6.1). Przypadek pustego zbioru Π_{q_j} nie występuje: brak odpowiedzi jest traktowany jak `NIE` (sekcja 7.3.2), a pytanie z więcej niż jedną odpowiedzią `N/D` jest wyłączane w całości. Jeżeli wszystkie pytania sekcji zostaną wyłączone ($\mathcal{Q}_k^{*} = \emptyset$), sekcja jest usuwana ze zbioru $\mathcal{S}(v)$ i nie wchodzi do równania (7.14).

7.4.2 Poziom 2: Wynik sekcji

Wynik sekcji tematycznej $\mathcal{S}_k$ jest wyznaczany jako ważona średnia wyników wszystkich pytań należących do tej sekcji, z uwzględnieniem obligatoryjności pytania.

Wynik sekcji $\mathcal{S}_k$ jest wyznaczany dwuetapowo na zbiorze pytań $\mathcal{Q}_k^{*}$ (równanie (7.6)). Najpierw sprawdzany jest warunek blokujący. Pytanie blokujące uznaje się za niespełnione, gdy perspektywa zgodności, która weryfikuje istnienie wymaganego dokumentu lub zapisu (sekcja 7.3.2), odpowiedziała `NIE`, albo gdy wynik pytania nie osiąga progu θ_{block}:

$$\mathrm{FLAG}_{block}(\mathcal{S}_k) = \texttt{TRUE} \iff \exists\, q_j \in \mathcal{Q}_k^{*} : \kappa_{eff}\Big(q_j, k(v_0)\Big) = \texttt{BLOKUJĄCE} \wedge \Big(a_{j,zg} = 0 \vee S(q_j) < \theta_{block}\Big) \tag{7.7}$$

DRAFT

gdzie $a_{j,zg} \in \{0,1\}$ jest odpowiedzią perspektywy zgodności na pytanie q_j, $S(q_j)$ jest wynikiem pytania według równania (7.5), $\theta_{block} = 0{,}5$ jest progiem blokady, a $\kappa_{eff}(q_j, k)$ jest efektywnym statusem blokującym pytania, określonym niżej wraz z wagą ω. Warunek jest spójny z modelem dowodowym $V_{eff} = a_{ij} \cdot d_{ij}$ (równanie (6.1)). Przy podpisanym oświadczeniu użytkownika ($d = 0{,}7$) typowe przypadki są następujące:

- jednomyślne `TAK` z dowodami silnymi zgodności i techniki daje $S(q_j) = 0{,}9$; blokada nie jest aktywna;
- jednomyślne `TAK` z dowodami słabymi ($d = 0{,}4$) zgodności i techniki daje $S(q_j) = (0{,}4 + 0{,}4 + 0{,}7)/3 = 0{,}5$, czyli wartość równą progowi; blokada nie jest aktywna, ale nie ma już marginesu;
- `TAK` zgodności i techniki z dowodami silnymi przy `NIE` użytkownika daje $S(q_j) = 0{,}5$; blokada nie jest aktywna;
- `TAK` zgodności i użytkownika przy `NIE` perspektywy technicznej daje $S(q_j) = 0{,}5 \cdot (1{,}0 + 0{,}7)/2 = 0{,}425 < \theta_{block}$; blokada jest aktywna;
- `TAK` perspektywy zgodności przy dwóch odpowiedziach `NIE` daje $S(q_j) = 0$; blokada jest aktywna;
- `NIE` perspektywy zgodności zawsze aktywuje blokadę, niezależnie od wyniku pytania.

W pytaniu blokującym każda rozbieżność, w której wymaganie nie zostało potwierdzone przez perspektywę zgodności lub techniczną, aktywuje więc blokadę sekcji. Brak potwierdzenia wyłącznie przez użytkownika jej nie aktywuje, o ile obie pozostałe perspektywy przedstawiły dowody silne.
Jeśli $\mathrm{FLAG}_{block}(\mathcal{S}_k) = \texttt{TRUE}$, wynik sekcji wynosi zero niezależnie od pozostałych odpowiedzi:

$$S(\mathcal{S}_k) = 0 \qquad \text{jeśli } \mathrm{FLAG}_{block}(\mathcal{S}_k) = \texttt{TRUE} \tag{7.8}$$

W przeciwnym razie wynik sekcji jest wyznaczany jako ważona średnia wyników pytań:

$$S(\mathcal{S}_k) = \frac{\sum\limits_{q_j \in \mathcal{Q}_k^*} S(q_j) \cdot \omega(q_j, k(v_0))}{\sum\limits_{q_j \in \mathcal{Q}_k^*} \omega(q_j, k(v_0))} \tag{7.9}$$

gdzie $\omega(q_j, k)$ jest wagą pytania wynikającą z jego efektywnej obligatoryjności $\tau_{eff}(q_j, k)$ przy klasie regulacyjnej podmiotu $k = k(v_0)$ (równanie (7.1)):

$$\omega(q_j, k) = \begin{cases} 2{,}0 & \text{jeśli } \tau_{eff}(q_j, k) = \text{OBOWIĄZKOWE} \\ 1{,}0 & \text{jeśli } \tau_{eff}(q_j, k) = \text{ZALECANE} \\ 0{,}5 & \text{jeśli } \tau_{eff}(q_j, k) = \text{INFORMACYJNE} \end{cases} \tag{7.10}$$

Efektywna obligatoryjność zależy od typu pytania $\tau(q_j)$ (kolumna „Typ pytania”) oraz od tego, czy zakres regulacyjny pytania $\mathrm{zakres}(q_j)$ (kolumna „Zakres”) obejmuje akt mający zastosowanie do podmiotu danej klasy. Zbiór aktów stosowanych do podmiotu klasy k oznaczamy $\mathcal{A}_{reg}(k)$:

DRAFT

$$\mathcal{A}_{reg}(k) = \begin{cases} \{\texttt{DORA}, \texttt{RODO}\} & \text{dla } k = \texttt{FINANSOWY}, \\ \{\texttt{NIS2}, \texttt{RODO}\} & \text{dla } k \in \{\texttt{KLUCZOWY}, \texttt{WAŻNY}\}, \\ \{\texttt{RODO}\} & \text{dla } k = \texttt{POZOSTAŁE}, \end{cases} \tag{7.11}$$

$$\tau_{eff}(q_j, k) = \begin{cases} \text{ZALECANE} & \text{jeśli } \tau(q_j) = \text{OBOWIĄZKOWE} \ \wedge \ \text{zakres}(q_j) \cap \mathcal{A}_{reg}(k) = \emptyset, \\ \tau(q_j) & \text{w przeciwnym razie,} \end{cases} \tag{7.12}$$

$$\kappa_{eff}(q_j, k) = \texttt{BLOKUJĄCE} \iff \kappa(q_j) = \texttt{BLOKUJĄCE} \ \wedge \ \tau_{eff}(q_j, k) = \text{OBOWIĄZKOWE}, \tag{7.13}$$

gdzie $\kappa(q_j)$ jest statusem blokującym pytania z kwestionariusza (kolumna „Blokujące"). Klasa regulacyjna podmiotu wpływa więc nie tylko na wagi pytań, lecz także na to, które pytania są blokujące. Dla podmiotu finansowego NIS2 nie jest uwzględniana, ponieważ w zakresie zarządzania ryzykiem ICT i zgłaszania incydentów pierwszeństwo ma rozporządzenie DORA (art. 4 dyrektywy NIS2). Wszystkie pytania kwestionariusza mające podstawę w NIS2 mają jednocześnie podstawę w DORA lub RODO, zatem dla tej klasy żadne pytanie nie traci statusu obowiązkowego. Pytania, których podstawą jest RODO, pozostają obowiązkowe dla wszystkich klas, gdyż RODO stosuje się niezależnie od klasyfikacji według NIS2 i DORA. Pytanie obowiązkowe spoza zakresu aktów danej klasy zachowuje wagę pytania zalecanego, ponieważ opisuje dobrą praktykę bezpieczeństwa, lecz nie jest blokujące.

Dla podmiotów `KLUCZOWY` i `WAŻNY` status zalecanych otrzymuje 12 pytań obowiązkowych, których zakres obejmuje wyłącznie DORA. Osiem z nich to pytania blokujące: prawo do audytu dostawcy, klauzule SLA, klauzule exit, istnienie exit planu, rejestr dostawców ICT oraz trzy pytania o ryzyko koncentracji. Dyrektywa NIS2 wymaga bezpieczeństwa łańcucha dostaw w sposób ogólny (art. 21 ust. 2 lit. d i ust. 3), lecz nie nakłada obowiązku określonych klauzul umownych, rejestru informacji, strategii wyjścia ani oceny ryzyka koncentracji. Liczbę pytań obowiązkowych i blokujących w poszczególnych klasach przedstawia tabela 7.1.

Pytania, dla których $\tau_{eff} = \text{OBOWIĄZKOWE}$, wynikają bezpośrednio z przepisów prawa i mają podwojoną wagę względem pytań zalecanych. Pytanie obowiązkowe z wynikiem $S(q_j) < 0{,}3$ generuje rekomendację o priorytecie P1 niezależnie od wyniku sekcji (tabela 7.10).

7.4.3 Poziom 3: Wynik obiektu

Wynik obiektu v jest wyznaczany jako *średnia arytmetyczna* wyników wszystkich aktywnych sekcji. Wszystkie sekcje pytań audytowych są traktowane jako równoważne pod względem znaczenia regulacyjnego:

$$S_{total}(v) = \frac{1}{|\mathcal{S}(v)|} \sum_{\mathcal{S}_k \in \mathcal{S}(v)} S(\mathcal{S}_k) \tag{7.14}$$

Sekcja z aktywną flagą blokującą ma wynik zerowy (równanie (7.8)), co bezpośrednio obniża $S_{total}(v)$. Na poziomie obiektu flagi sekcji są agregowane do flagi obiektu:

$$\text{FLAG}^{obj}_{block}(v) = \texttt{TRUE} \iff \exists\, \mathcal{S}_k \in \mathcal{S}(v) : \text{FLAG}_{block}(\mathcal{S}_k) = \texttt{TRUE} \tag{7.15}$$

DRAFT

Flaga $\mathrm{FLAG}_{TIA}(v)$ (równanie (7.4)) jest szczególnym przypadkiem $\mathrm{FLAG}^{obj}_{block}(v)$ dla sekcji `TIA`.
Wynik $S_{total}(v) \in [0,1]$ jest interpretowany na pięciostopniowej skali zgodności:

Tabela 7.7: Skala interpretacji wyniku obiektu

Wynik S_{total}	**Klasyfikacja**	**Interpretacja**
[0,85; 1,0]	ZGODNY	Wysoki poziom zgodności; dowody kompletne; brak istotnych niezgodności
[0,70; 0,85)	CZĘŚCIOWO ZGODNY	Większość wymogów spełniona; luki w dokumentacji lub pojedyncze niezgodności drugorzędne
[0,50; 0,70)	WYMAGA POPRAWY	Znaczące luki; wymogi obowiązkowe niespełnione lub spełnione bez wystarczających dowodów
[0,25; 0,50)	NIEZGODNY	Poważne naruszenia; wysokie ryzyko sankcji; pilne działania naprawcze
[0; 0,25)	KRYTYCZNIE NIEZGODNY	Brak podstawowych mechanizmów zgodności; ryzyko natychmiastowych sankcji regulatora

Nadpisanie klasyfikacji. Klasyfikacja obiektu $K(v)$ jest wyznaczana ze skali w tabeli 7.7 na podstawie $S_{total}(v)$, a następnie korygowana według jednej reguły:

$$K(v) = \begin{cases} \min\big(K_S(v),\ \text{NIEZGODNY}\big) & \text{jeśli } \mathrm{FLAG}^{obj}_{block}(v) = \texttt{TRUE}, \\ K_S(v) & \text{w przeciwnym razie,} \end{cases} \tag{7.16}$$

gdzie $K_S(v)$ jest klasą wynikającą wyłącznie z $S_{total}(v)$, a minimum oznacza wybór gorszej z dwóch klas (KRYTYCZNIE NIEZGODNY < NIEZGODNY < WYMAGA POPRAWY < CZĘŚCIOWO ZGODNY < ZGODNY). Aktywna flaga blokująca, w tym $\mathrm{FLAG}_{TIA}(v)$, obniża więc klasyfikację co najmniej do NIEZGODNY. Klasyfikacja KRYTYCZNIE NIEZGODNY wynika wyłącznie z wartości $S_{total}(v) < 0{,}25$. Ponieważ zgodnie z równaniem (7.13) każde efektywnie blokujące pytanie jest obowiązkowe, odrębna reguła dla „flagi z pytania obowiązkowego” nie jest potrzebna. Nadpisaniu podlega klasyfikacja, a nie wartość $S_{total}(v)$, która w niezmienionej postaci wchodzi do agregacji na poziomie podmiotu. Żadna agregacja arytmetyczna nie może ukryć fundamentalnej niezgodności z przepisem prawa o charakterze bezwzględnie obowiązującym.

7.4.4 Poziom 4: Wynik podmiotu z propagacją ryzyka

Wynik podmiotu łączy dwa składniki: wynik organizacyjny $S_{total}(v_0)$, wyznaczony według równania (7.14) z sekcji przypisanych do podmiotu (`ORGANIZACJA`, `BEZPIECZENSTWO_TECH`, `BEZPIECZENSTWO_FIZYCZNE` oraz, jeśli aktywne, `DANE_SZCZEGÓLNE` i `KONCENTRACJA_RYZYKA`),

DRAFT

oraz wynik grafu S_{graf}, wyznaczany jako ważona średnia wyników wszystkich pozostałych obiektów w grafie ICT, z uwzględnieniem łącznej wagi obiektu $w_{total}(v)$ oraz współczynnika deprecjacji głębokości λ:

$$S_{graf} = \frac{\sum\limits_{v \in V \setminus \{v_0\}} S_{total}(v) \cdot w_{total}(v) \cdot \lambda^{\,depth(v)}}{\sum\limits_{v \in V \setminus \{v_0\}} w_{total}(v) \cdot \lambda^{\,depth(v)}} \tag{7.17}$$

$$S_{podmiot} = \alpha \cdot S_{total}(v_0) + (1 - \alpha) \cdot S_{graf} \tag{7.18}$$

gdzie:

(i) $\alpha \in [0, 1]$ jest udziałem wyniku organizacyjnego (wartość domyślna: $\alpha = 0{,}5$); kombinacja wypukła zapobiega rozmyciu wyniku organizacyjnego, które nastąpiłoby przy włączeniu v_0 do średniej (7.17) jako jednego z wielu wierzchołków,

(ii) $w_{total}(v) = w_{krit}(v) \cdot w_{data}(v) \cdot w_{dost}(v)$ jest łączną wagą obiektu wynikającą z jego krytyczności (tabela 6.6), klasyfikacji przetwarzanych danych (tabela 6.8) i dostępności (tabela 6.5); dla obiektów typu `DOSTAWCA` i `PODDOSTAWCA`, które nie mają własnych atrybutów krytyczności, typu danych i dostępności, przyjmuje się maksymalne wartości mnożników spośród systemów, od których prowadzi do nich ścieżka w grafie (tj. systemów obsługiwanych bezpośrednio lub pośrednio),

(iii) $depth(v)$ jest głębokością wierzchołka v w grafie ICT, czyli odległością od korzenia v_0 mierzoną liczbą krawędzi,

(iv) $\lambda \in (0, 1]$ jest konfigurowalnym współczynnikiem deprecjacji głębokości (wartość domyślna: $\lambda = 0{,}8$), określającym, jak mocno niezgodności głębszych warstw łańcucha dostaw wpływają na wynik podmiotu.

Wierzchołki, których audyt nie został zakończony (np. poddostawcy zidentyfikowani w fazie trzeciej, dla których nie uzyskano odpowiedzi), nie wchodzą do sumy (7.17), lecz są wykazywane w raporcie jako ograniczenie zakresu audytu. Klasyfikacja podmiotu jest wyznaczana ze skali w tabeli 7.7 na podstawie $S_{podmiot}$ i ograniczana do NIEZGODNY, jeżeli $\mathrm{FLAG}^{obj}_{block}(v_0) =$ `TRUE` lub jeżeli flaga $\mathrm{FLAG}^{obj}_{block}(v)$ jest aktywna dla systemu o krytyczności `KRYTYCZNY` albo dla dostawcy kluczowego (definicja 7.3). Wartość domyślna $\alpha = 0{,}5$ odzwierciedla nacisk, jaki dyrektywa NIS2 (art. 20) i rozporządzenie DORA (art. 5) kładą na odpowiedzialność organu zarządzającego. Ograniczenie klasy podmiotu obejmuje wyłącznie flagi na podmiocie, na systemach krytycznych i u dostawców kluczowych. Flaga na obiekcie o mniejszym znaczeniu obniża wynik liczbowy, ale nie przesądza o klasie całej organizacji.

Interpretacja współczynnika λ jest następująca: przy $\lambda = 1{,}0$ niezgodności poddostawcy trzeciego poziomu wpływają na wynik podmiotu z taką samą siłą jak niezgodności systemu własnego; przy $\lambda = 0{,}8$ każdy kolejny poziom głębokości zmniejsza wpływ o 20%. Wartość λ może być konfigurowana przez audytora w zależności od oceny faktycznej ekspozycji podmiotu na ryzyko łańcucha dostaw.

DRAFT

7.4.5 Identyfikacja dostawców kluczowych

Dostawca kluczowy to dostawca, którego niezgodność lub niedostępność stanowi zagrożenie dla stabilności podmiotu. Pojęcie to jest kategorią metodologii ORION wyznaczaną z grafu ICT danego podmiotu i nie jest tożsame z kluczowymi zewnętrznymi dostawcami usług ICT (CTPP), których na podstawie art. 31 rozporządzenia DORA wyznaczają Europejskie Urzędy Nadzoru. ORION identyfikuje dostawców kluczowych formalnie na podstawie warunku alternatywnego: wystarczy spełnienie **co najmniej jednego** z poniższych kryteriów:
Definicja korzysta ze zbiorów V_{SYS}, V_{DOST} i E_{svc} wprowadzonych w kroku 7.2.2. Kierunek krawędzi jest zgodny z konwencją grafu ICT (sekcja 7.5.2): od systemu do podmiotu, który go obsługuje.

Definicja 7.3 (Dostawca kluczowy)**.** *Dostawca $v \in V_{DOST}$ jest uznawany za **kluczowego** (KeyVendor), jeżeli spełnia co najmniej jeden z następujących warunków:*

*(i) obsługuje co najmniej jeden system o klasyfikacji **KRYTYCZNY**:*

$$\exists\, u \in V_{SYS} : (u, v) \in E_{svc} \ \wedge\ \textit{krytyczność}(u) = \texttt{KRYTYCZNY}$$

(ii) obsługuje co najmniej $n^*_{KV} = 3$ systemy podmiotu (niezależnie od ich klasyfikacji krytyczności):

$$\Big|\{u \in V_{SYS} : (u, v) \in E_{svc}\}\Big| \geq n^*_{KV}$$

Formalnie:

$$\textsc{KeyVendor}(v) = \texttt{TRUE} \iff \Big(\exists\, u \in V_{SYS} : (u, v) \in E_{svc} \wedge \textit{krytyczność}(u) = \texttt{KRYTYCZNY}\Big) \vee \Big(|\{u \in V_{SYS} : (u, v) \in E_{svc}\}| \geq n^*_{KV}\Big) \quad (7.19)$$

gdzie $n^*_{KV} = 3$ jest minimalną liczbą systemów obsługiwanych przez dostawcę (wartość domyślna, konfigurowalna przez audytora).

Innymi słowy: dostawca jest kluczowy, jeśli obsługuje choćby jeden system krytyczny niezależnie od liczby obsługiwanych systemów lub jeśli obsługuje co najmniej trzy systemy podmiotu, niezależnie od ich poziomu krytyczności. Spełnienie wyłącznie jednego warunku jest wystarczające.

Sekcja `KONCENTRACJA_RYZYKA` jest sekcją podmiotu. Jej pytania dotyczą organizacji jako całości (mapowania funkcji krytycznych do dostawców, ocen koncentracji, progów i planów redukcji), dlatego jest ona zadawana jednorazowo dla v_0, a nie dla poszczególnych dostawców. Jest aktywowana **wyłącznie** wtedy, gdy od co najmniej jednego dostawcy lub poddostawcy zależy, bezpośrednio lub pośrednio, co najmniej n^*_{KV} systemów podmiotu:

$$\Phi_{\texttt{KONCENTRACJA_RYZYKA}}(v_0) = \texttt{TRUE} \iff \exists\, w : \Big|\{u \in V_{SYS} : w \in R(u)\}\Big| \geq n^*_{KV} \quad (7.20)$$

gdzie $R(u)$ jest zbiorem dostawców i poddostawców osiągalnych w grafie ICT z systemu u (sekcja 7.2.6). Warunek obejmuje więc zarówno dostawcę bezpośrednio obsługującego wiele systemów (warunek (ii) definicji dostawcy kluczowego), jak i wspólną infrastrukturę

DRAFT

bazową: np. trzy systemy dostarczane przez trzech różnych dostawców SaaS, którzy korzystają z tego samego dostawcy chmury jako poddostawcy. Definicja dostawcy kluczowego pozostaje natomiast relacją bezpośrednią (E_{svc}), ponieważ karta dostawcy kluczowego jest adresowana do zarządu jako ocena kontrahenta organizacji.
Uzasadnienie tego rozróżnienia jest następujące: ryzyko koncentracji w rozumieniu art. 29 DORA materializuje się przez uzależnienie wielu systemów jednocześnie od jednego podmiotu, obsługującego je bezpośrednio albo jako wspólny poddostawca kilku dostawców. Dostawca obsługujący jeden system krytyczny jest kluczowy z uwagi na wagę tego systemu, lecz nie generuje ryzyka koncentracji w sensie regulacyjnym. Jeżeli w grafie nie ma dostawcy ani poddostawcy, od którego zależy co najmniej n^*_{KV} systemów, sekcja `KONCENTRACJA_RYZYKA` nie jest aktywowana.

Wynik sekcji `KONCENTRACJA_RYZYKA` wchodzi do wyniku organizacyjnego $S_{total}(v_0)$ zgodnie z równaniem (7.14). Karty dostawców kluczowych (sekcja 7.5.4) są adresowane do zarządu i rady nadzorczej.

7.5 Faza 5: Raport końcowy i rekomendacje

Wynikiem audytu ORION jest ustrukturyzowany raport zawierający cztery elementy: macierz zgodności, graf ICT z oznaczeniami, listę priorytetyzowanych rekomendacji oraz kartę dostawców kluczowych.

7.5.1 Macierz zgodności

Macierz zgodności przedstawia wyniki sekcji $S(\mathcal{S}_k)$ i wyniki $S_{total}(v)$ dla wszystkich obiektów w grafie ICT, pogrupowane według sekcji tematycznych. Umożliwia to audytorowi i zarządowi szybką identyfikację obszarów, w których poziom zgodności jest najniższy, niezależnie od tego, których konkretnych systemów lub dostawców te obszary dotyczą. Komórka jest wypełniona wyłącznie wtedy, gdy sekcja jest aktywna dla danego obiektu (tabela 7.6); znak „—” oznacza sekcję nieaktywną.

Tabela 7.8 odpowiada przykładowemu grafowi z sekcji 7.5.2 dla podmiotu klasy `KLUCZOWY`. Sekcja `KONCENTRACJA_RYZYKA` jest nieaktywna, ponieważ od żadnego dostawcy ani poddostawcy nie zależą, bezpośrednio lub pośrednio, trzy systemy (d_1 obsługuje dwa, a d_2, p_1 i p_2 po jednym). Sekcje `PLAN_CIAGLOSCI_DZIALANIA` i `EXIT_PLAN` nie dotyczą systemu v_3 o krytyczności `STANDARDOWY`.

DRAFT

Tabela 7.8: Przykładowa macierz zgodności dla grafu z rysunku 7.2 (ilustracja struktury)

Sekcja / Obiekt	v_0 **Podmiot**	v_1 **ERP**	v_2 **CRM**	v_3 **Portal**	d_1	d_2	p_1 **CDN**	**Średnia**
Organizacja	0,82	—	—	—	—	—	—	0,82
Dane poufne	0,75	—	—	—	—	—	—	0,75
Bezpieczeństwo techniczne	0,70	—	—	—	—	—	—	0,70
Bezpieczeństwo fizyczne	0,85	—	—	—	—	—	—	0,85
Koncentracja ryzyka	—	—	—	—	—	—	—	—
System informatyczny	—	0,94	0,86	0,80	—	—	—	0,87
Usługi w chmurze	—	—	0,80	0,64	—	—	—	0,72
Plan ciągłości działania	—	0,99	0,84	—	—	—	—	0,92
Exit plan	—	0,80	0,62	—	—	—	—	0,71
Transfer Impact Assessment	—	—	—	0,00†	—	0,00†	0,25	0,08
Dostawcy ICT	—	—	—	—	0,72	0,62	0,15	0,50
Wynik obiektu S_{total}	0,78	0,91	0,78	0,48	0,72	0,31	0,20	
Klasyfikacja (tab. 7.9)	[∼]	[✓]	[∼]	[×!!]†	[∼]	[×!!]†	[×!]	

† aktywna flaga FLAG_{TIA} dla v_3 i d_2: brak ważnej umowy DPA dotyczy tego samego transferu, więc blokuje sekcję TIA obu obiektów (równanie (7.8)); klasyfikacja ograniczona do NIEZGODNY.

Wiersze sekcji `TIA` i `DOSTAWCY` w powyższej tabeli ilustrują obserwację, na której opiera się metodologia: najniższe wyniki mogą skupiać się w sekcjach dotyczących łańcucha dostaw i transferu danych, a nie w obszarach bezpieczeństwa technicznego, które są tradycyjnie najlepiej monitorowane. Ze względu na ilustracyjny charakter danych przykład nie stanowi dowodu empirycznego, lecz pokazuje, w jaki sposób macierz uwidacznia lukę badawczą opisaną w sekcji 6.1.

7.5.2 Graf ICT z oznaczeniami

Graf ICT generowany jako element raportu końcowego jest wizualną reprezentacją skierowanego grafu ważonego $G = (V, E, W)$ zbudowanego w toku przeprowadzenia audytu. Wierzchołki V reprezentują obiekty audytowe wszystkich czterech typów: podmiot v_0, systemy informatyczne, dostawców i poddostawców. Krawędzie skierowane $E \subseteq V \times V$ wskazują kierunek zależności: od podmiotu do jego systemów oraz od obiektu obsługiwanego do obsługującego (system → dostawca → poddostawca). Wagi W krawędzi usługowych odzwierciedlają poziom krytyczności obsługiwanego systemu, tj. mnożnik w_{krit} z tabeli 6.6, wyznaczony zgodnie z klasyfikacją przyjętą w Sekcji 7.2.3. Krawędzie do poddostawców, zidentyfikowanych w fazie trzeciej, mają ten sam kierunek i wagę krawędzi, przez którą poddostawca jest osiągany.

Graf spełnia podwójną funkcję audytową. Po pierwsze, jest *narzędziem komunikacji wyników do zarządu*, pozwala w kilka sekund zidentyfikować, na którym poziomie łańcucha dostaw ICT koncentruje się ryzyko regulacyjne. Po drugie, jest *dowodem audytowym* dokumentującym kompletność przeprowadzonej analizy i wszystkie odkryte ogniwa łańcucha, włącznie z poddostawcami ujawnionymi w toku identyfikacji poddostawców opisanej w Sekcji 7.3.9.

DRAFT

Notacja wierzchołków

Każdy wierzchołek grafu jest identyfikowany przez *kod literowy z indeksem głębokości* $\text{depth}(v)$, rozumianej jako odległość od korzenia v_0 mierzona liczbą krawędzi. Przyjęta konwencja nazewnicza jest następująca:

- v_0: podmiot-korzeń, czyli audytowana organizacja (głębokość 0);
- $v_1, v_2, \ldots, v_n$: systemy informatyczne własne podmiotu, zidentyfikowane w Kroku 2.1 (głębokość 1);
- $d_1, d_2, \ldots, d_m$: bezpośredni dostawcy ICT, zidentyfikowani w Kroku 2.2 (głębokość 2);
- $p_1, p_2, \ldots, p_k$: poddostawcy zidentyfikowani w toku Fazy 3 (głębokość 3 i wyżej).

W przypadku rozległych grafów dopuszcza się stosowanie notacji złożonej, np. $d_{1.1}, d_{1.2}$ dla kolejnych dostawców powiązanych z systemem v_1, co ułatwia czytelność przy dużej liczbie obiektów.

Oznaczenia klasyfikacji zgodności

Biorąc pod uwagę ograniczenia techniczne związane z technologią druku i ograniczonej dostępności druku kolorowego, raport audytowy może być drukowany w wersji czarno-białej, klasyfikacja zgodności obiektu jest kodowana *symbolem wewnątrz wierzchołka*, a nie wyłącznie kolorem. Tabela 7.9 przedstawia kompletny słownik oznaczeń.

Tabela 7.9: Słownik oznaczeń wierzchołków w grafie ICT

Symbol	Klasyfikacja	Warunek	Priorytet naprawczy
[✓]	ZGODNY	$S_{total} \geq 0{,}85$	brak
[∼]	CZĘŚCIOWO ZGODNY	$0{,}70 \leq S_{total} < 0{,}85$	P3
[!]	WYMAGA POPRAWY	$0{,}50 \leq S_{total} < 0{,}70$	P2
[×]	NIEZGODNY	$0{,}25 \leq S_{total} < 0{,}50$	P1
[×!]	KRYTYCZNIE NIEZGODNY	$S_{total} < 0{,}25$	P0
[×!!]	Aktywna flaga $\text{FLAG}_{block}^{obj}$ (w tym FLAG_{TIA})	niezależnie od S_{total}; klasa co najwyżej NIEZGODNY (równanie (7.16))	P0

Aktywacja flagi $\text{FLAG}_{block}^{obj}$, w tym FLAG_{TIA}, ogranicza klasyfikację obiektu do co najwyżej NIEZGODNY niezależnie od wartości S_{total} (równanie (7.16)), co jest sygnalizowane przez dodanie symbolu `!!` do oznaczenia wierzchołka. Żadna agregacja arytmetyczna nie może ukryć fundamentalnej niezgodności z przepisem prawa o charakterze bezwzględnie obowiązującym.

DRAFT

Oznaczenia krawędzi

Krawędzie grafu ICT różnicowane są typem linii oraz opcjonalną etykietą:

(i) *Linia ciągła* ($\rightarrow$) – standardowa zależność usługowa; system korzysta z usług dostawcy na podstawie umowy;

(ii) *Linia przerywana* (`--→`) – krawędź do poddostawcy zidentyfikowanego w fazie trzeciej; oznacza podmiot niewidoczny na etapie Fazy 2, ujawniony dopiero w toku identyfikacji poddostawców. Etykieta TIA przy krawędzi wskazuje poddostawcę, dla którego spełniony jest warunek $\mathcal{C}_{TIA}$;

(iii) *Etykieta `[KV]`* na krawędzi, dostawca kluczowy (*KeyVendor*), spełniający co najmniej jeden warunek z definicji 7.3: obsługuje co najmniej jeden system KRYTYCZNY lub obsługuje co najmniej $n^*_{KV} = 3$ systemy podmiotu. Etykieta jest umieszczana na każdej krawędzi prowadzącej do dostawcy kluczowego.

Przykładowy graf ICT

Poniższy przykład ilustruje strukturę grafu ICT dla przykładowego podmiotu. Podmiot v_0 eksploatuje trzy systemy informatyczne:

(i) v_1 - system ERP, klasyfikacja KRYTYCZNY, wdrożony on-premise, wynik $S_{total} =$ 0,91 ([✓] ZGODNY);

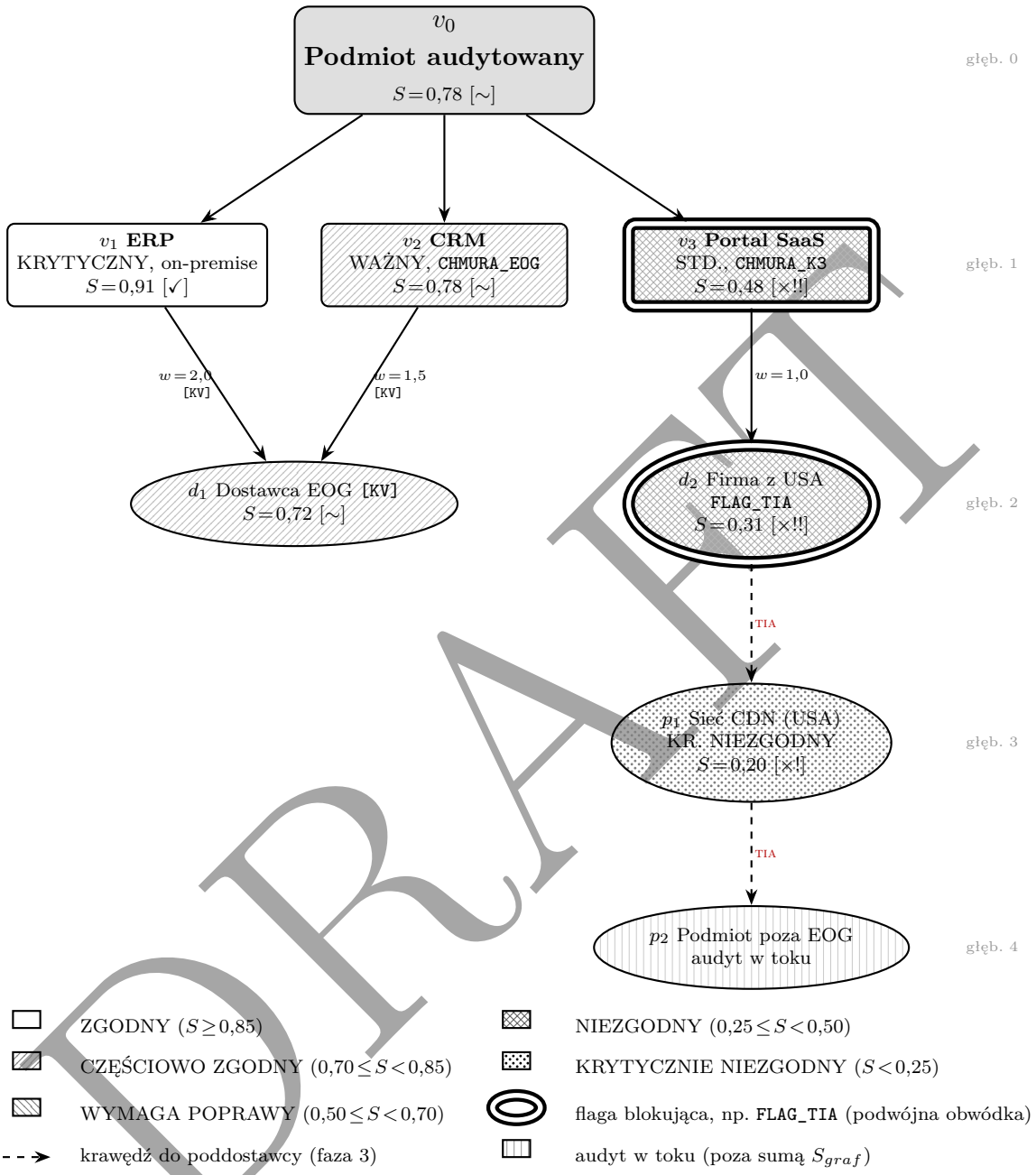
(ii) v_2 - system CRM, klasyfikacja WAŻNY, chmura EOG, wynik $S_{total} = 0{,}78$ ([∼] CZĘŚCIOWO ZGODNY);

(iii) v_3 - portal kliencki SaaS, klasyfikacja STANDARDOWY, chmura kraju trzeciego (USA), wynik $S_{total} = 0{,}48$ ([×!!] NIEZGODNY, `FLAG_TIA` aktywna).

Wynik organizacyjny podmiotu wynosi $S_{total}(v_0) = 0{,}78$ ([∼] CZĘŚCIOWO ZGODNY). Systemy v_1 i v_2 obsługiwane są przez dostawcę d_1 (firma z EOG świadcząca utrzymanie i wsparcie systemu v_1, działającego w centrum danych podmiotu, oraz hosting systemu v_2 na własnej infrastrukturze w EOG, $S_{total} = 0{,}72$, [∼] CZĘŚCIOWO ZGODNY); identyfikacja poddostawców d_1 udokumentowała ich brak. System v_3 obsługiwany jest przez dostawcę d_2 (firma z USA, $S_{total} = 0{,}31$, [×!!] – `FLAG_TIA` aktywna). Dostawca d_1 obsługuje tylko dwa systemy podmiotu, więc nie spełnia warunku (ii) definicji 7.3. Żaden podmiot w grafie nie należy do łańcucha $R(u)$ trzech systemów (d_1 występuje w łańcuchach v_1 i v_2, a d_2, p_1 i p_2 wyłącznie w łańcuchu v_3), dlatego warunek (7.20) nie jest spełniony i sekcja `KONCENTRACJA_RYZYKA` nie jest aktywowana. Obsługuje jednak system v_1 o krytyczności `KRYTYCZNY`, więc na mocy warunku (i) **jest dostawcą kluczowym**, co oznaczono etykietą `[KV]` na krawędziach $v_1 \rightarrow d_1$ i $v_2 \rightarrow d_1$. Dostawca d_2 obsługuje jeden system o krytyczności `STANDARDOWY` i nie jest dostawcą kluczowym. Identyfikacja poddostawców d_2 ujawnia poddostawcę p_1 – sieć CDN zlokalizowaną w USA, dla której również spełniony jest warunek $\mathcal{C}_{TIA}$ ($S_{total} = 0{,}20$, [×!] KRYTYCZNIE NIEZGODNY). Identyfikacja poddostawców p_1 ujawnia z kolei jego poddostawcę p_2 (podmiot zarejestrowany poza EOG), którego audyt jest w toku; do czasu jego zakończenia p_2 nie wchodzi do sumy (7.17).

Wynik podmiotu $S_{podmiot}$ obliczany jest zgodnie z równaniami (7.17) i (7.18), przy czym poddostawca CDN (p_1, głębokość 3) jest objęty współczynnikiem deprecjacji głębokości

DRAFT



DRAFT

Rysunek 7.2: Przykładowy graf ICT podmiotu z oznaczeniami klasyfikacji zgodności. Prostokąty oznaczają systemy informatyczne (SYSTEM_INFORMATYCZNY), elipsy oznaczają dostawców ICT. Podwójna obwódka sygnalizuje aktywną flagę blokującą obiektu (w przykładzie FLAG_TIA). Linia przerywana oznacza krawędź do poddostawcy zidentyfikowanego w fazie trzeciej (etykieta TIA: poddostawca objęty triggerem TIA). Etykieta [KV] oznacza krawędź prowadzącą do dostawcy kluczowego. Wagi krawędzi odpowiadają mnożnikowi w_{krit} obsługiwanego systemu (tabela 6.6: $w = 2{,}0$ KRYTYCZNY, $w = 1{,}5$ WAŻNY, $w = 1{,}0$ STANDARDOWY).

$\lambda^3 = 0{,}8^3 = 0{,}512$, a system własny (głębokość 1) współczynnikiem $\lambda^1 = 0{,}8$. Przy równej wadze w_{total} niezgodność poddostawcy wpływa więc na wynik podmiotu z siłą $0{,}512/0{,}8 = 64\%$ siły niezgodności systemu własnego.

Interpretacja grafu przez zarząd

Graf ICT jest jedynym elementem raportu przeznaczonym do odczytania bez uprzedniego zapoznania się z treścią kwestionariuszy. Zarząd i rada nadzorcza powinni być w stanie, wyłącznie na podstawie grafu, odpowiedzieć na trzy pytania operacyjne:

(i) *Gdzie skupia się ryzyko?* Wierzchołki oznaczone [×], [×!] lub [×!!] wymagają natychmiastowej uwagi, niezależnie od ich głębokości w grafie.

(ii) *Który dostawca jest kluczowy?* Krawędzie z etykietą `[KV]` wskazują podmioty, których awaria lub niezgodność zagraża stabilności całej organizacji.

(iii) *Jak głęboko sięga łańcuch?* Liczba poziomów grafu ujawnia, czy organizacja jest świadoma pełnej ekspozycji na ryzyko poddostawców, co jest wymogiem art. 28 DORA i art. 21 ust. 2 lit. d dyrektywy NIS2.

Brak wierzchołków na poziomie głębokości 3 i wyżej jest dopuszczalny wyłącznie wtedy, gdy identyfikacja poddostawców (sekcja 7.3.9) została przeprowadzona dla każdego dostawcy i udokumentowała brak poddostawców. Audytor jest zobowiązany do odnotowania w raporcie, czy głębokość grafu wynika z faktycznego braku poddostawców, czy też z niewykonania należytej staranności przez audytowany podmiot lub jego dostawców.

7.5.3 Lista rekomendacji z priorytetami

Każda niezgodność zidentyfikowana w toku audytu generuje rekomendację przypisaną do jednego z czterech poziomów priorytetu. Priorytet jest wyznaczany na dwóch poziomach: obiektu (na podstawie klasyfikacji $K(v)$ z równania (7.16), spójnie z tabelą 7.9) oraz pojedynczego pytania. Rekomendacja otrzymuje wyższy z dwóch priorytetów.

DRAFT

Tabela 7.10: Priorytety rekomendacji naprawczych w ORION

Priorytet	**Definicja**	**Termin działania**	**Warunek na poziomie obiektu**	**Warunek na poziomie pytania**
P0 Krytyczny	Naruszenie przepisu bezwzględnie obowiązującego grożące natychmiastową sankcją regulatora	Natychmiast (max. 72 h)	KRYTYCZNIE NIEZGODNY ($S_{total} < 0{,}25$) lub $\mathrm{FLAG}^{obj}_{block}(v)$ (w tym FLAG_{TIA})	pytanie z $\kappa_{eff} =$ `BLOKUJĄCE` spełniające warunek (7.7)
P1 Wysoki	Istotna niezgodność z przepisami prawa	30 dni	NIEZGODNY $S_{total} \in [0{,}25;\ 0{,}50)$	pytanie z $\tau_{eff} =$ OBOWIĄZKOWE i $S(q_j) < 0{,}3$
P2 Średni	Niezgodność z zaleceniami regulacyjnymi lub luki w dokumentacji	90 dni	WYMAGA POPRAWY $S_{total} \in [0{,}50;\ 0{,}70)$	pytanie z $\tau_{eff} =$ ZALECANE i $S(q_j) < 0{,}5$ lub pytanie z $\tau_{eff} =$ OBOWIĄZKOWE z rozbieżnością perspektyw (konsensus `TAK` bez jednomyślności)
P3 Niski	Obszar do usprawnienia; brak aktualnej dokumentacji lub dowodów słabych	180 dni	CZĘŚCIOWO ZGODNY $S_{total} \in [0{,}70;\ 0{,}85)$	odpowiedź `TAK` z dowodem słabym ($d = 0{,}4$)

Obiekt ZGODNY ($S_{total} \geq 0{,}85$) nie generuje rekomendacji na poziomie obiektu; rekomendacje mogą jednak wynikać z warunków na poziomie pojedynczych pytań.
Każda rekomendacja zawiera: identyfikator niezgodności, numer pytania audytowego i sekcji, obiekt którego dotyczy, perspektywę która ujawniła niezgodność, treść niezgodności sformułowaną w języku zrozumiałym dla zarządu, podstawę regulacyjną z numerem artykułu, sugerowane działanie naprawcze oraz termin wynikający z priorytetu.

7.5.4 Karta dostawców kluczowych

Raport końcowy zawiera oddzielną kartę dla każdego dostawcy spełniającego warunek (7.19). Karta zawiera: wynik S_{total} dostawcy, listę systemów podmiotu przez niego obsługiwanych, status TIA i exit planu, klasyfikację zgodności ze wskazaniem priorytetów naprawczych oraz rekomendację dotyczącą zarządzania ryzykiem koncentracji. Karty dostawców kluczo-

DRAFT

wych są bezpośrednio adresowane do zarządu i rady nadzorczej, gdyż to na tych organach spoczywa odpowiedzialność za nadzór nad kluczowymi zależnościami ICT w rozumieniu art. 5 DORA i art. 8 KSC.

DRAFT

7.6 Wyniki audytu

W celu praktycznej weryfikacji metodologii ORION przeprowadzono audyt technologiczno-prawny w jednym z banków spółdzielczych działających na terenie Polski. Na wniosek instytucji dane identyfikacyjne banku zostały zanonimizowane. Przypadek ma charakter studium ilustracyjnego opartego na rzeczywistym audycie. Audyt objął kompletny cykl klasyfikacyjny przewidziany metodologią: identyfikację reżimu regulacyjnego, klasyfikację ekspozycji sieciowej, ocenę poziomu krytyczności oraz określenie modelu utrzymania infrastruktury i jurysdykcji podmiotu hostującego.

Przedmiotem badania był system Cyfrowego Trwałego Nośnika (CTN), pełniący funkcję w procesie masowej komunikacji banku z klientami-konsumentami. Podstawowym zadaniem systemu jest dystrybucja dokumentów oraz oświadczeń woli w sposób zgodny z restrykcyjnymi wymogami prawnymi. Architektura systemu realizuje postanowienia Unijnej Dyrektywy o Prawach Konsumenta (Dyrektywa 2011/83/UE) oraz krajowych przepisów implementujących jej założenia, w szczególności Ustawy o prawach konsumenta. Regulacje te nakładają na przedsiębiorców, w tym instytucje sektora finansowego, obowiązek przekazywania konsumentom informacji (takich jak regulaminy, taryfy opłat i prowizji czy formularze informacyjne) na trwałym nośniku, co gwarantuje integralność treści oraz wyklucza możliwość ich jednostronnej modyfikacji przez bank.

7.6.1 Klasyfikacja podmiotu

W pierwszej kolejności zespół audytorski ustalił reżim regulacyjny, jakiemu podlega badana instytucja. Bank spółdzielczy, jako podmiot sektora bankowego, został jednoznacznie zaklasyfikowany jako **podmiot finansowy** w rozumieniu Rozporządzenia DORA (*Digital Operational Resilience Act*). Kwalifikacja ta wynika bezpośrednio z art. 2 ust. 1 lit. a DORA, który na pierwszym miejscu katalogu podmiotów objętych rygorem odporności cyfrowej wymienia instytucje kredytowe. W ankiecie kroku 1.1 kryteria R1 i R2 uzyskały wartość `TAK`, co zgodnie z regułą pierwszeństwa (równanie (7.1)) przesądza o klasie `FINANSOWY` niezależnie od wartości kryteriów R3 i R4.

Klasyfikacja ta determinuje zakres obowiązków banku w obszarze zarządzania ryzykiem ICT: obejmuje wymóg wdrożenia ram zarządzania ryzykiem (art. 5–16 DORA), prowadzenia rejestru umów z dostawcami ICT (art. 28 DORA) oraz testowania operacyjnej odporności cyfrowej; zaawansowane testy penetracyjne oparte na analizie zagrożeń (TLPT, *Threat-Led Penetration Testing*) dotyczą wyłącznie podmiotów wskazanych przez właściwe organy (art. 26 DORA).

7.6.2 Klasyfikacja atrybutu ekspozycji sieciowej

Kolejnym krokiem było określenie poziomu ekspozycji sieciowej systemu CTN z zastosowaniem ankiety dostępności metodologii ORION. Analiza architektury systemu wykazała, że dokumenty bankowe oraz interfejs użytkownika są udostępniane masowemu odbiorcy bezpośrednio za pośrednictwem sieci Internet i standardowych przeglądarek internetowych, bez wymogu połączenia VPN ani dostępu do sieci wewnętrznej banku.

Taka architektura wyczerpuje przesłanki *Kryterium D1: Dostęp spoza sieci organizacji* (system jest osiągalny z dowolnego węzła sieci publicznej) oraz *Kryterium D4: Publiczny adres lub domena*, usługa jest opublikowana pod publicznie rozwiązywalną nazwą domenową. Publiczna ekspozycja systemu rozszerza wektor ataku i implikuje konieczność

DRAFT

wdrożenia zaawansowanych zabezpieczeń perymetrycznych, w szczególności zapory aplikacyjnej (WAF), mechanizmów mitygacji ataków DDoS oraz inspekcji ruchu TLS.

W rezultacie system CTN został zaklasyfikowany jako **system publiczny**, któremu odpowiada mnożnik $w_{dost} = 1{,}8$ (tabela 6.5).

7.6.3 Klasyfikacja atrybutu poziomu krytyczności

Ocena krytyczności systemu CTN została przeprowadzona z zastosowaniem sześciokryterialnej ankiety metodologii ORION (Kryteria K1–K6). Poniższa tabela przedstawia wyniki punktacji dla każdego z kryteriów wraz z uzasadnieniem.

Tabela 7.11: Ocena punktowa krytyczności systemu CTN

Kryterium	**Opis**	**Wynik**	**Uzasadnienie**
K1	Wpływ finansowy i operacyjny niedostępności	NIE	Awaria nie zatrzymuje transakcji; BCP przewiduje zastępczy kanał papierowy
K2	Przetwarzanie danych osobowych, w tym szczególnych kategorii danych osobowych	TAK	Spersonalizowane dokumenty i dane PII klientów (imię, numer umowy, dane adresowe)
K3	Podleganie regulacjom zewnętrznym	TAK	Nadzór KNF (DORA; Rekomendacja D uchylona z dniem 17 stycznia 2025 r.) i wymogi Prezesa UOKiK dot. trwałego nośnika
K4	Zależności innych systemów produkcyjnych	NIE	Brak systemów operacyjnie uzależnionych od CTN
K5	Ryzyko wycieku lub utraty danych	TAK	Naruszenie poufności rodzi obowiązek zgłoszenia incydentu do UODO i ryzyko reputacyjne
K6	Obsługa procesów podstawowej działalności	NIE	Awaria CTN nie blokuje realizacji transakcji płatniczych ani procesów corebankingowych
Liczba kryteriów o wartości TAK		**3**	**System ważny**

Trzy kryteria o wartości `TAK` (K2, K3, K5) plasują system CTN w kategorii **systemu ważnego** zgodnie z matrycą klasyfikacji metodologii ORION (tabela 7.3), któremu odpowiada mnożnik $w_{krit} = 1{,}5$ (tabela 6.6). Trzy kryteria wyznaczają klasę `WAŻNY` bezpośrednio, bez odwołania do zasady dominacji operacyjnej. Zasada ta miałaby znaczenie

DRAFT

przy spełnieniu czwartego kryterium (np. K4): również wtedy brak K1 i K6 (wyznaczników bezpośredniego wpływu na ciągłość podstawowej działalności) wykluczałby uznanie systemu za krytyczny. Wdrożone plany ciągłości działania (BCP) przewidują procedurę awaryjną polegającą na tymczasowym zastąpieniu kanału cyfrowego klasyczną korespondencją papierową, co pozwala zachować pełną zgodność prawną nawet przy długotrwałej niedostępności systemu informatycznego.

Status systemu ważnego nie zwalnia organizacji z obowiązków nadzorczych. Nakłada on bezwzględny wymóg: ciągłego monitorowania systemu, regularnego przeprowadzania testów penetracyjnych, audytów zgodności regulacyjnej oraz utrzymania aktualnej dokumentacji przetwarzania danych osobowych zgodnie z art. 30 RODO. Parametry RTO i RPO nie muszą być skalibrowane w reżimie minutowym, jednak powinny zostać formalnie określone i zweryfikowane w ramach ćwiczeń BCP.

7.6.4 Klasyfikacja atrybutu utrzymania w chmurze

Ostatnim krokiem procedury audytowej było ustalenie modelu utrzymania infrastruktury systemu CTN oraz identyfikacja jurysdykcji podmiotu hostującego, z zastosowaniem dwuetapowej ankiety klasyfikacji atrybutu utrzymania w chmurze metodologii ORION: krok (a) obejmuje kryteria L1–L3 (model utrzymania), krok (b) kryteria L4–L6 (jurysdykcja). Wyniki dla każdego kryterium przedstawia poniższa tabela.

DRAFT

Tabela 7.12: Ocena punktowa klasyfikacji modelu utrzymania systemu CTN

Kryterium	**Opis**	**Wynik**	**Uzasadnienie**
L1	Model wdrożenia infrastruktury	TAK	System utrzymywany przez zewnętrznego dostawcę we własnym centrum danych dostawcy na terytorium RP
L2	Odpowiedzialność operacyjna	TAK	Dostępność zasobów i warstwa sprzętowa w gestii dostawcy na podstawie SLA
L3	Umowa outsourcingowa lub chmurowa	TAK	Umowa SaaS/PaaS i kontrakt outsourcingu IT z dostawcą
L4	Lokalizacja danych	TAK	Dane produkcyjne i kopie zapasowe w centrum danych na terytorium RP
L5	Jurysdykcja podmiotu hostującego	TAK	Dostawca z siedzibą w Polsce, wyłącznie kapitał europejski, bez poddostawców; brak ekspozycji na US CLOUD Act i FISA 702
L6	Wsparcie techniczne	TAK	Helpdesk i administracja świadczone wyłącznie przez zespół z terytorium EOG; geoblocking VPN
Krok (a): L1–L3 = TAK; krok (b): L4–L6 = TAK			`CHMURA_EOG`

Spełnienie kryteriów L1–L3 kwalifikuje system jako utrzymywany przez podmiot zewnętrzny, a wartość `TAK` kryteriów L4–L6 (lokalizacja danych, jurysdykcja podmiotu hostującego i wsparcie techniczne w EOG), przy dostawcy z krajem pochodzenia `PL`, przesądza o klasyfikacji systemu CTN jako **systemu utrzymywanego w chmurze EOG** (tabela 7.4). Żaden ze składników warunku $\mathcal{C}_{TIA}$ (równanie (7.3)) nie jest spełniony. Jest to klasyfikacja o najwyższym poziomie bezpieczeństwa jurydycznego: podmiot hostujący oparty wyłącznie na kapitale europejskim i niemający siedziby w państwach objętych regulacjami o ekstraterytorialnym dostępie do danych (takim jak US CLOUD Act czy FISA Section 702) eliminuje ryzyko nieautoryzowanego transferu danych do państw trzecich.

Klasyfikacja ta eliminuje ryzyka jurysdykcyjne, istotne z punktu widzenia komunikatów chmurowych UKNF i wymogów DORA dotyczących zewnętrznych dostawców usług ICT (art. 28–30 DORA); nie przesądza jednak o pełnej zgodności z tymi wymogami, którą oceniają dalsze sekcje (w szczególności exit plan). Narzędzia zdalnego dostępu serwisowego skonfigurowane z restrykcyjnym geoblockingiem, uniemożliwiające zestawienie sesji administracyjnej spoza obszaru EOG, stanowią dodatkową warstwę zabezpieczenia

DRAFT

weryfikowalną przez audytorów bezpośrednio w logach dostępowych.

7.6.5 Klasyfikacja atrybutu typów przetwarzanych danych

Klasyfikacja typów przetwarzanych danych została przeprowadzona zgodnie z tabelą 6.8 metodologii ORION. System CTN przetwarza spersonalizowane dokumenty bankowe zawierające dane identyfikacyjne klientów (imię i nazwisko, numer umowy, dane adresowe) oraz informacje objęte tajemnicą bankową w rozumieniu art. 104 ustawy Prawo bankowe, a więc dane o rachunkach, historię transakcji i informacje o zobowiązaniach kredytowych. Tajemnica bankowa stanowi informację prawnie chronioną na mocy ustawy sektorowej, co w klasyfikacji ORION odpowiada najwyższej kategorii wrażliwości.

Ankieta typu danych dała zbiór spełnionych kategorii $D(\text{CTN}) = \{O, T\}$: system przetwarza dane osobowe klientów oraz informacje objęte tajemnicą bankową. Zgodnie z regułą najwyższego mnożnika (tabela 7.5) system CTN został sklasyfikowany jako przetwarzający dane kategorii `TAJEMNICA` (symbol T_3, mnożnik wagowy $w_{data} = 2{,}0$). Klasyfikacja ta ma bezpośrednie przełożenie na wagę obiektu w agregacji końcowej. Ponieważ $O \in D(\text{CTN})$, aktywowana jest również sekcja pytań dotyczących danych poufnych, oceniana na poziomie podmiotu. Naruszenie bezpieczeństwa systemu przetwarzającego tajemnicę bankową rodzi po stronie instytucji obowiązek zgłoszenia incydentu do organu nadzoru (KNF) oraz potencjalną odpowiedzialność odszkodowawczą wobec klientów, których dane zostały ujawnione osobom nieuprawnionym.

7.6.6 Klasyfikacja atrybutu kraju pochodzenia

Atrybut kraju pochodzenia dostawcy systemu CTN został wyznaczony na podstawie weryfikacji statusu prawnego i kapitałowego podmiotu świadczącego usługę utrzymania oraz przeprowadzającego wdrożenie. Dostawca jest spółką zarejestrowaną i prowadzącą działalność operacyjną wyłącznie na terytorium Rzeczypospolitej Polskiej, bez powiązań kapitałowych z podmiotami spoza Europejskiego Obszaru Gospodarczego. Zarówno wsparcie techniczne, jak i administracja systemu są świadczone przez personel zlokalizowany w Polsce.

Atrybut przyjął wartość `PL`, zatem ani dla dostawcy ($\mathcal{C}_{TIA}(d_1) = \texttt{FALSE}$), ani, za jego pośrednictwem, dla systemu CTN składnik pochodzenia podmiotu w warunku (7.3) nie jest spełniony. Konsekwencją tej klasyfikacji jest brak obowiązku przeprowadzenia oceny skutków transferu danych (TIA), ponieważ żaden etap przetwarzania nie wiąże się z przekazaniem danych do państwa trzeciego w rozumieniu RODO. Dostawca nie podlega jurysdykcji przepisów o ekstraterytorialnym dostępie do danych (takich jak US CLOUD Act czy FISA Section 702), co eliminuje ryzyko nieautoryzowanego udostępnienia danych organom obcego państwa.

7.6.7 Analiza aktywowanych sekcji pytań

Zbiór atrybutów wyznaczonych w poprzednich krokach determinuje zakres sekcji pytań aktywowanych przez system ORION dla danego audytu. Poniżej przedstawiono wynik tej aktywacji wraz z uzasadnieniem dla każdej sekcji.

Podmiot audytowany (bank spółdzielczy) został sklasyfikowany jako `FINANSOWY`, system CTN jako `PUBLICZNY` o poziomie krytyczności `WAŻNY`, utrzymywany w trybie `CHMURA_EOG`, przetwarzający dane kategorii `TAJEMNICA` ($D(\text{CTN}) = \{O, T\}$), dostarczany przez podmiot z kraju `PL`. Zidentyfikowano jednego zewnętrznego dostawcę ICT, działającego w

DRAFT

jurysdykcji EOG. Graf ICT audytu składa się zatem z trzech obiektów: podmiotu v_0 (bank), systemu v_1 (CTN) i dostawcy d_1.

Dla podmiotu `FINANSOWY` zbiór stosowanych aktów obejmuje DORA i RODO ($\mathcal{A}_{reg}(\texttt{FINANSOWY}) = \{\text{DORA}, \text{RODO}\}$, równanie (7.11)). Przepisy NIS2 i ustawy o KSC, przywoływane w opisach poszczególnych obszarów obok DORA, są więc w audycie banku traktowane jako dobra praktyka: wskazują źródło wymagania, ale nie decydują o obligatoryjności pytania. Obligatoryjność i charakter blokujący wynikają z DORA lub RODO.

Na podstawie powyższych atrybutów aktywowano następujące sekcje pytań (tabela 7.6):

Podmiot v_0 (bank):

(i) *Organizacja* (aktywacja stała dla obiektów typu `PODMIOT`): ocena struktury zarządzania ryzykiem ICT, polityk bezpieczeństwa i nadzoru zarządczego nad funkcjami cyfrowymi.

(ii) *Bezpieczeństwo techniczne* (aktywacja stała dla obiektów typu `PODMIOT`): ocena technicznych środków ochrony infrastruktury, zarządzania dostępem, segmentacji sieci oraz szkoleń pracowników.

(iii) *Bezpieczeństwo fizyczne* (aktywacja stała dla obiektów typu `PODMIOT`): weryfikacja zabezpieczeń fizycznych siedziby i pomieszczeń serwerowni podmiotu audytowanego.

(iv) *Dane poufne* (aktywacja dla podmiotu, gdy $\exists\, u : D(u) \cap \{W, O\} \neq \emptyset$): system CTN przetwarza dane osobowe klientów, wobec czego oceniane są obowiązki administratora danych: rejestr czynności przetwarzania, IOD, procedura zgłaszania naruszeń do UODO i harmonogram retencji.

System v_1 (CTN):

(v) *System informatyczny* (aktywacja stała dla obiektów typu `SYSTEM_INFORMATYCZNY`): weryfikacja bezpieczeństwa systemu CTN, obejmująca m.in. uwierzytelnianie wieloskładnikowe, szyfrowanie komunikacji, logowanie, kopie zapasowe oraz kontrolę dostępu dostawcy.

(vi) *Usługi w chmurze* (aktywacja warunkowa: *utrzymanie_chmura* $\in \{\texttt{CHMURA_EOG}, \texttt{CHMURA_K3}\}$): ocena zgodności wynikającej ze specyfiki przetwarzania w środowisku zewnętrznym, w tym DPIA, model zarządzania kluczami kryptograficznymi, izolacja danych między klientami dostawcy oraz umowny czas powiadamiania o incydentach.

(vii) *Plan wyjścia z usługi (exit plan)* (aktywacja warunkowa: system o krytyczności $\in \{\texttt{KRYTYCZNY}, \texttt{WAŻNY}\}$, obsługiwany przez co najmniej jednego dostawcę, $\wedge\, k(v_0) \in \{\texttt{FINANSOWY}, \texttt{KLUCZOWY}\}$): weryfikacja planu wyjścia z relacji z dostawcą, obejmująca zdolność do pełnego eksportu danych w formacie otwartym, zmierzony czas migracji (RTE) oraz identyfikację alternatywnego dostawcy.

(viii) *Plan ciągłości działania (BCP)* (aktywacja warunkowa: *krytyczność*$(v) \in \{\texttt{KRYTYCZNY}, \texttt{WAŻNY}\}$ oraz $k(v_0) \in \{\texttt{FINANSOWY}, \texttt{KLUCZOWY}, \texttt{WAŻNY}\}$): ocena planów BCP i DRP, wskaźników RTO i RPO, scenariuszy odtwarzania po awarii dostawcy chmury oraz kopii zapasowych izolowanych od infrastruktury produkcyjnej.

Dostawca d_1:

DRAFT

(ix) *Dostawcy ICT* (aktywacja stała dla obiektów typu `DOSTAWCA`): ocena zarządzania ryzykiem dostawcy d_1, w tym due diligence przedkontraktowe, prawo do audytu, dostęp do logów po stronie dostawcy oraz kompletność wymogów umownych (SLA, powiadomienia o zmianach, odpowiedzialność i regres).

Następujące sekcje nie zostały aktywowane z uwagi na niespełnienie warunków progowych:

(i) *Transfer Impact Assessment (TIA)* (warunek: $\mathcal{C}_{TIA}(v) = \texttt{TRUE}$): sekcja nie została aktywowana ani dla systemu CTN, ani dla dostawcy d_1. Kryteria L4–L6 uzyskały wartość `TAK`, a dostawca ma kraj pochodzenia `PL`. Żaden etap przetwarzania nie obejmuje transferu danych do państwa trzeciego, wobec czego obowiązek przeprowadzenia TIA wymagany przez RODO nie powstaje.

(ii) *Koncentracja ryzyka* (sekcja podmiotu; warunek: istnieje dostawca lub poddostawca, od którego zależą ≥ 3 systemy podmiotu): zakres audytu obejmował jeden system; zidentyfikowano jednego zewnętrznego dostawcę ICT, obsługującego wyłącznie system CTN i niekorzystającego z poddostawców. Próg koncentracji nie został osiągnięty, wobec czego ryzyko nadmiernego uzależnienia od jednego podmiotu nie wymaga pogłębionej oceny w ramach tego audytu.

Dostawca d_1 nie jest dostawcą kluczowym w rozumieniu definicji 7.3: obsługuje jeden system o krytyczności `WAŻNY`.

7.6.8 Wyniki sekcji organizacja

Sekcja organizacja jest oceniana dla podmiotu v_0 i obejmuje osiem obszarów tematycznych wymaganych przez DORA (z odwołaniem do NIS2 jako dobrej praktyki), dotyczących ładu zarządczego, zarządzania ryzykiem ICT oraz zdolności operacyjnej do obsługi incydentów. Ocena każdego obszaru była przeprowadzana metodą cross-validation, tzn. każde pytanie było zadawane niezależnie trzem perspektywom: prawno-compliance, technicznej (dział IT) oraz użytkownika końcowego. Zgodność odpowiedzi ze wszystkich trzech perspektyw stanowiła warunek udzielenia odpowiedzi twierdzącej bez kary za niepotwierdzenie deklaracji.

Bank spółdzielczy uzyskał kompletne, pozytywne wyniki we wszystkich ośmiu obszarach, bez żadnych niezgodności i bez rozbieżności między perspektywami. Szczegółowe ustalenia dla każdego obszaru przedstawiono poniżej.

(i) *Strategia cyberbezpieczeństwa* (NIS2 art. 20 ust. 1, DORA art. 5): zarząd banku formalnie zatwierdził strategię cyberbezpieczeństwa i ponosi za nią odpowiedzialność prawną. Dokument jest dostępny dla pracowników: użytkownicy końcowi wiedzieli, gdzie go znaleźć, a jego istnienie potwierdzili niezależnie radca prawny i dział IT, co świadczy o realnym wdrożeniu, a nie jedynie formalnym istnieniu dokumentu.

(ii) *Szkolenia zarządu* (NIS2 art. 20 ust. 2, DORA art. 5 ust. 4): członkowie zarządu odbyli obowiązkowe szkolenia z cyberbezpieczeństwa. Dokumentacja szkoleń (lista uczestników, daty, zakresy tematyczne) była dostępna do wglądu audytorów, co eliminuje ryzyko zakwalifikowania szkolenia jako deklaratywnego. Użytkownicy potrafili wskazać członka zarządu odpowiedzialnego za cyberbezpieczeństwo i nadzór nad ryzykiem ICT.

DRAFT

(iii) *Ramy zarządzania ryzykiem ICT* (NIS2 art. 21 ust. 1, DORA art. 6): organizacja wdrożyła udokumentowane ramy zarządzania ryzykiem ICT zatwierdzone przez zarząd, obejmujące rejestr ryzyk z przypisanymi właścicielami i planami mitygacji. Rejestr jest aktualizowany co najmniej raz w roku. Użytkownicy wiedzieli, komu zgłosić zauważone ryzyko związane z systemami IT, co świadczy o wysokiej świadomości organizacyjnej.

(iv) *Ocena ryzyka łańcucha dostaw* (NIS2 art. 21 ust. 2 lit. d, DORA art. 28): organizacja przeprowadza regularną ocenę ryzyka uwzględniającą łańcuch dostaw ICT i dostawców zewnętrznych. Ocena obejmuje wszystkich dostawców z klasyfikacją krytyczności i udokumentowanymi wynikami. Użytkownicy potwierdzili wiedzę o tym, które zewnętrzne podmioty mają dostęp do systemów lub danych organizacji.

(v) *Zgłaszanie poważnych incydentów w ciągu 24 godzin* (NIS2 art. 23 ust. 4 lit. a, DORA art. 19 ust. 4 i art. 20): bank posiada udokumentowaną procedurę umożliwiającą zgłoszenie poważnego incydentu do organu krajowego w wymaganych terminach, w tym w terminie 24 godzin od wykrycia wskazanym w pytaniu. System ticketowy wymusza checkpointy czasowe z automatycznym przypomnieniem. Użytkownicy końcowi wykazali się znajomością kroków postępowania w sytuacji podejrzanego zdarzenia, co potwierdza skuteczność szkoleń.

(vi) *Klasyfikacja incydentów* (NIS2 art. 23 ust. 3, DORA art. 18): organizacja dysponuje procedurą klasyfikacji incydentów pozwalającą ocenić, czy dane zdarzenie spełnia kryteria incydentu poważnego lub znaczącego w rozumieniu regulacji. Użytkownicy wiedzieli, gdzie znaleźć opis, kiedy zdarzenie należy zgłosić jako incydent bezpieczeństwa (instrukcja w intranecie).

(vii) *Powiadamianie klientów o incydentach* (NIS2 art. 23 ust. 1, DORA art. 14 i art. 19 ust. 3): bank posiada zatwierdzoną procedurę komunikacji kryzysowej z gotowymi szablonami i zdefiniowanymi kanałami komunikacji z klientami. Procedura jest możliwa do uruchomienia w krótkim czasie. Użytkownicy wiedzieli, kto w banku decyduje o powiadomieniu klientów lub pracowników o poważnym incydencie.

(viii) *Rejestr dostawców ICT* (DORA art. 28 ust. 3, art. 29 ust. 1): organizacja prowadzi aktualny rejestr zewnętrznych dostawców ICT z klasyfikacją ich krytyczności i przypisaniem do funkcji krytycznych lub istotnych. Rejestr obejmuje dane kontraktowe, zakres usług i daty przeglądów. Użytkownicy potrafili wskazać zewnętrznego dostawcę IT świadczącego usługi najważniejsze dla pracy ich działu.

Kompletna zgodność we wszystkich ośmiu obszarach, potwierdzona niezależnie przez trzy perspektywy, wskazuje na wysoki poziom dojrzałości organizacyjnej banku w zakresie ładu zarządzania ryzykiem ICT. Brak rozbieżności między odpowiedziami działu compliance, działu IT i użytkowników końcowych świadczy o tym, że wdrożone procedury i polityki funkcjonują realnie, a nie tylko jako dokumentacja formalna. Jest to wynik szczególnie istotny w kontekście przeciwdziałania zjawisku compliance theater: potwierdzone, weryfikowalne dowody zastępują deklaratywne zapewnienia, co stanowi jeden z kluczowych postulatów metodologii ORION.

DRAFT

7.6.9 Wyniki sekcji bezpieczeństwo techniczne

Sekcja bezpieczeństwo techniczne jest aktywowana dla obiektów typu `PODMIOT` i w audycie CTN obejmowała ocenę banku jako organizacji. Obejmuje osiem obszarów dotyczących technicznych środków ochrony infrastruktury ICT, zarządzania dostępem, monitorowania oraz ciągłości procesów bezpieczeństwa, wymaganych przez DORA i RODO (NIS2 jako dobra praktyka). We wszystkich ośmiu obszarach bank uzyskał wyniki pozytywne, bez żadnych uchybień i bez rozbieżności między perspektywami. Jest to jeden z silniejszych wyników całego audytu, wskazujący na dojrzałość operacyjną działu IT oraz na skuteczność szkoleń i kultury bezpieczeństwa w organizacji.

(i) *Testy bezpieczeństwa i testy penetracyjne* (NIS2 art. 21 ust. 2 lit. f, DORA art. 24–25): organizacja przeprowadza regularne testy bezpieczeństwa, testy podatności oraz testy penetracyjne zgodnie z rocznym planem obejmującym harmonogram i zakres. Wyniki testów są dokumentowane i powiązane z procesem naprawczym. Użytkownicy potrafili wskazać komórkę odpowiedzialną za testy bezpieczeństwa używanych systemów.

(ii) *Monitoring i wykrywanie anomalii* (NIS2 art. 21 ust. 2 lit. b, DORA art. 10): wdrożone mechanizmy ciągłego monitorowania pokrywają wszystkie systemy krytyczne i generują alerty w czasie rzeczywistym. Ponieważ żaden system krytyczny nie jest wyłączony z monitoringu, wymóg dokumentowania wyłączeń i środków kompensujących (zasada Z8) nie miał w tym audycie zastosowania do systemów krytycznych. Za obsługę alertów odpowiada dedykowany zespół, co potwierdzili użytkownicy: wiedzieli, że podejrzane zdarzenie mogą zgłosić do tego zespołu o każdej porze.

(iii) *Zasada minimalnych uprawnień* (DORA art. 9, NIS2 art. 21): dostęp do systemów krytycznych jest nadawany zgodnie z zasadą least privilege i regularnie przeglądany. Przeglądy uprawnień odbywają się co najmniej raz na kwartał i są odnotowywane w narzędziu klasy PAM (Privileged Access Management). Użytkownicy potwierdzili, że nie posiadają dostępu do zasobów wykraczających poza zakres ich obowiązków.

(iv) *Szkolenia i świadomość pracowników* (NIS2 art. 21 ust. 2 lit. g, DORA art. 13 ust. 6): pracownicy przechodzą regularne szkolenia z cyberbezpieczeństwa dostosowane do roli (odrębne ścieżki dla personelu IT, biznesowego i zarządu). Skuteczność szkoleń jest mierzona przez symulowane kampanie phishingowe. Użytkownicy potwierdzili udział w szkoleniu z cyberbezpieczeństwa w ciągu ostatnich 12 miesięcy.

(v) *Offboarding i usuwanie dostępu* (DORA art. 9 ust. 4 lit. c, NIS2 art. 21 ust. 2 lit. i): organizacja posiada udokumentowany i zautomatyzowany proces dezaktywacji kont przy odejściu pracownika. Dezaktywacja następuje w dniu odejścia i obejmuje wszystkie systemy bez konieczności ręcznej interwencji administratora w poszczególnych aplikacjach. Użytkownicy potwierdzili, że konta osób, które odeszły z banku, znikają z książki adresowej i komunikatora najpóźniej w dniu odejścia.

(vi) *Bezpieczeństwo poczty elektronicznej i załączników* (RODO art. 32, NIS2 art. 21, DORA art. 9 ust. 3 lit. a): organizacja posiada politykę regulującą wysyłanie danych osobowych, w tym szczególnych kategorii danych osobowych, pocztą elektroniczną, z wymogiem szyfrowania załączników zawierających dane klientów. Użytkownicy zadeklarowali, że pliki z danymi klientów wysyłają wyłącznie zaszyfrowane albo przez firmowe narzędzie do bezpiecznego udostępniania plików.

DRAFT

(vii) *Segmentacja sieci i kontrola ruchu bocznego* (DORA art. 9, NIS2 art. 21): systemy krytyczne są logicznie odizolowane od pozostałej infrastruktury sieciowej przez segmentację VLAN uniemożliwiającą niekontrolowane przemieszczanie się potencjalnego atakującego między segmentami (lateral movement). Polityki firewalla wymuszają kontrolę ruchu wschód-zachód między segmentami. Użytkownicy potwierdzili, że połączenie z systemami krytycznymi wymaga specjalnego dostępu (np. VPN lub stacji przesiadkowej) i nie jest możliwe bezpośrednio z sieci biurowej.

(viii) *Zarządzanie certyfikatami TLS* (DORA art. 9, NIS2 art. 21 ust. 2 lit. h): organizacja prowadzi inwentarz certyfikatów TLS z datami wygasania i wdrożonym procesem automatycznego odnawiania. Stosowane narzędzie monitorujące generuje alerty z wyprzedzeniem co najmniej 30 dni przed wygaśnięciem certyfikatu. Użytkownicy nie odnotowali przypadków ostrzeżeń przeglądarki o wygasłym certyfikacie na systemach banku.

Pełna zgodność we wszystkich ośmiu obszarach technicznych, potwierdzona spójnie przez wszystkie trzy perspektywy, świadczy o wysokiej kulturze bezpieczeństwa technicznego w organizacji. Szczególnie istotny jest wynik w obszarze szkoleń i świadomości: użytkownicy końcowi wykazali praktyczną wiedzę z zakresu cyberbezpieczeństwa, co bezpośrednio przekłada się na ograniczenie ryzyka ataków socjotechnicznych (phishing, vishing) jako najczęstszego wektora inicjalnego kompromitacji systemów finansowych.

7.6.10 Wyniki sekcji bezpieczeństwo fizyczne

Sekcja bezpieczeństwo fizyczne obejmuje osiem obszarów dotyczących ochrony fizycznej obiektów, infrastruktury serwerowej i nośników danych, wymaganych przez DORA oraz RODO (NIS2 jako dobra praktyka). Spośród ośmiu obszarów siedem zostało ocenionych pozytywnie przez wszystkie trzy perspektywy (zgodności, techniczną i użytkownika). Jeden obszar sklasyfikowany jako zalecany (strefy bezpieczeństwa) ujawnił nieprawidłowość, omówioną szczegółowo poniżej.

(i) *Bezpieczeństwo fizyczne centrów danych* (DORA art. 9, NIS2 art. 21): polityki bezpieczeństwa fizycznego centrum danych spełniają wymogi w zakresie poufności, integralności i ochrony dostępu. Stosowana jest kontrola dostępu (karty dostępu) z rejestrowaniem każdego wejścia, monitoring środowiskowy z alertowaniem całodobowym oraz CCTV. Użytkownicy potwierdzili, że pomieszczenia z serwerami i urządzeniami sieciowymi są zamknięte i niedostępne dla osób bez uprawnień.

(ii) *Kontrola dostępu fizycznego do obiektów* (DORA art. 9, NIS2 art. 21): organizacja posiada formalną politykę kontroli dostępu fizycznego do pomieszczeń przetwarzających dane. Dostęp do serwerowni jest logowany elektronicznie, bez możliwości wejścia wyłącznie na podstawie klucza mechanicznego, a użytkownicy uprawnieni do wejścia korzystają z imiennych kart. Wynik potwierdzony zgodnie przez wszystkie trzy perspektywy.

(iii) *Monitoring CCTV i rejestracja wideo* (RODO art. 5 ust. 1 lit. e, NIS2 art. 21, DORA art. 6 ust. 2): obszary krytyczne są objęte monitoringiem kamer z retencją nagrań zgodną z polityką bezpieczeństwa i wymogami RODO. Kamery obejmują punkty wejścia do stref krytycznych, a nagrania są chronione przed modyfikacją.

DRAFT

(iv) *Zasilanie i redundancja energetyczna* (DORA art. 11, NIS2 art. 21): obiekty krytyczne posiadają redundantne zasilanie z niezależnych źródeł oraz zasilacze UPS. Urządzenia zasilające są regularnie testowane pod obciążeniem. Użytkownicy potwierdzili, że przy krótkim zaniku zasilania używane systemy nadal działają.

(v) *Wynoszenie i transport urządzeń* (RODO art. 32, NIS2 art. 21, DORA art. 6 ust. 2): organizacja posiada procedurę wynoszenia urządzeń poza siedzibę z rejestrem wydanych sprzętów. Urządzenia przenośne mają wymuszone szyfrowanie całego dysku oraz możliwość zdalnego wyczyszczenia w przypadku utraty lub kradzieży. Użytkownicy wiedzieli, co zrobić i dokąd zadzwonić w razie zgubienia służbowego laptopa lub telefonu.

(vi) *Niszczenie i utylizacja nośników danych* (RODO art. 5, NIS2 art. 21, DORA art. 6 ust. 2): bank posiada procedurę bezpiecznego niszczenia nośników danych, obejmującą dyski twarde, nośniki przenośne oraz wydruki. Dyski są niszczone fizycznie lub nadpisywane skuteczną metodą przed utylizacją. Użytkownicy wiedzieli, komu oddać sprzęt lub nośnik do bezpiecznego usunięcia danych.

(vii) *Strefy bezpieczeństwa i segmentacja fizyczna* (NIS2 art. 21, DORA art. 6 ust. 2 i art. 9 ust. 4 lit. c, ISO 27001 A.11): w tym obszarze stwierdzono niezgodność. Obiekty nie są w wystarczającym stopniu podzielone na odrębne strefy bezpieczeństwa z różnymi poziomami kontroli dostępu. W trakcie audytu z perspektywy użytkownika ustalono, że goście i serwisanci zewnętrzni nie są stale eskortowani przez pracownika i mogą swobodnie poruszać się po biurze bez dodatkowej autoryzacji na kolejnych granicach stref. Oznacza to, że osoba posiadająca dostęp do przestrzeni biurowej może potencjalnie zbliżyć się do obszarów technicznych bez skutecznej przeszkody fizycznej lub proceduralnej.

(viii) *Ochrona przed kradzieżą i sabotażem fizycznym* (NIS2 art. 21, DORA art. 6 ust. 2 i art. 9 ust. 4 lit. c, ISO 27001 A.11): bank stosuje system alarmowy, a szafy rack z serwerami są zamknięte na klucz (perspektywa zgodności: `TAK`). Weryfikacja techniczna potwierdziła kontrolę portów USB i zamknięcie szaf (`TAK`), a użytkownicy potwierdzili, że prywatny pendrive jest blokowany na komputerze służbowym (`TAK`). Obserwacja dotycząca niewystarczającego nadzoru nad gośćmi, którzy mogą zbliżyć się do pomieszczeń ze sprzętem IT, jest przedmiotem pytania o strefy bezpieczeństwa i została uwzględniona tam; nie jest liczona ponownie w tym obszarze.

Zidentyfikowane ryzyko ma charakter zalecenia (nie wymagania obowiązkowego w rozumieniu DORA) i wynika z braku formalnej procedury nadzoru nad gośćmi oraz braku fizycznej segmentacji stref o różnym poziomie wrażliwości. Jako działania naprawcze wskazano wdrożenie rejestru gości z obowiązkowym eskortowaniem poza strefą publiczną, wprowadzenie bramek lub drzwi z osobną autoryzacją na granicy strefy biurowej i technicznej oraz rozważenie instalacji systemu zarządzania gośćmi (visitor management system) rejestrującego każde wejście i wyjście w czasie rzeczywistym.

7.6.11 Wyniki sekcji system informatyczny

Sekcja system informatyczny obejmuje dziewięć obszarów dotyczących bezpieczeństwa warstwy aplikacyjnej systemu CTN, w tym zarządzania dostępem, szyfrowania, kopii zapasowych, logowania i zarządzania podatnościami, wymaganych przez DORA i RODO

DRAFT

(NIS2 jako dobra praktyka). Spośród dziewięciu obszarów osiem zostało ocenionych jednomyślnie twierdząco przez wszystkie trzy perspektywy, w tym MFA, którego brak wykryto na początku audytu jako niespełnienie pytania blokującego i usunięto przed jego zakończeniem. Jeden obszar ujawnił rozbieżność perspektyw: perspektywa użytkownika nie potwierdziła stanu deklarowanego przez perspektywy zgodności i techniczną (retencja logów).

(i) *Uprawnienia i dostępy aplikacji dostawcy* (DORA art. 9, NIS2 art. 21): konta serwisowe aplikacji dostawcy posiadają ograniczony zakres uprawnień w usłudze katalogowej, bez dostępu do systemów niezwiązanych z obsługą CTN, i są regularnie przeglądane. Użytkownicy wiedzieli, kto w banku zatwierdza zakres dostępu aplikacji i integracji dostawcy.

(ii) *Dostęp zdalny dostawcy* (DORA art. 28, NIS2 art. 21 ust. 2 lit. d i lit. i): zdalny dostęp dostawcy do systemu jest kontrolowany, logowany i ograniczony czasowo. Sesje serwisowe wymagają jawnej akceptacji po stronie organizacji, co wyklucza możliwość nieautoryzowanego dostępu przez dostawcę bez wiedzy banku.

(iii) *Rejestr zasobów ICT* (DORA art. 8, NIS2 art. 21 ust. 2 lit. i): system CTN figuruje w oficjalnym rejestrze zasobów ICT z przypisaną klasyfikacją krytyczności, właścicielem biznesowym i właścicielem technicznym. Użytkownicy wiedzieli, kto jest właścicielem aplikacji odpowiadającym za jej bezpieczeństwo i aktualizacje.

(iv) *Retencja i ochrona logów aplikacji* (DORA art. 10, NIS2 art. 21): pytanie dotyczy logów aplikacji CTN wraz ze śladem zmian danych (kto, kiedy i co zmienił), a nie logów zdarzeń bezpieczeństwa monitorowanych w sekcji bezpieczeństwa technicznego ani logów operacji dostawcy ocenianych w sekcji dostawcy ICT. Polityka rejestrowania zdarzeń określa zakres, okres przechowywania i ochronę logów (perspektywa zgodności: `TAK`). Logi są przechowywane przez wymagany okres w magazynie chronionym przed modyfikacją (perspektywa techniczna: `TAK`). Perspektywa użytkownika była pytana, czy może uzyskać informację, kto, kiedy i co zmienił w rekordzie, także dla operacji sprzed kilku miesięcy, w aplikacji albo na zgłoszenie do działu IT. Użytkownicy nie potrafili wskazać, czy i jak taką informację uzyskać. Mechanizm logowania został wprawdzie zademonstrowany przez dział IT w toku sesji audytowej, ale audytorom, a nie użytkownikom, więc luka utrzymała się do chwili odpowiedzi (`NIE`). Zgodnie z regułą konsensusu z karą (równanie (7.5)) wynik pytania wynosi $\beta_{cv} \cdot 1{,}0 = 0{,}5$: logi istnieją i są chronione, lecz organizacja nie zapewniła użytkownikom ścieżki uzyskania z nich informacji. Jako działanie naprawcze wskazano opisanie i zakomunikowanie procedury udostępniania historii zmian na zgłoszenie do działu IT.

(v) *Szyfrowanie komunikacji* (DORA art. 9, NIS2 art. 21 ust. 2 lit. h, RODO art. 32): cała komunikacja aplikacji jest szyfrowana przy użyciu protokołu TLS 1.2 lub nowszego. Skanowanie konfiguracji potwierdziło brak przestarzałych protokołów (TLS 1.0/1.1, SSL). Interfejs użytkownika jest dostępny wyłącznie przez HTTPS, co potwierdzili użytkownicy.

(vi) *MFA dla wszystkich użytkowników* (DORA art. 9, NIS2 art. 21 ust. 2 lit. j): w momencie rozpoczęcia audytu stwierdzono brak obowiązkowego uwierzytelnienia wieloskładnikowego (MFA) dla kont użytkowników systemu CTN, w tym kont uprzywi-

DRAFT

lejowanych. Pytanie to zostało sklasyfikowane przez metodologię ORION jako **pytanie blokujące** (wymóg obowiązkowy), co oznacza, że jego niespełnienie zeruje wynik całej sekcji (równanie (7.8)), ogranicza klasyfikację obiektu co najwyżej do NIEZGODNY (równanie (7.16)) i generuje rekomendację o priorytecie P0. Uchybienie zostało niezwłocznie zgłoszone dostawcy d_1, który jest również producentem systemu. W trakcie trwania audytu dostawca wdrożył stosowną zmianę konfiguracyjną, a audytorzy zweryfikowali jej działanie technicznie. Odpowiedzi wszystkich trzech perspektyw na to pytanie zebrano po wdrożeniu poprawki. Wynik obszaru został skorygowany do pozytywnego po potwierdzeniu wdrożenia.

(vii) *Zarządzanie hasłami i polityką haseł* (NIS2 art. 21, DORA art. 9): organizacja posiada formalną politykę haseł określającą minimalną długość, złożoność oraz zakaz ponownego użycia poprzednich haseł. Polityka jest wymuszana technicznie przez dostawcę tożsamości. Perspektywa użytkownika potwierdziła, że system odrzuca zbyt krótkie i popularne hasła oraz nie pozwala ponownie użyć wcześniejszego hasła. Wszystkie trzy perspektywy odpowiedziały `TAK`. Audytorzy odnotowali ponadto, że system nie wymusza okresowej zmiany hasła; kwestia ta nie jest przedmiotem pytania i nie wpływa na wynik.

(viii) *Backup* (DORA art. 12, NIS2 art. 21 ust. 2 lit. c): kopie zapasowe są przechowywane w geograficznie odrębnej lokalizacji, retencja spełnia wymogi regulacyjne, a procedura odtwarzania była regularnie testowana z udokumentowanymi wynikami. Kopie są odizolowane od środowiska produkcyjnego i chronione przed modyfikacją lub usunięciem. Użytkownicy potwierdzili, że przypadkowo usunięte lub uszkodzone dane można odzyskać na zgłoszenie do działu IT.

(ix) *Zarządzanie podatnościami* (NIS2 art. 21 ust. 2 lit. e, DORA art. 9): organizacja posiada formalny proces skanowania podatności CVE i zarządzania aktualizacjami z udokumentowanymi terminami naprawy przypisanymi do właścicieli. Skanowanie systemów krytycznych jest przeprowadzane co najmniej raz w miesiącu. Użytkownicy otrzymują komunikaty o zaplanowanych przerwach serwisowych na instalację poprawek.

Najistotniejszym ustaleniem sekcji jest wykrycie braku MFA jako pytania blokującego. Fakt jego usunięcia w trakcie audytu dokumentuje jedną z kluczowych właściwości metodologii ORION: identyfikacja konkretnego, weryfikowalnego uchybienia i jego naprawa w czasie rzeczywistym jest bardziej wartościowym wynikiem audytu niż brak niezgodności wynikający z powierzchownej oceny. Otwartą kwestią pozostaje brak ścieżki, którą użytkownicy mogliby uzyskać informację z logów aplikacji, co obniża wynik sekcji jako rozbieżność perspektyw.

7.6.12 Wyniki sekcji usługi chmurowe

Sekcja usługi chmurowe jest oceniana dla systemu CTN i obejmuje cztery obszary dotyczące zgodności wynikającej ze specyfiki przetwarzania danych w środowisku zewnętrznym, w tym wymagań RODO i DORA wobec relacji z dostawcą usługi chmurowej (NIS2 jako dobra praktyka). Sekcja została aktywowana z uwagi na klasyfikację systemu CTN jako `CHMURA_EOG`. Trzy z czterech obszarów uzyskały konsensus twierdzący, w tym jeden (procedura reagowania na incydenty po stronie dostawcy) z rozbieżnością perspektyw; niezgodność stwierdzono w zalecanym obszarze zarządzania kluczami szyfrującymi. Prawo

DRAFT

do audytu dostawcy oraz klauzule odpowiedzialności i regresu są oceniane w sekcji dostawcy ICT. Dostawca d_1 utrzymuje system we własnym centrum danych na terytorium RP i działa wyłącznie w jurysdykcji EOG, co w istotny sposób upraszcza część wymagań w porównaniu z dostawcami podlegającymi prawu państw trzecich.

Charakterystycznym ustaleniem tej sekcji był niski poziom wiedzy użytkowników o obowiązkach wynikających z modelu chmurowego, przy jednoczesnej zgodności po stronie technicznej i prawno-compliance w obszarach obowiązkowych. Perspektywa użytkownika ujawniła, że pracownicy banku nie byli świadomi, jakie obowiązki w zakresie bezpieczeństwa spoczywają na organizacji jako administratorze danych, a jakie przejmuje dostawca chmury jako podmiot przetwarzający. Żadne z pytań sekcji nie dotyczy wprost modelu współodpowiedzialności, dlatego luka ta obniża wynik sekcji tylko pośrednio, przez rozbieżność w pytaniu o procedurę reagowania na incydenty po stronie dostawcy; wskazuje na potrzebę przeprowadzenia dedykowanego szkolenia z zakresu modelu współodpowiedzialności (shared responsibility model) obowiązującego w środowiskach chmurowych.

(i) *Dokumentacja DPIA dla przetwarzania w chmurze* (RODO art. 35): przed uruchomieniem systemu CTN przeprowadzono i udokumentowano ocenę skutków dla ochrony danych (DPIA), obejmującą opis przepływów danych osobowych, zidentyfikowane ryzyka i zastosowane środki techniczne. Dokument jest aktualny i był aktualizowany po ostatniej istotnej zmianie infrastruktury.

(ii) *Szyfrowanie at-rest* (DORA art. 9 ust. 4 lit. d, NIS2 art. 21 ust. 2 lit. h, RODO art. 32): dane organizacji przechowywane w systemie są szyfrowane w spoczynku. Obszar ten dotyczy modelu zarządzania kluczami szyfrującymi. Pytanie jest sklasyfikowane jako zalecane, ponieważ żaden z przywołanych przepisów nie nakazuje wprost modelu HYOK; kontrola organizacji nad kluczami jest jednak warunkiem zapewnienia poufności danych klientów banku wobec dostawcy i jego personelu, dlatego w ocenie audytorów stanowi wymaganie konieczne dla bezpieczeństwa systemu, a nie jedynie usprawnienie. Stwierdzono niezgodność: szyfrowanie jest realizowane po stronie dostawcy, który zarządza kluczami, a pytanie dotyczy kluczy kontrolowanych wyłącznie przez organizację (model HYOK). Dostawca ma więc techniczną możliwość odszyfrowania danych. Jako działanie naprawcze wskazano wdrożenie modelu HYOK lub zewnętrznego systemu zarządzania kluczami (external KMS) poza infrastrukturą dostawcy.

(iii) *Procedura reagowania na incydenty po stronie dostawcy* (DORA art. 30 ust. 2 lit. f i ust. 3 lit. b, NIS2 art. 21 ust. 2 lit. d): umowa z dostawcą określa maksymalny czas powiadomienia organizacji o incydencie bezpieczeństwa, umożliwiający dotrzymanie ustawowego obowiązku zgłoszenia do CSIRT lub KNF w ciągu 24 godzin. Powiadomienie trafia do wyznaczonego punktu kontaktowego i zawiera wymagany zakres informacji o zdarzeniu. Użytkownicy nie wiedzieli, kto w organizacji odbiera powiadomienia od dostawcy, co przy odpowiedziach `TAK` pozostałych perspektyw daje rozbieżność i wynik pytania 0,5.

(iv) *Izolacja danych między klientami* (DORA art. 9, RODO art. 32, ISO 27017): dostawca zapewnia pełną logiczną izolację danych organizacji od danych innych klientów (tenantów). Dane systemu CTN są przechowywane w dedykowanej przestrzeni przypisanej wyłącznie do banku. Organizacja posiada dokumentację dostawcy potwierdzającą mechanizmy izolacji. Użytkownicy potwierdzili, że w systemie widzą wyłącznie dane banku.

DRAFT

Wyniki sekcji CHMURA potwierdzają, że wybór krajowego dostawcy działającego w jurysdykcji EOG istotnie ogranicza ryzyko regulacyjne związane z przetwarzaniem w chmurze. Brak ekspozycji na przepisy o ekstraterytorialnym dostępie do danych (US CLOUD Act, FISA Section 702) eliminuje potrzebę przeprowadzenia TIA. Rekomendacjami wynikającymi z tej sekcji są przejęcie przez organizację kontroli nad kluczami szyfrującymi oraz uzupełnienie wiedzy użytkowników na temat modelu współodpowiedzialności w środowiskach chmurowych, tak aby personel operacyjny rozumiał granicę między obowiązkami banku a obowiązkami dostawcy w przypadku incydentu lub kontroli regulatora.

7.6.13 Wyniki sekcji dane poufne

Sekcja dane poufne obejmuje cztery obszary dotyczące obowiązków administratora danych osobowych, wymaganych przez RODO. Sekcja jest oceniana na poziomie podmiotu v_0 i została aktywowana, ponieważ system CTN przetwarza dane osobowe klientów ($O \in D(\text{CTN})$). Dwa z czterech pytań (procedura zgłaszania naruszeń do UODO i rejestr czynności przetwarzania) są obowiązkowe i blokujące. We wszystkich czterech obszarach organizacja uzyskała wyniki pozytywne, a odpowiedzi były spójne we wszystkich trzech perspektywach. Bank wykazał się pełną wiedzą proceduralną i techniczną w zakresie ochrony danych osobowych klientów.

(i) *Zgłaszanie naruszeń danych osobowych do UODO* (RODO art. 33): organizacja posiada odrębną procedurę zgłaszania naruszeń ochrony danych osobowych do Prezesa UODO w ciągu 72 godzin, wyraźnie rozróżnioną od procedury zgłoszeń ICT do CSIRT i KNF. Istnieją oddzielne ścieżki eskalacji dla obu typów zdarzeń, co eliminuje ryzyko błędnego zakwalifikowania naruszenia danych osobowych wyłącznie jako incydentu technicznego i pominięcia obowiązku zgłoszenia do organu ochrony danych. Użytkownicy wiedzieli, komu zgłosić podejrzenie wycieku danych osobowych, np. wysłanie wiadomości z danymi klientów do niewłaściwej osoby.

(ii) *Inspektor Ochrony Danych* (RODO art. 37–39): organizacja powołała Inspektora Ochrony Danych, zarejestrowała go w UODO i udostępniła jego dane kontaktowe klientom oraz pracownikom. IOD posiada bezpośredni dostęp do zarządu i działa niezależnie, bez podlegania instrukcjom w zakresie wykonywania swoich zadań ustawowych. Użytkownicy wiedzieli, kto pełni funkcję IOD i jak można się z nim skontaktować, co świadczy o skutecznej komunikacji wewnętrznej w tym obszarze.

(iii) *Rejestr Czynności Przetwarzania* (RODO art. 30): organizacja prowadzi aktualny rejestr czynności przetwarzania (RCP) w formie elektronicznej, obejmujący cele przetwarzania, podstawy prawne, kategorie danych i odbiorców oraz okresy retencji i stosowane środki bezpieczeństwa dla każdej czynności. Rejestr jest aktualizowany w ramach procesu zarządzania zmianami, dzięki czemu odzwierciedla aktualny stan systemu. Użytkownicy wiedzieli, kto w banku prowadzi rejestr i do kogo zgłasza się nowe procesy przetwarzania danych osobowych.

(iv) *Harmonogram retencji i usuwania danych osobowych* (RODO art. 5): organizacja posiada formalny harmonogram retencji z określonymi maksymalnymi okresami przechowywania danych osobowych i mechanizmem ich automatycznego usuwania lub

DRAFT

anonimizacji po upływie tych okresów. Proces jest logowany, co umożliwia jego weryfikację przez audytorów. Użytkownicy potwierdzili, że w używanych systemach nie widzą danych osób, z którymi bank dawno zakończył współpracę.

Pełna zgodność we wszystkich czterech obszarach, z wysokim poziomem świadomości we wszystkich trzech perspektywach, potwierdza dojrzałość organizacji w zakresie ochrony danych osobowych. Szczególnie istotna jest spójność między procedurami zgłaszania naruszeń do UODO i do CSIRT (oddzielne ścieżki eskalacji), która eliminuje jedno z najczęstszych uchybień proceduralnych obserwowanych w audytach sektora finansowego, polegające na myleniu incydentu ICT z naruszeniem ochrony danych osobowych w rozumieniu RODO.

7.6.14 Wyniki sekcji dostawcy ICT

Sekcja dostawcy ICT dotyczy zarządzania ryzykiem zewnętrznych dostawców ICT, wymaganego przez DORA, z odwołaniem do NIS2 i wytycznych EBA jako dobrej praktyki. Jest oceniana dla obiektu d_1 typu `DOSTAWCA`: krajowej spółki, która jest producentem systemu CTN, przeprowadziła jego wdrożenie i utrzymuje go we własnym centrum danych na terytorium RP. Identyfikacja poddostawców (sekcja 7.3.9) udokumentowała, że dostawca nie korzysta z poddostawców przy świadczeniu usługi; graf ICT nie zawiera więc wierzchołków na głębokości 3. Sekcja obejmuje osiem pytań. Weryfikacja umów i dokumentacji dostawcy nie wykazała niezgodności. Siedem obszarów uzyskało jednomyślne `TAK`, a jeden (dostęp do logów po stronie dostawcy) rozbieżność perspektyw.

(i) *Dostęp do logów bezpieczeństwa po stronie dostawcy* (DORA art. 10, NIS2 art. 21): pytanie dotyczy innych logów niż pytanie o retencję logów aplikacji: logów prowadzonych przez dostawcę, rejestrujących jego dostępy administracyjne i zmiany konfiguracji w środowisku, w którym działa system CTN. Umowa zapewnia organizacji dostęp do tych logów przez wymagany okres (perspektywa zgodności: `TAK`), a ich udostępnianie, retencja i ochrona przed modyfikacją zostały zweryfikowane przez audytorów bezpośrednio w środowisku dostawcy (perspektywa techniczna: `TAK`). Użytkownicy potwierdzili, że system przechowuje historię dostępu do danych, lecz, podobnie jak w pytaniu o logi aplikacji, nie potrafili wskazać, jak uzyskać informację o operacjach wykonanych przez dostawcę, w systemie albo za pośrednictwem działu IT. Luka utrzymała się do chwili odpowiedzi (`NIE`), co daje rozbieżność perspektyw i wynik pytania 0,5. Oba pytania dotyczą różnych logów, lecz tej samej przyczyny rozbieżności: braku znanej użytkownikom ścieżki uzyskania informacji z logów.

(ii) *Due diligence i ocena ryzyka dostawcy* (DORA art. 28, NIS2 art. 21 ust. 2 lit. d i ust. 3, EBA/GL/2019/02): przed zawarciem umowy z dostawcą systemu CTN przeprowadzono due diligence obejmujące weryfikację posiadanych certyfikatów bezpieczeństwa, lokalizacji przetwarzania danych, listy sub-procesorów oraz wyników testów penetracyjnych środowiska dostawcy. Użytkownicy wiedzieli, kto w banku ocenia i zatwierdza dostawców IT przed podpisaniem umowy.

(iii) *Analiza skutków awarii dostawcy dla funkcji organizacji* (DORA art. 28, NIS2 art. 21 ust. 2 lit. a i lit. d): organizacja przeprowadziła i udokumentowała analizę skutków niedostępności dostawcy dla funkcji realizowanych przez system CTN. Analiza jest

DRAFT

częścią dokumentacji ciągłości działania i obejmuje scenariusz niedostępności dostawcy oraz awarii kaskadowej. Użytkownicy potwierdzili, że uzgodniono z nimi tryb pracy zastępczej, czyli tymczasowe zastąpienie kanału cyfrowego korespondencją papierową.

(iv) *Prawa audytu dostawcy* (DORA art. 30 ust. 3 lit. e, EBA/GL/2019/02): umowa z dostawcą zawiera zapis gwarantujący organizacji prawo do przeprowadzenia audytu, w tym audytu na miejscu (onsite), bez możliwości zastąpienia go wyłącznie raportem własnym dostawcy. Organizacja posiada dostęp do logów infrastrukturalnych i konfiguracji bezpieczeństwa środowiska dostawcy, a ostatni raport z audytu był dostępny do wglądu audytorów z potwierdzeniem zaadresowania wszystkich obserwacji. Użytkownicy potrafili wskazać osobę odpowiedzialną za audyty i przeglądy dostawcy.

(v) *Klauzule SLA i gwarantowana dostępność* (DORA art. 30 ust. 2 lit. e i ust. 3 lit. a): umowa z dostawcą zawiera mierzalne i egzekwowalne wskaźniki poziomu usług (SLA) z gwarantowaną dostępnością dostosowaną do krytyczności systemu CTN, wraz z sankcjami umownymi za niedotrzymanie uzgodnionych parametrów. Dostępność usługi jest mierzona technicznie przez bank i porównywana z wartościami SLA. Użytkownicy wiedzieli, gdzie sprawdzić dopuszczalny czas niedostępności systemu wynikający z umowy (u właściciela systemu).

(vi) *Klauzule exit i prawo do migracji danych* (DORA art. 30 ust. 3 lit. f): umowa z dostawcą zawiera klauzule exit obejmujące prawo do pełnego eksportu danych w otwartym formacie, wsparcie przejściowe dostawcy oraz zakaz utrudniania migracji. Osoba odpowiedzialna za umowę wskazała zapis gwarantujący zabranie wszystkich danych po zakończeniu współpracy bez dodatkowych opłat.

(vii) *Klauzule powiadomień o zmianach u dostawcy* (DORA art. 30 ust. 2 lit. b i ust. 3 lit. b): umowa zobowiązuje dostawcę do uprzedniego informowania organizacji o istotnych zmianach, w tym zmianach w sub-procesorach, lokalizacji danych, architekturze bezpieczeństwa i strukturze właścicielskiej, z zachowaniem minimalnego okresu wyprzedzenia. Brak powiadomienia w wymaganym terminie uprawnia organizację do rozwiązania umowy bez kary. Użytkownicy wiedzieli, kto w banku otrzymuje od dostawcy takie powiadomienia.

(viii) *Klauzule odpowiedzialności i regres od dostawcy* (dobra praktyka, brak wymogu ustawowego): umowa zawiera klauzulę umożliwiającą organizacji dochodzenie regresem kosztów kar regulacyjnych nałożonych na bank przez KNF lub UODO w przypadku, gdy ich przyczyną był błąd lub zaniedbanie po stronie dostawcy. Zakres klauzuli odpowiedzialności nie jest ograniczony wyłącznie do wartości ostatniej faktury, a osoba odpowiedzialna za umowę wskazała odpowiedni zapis.

Wyniki sekcji dostawcy ICT potwierdzają, że bank prowadzi relację z dostawcą systemu CTN zgodnie z wymaganiami DORA w zakresie zarządzania ryzykiem stron trzecich. Krajowy charakter dostawcy i jego działalność wyłącznie w jurysdykcji EOG istotnie upraszcza zarządzanie ryzykiem w łańcuchu dostaw: brak sub-procesorów z krajów trzecich eliminuje konieczność prowadzenia rozbudowanego monitoringu na poziomie poddostawców, który jest typowym źródłem niezgodności w przypadku dostawców korzystających z infrastruktury globalnych hiperskalerów.

DRAFT

7.6.15 Wyniki sekcji plan wyjścia z usługi (exit plan)

Sekcja exit plan obejmuje sześć obszarów dotyczących gotowości organizacji do zakończenia współpracy z dostawcą systemu CTN w sposób kontrolowany, bez utraty danych i bez zakłócenia ciągłości działania, wymaganych przez DORA art. 28. Sekcja została aktywowana z uwagi na klasyfikację audytowanego podmiotu jako `FINANSOWY`, krytyczność systemu `WAŻNY` i obsługę systemu przez zewnętrznego dostawcę ICT. Cztery spośród sześciu obszarów uzyskały konsensus twierdzący, w tym jeden (eksport danych) z rozbieżnością perspektyw. Konsensus przeczący uzyskały dwa obszary: testowanie planu oraz czas i koszty wyjścia; oba wynikają z tego, że plan nie był dotychczas testowany. Bank wykazał się wysoką świadomością proceduralną i prawną, natomiast audyt ujawnił lukę w wiedzy użytkowników o tym, czym jest exit plan i jakie uprawnienia organizacji z niego wynikają, którą uzupełniono w toku sesji audytowej.

(i) *Istnienie i zatwierdzenie exit planu* (DORA art. 28 ust. 8): organizacja posiada formalny exit plan zatwierdzony przez zarząd, traktowany jako dokument żywy i aktualizowany przy każdej istotnej zmianie systemu lub dostawcy. Dokument zawiera konkretne kroki techniczne, narzędzia migracyjne i sekwencje wyłączeń, a nie jedynie deklaratywny opis intencji. Użytkownicy wiedzieli, kto w banku odpowiada za plan zmiany dostawcy systemu.

(ii) *Kompletność i możliwość eksportu danych* (DORA art. 30 ust. 2 lit. d, art. 28 ust. 8): exit plan gwarantuje pełny eksport danych do formatu niezależnego od narzędzi własnościowych dostawcy, a użytkownicy, po wyjaśnieniu i demonstracji w toku sesji audytowej, potwierdzili, że dane można pobrać w całości w standardowym formacie. Procedura eksportu nie została jednak przetestowana, a jej czas i kompletność nie są udokumentowane (zob. testowanie exit planu). Perspektywa techniczna odpowiedziała więc `NIE`, co daje rozbieżność perspektyw i wynik pytania 0,5.

(iii) *Czas i koszty wyjścia* (DORA art. 28 ust. 8): exit plan zawiera udokumentowaną analizę czasu pełnej migracji (RTE) oraz kosztów wyjścia zatwierdzoną przez zarząd, obejmującą czas migracji danych, koszt wdrożenia alternatywnego systemu, koszty równoległego utrzymania obu środowisk oraz ryzyko utraty ciągłości działania. Analiza nie została jednak zweryfikowana w teście, czego wymaga pytanie techniczne, więc perspektywa techniczna odpowiedziała `NIE`. Użytkownicy nie posiadali wiedzy o szacowanych czasach migracji (`NIE`). Przy jednej odpowiedzi twierdzącej (zgodność) konsensus jest przeczący, a wynik pytania wynosi 0.

(iv) *Alternatywny dostawca i przenośność usługi* (DORA art. 28 ust. 8): organizacja zidentyfikowała co najmniej jednego alternatywnego dostawcę zdolnego do przejęcia funkcji systemu CTN i oceniła jego zdolność do onboardingu. Architektura systemu opiera się na otwartych standardach, bez uzależnienia od własnościowych formatów danych lub interfejsów API uniemożliwiających migrację. Użytkownicy zostali poinformowani o istnieniu zidentyfikowanego dostawcy alternatywnego, co wzmacnia ich poczucie ciągłości obsługi.

(v) *Bezpieczne usunięcie danych u dostawcy po wyjściu* (RODO art. 28 ust. 3 lit. g, DORA art. 30 ust. 2 lit. d): umowa z dostawcą zawiera klauzulę zobowiązującą go do wydania certyfikatu zniszczenia danych po zakończeniu współpracy, obejmującego kopie zapasowe, logi i dane archiwalne. Procedura bezpiecznego usunięcia danych

DRAFT

jest opisana w exit planie z przypisaną odpowiedzialnością i terminami. Użytkownicy, po uzupełnieniu wiedzy w toku sesji audytowej, wskazali osobę odbierającą od dostawcy potwierdzenie usunięcia danych.

(vi) *Testowanie exit planu* (DORA art. 28 ust. 8): stwierdzono niezgodność. Exit plan nie był dotychczas testowany w żadnej formie, ani jako rzeczywiste przełączenie środowiska, ani jako ćwiczenie stołowe (tabletop exercise). DORA art. 28 ust. 8 wymaga, aby plany wyjścia były wystarczająco przetestowane i podlegały okresowym przeglądom, z udokumentowanymi wynikami dostępnymi dla audytorów. Brak testów oznacza, że poprawność procedur migracyjnych, kompletność eksportu danych i realność zadeklarowanych parametrów RTE pozostają niezweryfikowane empirycznie. Jako działanie naprawcze wskazano przeprowadzenie w najbliższym cyklu rocznym testu eksportu danych do formatu niezależnego od dostawcy, z udokumentowaniem czasu i kompletności eksportu, oraz opracowanie harmonogramu regularnych ćwiczeń z exit planu.

Wyniki sekcji exit plan wskazują na wysoką dojrzałość organizacji w zakresie dokumentacji i struktury planu wyjścia, z jednym istotnym uchybieniem: brakiem jakiegokolwiek testowania planu. Brak testów przekłada się również na wynik dwóch innych obszarów: czasu i kosztów wyjścia (konsensus przeczący) oraz eksportu danych (rozbieżność perspektyw). Pozostałe trzy obszary (istnienie i zatwierdzenie planu, identyfikacja alternatywnego dostawcy, procedura bezpiecznego usunięcia danych) były kompletne i zgodne z wymogami DORA. Priorytetowym działaniem naprawczym jest przeprowadzenie pierwszego testu exit planu we współpracy z dostawcą, obejmującego rzeczywisty eksport danych, tak aby plan przestał być wyłącznie dokumentem, a stał się zweryfikowaną procedurą operacyjną. Rekomendowanym działaniem uzupełniającym jest podniesienie świadomości personelu operacyjnego o tym, czym jest exit plan i jakie uprawnienia (prawo do eksportu danych, prawo do certyfikatu zniszczenia, prawo do audytu) przysługują organizacji wobec dostawcy.

7.6.16 Wyniki sekcji plan ciągłości działania (BCP)

Sekcja plan ciągłości działania obejmuje pięć obszarów dotyczących gotowości organizacji do utrzymania ciągłości działania i odtworzenia funkcji krytycznych po poważnym incydencie ICT, wymaganych przez DORA art. 11 (NIS2 art. 21 jako dobra praktyka). Sekcja została aktywowana z uwagi na klasyfikację systemu CTN jako `WAŻNY` i klasyfikację podmiotu jako `FINANSOWY`. Wszystkie pięć obszarów uzyskało konsensus twierdzący, przy czym w dwóch (testowanie oraz komunikacja kryzysowa) wystąpiła rozbieżność perspektyw. Podobnie jak w sekcjach Usługi w chmurze i exit plan, wyniki wymagały uzupełnienia wiedzy użytkowników, którzy nie zawsze rozumieli czym jest plan ciągłości działania i jakie uprawnienia oraz obowiązki się z nim wiążą. Dział compliance i dział IT wykazały się wysoką świadomością i znajomością dokumentacji.

(i) *Istnienie i zatwierdzenie planów BCP i DRP* (DORA art. 11, NIS2 art. 21 ust. 2 lit. c): organizacja posiada formalne plany ciągłości działania (BCP) i odtwarzania po awarii (DRP) zatwierdzone przez zarząd, obejmujące funkcje krytyczne ICT. Dokumenty zawierają konkretne kroki techniczne, sekwencje przełączeń i drzewa decyzyjne dla poszczególnych scenariuszy, nie zaś ogólne deklaracje intencji. Użytkownicy potwierdzili ogólną wiedzę o procedurach awaryjnych, w tym o zastępczym trybie pracy w przypadku niedostępności systemu CTN.

DRAFT

(ii) *Scenariusze zagrożeń w BCP i DRP* (DORA art. 11, NIS2 art. 21): plany obejmują konkretne scenariusze zagrożeń, w tym atak ransomware, utratę centrum danych, niedostępność dostawcy chmury i awarię kaskadową w łańcuchu dostaw. Dla każdego scenariusza zdefiniowano odrębną ścieżkę odtwarzania z konkretnymi krokami technicznymi i przypisanymi odpowiedzialnościami. Użytkownicy, po zapoznaniu się ze scenariuszami w trakcie sesji audytowej, wiedzieli, co zrobić i od kogo otrzymają instrukcje, gdyby system został zaszyfrowany przez ransomware.

(iii) *Testowanie BCP i DRP* (DORA art. 11 ust. 6, NIS2 art. 21 ust. 2 lit. c i lit. f): plany były testowane w wymaganym cyklu rocznym, z udokumentowanymi wynikami dostępnymi dla audytorów. Testy obejmowały rzeczywiste przełączenie na środowisko zapasowe z mierzonym RTO i RPO, a nie jedynie ćwiczenie stołowe (tabletop exercise). Użytkownicy w większości nie uczestniczyli bezpośrednio w ćwiczeniach awaryjnych (odpowiedź `NIE` perspektywy użytkownika, wynik pytania 0,5), co wskazuje na potrzebę włączenia szerszego grona pracowników operacyjnych w kolejne testy, tak by posiadali praktyczną znajomość procedur przełączenia.

(iv) *Komunikacja kryzysowa* (NIS2 art. 21 ust. 2 lit. c i art. 23, DORA art. 14): BCP zawiera plan komunikacji kryzysowej z gotowymi szablonami i upoważnieniami do komunikowania się na zewnątrz. Organizacja dysponuje alternatywnym kanałem komunikacji działającym niezależnie od głównej infrastruktury IT, umożliwiającym koordynację działań w przypadku niedostępności poczty elektronicznej i systemów komunikacji wewnętrznej. Użytkownicy nie zawsze posiadali numery kontaktowe kluczowych osób poza środowiskami cyfrowymi (odpowiedź `NIE` perspektywy użytkownika, wynik pytania 0,5), co zostało wskazane jako obszar wymagający uzupełnienia w ramach szkoleń z procedur kryzysowych.

(v) *Scenariusz awarii kaskadowej w łańcuchu dostaw* (DORA art. 11, art. 29 ust. 1, NIS2 art. 21 ust. 2 lit. c i lit. d): organizacja opracowała scenariusz awarii kaskadowej uwzględniający drzewo zależności między dostawcami różnych poziomów i potencjalny wpływ awarii jednego węzła na dostępność funkcji krytycznych. Scenariusz był symulowany w ramach testów BCP, a mapa zależności w rejestrze systemów obejmuje dostawcę d_1 i dokumentuje brak jego poddostawców. Użytkownicy, po zapoznaniu się z koncepcją ryzyka kaskadowego podczas sesji audytowej, wiedzieli, gdzie znaleźć instrukcję postępowania na wypadek awarii dostawcy.

Wyniki sekcji plan ciągłości działania potwierdzają dojrzałość organizacyjną banku w zakresie zarządzania ciągłością działania. Szczególnie istotne jest przeprowadzenie testów z rzeczywistym przełączeniem środowiska, a nie jedynie ćwiczeń stołowych, co odpowiada wzorcowi empirycznej weryfikacji obserwowanemu w sekcji Exit Plan. Wspólnym mianownikiem rekomendacji dla obu tych sekcji jest potrzeba systematycznego włączania personelu operacyjnego w ćwiczenia i szkolenia, tak aby procedury kryzysowe były znane i zrozumiałe nie tylko na poziomie zarządu i działu IT, ale również przez pracowników bezpośrednio obsługujących audytowane systemy.

7.6.17 Podsumowanie wyników audytu i obliczenie $S_{podmiot}$

Krok 1: Zestawienie wszystkich odpowiedzi

Audyt objął łącznie 60 pytań w 9 aktywnych sekcjach, przypisanych do trzech obiektów grafu ICT: podmiotu v_0 (4 sekcje), systemu CTN v_1 (4 sekcje) i dostawcy d_1 (1 sekcja).

DRAFT

Spośród nich 56 uzyskało konsensus twierdzący (TAK), w tym 6 bez jednomyślności perspektyw (rozbieżność), a 4 konsensus przeczący (NIE). Jedno pytanie blokujące (brak MFA) zostało rozwiązane w trakcie audytu i ujęte jako pozytywne w wyniku końcowym. Żadna perspektywa nie udzieliła odpowiedzi `N/D`, zatem $\mathcal{Q}_k^*$ obejmuje wszystkie zadane pytania każdej sekcji (równanie (7.6)).

Tabela 7.13: Zestawienie odpowiedzi audytowych według obiektów i sekcji

Obiekt	**Sekcja**	**Pytań**	**TAK**	**w tym rozbieżn.**	**NIE**	**Niezgodność**
v_0 Bank	Organizacja	8	8	0	0	brak
	Dane poufne	4	4	0	0	brak
	Bezpieczeństwo techniczne	8	8	0	0	brak
	Bezpieczeństwo fizyczne	8	7	0	1	zalecane
v_1 CTN	System informatyczny	9	9	1	0	rozbieżność
	Usługi w chmurze	4	3	1	1	zalecane; rozbieżność
	Exit plan	6	4	1	2	obowiązkowe
	Plan ciągłości działania	5	5	2	0	rozbieżności
d_1	Dostawcy ICT	8	8	1	0	rozbieżność
Łącznie		**60**	**56**	**6**	**4**	

Zidentyfikowane niezgodności (konsensus `NIE`):

(i) *Strefy bezpieczeństwa i segmentacja fizyczna* (zalecane), obiekt v_0: brak segmentacji stref i niewystarczający nadzór nad gośćmi.

(ii) *Szyfrowanie at-rest poza natywnymi funkcjami dostawcy* (zalecane, lecz konieczne dla zapewnienia poufności danych klientów), obiekt v_1: klucze szyfrujące zarządzane przez dostawcę, brak modelu HYOK.

(iii) *Testowanie exit planu* (obowiązkowe) oraz *Czas i koszty wyjścia* (informacyjne), obiekt v_1: plan wyjścia nie był dotychczas testowany, więc również analiza czasu i kosztów wyjścia nie została zweryfikowana.

Rozbieżności perspektyw (konsensus `TAK` bez jednomyślności): w obiekcie v_1 retencja logów aplikacji (obowiązkowe), procedura incydentów po stronie dostawcy (obowiązkowe), eksport danych w exit planie (obowiązkowe; tu `NIE` odpowiedziała perspektywa techniczna), testowanie BCP (obowiązkowe) i komunikacja kryzysowa (zalecane), a w obiekcie d_1 dostęp do logów po stronie dostawcy (obowiązkowe). Poza eksportem danych `NIE` odpowiadała perspektywa użytkownika.

DRAFT

Krok 2: Wagi pytań, jakość dowodów i wzór na wynik sekcji

Zgodnie z równaniem (7.10), każdemu pytaniu przypisywana jest waga $\omega(q_j, k)$ wynikająca z jego efektywnej obligatoryjności. Dla podmiotu klasy $k = \texttt{FINANSOWY}$ efektywna obligatoryjność jest równa typowi pytania z kwestionariusza (równanie (7.12)):

$$\omega(q_j, \texttt{FINANSOWY}) = \begin{cases} 2{,}0 & \text{pytanie obowiązkowe} \\ 1{,}0 & \text{pytanie zalecane} \\ 0{,}5 & \text{pytanie informacyjne} \end{cases}$$

Wynik pytania $S(q_j)$ wyznaczono według reguły konsensusu z karą (równanie (7.5)). Odpowiedzi perspektyw zgodności i technicznej były weryfikowane przez audytorów w dokumentacji i systemach; w audycie pilotażowym nie różnicowano jakości tych dowodów, dlatego przyjęto dla nich dowód silny ($d = 1{,}0$). Użytkownicy składali odpowiedzi jako podpisane oświadczenia imienne, co odpowiada dowodowi średniemu ($d = 0{,}7$). Przy tych założeniach wynik pytania wynosi:

- 0,9 dla jednomyślnego TAK ($\bar{d}^{+} = (1{,}0 + 1{,}0 + 0{,}7)/3$),
- 0,5 dla rozbieżności z odpowiedzią NIE użytkownika ($0{,}5 \cdot 1{,}0$),
- 0,425 dla rozbieżności z odpowiedzią NIE perspektywy technicznej ($0{,}5 \cdot (1{,}0 + 0{,}7)/2$),
- 0 dla konsensusu przeczącego.

Zgodnie z zasadą, że respondent ustala stan faktyczny przed udzieleniem odpowiedzi (sekcja 7.3.2), perspektywa, która uzupełniła wiedzę w toku sesji audytowej przed udzieleniem odpowiedzi, odpowiadała TAK. Odpowiedź NIE przyjęto tam, gdzie luka utrzymała się do chwili odpowiedzi lub pytanie dotyczyło faktu (np. udziału w ćwiczeniu). Wynik sekcji:

$$S(\mathcal{S}_k) = \frac{\sum_{q_j \in \mathcal{Q}_k^*} S(q_j) \cdot \omega(q_j, k)}{\sum_{q_j \in \mathcal{Q}_k^*} \omega(q_j, k)}$$

Żadna sekcja nie ma aktywnej flagi blokującej (równanie (7.7)): wszystkie pytania blokujące uzyskały jednomyślne TAK ($S(q_j) = 0{,}9 \geq \theta_{block}$), w tym pytanie o MFA po wdrożeniu poprawki w trakcie audytu.

Krok 3: Obliczenie wyników poszczególnych sekcji

Podmiot v_0.

ORGANIZACJA: 8 pytań obowiązkowych, wszystkie jednomyślne TAK.

$$S(\mathrm{ORG}) = \frac{8 \times 2{,}0 \times 0{,}9}{8 \times 2{,}0} = 0{,}900$$

DANE_SZCZEGÓLNE: 2 obowiązkowe i 2 zalecane, wszystkie jednomyślne TAK.

$$S(\mathrm{DP}) = \frac{2 \times 2{,}0 \times 0{,}9 + 2 \times 1{,}0 \times 0{,}9}{2 \times 2{,}0 + 2 \times 1{,}0} = \frac{5{,}4}{6} = 0{,}900$$

BEZPIECZENSTWO_TECH: 5 obowiązkowych i 3 zalecane, wszystkie jednomyślne TAK.

$$S(\mathrm{BT}) = \frac{5 \times 2{,}0 \times 0{,}9 + 3 \times 1{,}0 \times 0{,}9}{5 \times 2{,}0 + 3 \times 1{,}0} = \frac{11{,}7}{13} = 0{,}900$$

DRAFT

BEZPIECZENSTWO_FIZYCZNE: 5 obowiązkowych i 2 zalecane jednomyślne TAK (CCTV, ochrona przed kradzieżą), 1 zalecane NIE (strefy).

$$S(\text{BF}) = \frac{5 \times 2{,}0 \times 0{,}9 + 2 \times 1{,}0 \times 0{,}9 + 1 \times 1{,}0 \times 0{,}0}{5 \times 2{,}0 + 2 \times 1{,}0 + 1 \times 1{,}0} = \frac{10{,}8}{13} \approx 0{,}831$$

System v_1 (CTN).

APLIKACJA: 9 obowiązkowych, 8 jednomyślnych TAK, 1 z rozbieżnością (retencja logów). Pytanie MFA zostało rozwiązane w trakcie audytu i wliczone jako TAK.

$$S(\text{APP}) = \frac{8 \times 2{,}0 \times 0{,}9 + 1 \times 2{,}0 \times 0{,}5}{9 \times 2{,}0} = \frac{15{,}4}{18} \approx 0{,}856$$

CHMURA: 2 obowiązkowe jednomyślne TAK, 1 obowiązkowe z rozbieżnością (procedura incydentów), 1 zalecane NIE (HYOK).

$$S(\text{CHM}) = \frac{2 \times 2{,}0 \times 0{,}9 + 1 \times 2{,}0 \times 0{,}5 + 1 \times 1{,}0 \times 0{,}0}{3 \times 2{,}0 + 1 \times 1{,}0} = \frac{4{,}6}{7} \approx 0{,}657$$

EXIT_PLAN: 2 obowiązkowe jednomyślne TAK (istnienie planu, usunięcie danych), 1 obowiązkowe z rozbieżnością perspektywy technicznej (eksport danych), 1 obowiązkowe NIE (brak testu), 1 zalecane jednomyślne TAK, 1 informacyjne NIE (RTE).

$$S(\text{EP}) = \frac{2 \times 2{,}0 \times 0{,}9 + 1 \times 2{,}0 \times 0{,}425 + 1 \times 2{,}0 \times 0{,}0 + 1 \times 1{,}0 \times 0{,}9 + 1 \times 0{,}5 \times 0{,}0}{4 \times 2{,}0 + 1 \times 1{,}0 + 1 \times 0{,}5} = \frac{5{,}35}{9{,}5} \approx 0{,}563$$

PLAN_CIAGLOSCI_DZIALANIA: 3 obowiązkowe jednomyślne TAK, 1 obowiązkowe z rozbieżnością (testowanie), 1 zalecane z rozbieżnością (komunikacja kryzysowa).

$$S(\text{BCP}) = \frac{3 \times 2{,}0 \times 0{,}9 + 1 \times 2{,}0 \times 0{,}5 + 1 \times 1{,}0 \times 0{,}5}{4 \times 2{,}0 + 1 \times 1{,}0} = \frac{6{,}9}{9} \approx 0{,}767$$

Dostawca d_1.

DOSTAWCY: 6 obowiązkowych jednomyślnych TAK, 1 obowiązkowe z rozbieżnością (dostęp do logów po stronie dostawcy), 1 zalecane jednomyślne TAK.

$$S(\text{DOS}) = \frac{6 \times 2{,}0 \times 0{,}9 + 1 \times 2{,}0 \times 0{,}5 + 1 \times 1{,}0 \times 0{,}9}{7 \times 2{,}0 + 1 \times 1{,}0} = \frac{12{,}7}{15} \approx 0{,}847$$

Krok 4: Obliczenie S_{total} obiektów

Zgodnie z równaniem (7.14), wynik każdego obiektu jest średnią arytmetyczną wyników jego aktywnych sekcji:

$$S_{total}(v_0) = \frac{0{,}900 + 0{,}900 + 0{,}900 + 0{,}831}{4} = \frac{3{,}531}{4} \approx \mathbf{0{,}883}$$

$$S_{total}(v_1) = \frac{0{,}856 + 0{,}657 + 0{,}563 + 0{,}767}{4} = \frac{2{,}843}{4} \approx \mathbf{0{,}711}$$

$$S_{total}(d_1) \approx \mathbf{0{,}847}$$

DRAFT

Tabela 7.14: Wyniki sekcji i obiektów audytu CTN

Obiekt	Sekcja	$S(\mathcal{S}_k)$	Niezgodności	Charakter
v_0 Bank	Organizacja	0,900	0	
	Dane poufne	0,900	0	
	Bezpieczeństwo techniczne	0,900	0	
	Bezpieczeństwo fizyczne	0,831	1	zalecane
	$S_{total}(v_0)$	**0,883**		
v_1 CTN	System informatyczny	0,856	1 rozb.	obowiązkowe
	Usługi w chmurze	0,657	1 + 1 rozb.	zalecane; rozb. obowiązkowe
	Plan wyjścia	0,563	2 + 1 rozb.	obowiązkowe
	Plan ciągłości działania (BCP)	0,767	2 rozb.	obowiązkowe i zalecane
	$S_{total}(v_1)$	**0,711**		
d_1	Dostawcy ICT	0,847	1 rozb.	obowiązkowe
	$S_{total}(d_1)$	**0,847**		

Krok 5: Obliczenie $S_{podmiot}$

Łączna waga systemu CTN wynosi $w_{total}(v_1) = w_{krit} \cdot w_{data} \cdot w_{dost} = 1{,}5 \cdot 2{,}0 \cdot 1{,}8 = 5{,}4$. Dostawca d_1 przejmuje mnożniki obsługiwanego systemu, zatem $w_{total}(d_1) = 5{,}4$. Przy $\lambda = 0{,}8$ oraz głębokościach $depth(v_1) = 1$ i $depth(d_1) = 2$ wynik grafu (równanie (7.17)) wynosi:

$$S_{graf} = \frac{0{,}711 \cdot 5{,}4 \cdot 0{,}8 + 0{,}847 \cdot 5{,}4 \cdot 0{,}64}{5{,}4 \cdot 0{,}8 + 5{,}4 \cdot 0{,}64} = \frac{0{,}711 \cdot 0{,}8 + 0{,}847 \cdot 0{,}64}{1{,}44} \approx 0{,}771$$

Ponieważ w grafie występuje jeden system i jeden obsługujący go dostawca o tej samej wadze, w_{total} skraca się, a o wyniku grafu decyduje wyłącznie współczynnik głębokości λ. Wynik podmiotu (równanie (7.18)) przy $\alpha = 0{,}5$ wynosi:

$$S_{podmiot} = 0{,}5 \cdot 0{,}883 + 0{,}5 \cdot 0{,}771 \approx \mathbf{0{,}827}$$

Krok 6: Klasyfikacja końcowa i priorytety

Klasyfikacje według skali interpretacyjnej metodologii ORION (tabela 7.7) są następujące: podmiot v_0 ($S_{total} = 0{,}883$) jest ZGODNY, system CTN ($S_{total}(v_1) = 0{,}711$) i dostawca d_1 ($S_{total} = 0{,}847$) są CZĘŚCIOWO ZGODNE, a wynik podmiotu $S_{podmiot} = 0{,}827$ odpowiada klasyfikacji **CZĘŚCIOWO ZGODNY** (przedział $[0{,}70;\ 0{,}85)$).

DRAFT

Żadna z aktywnych sekcji nie uzyskała wyniku zerowego spowodowanego flagą blokującą (pytanie MFA zostało rozwiązane przed zamknięciem audytu). Nie aktywowano flagi FLAG_{TIA}, ponieważ warunek $\mathcal{C}_{TIA}$ nie jest spełniony dla żadnego obiektu. Klasyfikacje nie podlegają zatem nadpisaniu według równania (7.16), a klasa podmiotu nie jest ograniczana.

Rekomendacje wynikają z warunków na poziomie obiektu i pojedynczych pytań (tabela 7.10):

(i) **P1** (30 dni): przeprowadzenie testu exit planu (pytanie obowiązkowe z $S(q_j) = 0 <$ 0,3).

(ii) **P2** (90 dni): segmentacja stref bezpieczeństwa fizycznego i nadzór nad gośćmi oraz przejęcie kontroli nad kluczami szyfrującymi (HYOK), czyli pytania zalecane z $S(q_j) =$ 0; ponadto rozbieżności w pytaniach obowiązkowych: procedura udostępniania użytkownikom historii zmian z logów aplikacji, wskazanie odbiorcy powiadomień o incydentach od dostawcy, test eksportu danych, włączenie użytkowników w testy BCP oraz ścieżka uzyskania informacji o operacjach administracyjnych dostawcy.

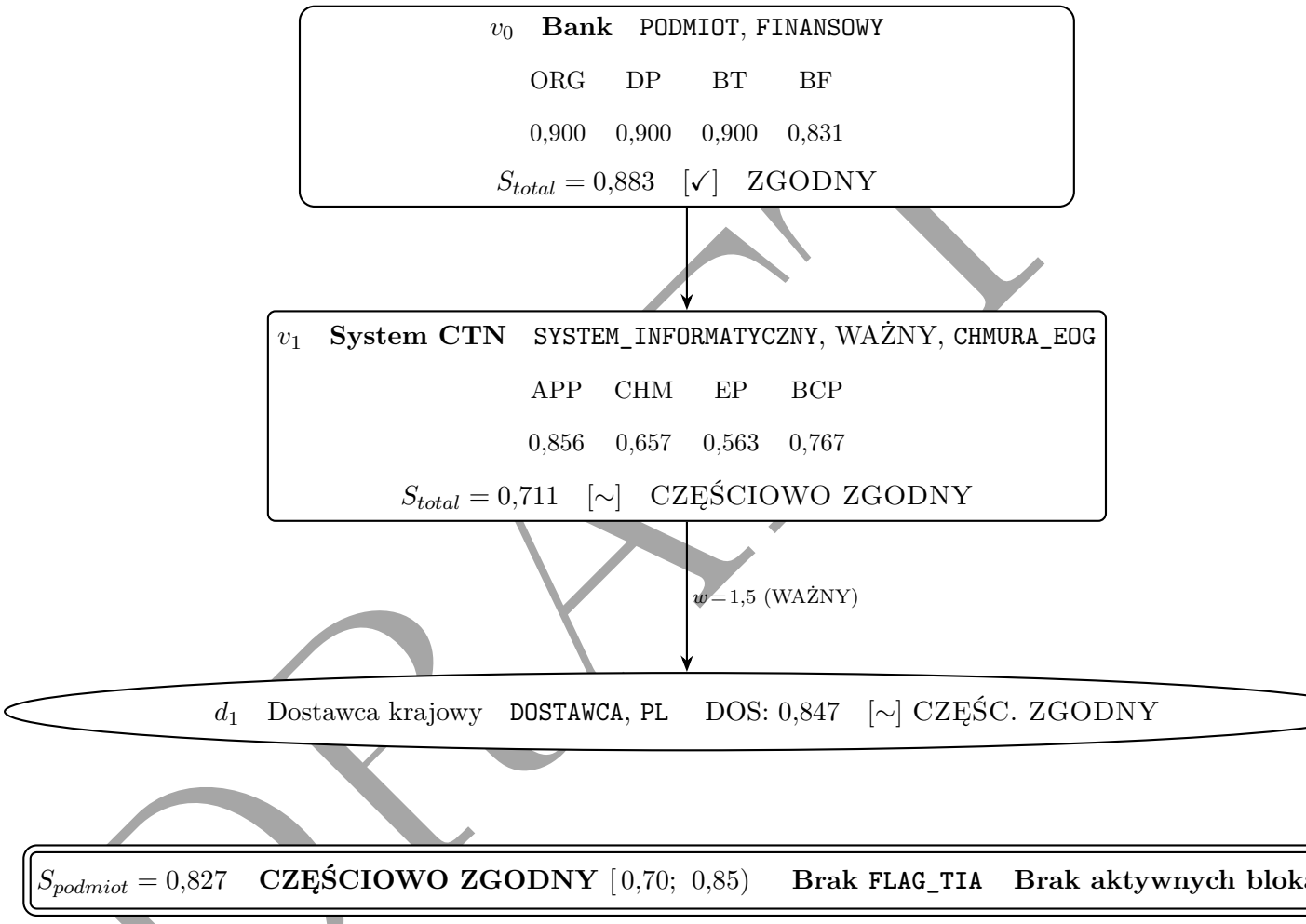
(iii) **P3** (180 dni): system CTN i dostawca d_1 jako obiekty CZĘŚCIOWO ZGODNE; w tym zweryfikowanie w teście czasu i kosztów wyjścia (RTE) oraz kontakty kryzysowe poza systemami cyfrowymi.

Obniżenie wyniku systemu CTN do 0,711 ma trzy źródła o podobnej wadze. Pierwsze to górna granica wynikająca z jakości dowodów: nawet jednomyślne `TAK` daje 0,9, ponieważ oświadczenie użytkownika jest dowodem średnim, co odpowiada stracie ok. 0,10. Drugie to sześć rozbieżności perspektyw (w systemie CTN pięć), które obniżają wynik obiektu o ok. 0,10. Trzecie to trzy pytania z konsensusem przeczącym (test exit planu, czas i koszty wyjścia, HYOK), odpowiadające za ok. 0,09. Wynik jest bezpośrednią konsekwencją modelu dowodowego i reguły konsensusu z karą: wdrożenie, którego nie potwierdza choćby jedna perspektywa, np. niewidoczne dla użytkowników albo nieprzetestowane technicznie, nie jest traktowane jako w pełni skuteczne. Usunięcie wszystkich niezgodności i rozbieżności podniosłoby $S_{podmiot}$ do 0,9, a wyższy wynik wymagałby dowodów silnych również po stronie użytkowników.

Graf ICT systemu CTN

Poniższy graf ICT przedstawia topologię audytowanego środowiska oraz wyniki poszczególnych sekcji w odwzorowaniu na obiekty audytowe. Każdy węzeł zawiera identyfikator obiektu, jego typ i atrybuty klasyfikacyjne oraz wyniki aktywnych sekcji. Krawędź z etykietą wagi w prowadzi od systemu informatycznego do obsługującego go dostawcy. Graf nie zawiera krawędzi do poddostawców, ponieważ identyfikacja poddostawców udokumentowała ich brak, a żaden obiekt nie spełnia warunku triggera TIA.

DRAFT



Rysunek 7.3: Graf ICT audytowanego systemu CTN. Skróty sekcji: ORG (Organizacja), DP (Dane poufne), BT (Bezpieczeństwo techniczne), BF (Bezpieczeństwo fizyczne), APP (System informatyczny), CHM (Usługi w chmurze), EP (Exit plan), BCP (Plan ciągłości działania), DOS (Dostawcy ICT). Waga krawędzi $w = 1{,}5$ odpowiada mnożnikowi w_{krit} systemu WAŻNEGO (tabela 6.6).

8. Zakończenie

Rosnąca złożoność środowisk ICT w organizacjach nadzorowanych, wzmocniona przez wejście w życie rozporządzenia DORA i implementację dyrektywy NIS2, stworzyła wyraźną lukę pomiędzy wymaganiami regulacyjnymi a dostępnymi narzędziami ich weryfikacji. Istniejące metodyki audytu (ISO 27001, COBIT, NIST CSF) dostarczają ogólnych ram kontrolnych, lecz nie oferują skwantyfikowanego, powtarzalnego mechanizmu oceny ryzyka uwzględniającego jednocześnie strukturę łańcucha dostaw ICT, klasyfikację przetwarzanych danych, specyfikę jurysdykcji dostawców chmurowych oraz wagę poszczególnych wymagań regulacyjnych. Niniejsza praca odpowiada na ten deficyt, proponując metodologię ORION (Ocena Ryzyka Informatycznego Organizacji Nadzorowanych), zaprojektowaną z myślą o organizacjach objętych regulacjami sektorowymi i unijną legislacją z zakresu cyfrowej odporności operacyjnej.

Centralnym elementem ORION jest model grafu ważonego $G = (V, E, W)$, w którym wierzchołki reprezentują obiekty audytowe czterech typów (PODMIOT, SYSTEM INFORMATYCZNY, DOSTAWCA, PODDOSTAWCA), a krawędzie kierowane odzwierciedlają zależności usługowe z wagami odpowiadającymi krytyczności obsługiwanych systemów. Model ten umożliwia propagację ryzyka wzdłuż łańcucha dostaw: poddostawcy każdego dostawcy są obowiązkowo identyfikowani i włączani do grafu, a podmioty spoza EOG lub kontrolowane z państwa trzeciego uruchamiają trigger TIA (Transfer Impact Assessment), co bezpośrednio adresuje wymogi art. 28 DORA dotyczące mapowania zależności zewnętrznych. Mechanizm walidacji krzyżowej (każde pytanie zadawane niezależnie trzem perspektywom: zgodności, technicznej oraz użytkownika) ocenia pytanie na podstawie konsensusu z karą za brak jednomyślności i z uwzględnieniem jakości dowodów, co ogranicza ryzyko konfabulacji i formalnego spełniania wymagań bez ich realnego wdrożenia. Wynik końcowy $S_{podmiot}$, łączący wynik organizacyjny podmiotu z ważonym wynikiem grafu ICT, jest wielkością skwantyfikowaną, wyznaczaną na podstawie jednolitych wzorów z jasno zdefiniowaną skalą pięciostopniową, co czyni ocenę porównywalną między audytami i organizacjami.

Przeprowadzony audyt pilotażowy systemu CTN w instytucji bankowej ilustruje wykonalność metodologii w warunkach rzeczywistych. Spośród 60 pytań 56 uzyskało konsensus twierdzący, w tym sześć z rozbieżnością perspektyw, a cztery konsensus przeczący. Jedna niezgodność dotyczy banku jako podmiotu (zalecane pytanie o strefy bezpieczeństwa fizycznego i nadzór nad gośćmi), a trzy systemu CTN: brak testu exit planu (pytanie obowiązkowe), niezweryfikowana analiza czasu i kosztów wyjścia oraz brak kontroli organizacji nad kluczami szyfrującymi. Wraz z rozbieżnościami i jakością dowodów (podpisane oświadczenia użytkowników jako dowód średni) przełożyły się one na wynik systemu CTN $S_{total} = 0{,}711$ i dostawcy 0,847 (oba CZĘŚCIOWO ZGODNE) oraz wynik podmiotu $S_{podmiot} = 0{,}827$, klasyfikowany jako CZĘŚCIOWO ZGODNY w przedziale $[0{,}70;\ 0{,}85)$. Żadna sekcja nie aktywowała flagi blokującej. Trigger TIA nie został wyzwolony, ponieważ dane są przechowywane w EOG, wsparcie techniczne jest świadczone z EOG, a dostawca systemu ma siedzibę w Polsce i nie korzysta z poddostawców. Wynik wskazuje, że organizacja ma dojrzałe podstawy zarządzania ryzykiem ICT na poziomie organizacyjnym (wynik banku jako podmiotu 0,883, ZGODNY), a jednocześnie precyzyjnie wskazuje

DRAFT

obszary wymagające korekty: test exit planu (priorytet P1) oraz wdrożenia nieprzetestowane lub niewidoczne dla użytkowników systemu, ujawnione przez rozbieżności perspektyw (w pytaniach obowiązkowych priorytet P2). Zakres pilotażu jest ograniczony: jeden system i jeden dostawca, bez poddostawców, bez aktywnego triggera TIA i bez dostawcy kluczowego, jakość dowodów perspektyw zgodności i technicznej przyjęto jako silną bez różnicowania

Jedną z celowych właściwości projektowych ORION jest jego adaptowalność. Choć przedstawiony przypadek użycia dotyczy sektora finansowego (banku nadzorowanego przez KNF), architektura metodologii nie zakłada żadnych elementów specyficznych wyłącznie dla bankowości. Biblioteka sekcji (bezpieczeństwo techniczne, chmura, dane poufne, ciągłość działania, zarządzanie dostawcami) stanowi zbiór bloków, które są włączane na podstawie typu i atrybutów obiektu audytowego oraz klasy regulacyjnej podmiotu. Szpital przetwarzający dane medyczne objęte tajemnicą lekarską (kategoria `TAJEMNICA`) otrzyma dla swoich systemów wyższy mnożnik w_{data} niż operator logistyczny, lecz korzysta z tego samego aparatu formalnego i tych samych procedur zbierania dowodów. Dostawca energii objęty NIS2 jako podmiot kluczowy, podmiot administracji publicznej prowadzący rejestr ludności, platforma przetwarzania danych medycznych, czy firma fintech objęta DORA, wszystkie te organizacje mają odmienną specyfikę ryzyka, lecz wspólny mianownik: konieczność wykazania organom nadzoru, że ryzyko ICT jest zarządzane w sposób mierzalny i udokumentowany. ORION dostarcza do tego celu jednolity język.

Żaden system oceny ryzyka nie może być lepszy niż jakość danych, na których operuje, a ta zależy przede wszystkim od kompetencji i rzetelności audytora. Kluczowe znaczenie ma konsekwentne przestrzeganie zasady niezależności perspektyw w walidacji krzyżowej: zbyt swobodna interpretacja odpowiedzi jednej perspektywy jako potwierdzenia dla pozostałych wypacza wynik i podważa sens całego mechanizmu. Równie istotna jest wytrwałość w dążeniu do weryfikacji dowodów (logi, konfiguracje, umowy, wyniki testów) zamiast poprzestania na deklaracjach słownych. Przypadek wykrycia braku MFA w trakcie audytu CTN, niezgodności naprawionej jeszcze przed zamknięciem kwestionariusza, ilustruje, jak rzetelna inspekcja może mieć bezpośredni, pozytywny wpływ na bezpieczeństwo systemu. Metodologia ORION tworzy ramy do przeprowadzenia takiej inspekcji, lecz jej realna wartość zależy od gotowości audytora do konfrontowania się z trudnymi obserwacjami i formułowania wniosków bez ulegania presji organizacyjnej.

Autor identyfikuje kilka kierunków dalszego rozwoju metodologii. Po pierwsze, automatyzacja zbierania i walidacji dowodów technicznych (logi SIEM, wyniki skanerów podatności, raporty certyfikatów TLS) może istotnie skrócić czas trwania fazy kwestionariuszowej i ograniczyć ryzyko błędów ludzkich. Po drugie, mechanizm propagacji ryzyka w grafie ICT może zostać rozszerzony o modele probabilistyczne uwzględniające historyczne dane o incydentach, co pozwoliłoby na szacowanie oczekiwanej straty operacyjnej powiązanej z konkretnym poddostawcą. Po trzecie, opracowanie branżowych szablonów pytań (dla sektora zdrowotnego, energetycznego, administracji publicznej) pozwoliłoby skrócić etap konfiguracji audytu przy zachowaniu wspólnego aparatu obliczeniowego. Po czwarte, integracja z rejestrami CMDB i systemami GRC (Governance, Risk and Compliance) umożliwiłaby ciągłą, automatyczną aktualizację grafu ICT bez konieczności inicjowania pełnego audytu przy każdej zmianie w środowisku.

Metodologia ORION nie pretenduje do bycia jedynym ani wyczerpującym narzędziem oceny ryzyka ICT w organizacjach nadzorowanych. Jest natomiast propozycją wypełnienia konkretnej luki: braku ustrukturyzowanej, skwantyfikowanej i regulacyjnie zakorzenionej metody łączącej audyt organizacyjny z analizą łańcucha dostaw w jednolitym modelu

DRAFT

grafowym. Zaprezentowany przypadek użycia wskazuje, że taki model jest wykonalny w praktyce i generuje wnioski działające dwukierunkowo: dając organom nadzoru czytelny wskaźnik zgodności, a organizacji audytowanej precyzyjny priorytet działań naprawczych. Dalszy rozwój metodologii, jej walidacja na większej próbie organizacji i ewentualna standaryzacja w postaci normy branżowej lub wytycznych regulatora, pozostają zadaniami otwartymi i stanowią naturalny kierunek kontynuacji niniejszych badań.

DRAFT

9. Słownik pojęć

AI Act (Artificial Intelligence Act)
Unijne rozporządzenie dotyczące sztucznej inteligencji, które weszło w życie 1 sierpnia 2024 r., istotne dla sektorów regulowanych.

API (Application Programming Interface)

Interfejs programistyczny umożliwiający komunikację między systemami i usługami.

BCP (Business Continuity Plan)

Plan ciągłości działania określający sposób utrzymania kluczowych procesów po incydencie lub awarii.

BION (Badanie i Ocena Nadzorcza)

Mechanizm oceny nadzorczej stosowany przez KNF wobec podmiotów rynku finansowego.

CLOUD Act (Clarifying Lawful Overseas Use of Data Act)

Ustawa USA dotycząca dostępu organów amerykańskich do danych przechowywanych przez dostawców usług.

CSF (Cybersecurity Framework)

Framework cyberbezpieczeństwa, do którego tekst odnosi się przy porównaniu z innymi standardami oceny.

CSIRT (Computer Security Incident Response Team)

Zespół reagowania na incydenty bezpieczeństwa komputerowego właściwy do przyjmowania zgłoszeń i koordynacji reakcji.

CTPP (Critical ICT Third-Party Providers)

Kluczowi zewnętrzni dostawcy usług ICT wyznaczani przez Europejskie Urzędy Nadzoru na podstawie art. 31 DORA i objęci unijnym nadzorem. Pojęcie odrębne od dostawcy kluczowego w metodologii ORION.

DORA (Digital Operational Resilience Act)

Rozporządzenie UE ustanawiające zasady operacyjnej odporności cyfrowej sektora finansowego.

DPF (Data Privacy Framework)

DRAFT

Ramy transferu danych między UE a USA omawiane w kontekście legalności przekazywania danych.

DPIA (Data Protection Impact Assessment)

Ocena skutków dla ochrony danych stosowana przy przetwarzaniu mogącym powodować wysokie ryzyko dla praw i wolności osób.

DRP (Disaster Recovery Plan)

Plan odtwarzania po awarii określający sposób przywrócenia systemów i usług po zakłóceniu.

DUC (Dostawca Usług Cyfrowych)

Kategoria podmiotów występująca w ustawie o krajowym systemie cyberbezpieczeństwa.

EBA (European Banking Authority)

Europejski Urząd Nadzoru Bankowego, wskazany przy standardach technicznych związanych z DORA.

EEHRxF (European Electronic Health Record Exchange Format)

Europejski format wymiany elektronicznej dokumentacji zdrowotnej.

EHDS (European Health Data Space)

Europejska Przestrzeń Danych Zdrowotnych, istotna dla regulacji przetwarzania danych medycznych.

EIOPA (European Insurance and Occupational Pensions Authority)

Europejski organ nadzoru dla sektora ubezpieczeń i pracowniczych programów emerytalnych.

EOG (Europejski Obszar Gospodarczy)

Obszar istotny dla oceny transferu danych i klasyfikacji jurysdykcyjnej.

ESMA (European Securities and Markets Authority)

Europejski organ nadzoru nad rynkami papierów wartościowych i rynkiem kapitałowym.

FISA 702 (Foreign Intelligence Surveillance Act Section 702)

Przepis prawa USA wskazywany w pracy jako źródło ryzyka dostępu do danych przez służby amerykańskie.

GRC (Governance Risk and Compliance)

Obszar zarządzania obejmujący ład organizacyjny, ryzyko i zgodność.

DRAFT

ICT (Information and Communications Technology)

Technologie informacyjno-komunikacyjne stanowiące podstawowy obszar analizy w pracy.

IOD (Inspektor Ochrony Danych)

Osoba odpowiedzialna za nadzór nad zgodnością przetwarzania danych osobowych.

ITS (Implementing Technical Standards)

Wykonawcze standardy techniczne towarzyszące regulacjom unijnym, w tym DORA.

JIT (Just-in-Time)

Model przyznawania uprawnień tylko na niezbędny czas.

KNF (Komisja Nadzoru Finansowego)

Polski organ nadzoru nad rynkiem finansowym.

KSC (Krajowy System Cyberbezpieczeństwa)

System krajowych ram organizacyjnych i prawnych cyberbezpieczeństwa.

MFA (Multi-Factor Authentication)

Uwierzytelnianie wieloskładnikowe wymagające użycia co najmniej dwóch różnych składników.

NIS2 (Network and Information Security Directive 2)

Dyrektywa UE ustanawiająca nowy model obowiązków cyberbezpieczeństwa dla podmiotów kluczowych i ważnych.

OChK (Operator Chmury Krajowej)

Polski dostawca i integrator usług chmurowych wspomniany w kontekście suwerenności danych.

ORION (Ocena Ryzyka Informatycznego Organizacji Nadzorowanych)

Autorska metodologia oceny zgodności systemów ICT i ich łańcucha dostaw z wymogami DORA, NIS2 i RODO, opisana w niniejszej publikacji.

OUK (Operator Usług Kluczowych)

Kategoria podmiotów objętych obowiązkami ustawy o KSC w wcześniejszym modelu regulacyjnym.

PAM (Privileged Access Management)

Zarządzanie dostępem uprzywilejowanym do kont i zasobów o podwyższonych uprawnieniach.

DRAFT

PUODO (Prezes Urzędu Ochrony Danych Osobowych)

Krajowy organ nadzorczy właściwy w sprawach ochrony danych osobowych.

RODO (Rozporządzenie o Ochronie Danych Osobowych)

Unijne ogólne rozporządzenie regulujące zasady przetwarzania danych osobowych.

RTS (Regulatory Technical Standards)

Regulacyjne standardy techniczne uszczegóławiające wymagania aktów unijnych.

SCC (Standard Contractual Clauses)

Standardowe klauzule umowne wykorzystywane przy transferze danych poza EOG.

TEE (Trusted Execution Environment)

Zaufane środowisko wykonawcze stosowane m.in. w poufnym przetwarzaniu danych.

TIA (Transfer Impact Assessment)

Ocena skutków transferu danych do państw trzecich pod kątem ryzyka prawnego i operacyjnego.

TLPT (Threat-Led Penetration Testing)

Zaawansowane testy penetracyjne sterowane scenariuszami zagrożeń.

UODO (Urząd Ochrony Danych Osobowych)

Urząd wspierający krajowy nadzór nad ochroną danych osobowych.

UKSC (Ustawa o Krajowym Systemie Cyberbezpieczeństwa)

Polska ustawa określająca obowiązki podmiotów w obszarze cyberbezpieczeństwa.

DRAFT

Bibliografia

Ustawa z dnia 5 lipca 2018 r. o krajowym systemie cyberbezpieczeństwa. Weszła w życie 28 sierpnia 2018 r. 2018.

Parlament Europejski i Rada Unii Europejskiej. *Rozporządzenie (UE) 2022/2554 w sprawie operacyjnej odporności cyfrowej sektora finansowego (DORA)*. Dz.Urz. UE L 333/1. Grudzień 2022. URL: https://eur-lex.europa.eu/legal-content/PL/TXT/?uri=CELEX%3A32022R2554.

Dyrektywa Parlamentu Europejskiego i Rady (UE) 2016/1148 z dnia 6 lipca 2016 r. w sprawie środków na rzecz wysokiego wspólnego poziomu bezpieczeństwa sieci i systemów informatycznych na terytorium Unii. 19 lipca 2016.

Ustawa z dnia 23 stycznia 2026 r. o zmianie ustawy o krajowym systemie cyberbezpieczeństwa oraz niektórych innych ustaw. 2026.

Dyrektywa Parlamentu Europejskiego i Rady (UE) 2022/2555 z dnia 14 grudnia 2022 r. w sprawie środków na rzecz wysokiego wspólnego poziomu cyberbezpieczeństwa na terytorium Unii (NIS2). 27 grudnia 2022.

Ustawa z dnia 10 maja 2018 r. o ochronie danych osobowych. Weszła w życie 25 maja 2018 r. 2018.

Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2016/679 z dnia 27 kwietnia 2016 r. w sprawie ochrony osób fizycznych w związku z przetwarzaniem danych osobowych i w sprawie swobodnego przepływu takich danych oraz uchylenia dyrektywy 95/46/WE (ogólne rozporządzenie o ochronie danych). Stosowane od 25 maja 2018 r. 4 maja 2016.

Ustawa z dnia 16 kwietnia 1993 r. o zwalczaniu nieuczciwej konkurencji. Tekst jednolity: Dz.U. z 2003 r. Nr 153, poz. 1503 z późn. zm. 1993.

Ustawa z dnia 23 kwietnia 1964 r. – Kodeks cywilny. Tekst jednolity: Dz.U. z 2023 r. poz. 1610 z późn. zm. 1964.

Ustawa z dnia 6 czerwca 1997 r. – Kodeks karny. Tekst jednolity: Dz.U. z 2024 r. poz. 17 z późn. zm. 1997.

Ustawa z dnia 6 marca 2018 r. – Prawo przedsiębiorców. Dz.U. 2018 poz. 646. art. 7; ELI: https://eli.gov.pl/eli/DU/2018/646/ogl. 2018. URL: https://eli.gov.pl/eli/DU/2018/646/ogl.

Komisja Nadzoru Finansowego. *Rekomendacja D dotycząca zarządzania obszarami technologii informacyjnej i bezpieczeństwa środowiska teleinformatycznego w bankach*. Załącznik do uchwały nr 7/2013 Komisji Nadzoru Finansowego z dnia 8 stycznia 2013 r., Dz. Urz. KNF z 2013 r. poz. 5. Ogłoszona 27 lutego 2013 r. 2013. URL: https://www.knf.gov.pl/knf/pl/komponenty/img/rekomendacja_d_8_01_13_uchwala_7_33016.pdf.

Urząd Komisji Nadzoru Finansowego. *Metodyka badania i oceny nadzorczej banków komercyjnych, zrzeszających oraz spółdzielczych (Metodyka BION)*. Urząd Komisji Nadzoru Finansowego, Warszawa, 12 lutego 2024 r. Dokument opisujący proces BION stosowany przez KNF. 2024. URL: https://www.knf.gov.pl/knf/pl/komponenty/img/Metodyka_BION_2024.pdf.

Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2022/2554 z dnia 14 grudnia 2022 r. w sprawie operacyjnej odporności cyfrowej sektora finansowego i zmieniające

DRAFT

rozporządzenia (WE) nr 1060/2009, (UE) nr 648/2012, (UE) nr 600/2014, (UE) nr 909/2014 oraz (UE) 2016/1011 (DORA). 27 grudnia 2022. URL: https://eur-lex.europa.eu/legal-content/PL/TXT/?uri=CELEX:32022R2554.

European Insurance and Occupational Pensions Authority (EIOPA). *Digital Operational Resilience Act (DORA)*. Strona instytucjonalna EIOPA. Informacje dotyczące wymogów DORA w zakresie zarządzania ryzykiem ICT, raportowania incydentów oraz wymiany informacji o zagrożeniach cybernetycznych. 2024. URL: https://www.eiopa.europa.eu/digital-operational-resilience-act-dora_en (dostęp 10.03.2025).

Komisja Nadzoru Finansowego (KNF). *Rozporządzenie DORA – strona tematyczna*. Serwis instytucjonalny KNF. Zbiór materiałów nadzorczych KNF dotyczących wdrożenia rozporządzenia (UE) 2022/2554 (DORA). 2024. URL: https://www.knf.gov.pl/dla_rynku/dora (dostęp 10.03.2025).

Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2016/679 z dnia 27 kwietnia 2016 r. w sprawie ochrony osób fizycznych w związku z przetwarzaniem danych osobowych i w sprawie swobodnego przepływu takich danych oraz uchylenia dyrektywy 95/46/WE (Ogólne rozporządzenie o ochronie danych, RODO). W szczególności art. 9 dotyczący szczególnych kategorii danych osobowych (w tym danych zdrowotnych). 27 kwietnia 2016. URL: https://eur-lex.europa.eu/legal-content/PL/TXT/?uri=CELEX:32016R0679.

Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2016/679 z dnia 27 kwietnia 2016 r. (RODO). W szczególności art. 37–39 RODO regulujące obowiązek wyznaczenia, zadania i pozycję Inspektora Ochrony Danych (IOD). 27 kwietnia 2016. URL: https://eur-lex.europa.eu/legal-content/PL/TXT/?uri=CELEX:32016R0679.

Ustawa z dnia 6 listopada 2008 r. o prawach pacjenta i Rzeczniku Praw Pacjenta. W szczególności art. 23–29 regulujące prawo pacjenta do dokumentacji medycznej oraz obowiązki podmiotów leczniczych w zakresie jej prowadzenia, przechowywania i udostępniania. 6 listopada 2008. URL: https://isap.sejm.gov.pl/isap.nsf/download.xsp/WDU20240000581/O/D20240581.pdf.

Centrum e-Zdrowia. *Systemy informacyjne w ochronie zdrowia – P1 (e-recepta, e-skierowanie) i krajowa infrastruktura elektronicznej dokumentacji medycznej*. Serwis instytucjonalny Centrum e-Zdrowia. Informacje o systemach P1, P2 oraz standardach informatycznych elektronicznej dokumentacji medycznej zarządzanych przez Centrum e-Zdrowia. 2024. URL: https://www.cez.gov.pl (dostęp 10.03.2025).

Rozporządzenia EHDS (UE) 2025/327, daty wejścia w życie (26.03.2025 r.) oraz harmonogramu wdrożenia do 26.03.2027 r. Parlament Europejski. 2025. URL: https://eur-lex.europa.eu/legal-content/PL/TXT/PDF/?uri=OJ:L_202500327 (dostęp 10.03.2025).

Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2025/327 z dnia 11 lutego 2025 r. w sprawie Europejskiej Przestrzeni Danych Dotyczących Zdrowia i zmieniające rozporządzenie (UE) 2018/1724 i dyrektywę 2011/24/UE. Weszło w życie 26 marca 2025 r.; ustanawia EHDS jako ogólnounijne ramy pierwotnego i wtórnego wykorzystania elektronicznych danych zdrowotnych. 5 marca 2025. URL: https://eur-lex.europa.eu/legal-content/PL/TXT/?uri=CELEX:32025R0327.

Swimlane. *GRC Chaos: The High Price of Audits and Non-Compliance*. Sprawozdanie techniczne. Survey conducted by Sapio Research among 500 IT and cybersecurity decision-makers in the US and UK, March 2025. Swimlane, Inc., kwiecień 2025. URL: https://swimlane.com/news/grc-audit-research/ (dostęp 10.03.2026).

DRAFT

Henry, Brandon. „The Next Generation Cybersecurity Auditor: Technical Competency Gaps in 151,000 IT Auditors in the Audit Industry". W: *Security Magazine* (październik 2022). Dotyczy luki kompetencyjnej między wiedzą deklaratywną a proceduralną u audytorów IT w firmach Big Four; wykazano 17% spadek poziomu wiedzy praktycznej względem teoretycznej. URL: https://www.securitymagazine.com/articles/98555-technical-competency-gaps-in-151-000-it-auditors-in-the-audit-industry (dostęp 10.03.2026).

Friesen, Lana. „Designing Self-Reporting Regimes to Encourage Truth Telling". W: *Journal of Economic Behavior & Organization* 95 (2013). DOI: 10.1016/j.jebo.2013.08.007. URL: https://www.sciencedirect.com/science/article/abs/pii/S0167268113002072.

Peer, Eyal, Thomas Vanhoof i in. „Commitment to honesty oaths decreases dishonesty, but commitment to another individual does not". W: *Communications Psychology* 1.1 (2023). DOI: 10.1038/s44271-023-00028-7. URL: https://www.nature.com/articles/s44271-023-00028-7.

IBM. *What Is Shadow IT?* Dostęp: 2026. 2022. URL: https://www.ibm.com/think/topics/shadow-it.

JumpCloud. *What Is Shadow IT? 2024 Statistics & Solutions*. Dostęp: 2026. 2024. URL: https://jumpcloud.com/blog/shadow-it.

Capterra. *Shadow IT Report 2023*. Cytowane w: Auvik (2024), dostęp: 2026. 2023. URL: https://www.capterra.com.

Josys. *Shadow IT Definition: 2024 Statistics and Solutions*. Dostęp: 2026. 2024. URL: https://josys.com/article/article-shadow-it-shadow-it-definition-2024-statistics-and-solutions.

Kaspersky. *IT Security Economics Report 2023*. Cytowane w: ISACA Journal (2024), dostęp: 2026. 2023. URL: https://www.kaspersky.com.

ISACA. „Risk in the Shadows". W: *ISACA Journal* 6 (2024). Dostęp: 2026. URL: https://www.isaca.org/resources/isaca-journal/issues/2024/volume-6/risk-in-the-shadows.

Grip Security. *How to Detect and Manage Shadow IT in 5 Steps*. Dostęp: 2026. 2025. URL: https://www.grip.security/blog/5-steps-to-detect-and-control-shadow-it.

Gartner, Inc. *Gartner Predicts Forty Percent of AI Data Breaches Will Arise from Cross-Border GenAI Misuse by 2027*. Gartner Newsroom Press Release. Accessed: June 2026. Luty 2025. URL: https://www.gartner.com/en/newsroom/press-releases/2025-02-17-gartner-predicts-forty-percent-of-ai-data-breaches-will-arise-from-cross-border-genai-misuse-by-2027.

LayerX Security. *Enterprise AI and SaaS Data Security Report 2025*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. LayerX Security Ltd., 2025. URL: https://www.cybersecurity-insiders.com/research-says-over-77-percent-of-data-is-shared-to-chatgpt-by-employees/.

Cyberhaven Labs. *11% of data employees paste into ChatGPT is confidential*. Dostęp: 10 marca 2026. 2023. URL: https://www.cyberhaven.com/blog/4-2-of-workers-have-pasted-company-data-into-chatgpt.

Microsoft i LinkedIn. *2024 Work Trend Index Annual Report: AI at Work Is Here. Now Comes the Hard Part*. Sprawozdanie techniczne. Based on a survey of 31,000 professionals across 31 countries. Accessed: June 2026. Microsoft Corporation, maj 2024. URL:

DRAFT

https://www.microsoft.com/en-us/worklab/work-trend-index/ai-at-work-is-here-now-comes-the-hard-part.

European Parliament i Council of the European Union. *Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 Laying Down Harmonised Rules on Artificial Intelligence (Artificial Intelligence Act)*. Entered into force: 1 August 2024. Accessed: June 2026. Lipiec 2024. URL: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32024R1689.

ISOQAR CEE. *Błąd ludzki – cichy sprawca naruszeń bezpieczeństwa informacji*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. ISOQAR CEE Sp. z o.o., 2024. URL: https://www.isoqar.pl/pl/aktualnosci/bezpieczenstwo-informacji/blad-ludzki-cichy-sprawca-naruszen-bezpieczenstwa-informacji.

Verizon Business. *2024 Data Breach Investigations Report*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. Verizon Communications Inc., 2024. URL: https://www.verizon.com/business/resources/reports/dbir/.

BrandsIT. *Im mniej szkoleń, tym więcej ataków. Jak brak edukacji wpływa na cyberbezpieczeństwo firm*. Dostęp: 10 marca 2026. 2025. URL: https://brandsit.pl/im-mniej-szkolen-tym-wiecej-atakow-jak-brak-edukacji-wplywa-na-cyberbezpieczenstwo-firm/.

CERT Polska / NASK. *Analiza bezpieczeństwa polskiego internetu w 2024 roku*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. Ministerstwo Cyfryzacji / NASK PIB, 2025. URL: https://www.gov.pl/web/baza-wiedzy/analiza-bezpieczenstwa-polskiego-internetu-w-2024-roku.

Keepnet Labs. *Security Awareness Training Statistics [Updated 2026]*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. Keepnet Labs Ltd., 2026. URL: https://keepnetlabs.com/blog/security-awareness-training-statistics.

PAP Biznes. *Cyberbezpieczeństwo najszybciej rosnącym segmentem rynku IT w Polsce*. Dostęp: 10 marca 2026. 2026. URL: https://biznes.pap.pl/wiadomosci/gry-i-technologie/cyberbezpieczenstwo-najszybciej-rosnacym-segmentem-rynku-it-w-polsce-w.

Autoriteit Financiële Markten (AFM). *Digital Operational Resilience Act (DORA)*. Strona instytucjonalna AFM. Informacje nt. wymogów DORA, w tym zarządzania ryzykiem ICT i obowiązków raportowania incydentów dla podmiotów finansowych. 2025. URL: https://www.afm.nl/en/sector/themas/digitalisering/dora (dostęp 10.03.2025).

WifiTalents. *Shadow IT Statistics: Reports 2025*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. WifiTalents, 2025. URL: https://wifitalents.com/shadow-it-statistics/.

Data Protection People. *GDPR Data Breaches & Human Error: How Bad Is It?* Dostęp: 10 marca 2026. 2026. URL: https://dataprotectionpeople.com/resource-centre/gdpr-data-breaches-human-error-how-bad-is-it/.

Agencia Española de Protección de Datos (AEPD). *Personal Data Breaches: Development and Pre-Production Environments*. Dostęp: 10 marca 2026. 2022. URL: https://www.aepd.es/en/prensa-y-comunicacion/blog/data-breaches-development-and-pre-production-enviroments.

Preuveneers, Davy i in. „Re-pseudonymization Strategies for Smart Meter Data Are Not Robust to Deep Learning Profiling Attacks". W: *arXiv preprint* (2024). DOI: 10.48550/arXiv.2404.03948. URL: https://arxiv.org/abs/2404.03948.

DRAFT

Legal.io / Bloomberg Law. *AI Meeting Tools Raise Privacy, Privilege, and Discovery Risks for Employers*. Dostęp: 10 marca 2026. 2025. URL: https://www.legal.io/articles/5767845/AI-Meeting-Tools-Raise-Privacy-Privilege-And-Discovery-Risks-For-Employers.

Privacy Partnership. *Why AI Transcription Bots Pose a Data Privacy Risk*. Dostęp: 10 marca 2026. 2025. URL: https://www.linkedin.com/posts/privacy-partnership_ai-bots-gdpr-activity-7387443108201787396-3dRL.

MailIntelligence. *Human Error Cases in Enterprise Email Security 2024*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. MailIntelligence AI, 2024. URL: https://mailintelligence.ai/reports/human-error-cases-2024.

Najwyższa Izba Kontroli. *RODO w szpitalu – wyniki kontroli*. Sprawozdanie techniczne. Dostęp: 10 marca 2026. Najwyższa Izba Kontroli, 2019. URL: https://www.nik.gov.pl/najnowsze-informacje-o-wynikach-kontroli/rodo-w-szpitalu.html.

Gazeta Prawna. „Raport: w 2025 r. padły rekordowe kary za naruszenia RODO – najwyższa dla Poczty Polskiej". W: *Gazeta Prawna* (2026). Dostęp: 10 marca 2026. URL: https://www.gazetaprawna.pl/firma-i-prawo/artykuly/10648769,raport-w-2025-r-padly-rekordowe-kary-za-naruszenia-rodo-najwyzsza-.html.

ODO 24. *Naruszenia ochrony danych – jakie są zgłaszane najczęściej i jak można im zapobiegać*. Dostęp: 10 marca 2026. 2020. URL: https://odo24.pl/blog-post.naruszenia-ochrony-danych-jakie-sa-zglaszane-najczesciej-i-w-jaki-sposob-mozna-im-zapobiegac.

Fidelis Security. *Shadow IT Risks, Examples, and Detection*. Dostęp: 10 marca 2026. 2026. URL: https://fidelissecurity.com/cybersecurity-101/cloud-security/shadow-it-risks-examples-and-detection/.

Putter, Johan i Sascha-Dominik Bachmann. „Russia and China Expected to Renew Their Espionage Vigour". W: *Journal on Baltic Security* 9.1 (2023), s. 1–31. DOI: 10.2478/jobs-2023-0001. URL: https://journalonbalticsecurity.com/journal/JOBS/article/113/text.

The White House. *Imposing Sanctions on the International Criminal Court*. Luty 2025. URL: https://www.whitehouse.gov/presidential-actions/2025/02/imposing-sanctions-on-the-international-criminal-court/ (dostęp 7.03.2026).

United States Congress. *Clarifying Lawful Overseas Use of Data Act (CLOUD Act)*. Pub. L. No. 115-141, div. V, 132 Stat. 348. 2018. URL: https://www.congress.gov/115/plaws/publ141/PLAW-115publ141.pdf.

— *Foreign Intelligence Surveillance Act, Section 702*. 50 U.S.C. §1881a; reauthorized most recently by the FISA Reform and Reauthorization Act of 2024. 1978. URL: https://www.govinfo.gov/content/pkg/STATUTE-92/pdf/STATUTE-92-Pg1783.pdf.

Synergy Research Group. *European Cloud Providers' Local Market Share Holds Steady at 15%*. Market Report. 2023. URL: https://www.srgresearch.com/articles/european-cloud-providers-local-market-share-now-holds-steady-at-15.

European Data Protection Board i European Data Protection Supervisor. *Initial Legal Assessment of the Impact of the US CLOUD Act on the European Union Legal Framework for Personal Data Protection*. Joint Response Annex. 2019. URL: https://www.edpb.europa.eu/sites/default/files/files/file2/edpb_edps_joint_response_us_cloudact_annex.pdf.

Braud, Tristan i in. „Scaling the Gaia-X Lighthouse: An Analysis of European Data Infrastructure". W: *Proceedings of the 2021 IEEE International Conference on Cloud*

DRAFT

Engineering (IC2E). IEEE, 2021. URL: https://publikationen.bibliothek.kit.edu/1000139020.

Operator Chmury Krajowej. *OChK osiągnął pełną suwerenność cyfrową zgodnie z Cloud Sovereignty Framework Komisji Europejskiej*. Komunikat prasowy. Październik 2025. URL: https://chmura.gov.pl.

Almutairi, Sulaiman i in. „Confidential Computing Using Trusted Execution Environments". W: *International Journal of Advances in Internet of Big Data and Cloud Management System* 3.1 (2024). URL: https://ijaibdcms.org/index.php/ijaibdcms/article/view/240.

Urząd Komisji Nadzoru Finansowego. *Komunikat UKNF w sprawie przetwarzania przez podmioty nadzorowane informacji w chmurze obliczeniowej publicznej i hybrydowej*. Komunikat UKNF. Styczeń 2020. URL: https://www.knf.gov.pl/knf/pl/komponenty/img/Komunikat_UKNF_Chmura_Obliczeniowa_68669.pdf.

Komisja Europejska. *Commission Delegated Regulation (EU) 2024/1532 — RTS on ICT Risk Management Tools, Methods, Processes and Policies (DORA Article 15)*. Dz.Urz. UE. 2024. URL: https://ec.europa.eu/finance/docs/level-2-measures/dora-regulation-rts--2024-1532_en.pdf.

— *Decyzja Komisji 2000/520/WE z dnia 26 lipca 2000 r. wydana na podstawie dyrektywy 95/46/WE Parlamentu Europejskiego i Rady w sprawie adekwatności ochrony przewidzianej przez zasady „bezpiecznej przystani" oraz związane z nimi najczęściej zadawane pytania, wydane przez Departament Handlu Stanów Zjednoczonych*. Dz.U. L 215 z 25.08.2000, s. 7–47. 2000.

Trybunał Sprawiedliwości Unii Europejskiej. *Wyrok z dnia 6 października 2015 r., Maximillian Schrems przeciwko Data Protection Commissioner, C-362/14*. ECLI: EU:C:2015:650. Schrems I. 2015.

— *Wyrok z dnia 16 lipca 2020 r., Data Protection Commissioner przeciwko Facebook Ireland Ltd i Maximillian Schrems, C-311/18*. ECLI: EU:C:2020:559. Schrems II. 2020.

Komisja Europejska. *Decyzja wykonawcza Komisji (UE) 2023/1795 z dnia 10 lipca 2023 r. wydana na podstawie rozporządzenia (UE) 2016/679 Parlamentu Europejskiego i Rady w sprawie odpowiedniego poziomu ochrony danych osobowych na podstawie ram ochrony danych UE–USA*. Dz.U. UE L 231 z 20.09.2023. dokument C(2023) 4745. 2023.

Parlament Europejski i Rada Unii Europejskiej. *Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2023/2854 z dnia 13 grudnia 2023 r. w sprawie zharmonizowanych przepisów dotyczących sprawiedliwego dostępu do danych i ich wykorzystywania oraz w sprawie ich zmiany*. Stosowane od 12 września 2025 r. 22 grudnia 2023. URL: https://data.europa.eu/eli/reg/2023/2854/oj (dostęp 21.03.2026).

European Union Agency for Cybersecurity (ENISA). *EUCS – Cloud Services Scheme: Draft Candidate Scheme for the European Cybersecurity Certification of Cloud Services*. Draft Candidate Scheme. ENISA, 2022. URL: https://www.enisa.europa.eu/publications/eucs-cloud-service-scheme (dostęp 21.03.2026).

Komisja Europejska. *Proposal for a Regulation of the European Parliament and of the Council on Cloud and AI Development (CADA)*. Czerwiec 2026. URL: https://digital-strategy.ec.europa.eu/pl/library/proposal-cloud-and-ai-development-act-cada (dostęp 11.06.2026).

— *Commission Work Programme 2026*. Inicjatywa Cloud and AI Development Act (CADA) zapowiedziana na I kwartał 2026 r.; wniosek złożony 3 czerwca 2026 jako COM(2026)

DRAFT

502; podstawa prawna: art. 114 TFUE. 2025. URL: https://commission.europa.eu/document/09579818-64a6-4dd5-9577-446ab6219113_en (dostęp 21.03.2026).

European Parliamentary Research Service (EPRS). *Cloud and AI Development Act*. Sprawozdanie techniczne EPRS_BRI(2025)779251. Europejski Parlament – EPRS, grudzień 2025. URL: https://www.europarl.europa.eu/thinktank/en/document/EPRS_BRI(2025)779251 (dostęp 21.03.2026).

Draghi, Mario. *The Future of European Competitiveness. A Competitiveness Strategy for Europe*. Bruksela: Komisja Europejska, wrzesień 2024. URL: https://commission.europa.eu/topics/strengthening-european-competitiveness/eu-competitiveness-looking-ahead_en (dostęp 21.03.2026).

Microsoft Corporation. *Configure Windows diagnostic data in your organization*. Microsoft Learn. Dostęp: 2026-04-07. 2023. URL: https://learn.microsoft.com/en-us/windows/privacy/configure-windows-diagnostic-data-in-your-organization.

Privacy Guides. *macOS Overview — Privacy and Telemetry*. Privacy Guides. Dostęp: 2026-04-07. 2025. URL: https://www.privacyguides.org/en/os/macos-overview/.

Fedora Project. *Changes/Telemetry — Fedora Project Wiki*. Fedora Project Wiki. Dostęp: 2026-04-07. 2024. URL: https://fedoraproject.org/wiki/Changes/Telemetry.

Krosnick, Jon A. i in. „The Impact of "No Opinion" Response Options on Data Quality: Non-Attitude Reduction or an Invitation to Satisfice?" W: *Public Opinion Quarterly* 66.3 (2002), s. 371–403. DOI: 10.1086/341394.

Dolnicar, Sara, Bettina Grün i Friedrich Leisch. „Quick, simple and reliable: forced binary survey questions". W: *International Journal of Market Research* 53.2 (2011), s. 231––252. DOI: 10.2501/IJMR-53-2-231-252.

Waters, Erika A. i in. „Dismissing "don't know" responses to perceived risk survey questions". W: *Sage Journals* (2021). DOI: 10.1177/17456916211017860.

DRAFT